
Project Savanna

Enterprise Data Management Turnaround

Individual Integrated Capstone Portfolio
18-Month Board Consultancy Package for Savanna Retail Group, Kampala – Uganda

Name: kutosi chris
School/College: SOMAC
Registration number: 2024-08-32939
Course: Enterprise Data Management (EDM) – 30% individual capstone
Submission date: 5 October 2026
Client: Savanna Retail Group (SRG)
Mandate: 18 months • UGX 480,000,000 envelope

Published dashboard: <https://ccosecret.github.io/srg-enterprise-data-management/>

Technical repository: <https://github.com/ccosecret/srg-enterprise-data-management>

Confidential – prepared for the Board of Savanna Retail Group.
Body: 40 pages maximum • Appendices A–AA: full registers, policies, matrices and execution evidence.

Contents

Executive Summary	3
1 Part A — Foundations & Governance	5
1.1 Task A1 — EDM Diagnostic & Data Lifecycle Mapping	5
1.2 Task A2 — Governance Framework & Compliance Register	7
2 Part B — Technical Core	11
2.1 Task B1 — Architecture Selection, ER Model & Normalization	11
2.2 Task B2 — Data Quality Assessment & Cleansing (Hands-On)	13
2.3 Task B3 — Master Data Management Design	15
2.4 Task B4 — Data Integration & Real-Time Architecture (Hands-On)	17
3 Part C — Protection, Metadata & Insight	21
3.1 Task C1 — Metadata: Dictionary, Lineage & Catalog Strategy	21
3.2 Task C2 — Security Risk Assessment, Access Controls & Privacy	23
3.3 Task C3 — BI Dashboard & Emerging Technology Evaluation	26
4 Part D — Synthesis, Defense & Reflection	30
4.1 Task D1 — Integrated 18-Month EDM Strategy Roadmap	30
4.2 Task D2 — Decision Log, Red-Team Critique & Reflective Essay	35
Appendix A — Assumptions Register	40
Appendix B — EDM Diagnostic — Executive Briefing Memo to the Board	44
Appendix C — Customer Data Lifecycle Map & DAMA-DMBOK Gap Analysis	46
Appendix D — Data Governance Charter, Operating Structure & RACI Matrix	49
Appendix E — Three Enforceable Data Policies (Access & Classification, Quality, Retention)	55
Appendix F — Compliance Obligations & Gap Register (DPPA 2019 / GDPR / CCPA)	59
Appendix G — CFO Rebuttal Memo — The Cost of Inaction	68
Appendix H — Architecture Selection — Weighted Trade-Off Decision	69
Appendix I — ER Model & Normalization (1NF → 2NF → 3NF)	75
Appendix J — Data Quality Evidence — Profiling, Before/After Metrics, Validation Rules, Monitoring & Root Cause	85
Appendix K — Customer Master Data Management Design	98
Appendix L — ETL Workflow, Job Diagnosis & ETL vs ELT Decision	107
Appendix M — Real-Time Integration Architecture (Footfall & Mobile-Money Streams)	125
Appendix N — Warehouse Data Dictionary (25 Classified Attributes)	130
Appendix O — KPI Lineage (Monthly Active Customers) & Address-Schema Impact Analysis	134
Appendix P — Data Catalog Taxonomy & Metadata Tool Evaluation	151
Appendix Q — Threat Model & Enterprise Risk Register	157
Appendix R — RBAC Matrix, GRANT/REVOKE Test Evidence & Masking Specification	168
Appendix S — Data Protection Impact Assessment & Breach Response Plan	176

Appendix T — Compliance Audit Checklist & Prioritised Remediation Plan	194
Appendix U — Five Strategic Business Questions & Analytics Workflow	210
Appendix V — Dashboard Specification, Interaction Map & Published Screenshots	218
Appendix W — Executive Insight Brief (Three Findings, Three Actions)	223
Appendix X — Emerging Technology Evaluation & Analytics Maturity Path	224
Appendix Y — Integrated 18-Month EDM Strategy Roadmap (Full Plan)	233
Appendix Z — Decision Log (26 Entries)	241
Appendix AA — Red-Team Critique — Full Dossier (15 Findings)	252

Executive Summary

The mandate. Savanna Retail Group hired its first Enterprise Data Management Consultant to take the organization from data chaos to data-driven in 18 months, inside a fixed envelope of **UGX 480,000,000**, with visible results by month 6 and a PDPO audit expected within 12 months. This package is the board-ready consultancy deliverable: diagnosis, governance, technical build, protection, insight, roadmap, and an honest defense of every decision in it.

The diagnosis. SRG's symptoms are one disease. Twenty-three store POS databases plus seven other siloed systems produce ~23% **duplicate customer records**, **five identifiers for the same product**, an **11-day monthly close**, and an **8.4% book-vs-physical stock variance** that nobody can attribute. The Jinja incident — an unencrypted laptop holding 9,000 customer records, reported 11 days late, with no breach notification — is the same failure at its most expensive: data treated as a by-product rather than a managed asset. The Board's working remedy ("hire two more DBAs") addresses storage, not ownership: nothing in the current estate assigns an owner, a standard, or a gate from data creation to deletion.

What has been built and proven. The technical work in this package was executed, not sketched:

Deliverable	Evidence
Profiling & cleansing of 5,000 customers / 1,200 products	Duplicates 22.84% → 0.00% (5,000 → 3,858 golden records); districts 127 → 42; UOM conformance 15.33% → 100%; composite validity 3.25% → 100%
Repaired nightly ETL into a star schema	Pipeline self-test 3/3 PASS ; control total UGX 252,382,814.16 across 10,000 sales lines (Jul–Dec 2024)
Customer MDM design	Golden record with attribute-level survivorship; deterministic + weighted matching (auto-merge ≥85, review 65–84)
Security & privacy	RBAC matrix with GRANT/REVOKE scripts and failed-access test evidence; field masking demonstrated; DPIA for the EU-facing loyalty rollout; DPPA s.23 / GDPR Art.33 breach procedure
Metadata	25-attribute classified data dictionary; annotated lineage for the Board's "monthly active customers" KPI; catalog tool evaluation
Interactive dashboard	Live at https://ccosecret.github.io/srg-enterprise-data-management/ — filters, five chart types, drill-down, published from the executed warehouse

Three findings the Board should act on. First, **e-commerce already delivers 20.3% of revenue from one node** — about 5.9× an average store's share — while the estate carries 8.4% unexplained stock variance, so every availability decision inherits a measurement error the firm can now decompose. Second, **new customers fell from 1,272 to 148 (–88%)** across the window with a churn proxy of **69.4%**: SRG has a retention problem wearing an acquisition costume, and the cleansed identity layer is what makes segment-level answers possible at all. Third, **mobile money is 73.2% of net revenue (MTN 48.2% + Airtel 25.1%)** yet **11.5% of MoMo lines (849 of 7,385 ≈ UGX 21.2M) sit unreconciled**: the payment rail the business depends on is the reconciliation rail it does not control.

The plan and the money. The 18-month roadmap runs three phases — Foundation (M1–M6), Scale (M7–M12), Intelligence (M13–M18) — and totals **exactly UGX 480,000,000** (People 150,650,000; Foundation 105,000,000; Security 72,000,000; Cloud 60,000,000; Governance 21,000,000; Training 18,000,000; Licences 15,000,000; Contingency 38,350,000 = 8.0%), planned to the stricter reading that the envelope covers the full programme rather than each year. Quick wins are visible by month 6: the dashboard is live now, duplicate-person rate falls below 1.0%, the monthly close compresses from 11 days to ≤5, and device encryption plus a breach procedure close the exposure the Jinja laptop opened. Four governance gates (G1–G4) release each phase; G1 must confirm three things — the payroll treatment of the existing four IT staff, the budget-reading interpretation, and tooling — before Phase 2 spend commits.

How to read this package. The body (40 pages maximum) carries the executive narrative, the decisions, and the evidence that matters most. Appendices A–AA hold the full registers, policies, matrices, DPIA, red-team dossier, and execution outputs; the GitHub repository holds every script, DDL, and test. The defense of individual choices is recorded in the 26-entry decision log, and the strategy's weakest points are attacked in the red-team section — because a package that only argues for itself is marketing, not consultancy.

The single ask: approve the roadmap, confirm the three G1 items, and authorize the three hires by month 5 — the rest is already running.

1 Part A — Foundations & Governance

1.1 Task A1 — EDM Diagnostic & Data Lifecycle Mapping

To: Board of Directors, Savanna Retail Group (SRG)

From: Enterprise Data Management Consultant

Date: Month 1 of the 18-month EDM transformation programme

Subject: Why our data problems are structural, not technical

The proposal before the Board is to hire two more database administrators. It is a plausible answer to a question not yet asked: what is broken at SRG — the engines, or the enterprise’s command of its data?

Traditional database management administers engines. Uptime, backups, indexes, query tuning, replication, patching: it asks whether the database is healthy. **Enterprise data management governs data across systems** — policies, ownership, standards, quality loops, metadata, lifecycle and cross-system meaning. It asks whether “customer”, “product” and “revenue” mean one thing everywhere, and who is accountable for that. Four pieces of SRG’s own evidence decide the question.

SRG symptom	What a DBA would fix	What actually causes it
The same product carries 5 identifiers across POS, e-commerce and supplier files	Nothing — the identifiers sit in five healthy databases	No master-data standard, no product owner, no golden SKU
23% duplicate customer records; loyalty points posted to wrong members	Nothing — no query returns “too fast”	No shared customer identity key and no entry rules across 23 POS databases, e-commerce, loyalty and CRM
11-day monthly reporting cycle	Speed up each of 23 databases individually	Absent data architecture and absent KPI definitions — consolidation happens in Excel because no integrated layer exists
Board cannot answer segment growth or churn	Nothing	No conformed customer, product or revenue definitions to segment on

The decisive proof is the cleanse already executed. Taking confirmed duplicates from **22.84% → 0.00%** (total duplicate-flag rate 25.06% → 2.85%) required cross-system matching rules — 953 deterministic phone matches plus 189 fuzzy Levenshtein matches — a survivorship policy, **365 homonym pairs deliberately rejected** by the email-conflict rule, **110 pairs held in stewardship review**, and standardisation of 6 phone formats into 1 (E.164) and 127 district labels into 42, with product UOM conformance 15.33% → 100%. Not one index, tuning pass or backup produced a single customer view. Those results came from matching rules and stewardship decisions SRG never had.

Two more DBAs would deepen the problem. They would keep the **23 silos** — per-store MySQL databases — healthier, faster and better backed up: better management of a *by-product*. Databases are containers; customer identity, product meaning and revenue definition are the assets. Hiring DBAs increases investment in the wrong asset class while the assets remain ownerless.

One problem, three symptoms. Each clean-up so far has treated data as disposable output: extract, fix, admire, discard. Three control loops were missing, and each now has a name. **No upstream enforcement:** the validation rules **VR-001..VR-012** (E.164 phone mask, district dropdown, SKU uniqueness, MoMo payment_ref within 24 hours or PENDING) existed at no capture point, so defects re-entered at source the day after cleansing. **No data ownership:** nobody was accountable for the customer, product or payment domain, so nobody could declare a field mandatory or rule that two records are the same person. **No monitoring:** checks **DQC-01..DQC-10** did not exist, so drift stayed invisible until the next manual audit — the ETL diagnosis shows the same pattern under root cause **RC-6**, alerts to an unmonitored mailbox and four days of silent failure. The 8.4% stock variance, the duplicate customers and the 11-day report are therefore not three problems. They are one — *nobody owns data quality from creation to deletion* — surfacing in three places. Cleansing without enforcement is a recurring cost, not an improvement.

Data as by-product or as managed asset. Treated as a by-product, data is exhaust from selling: created incidentally by whoever typed it, owned by nobody, kept until inconvenient, repaired only when a report embarrasses someone, and

deleted — if ever — by hand. That framing explains all three chronic symptoms: the 8.4% variance stays “unexplained” because it has no owner; the 11-day report persists because nobody owns the *definition* of revenue; duplicates return because identity was never a rule, only a keystroke. Treated as a managed asset, each stage acquires an owner, an enforced gate and a measurable standard: rules at creation, continuous measurement, scheduled retention, retirement with evidence.

Recommended Board actions. Adopt the Data Governance Charter in Month 2 — a Council, seven domain owners and stewards from existing job titles, zero headcount, a fortnightly 30-minute stand-up. **Approve POL-001 first, Month 2** — four-tier classification, default-deny grants, encrypted-export approval: the exact path the unencrypted laptop walked out of. **Bind quality at entry, Months 2–4** — VR-001..VR-012 on forms and in the ETL quarantine, DQC-01..DQC-10 as a daily scorecard. **One definition per KPI and one reporting layer by Month 6**, collapsing the 11-day cycle. **Fund it inside the UGX 480,000,000 envelope** — an 18-month programme total on the stricter reading — **phased**: quick wins in Months 1–6, PDPO-audit-ready by Month 12.

The lifecycle map. It traces customer data across **creation** → **storage** → **usage** → **sharing** → **archiving** → **deletion**, naming the system, the stakeholder and the failure point at every stage. Its sharpest findings sit at *sharing* (e-mailed supplier Excels, manual MoMo CSV downloads against a mobile-money share of **73.2%** of revenue, unencrypted laptop exports) and at *deletion* (no retention or erasure process at all, contrary to the DPPA 2019 (Cap.97) s.3 protection principles and s.28 erasure right). Every failure point is a *control* that does not exist, not a *tool* that is missing — which is why the same defects recur after each clean-up. The Jul–Dec 2024 baseline carries a control total of **UGX 252,382,814.16**: sound rows, still no Board answer without owners and definitions.

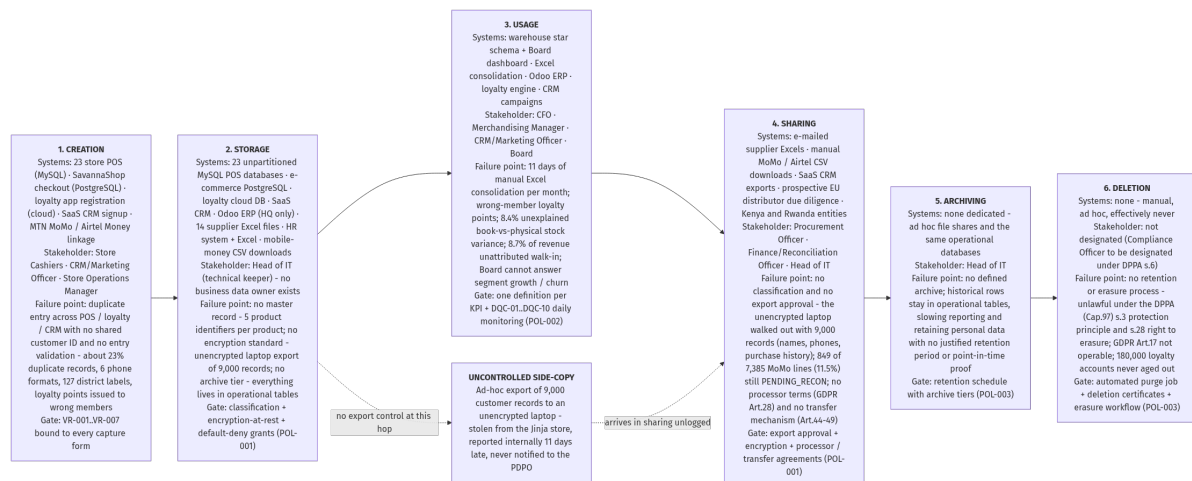


Figure 1: Fig. A1 — Customer data lifecycle: systems, stakeholders, failure points and control gates

DAMA-DMBOK gap mapping. Against the eleven knowledge areas, SRG shows two emerging (Data Quality, Data Security), five partial and four effectively absent. The six most striking:

Knowledge area	SRG state	What SRG lacks entirely
Data Governance	Absent	Policy issuance, governance council, RACI decision rights, funding of data work
Data Architecture	Absent	Enterprise architecture blueprint, integration/consolidation layer, architecture standards
Documents & Content	Absent	Content and records management, versioning and retention, DLP over e-mail and endpoints
Reference & Master Data	Partial (emerging)	Named master-data owners, approved survivorship rules, authoritative product → category hierarchy maintained in Odoo

Knowledge area	SRG state	What SRG lacks entirely
Data Security	Partial (emerging)	Classification policy, endpoint and export controls, access recertification, access/audit-log review
Data Quality	Present (emerging)	Binding rules at the point of capture, a stewardship loop with SLAs, a monthly scorecard to the Council

The three most consequential gaps. No governance decision rights — every other gap is a symptom of it, and it is the cheapest to close (Charter, Month 2). **No architecture or integration layer** — the direct cause of the 11-day cycle, five product identifiers and 23% duplicates. **No lifecycle end** — archiving and deletion, leaving SRG unable to demonstrate retention periods or honour erasure inside the 12-month audit window.

Think deeper. Why do the same symptoms keep returning after every clean-up? Because cleaning is an event applied to a stock, while quality is a property of a flow. SRG scrubs the stock and re-opens the taps: with no validation at capture, no owner and no monitoring, defects re-enter within days — the 22.84% duplicate rate was measured on data already cleaned in earlier exercises. Each exercise intervened in usage while defects were manufactured at creation and copied out at sharing. As a by-product, data is repaired when a report embarrasses someone; as a managed asset, every stage has an owner and an enforced gate. The test after any cleansing: what stops this recurring on Monday?

1.2 Task A2 — Governance Framework & Compliance Register

Vision. SRG's data is owned by named people, defined once, validated at entry, protected by default and retired on schedule — so any Board question is answered from one trusted source within a day rather than eleven. Sized for a four-person IT team and a ~200-staff retailer, it takes effect on Board resolution in Month 2 with no new headcount.

Six principles:

Principle	What it means at SRG
Data is a managed asset, not a by-product	Every domain has a named owner; data work is budgeted, measured and reported like inventory
Enforce technically, not by poster	If a rule can be a constraint, dropdown, mask or quarantine, it must be; documentation is the fallback, not the control
One definition per KPI, one master per entity	Revenue, active customer and stock on hand defined once and signed by the Council; Odoo is product master, golden record is customer master
Quality is built at entry, never cleaned after	VR-001..VR-012 bind at the form and the ETL gate; cleansing is remediation, not the operating model
Privacy by default	Masked until proven otherwise; default-deny access; classify before you grant; collect the minimum (DPPA s.3, GDPR Art.5, Art.25)
Ownership before tooling	No new platform, licence or hire before the receiving domain has a named owner and steward

Scope. Seven domains are governed, each with one definition, its systems, a Domain Data Owner and a Data Steward drawn from **existing SRG job titles only**: Customer & Loyalty (180,000 members plus walk-ins), Product (one product = one SKU), Store & Organisation (ST01–ST23 and ECOM01), Supplier (14 Excel files into a controlled repository), Price & Promotion, Transaction & Payment (MoMo/Airtel references) and HR-restricted (highest sensitivity):

Domain	Domain Data Owner	Data Steward
Customer & Loyalty	CRM/Marketing Officer	Store Operations Manager
Product	Merchandising Manager	Procurement Officer
Store & Organisation	Store Operations Manager	Head of IT Operations
Supplier	Procurement Officer	Finance/Reconciliation Officer
Price & Promotion	Merchandising Manager	Finance/Reconciliation Officer

Domain	Domain Data Owner	Data Steward
Transaction & Payment	CFO	Finance/Reconciliation Officer
HR-restricted	HR & Payroll Officer	Compliance Officer (DPO)

Out of scope, deferred rather than rejected: footfall-sensor content and biometric processing (pending a DPIA, Month 12); HR analytics beyond payroll accuracy; predictive segmentation or automated decisions (blocked until DPPA s.27 / GDPR Art.22 review); cloud migration and real-time streaming; Kenya and Rwanda localisation; document management beyond a supplier-contract pilot at Month 9.

Operating structure. The **Data Governance Council** is sponsored by the **Managing Director** and chaired by the **CFO**; members are the Head of IT, Merchandising Manager, CRM/Marketing Officer, Store Operations Manager, Finance/Reconciliation Officer and Compliance Officer. The Council owns the policy set, resolves domain disputes and approves exceptions. DPPA 2019 (Cap.97) s.6 requires a designated data protection officer: the Board designates the **Compliance Officer as DPO** in Month 1 — an existing role, no hire — reporting independently to the Managing Director for breach matters and owning PDPO registration (s.29). **Domain Data Owners** are accountable for their domain's meaning, quality targets and access decisions; **Data Stewards** run checks, triage the stewardship queue (110 items today) and propose rule changes. Escalation runs stewards → owners after 14 days, owners → Council for disputes, Council → Board for P1 incidents and budget, DPO → Managing Director for breach declaration. Cadence stays light: a 30-minute stewards' stand-up fortnightly, a 60-minute Council monthly, a one-page Board report quarterly against the UGX 480,000,000 envelope, and an incident cell — Head of IT, DPO, domain owner — within 24 hours under DPPA s.23 and GDPR Art.33. Adoption is one signature page in Month 2 with POL-001..POL-003 attached.

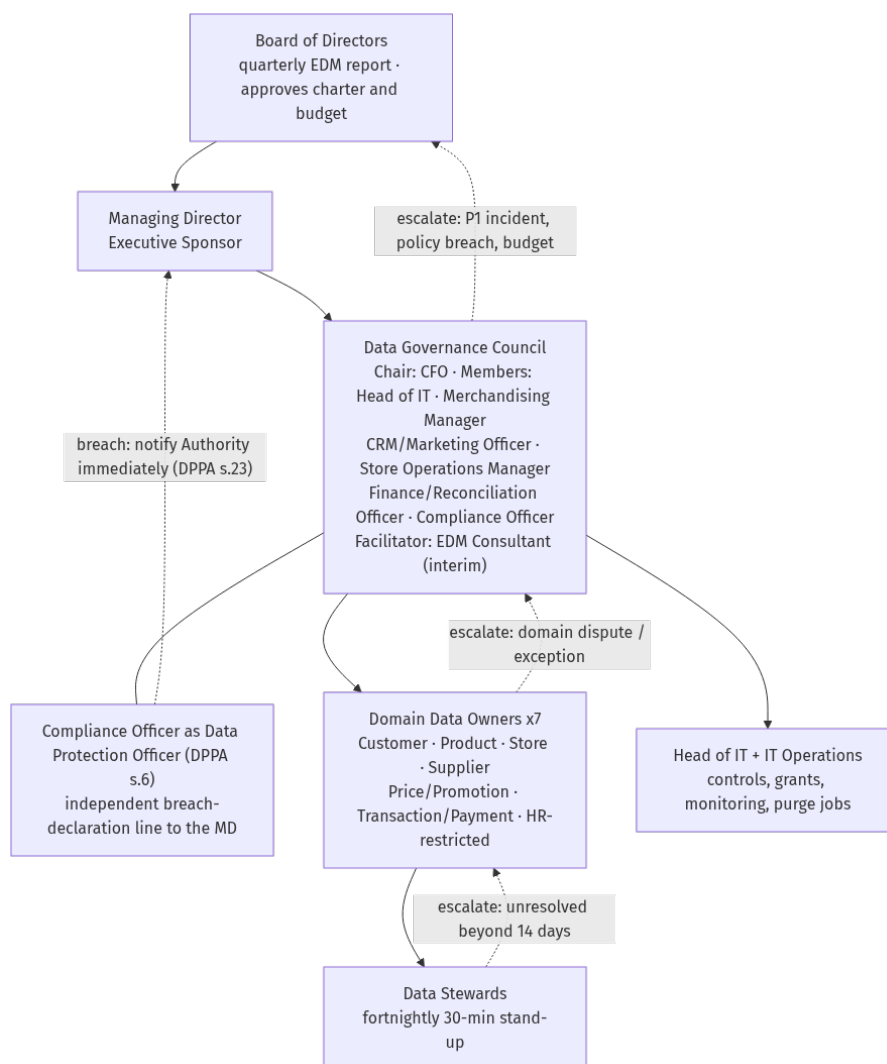


Figure 2: Fig. A2 — Governance operating structure: data council, stewardship, ownership — existing SRG roles only

Decision rights (RACI). Responsible, Accountable, Consulted and Informed roles are assigned across fourteen activities: customer record creation at POS, e-commerce and loyalty signup; master-data change approval for product, price and promotions; breach declaration; retention and deletion execution under POL-003; quarterly access recertification; data-quality rule exceptions; ETL failure triage and quarantine release; KPI definition sign-off; mobile-money reconciliation sign-off; supplier file ingestion; PDPO registration and audit response; loyalty points dispute resolution; dashboard publication approval; and data-subject erasure or access requests under DPPA s.24, s.28 and GDPR Art.15, Art.17. Accountability attaches to job titles, not committees: the CFO signs KPI definitions and reconciliation, the Compliance Officer (DPO) owns breach declaration, and the Council is informed of every exception. Full RACI matrix (14 activities): Appendix D.

Three enforceable policies. POL-001 and POL-002 take effect in Month 2 and POL-003 in Month 3, each an annex to the Charter binding to a control that fails closed:

ID & policy	Owner (job title)	Measurable requirement	Enforcement mechanism
POL-001 — Data Access & Classification	Head of IT (day-to-day control owner); Compliance Officer / DPO owns the classification taxonomy	One of four tiers (Public, Confidential, Restricted, Prohibited) on 100% of attributes by Month 3; 0 standing ad-hoc grants ; recertification ≥95% each quarter; extracts above 100 Restricted records need Head of IT + DPO approval, encryption and 7-day expiry; endpoint ≥98%	Default-deny GRANT/REVOKE with column grants and row-level security; masking views as the only analytic surface; Restricted reads logged and reviewed monthly for 12 months; export workflow refuses unencrypted containers
POL-002 — Data Quality	Head of IT (control operation); Domain Data Owners (quality targets); CRM/Marketing Officer (customer domain)	VR-001..VR-012 bound client- and server-side — Month 2 at ETL, Month 4 for 100% of capture forms; DQC-01..DQC-10 daily at 06:00 (duplicates >1.0%, phone validity <99.0%, quarantine >0.5%); SLAs: critical <24 hours, high <3 days, medium <10; 0 unticketed production edits	Blocked saves at the form; ETL quarantine with reason codes and no batch aborts; alerts to the on-call rotation and Council dashboard, never an unmonitored mailbox (RC-6) ; store scorecard on store-manager KPIs
POL-003 — Retention & Deletion	Compliance Officer / DPO (schedule and erasure workflow); Head of IT Operations (purge jobs)	Transactions and MoMo references 7 years ; loyalty 24 months after inactivity; marketing consent 24 months; supplier records 6 years; backups 90 days ; monthly purge with deletion certificate; erasure acknowledged in 5 working days , fulfilled in 30	Scheduled purge jobs with append-only logs; cryptographic erasure at backup cycle end; automatic revocation at 24 months' inactivity; quarterly spot audit of 10 records per domain tabled with certificates

Compliance register. Obligations are scored Risk = Likelihood × Impact (1–5 each), with P1 at 20–25 or a statutory deadline already running; ten rows are P1. Three frameworks are carried: the Uganda Data Protection and Privacy Act (DPPA) 2019 / Cap.97 as the binding regime, EU GDPR because a European distributor's due-diligence team is asking about SRG now, and CCPA/CPRA as comparative reference — §1798.140 thresholds below range today, §1798.100 and §1798.130's 45-day response unattainable, §1798.105/§1798.120/§1798.150/§1798.155 benchmarking deletion, opt-out and liability. The five most severe P1 gaps:

Obligation	Current practice	Gap	Risk priority
DPPA 2019 (Cap.97) s.29 — data protection register	No registration; processing 180,000 members, e-commerce and app data	Unregistered controller; audit-critical failure	$5 \times 5 = 25$ — P1
DPPA s.23 incl. s.23(4) content — breach notification	Jinja incident: internal report 11 days late, no notification ever made	Missed immediate notification; incomplete incident record	$5 \times 5 = 25$ — P1
DPPA s.20 and s.21 — security measures (controller and processor)	No endpoint encryption, no export approval, unencrypted 9,000-record export	Direct cause of the Jinja incident	$5 \times 5 = 25$ — P1
GDPR Art.33 (72 hours) and Art.34 (high-risk subject notification)	No procedure of any kind	Hard deadline would be missed on day one of EU data flows	$5 \times 5 = 25$ — P1
DPPA s.6 — data protection officer	No DPO; breach and consent decisions unowned	Accountability vacuum	$5 \times 4 = 20$ — P1

A row closes only when the remediation artifact exists and has been demonstrated at the Council — CMP-05 closes on the export-approval workflow and RBAC assertion suite, not on a statement of intent. Any P1 open beyond 30 days goes to the Board with a named owner and recovery date; by Month 12, registration, DPO designation, the breach procedure and drill, the ROPA, the DPIA and POL-001..POL-003 records form the PDPO audit pack. Full register: Appendix F.

The absence of governance already has a price tag. The Jinja incident, priced (consultant estimates, to be validated): notification at UGX 6,000 per record-contact (SMS and letter) — $9,000 \times 6,000 = \text{UGX } 54,000,000$; an incident-response retainer at **UGX 15,000,000**; internal staff time at 6 people $\times 15$ days $\times \text{UGX } 250,000 = \text{UGX } 22,500,000$. Direct cost: **UGX 91,500,000 — 19% of the UGX 480,000,000 envelope** — spent replacing data, not building anything. Worse, the theft was reported internally **11 days late** and **never notified**, against DPPA 2019 (Cap.97) s.23, which requires the Authority to be notified *immediately*. Beyond that: compensation exposure under DPPA Part VII (s.33, verify with counsel), a PDPO investigation within 12 months, and the trust of 180,000 members.

Two comparable industry cases. The UK Information Commissioner fined **Marriott International GBP 18.4 million (October 2020)** after a breach in acquired Starwood systems lacking security **due diligence**; converted, **UGX 86 billion** — roughly **180 times** the UGX 480,000,000 envelope. The ICO fined **British Airways GBP 20 million (October 2020, GDPR Art.83)** after about **400,000 customers** were affected by a web-skimming attack — a single control gap producing roughly **UGX 94 billion**. Integrating with unassessed systems inherits their liability, and the distributor's due-diligence team is asking that question about SRG now — mid-market retailers are the affordable target.

The monthly drag. Reporting: 4 staff $\times 11$ days $\times 12$ months = 528 person-days $\times \text{UGX } 150,000 = \text{UGX } 79,200,000$ **per year** to build one month's report. Duplicates: 23% of 180,000 $\approx 41,400$ profiles $\times 4$ campaigns $\times \text{UGX } 150$ per SMS = **UGX 24,840,000 per year** wasted. Stock variance: $\text{UGX } 504.8\text{M revenue} \times \sim 70\%$ cost of goods = $\text{UGX } 353.3\text{M} \times 8.4\% = \text{UGX } 29,700,000$ **per year** unexplained. Total drag $\approx \text{UGX } 133,700,000$ **yearly — 28% of the data budget**, plus the one-off UGX 91.5M incident: **UGX 225M+, about 47% of the envelope, spent on the absence of governance.** Meanwhile 849 of 7,385 mobile-money lines (11.5%) sit as PENDING — cash finance cannot prove it received.

The ask and the rebuttal. No new money: Phase 1 (Months 1–6) commits roughly **UGX 96M — 20% of the existing UGX 480,000,000 envelope** — to classification and encryption, the export-approval workflow, entry validation and one reporting layer. By Month 6: reporting from 11 days to 2 or fewer, duplicates below 1%, PDPO registration filed (DPPA s.29), a signed evidence trail for the distributor. Without classification and access rules, every future export is another 9,000-record laptop waiting to happen; the cheapest line in this programme is POL-001, the most expensive is doing nothing.

Think deeper. POL-001 (Access & Classification) is the single policy that would have prevented the Jinja incident: the 9,000 records were Restricted, the export required dual approval and encryption, and the copy would never have left. POL-002 is the one violated daily — free-text phones and districts at the till, e-mailed supplier Excels, ad-hoc spreadsheets, unticketed production edits — because each is individually convenient. Enforcement becomes real when controls fail closed rather than persuade: default-deny grants, masking views as the only analytic surface, a workflow that refuses unencrypted containers, quarantine instead of silent passes, and a store scorecard attached to manager KPIs. Non-compliance must become visible to a manager with authority; every month skipped re-books the UGX 91.5M.

Evidence: Appendices B–G; repo: docs/.

2 Part B — Technical Core

2.1 Task B1 — Architecture Selection, ER Model & Normalization

Weighted trade-off. Four enterprise patterns were scored 1 (worst) to 5 (best) against six criteria. Weights are derived from SRG’s constraint set, not from a generic architecture scorecard.

Criterion	Weight	Centralized	Decentralized	Federated	Hub-and-spoke
C1 Resilience under intermittent connectivity	25%	1	5	4	4
C2 Fit for the four-person team’s skills	20%	3	2	2	4
C3 Budget fit (UGX 480,000,000/yr envelope)	20%	2	3	3	5
C4 Time-to-value by month 6	15%	2	3	2	5
C5 Single version of truth	10%	5	1	3	4
C6 Scalability to Kenya and Rwanda	10%	4	2	5	4
Weighted total	100%	2.45	3.00	3.10	4.35

Why the weights sit where they do. Connectivity takes 25% because several stores lose links for hours daily — the least negotiable fact and the one an always-on design breaks on first. Skills (20%) and budget (20%) follow the roster and the envelope: two of four IT staff write SQL, none have data-engineering experience, and UGX 480,000,000 (~USD 130,000) must carry licences, cloud and hires together. Month-6 time-to-value takes 15% because the Board expects visible quick wins; single version of truth takes only 10% because a delayed but governed core still restores one truth, whereas an outage cannot be negotiated away; expansion across the border (10%) is a 12–18 month concern. Full analysis: Appendix H.

Recommendation: hub-and-spoke, 4.35 / 5.00 — one central governed core (immutable landing, staging, warehouse, golden records, DQ rules) fed by offline-first spokes that capture locally, buffer and sync in a 23:00–02:00 window. Three reasons decide it. First, it leads on every non-negotiable criterion simultaneously: connectivity, skills, budget and the month-6 deadline. Second, one pipeline in SQL and pandas with one run log is operable by the existing four-person team, with no unattended streaming platform in the critical path. Third, the outcome is provably deliverable inside two quarters: the repaired pipeline holds 10,000 lines to a control total of UGX 252,382,814.16 net and reports self-test 3/3 PASS.

Rejected alternatives. Centralized (2.45) turns every store outage into lost sales and spends the month-6 window on network remediation before a single dashboard ships. Decentralized (3.00) is the current disease, not a hypothesis: 23 MySQL silos, 22.84% duplicate customers, five identifiers per product, an 11-day monthly close and an 8.4% stock variance. Federated (3.10) needs domain owners, stewards and published data contracts that do not exist yet — correct as a year-3 posture, wrong as the year-1 backbone. An enterprise commercial integration or MDM suite falls outside the UGX 480,000,000 envelope and would still fail the connectivity test.

From decision to delivered build. The pattern shows up in what shipped. Offline capture is a designed state rather than an error: walk-in rows load with `customer_sk = 0` (“Unknown / Walk-in”) and missing mobile-money references become `payment_ref = 'PENDING_RECON'` with status PENDING instead of aborting the run. Sync is asynchronous and windowed, never always-on, with a single-writer lock so replay cannot deadlock the nightly job. The core fails visibly rather than silently — quarantine table, run log and post-load control total replace the diagnosed stale-fallback anti-pattern — and golden records return to the spokes nightly, keyed by E.164 phone.

The ER model. Eight entities — Customer, Product, Store, Order, OrderLine, Payment, Supplier and LoyaltyAccount — form the consolidated operational core.

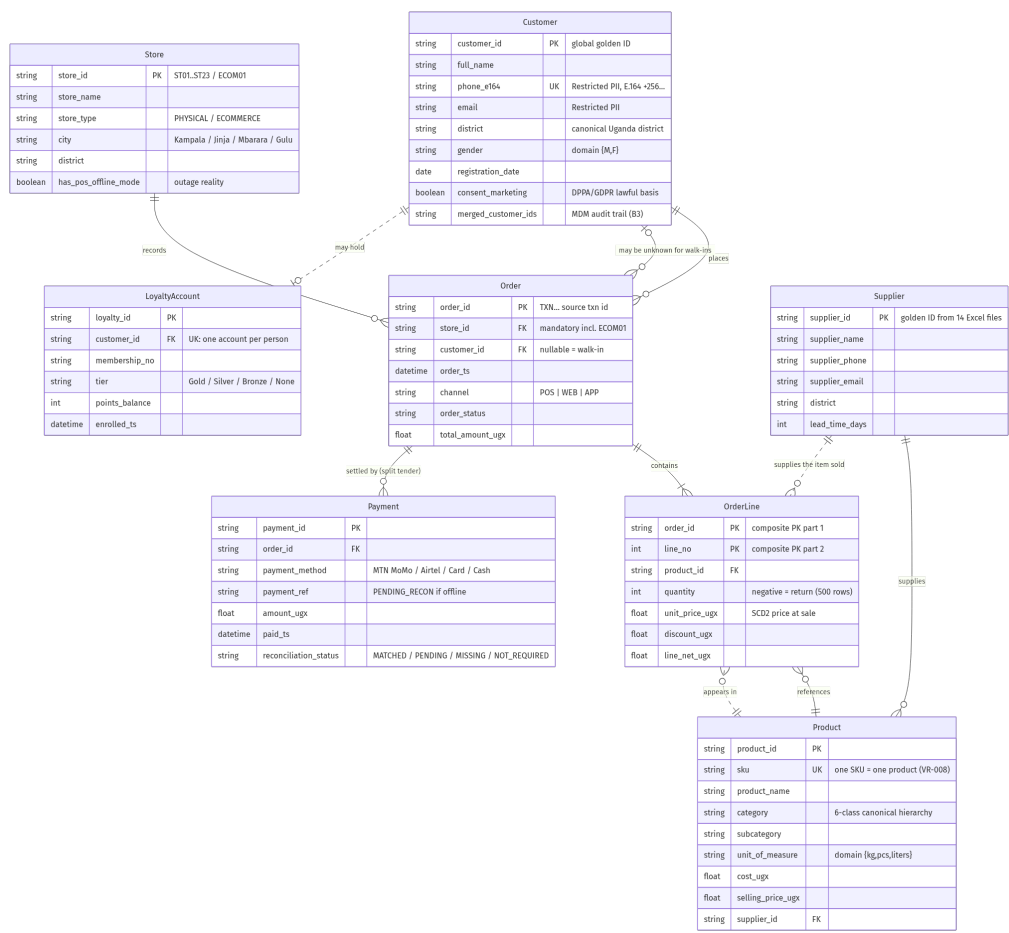


Figure 3: Fig. B1 — Consolidated operational core: Crow's Foot ER model, 8 entities with keys and cardinalities

Cardinalities and assumptions. Every order resolves to exactly one selling location but at most one customer, so a walk-in sale never violates the model; an order must carry at least one line, lines are the only place a price is frozen, and split tender is represented as multiple payment rows rather than nullable columns. Three assumptions are embedded, each kept deliberately soft: a customer *may* belong to a household (a non-identifying grouping, not an identity link), one customer holds one phone number (phone_e164 unique and reused as the MDM deterministic key), and one product is supplied by one supplier (mandatory M:1 foreign key). Modelling them as optional, versioned or soft is what lets the observed exception survive. Alignment to the warehouse is direct: OrderLine becomes fact_sales, Customer and Product become SCD2 dimensions, Store stays Type 1, and Payment splits into a method dimension plus reconciliation columns on the fact. ER and normalization evidence: Appendix I.

Normalization, one pass.

Form	Violation	Fix	Rationale
1NF	Repeating multi-value group — items and unit_prices cells hold COC1001×2; KAK1002×1	One atomic row per transaction line; composite PK (tx_id, line_no)	The row states one fact at one grain, identical to fact_sales, so no delimited string is ever parsed
2NF	Partial dependencies — customer, store and payment attributes repeat on every line	Extract Customer, Store and Payment relations under their own keys	One name correction touches one row; a store rename stops being a mass update across 10,000+ sales rows

Form	Violation	Fix	Rationale
3NF	Transitive dependencies — district → region, line → product → supplier — plus a stored order_total	Extract District, Product and Supplier masters; drop the derived total and compute Σ line_net_ugx	Region re-mapping and supplier phone changes no longer rewrite sales history; unit_price_ugx stays on the line as a time-of-sale snapshot, which is a fact, not a dependency

Denormalization memo. Two labels — category_label and store_city — are carried onto a nightly-rebuilt reporting view over the star schema, turning a category-by-city card into a single scan for a four-person team. Both labels are always read from the SCD2 dimension version stamped at event_ts, never from is_current, so a re-categorisation cannot silently rewrite Q3 history. The view is an idempotent projection and is never edited in place: performance is bought with a decoration, not with a copy of the truth.

Think deeper. The household grouping breaks in Jinja, where three unrelated students rent rooms under the landlord's surname and share the house phone — merge them and one person's purchases and consent sit on another's record. Phone uniqueness breaks in Mbarara, where a family answers whichever handset rings and one +2567... legitimately belongs to four people. Single-supplier breaks during shortages, when the same sugar SKU arrives from Kakira and an importer with two costs in one week, falsifying margin history. Each assumption stays safe only while it remains optional or versioned; the moment it hardens into a UNIQUE or mandatory constraint, the observed exception returns as a defect.

2.2 Task B2 — Data Quality Assessment & Cleansing (Hands-On)

Profiling before and after. The same functions ran on raw and cleansed states, so every delta below is measured rather than asserted. Composite measures are reported honestly: customer composite validity reaches 68.51%, not 100%, because 110 suspected duplicates stay open by design — declaring completion would mean silently merging people the evidence cannot separate.

Dataset	Metric	Before	After	Change
Customers	Confirmed duplicate rows, auto-matched	22.84%	0.00%	−22.84 pp
Customers	Total duplicate-person flag rate	25.06%	2.85%	−22.21 pp
Customers	Exact duplicate rows (all fields but ID)	14.88%	0.29%	−14.59 pp
Customers	Distinct raw district labels	127	42	−85
Customers	Distinct phone format variants	6	1	−5
Customers	Phone already in E.164 format	22.76%	91.96%	+69.20 pp
Customers	Gender stored in canonical domain {M, F}	32.88%	100.00%	+67.12 pp
Customers	Composite record validity, all four rules	17.30%	68.51%	+51.21 pp
Products	Unit of measure in {kg, pcs, liters}	15.33%	100.00%	+84.67 pp

Dataset	Metric	Before	After	Change
Products	Composite product validity, all rules	3.25%	100.00%	+96.75 pp

Matching logic in one sentence. Candidates are blocked on canonical district and must reach name similarity ≥ 90 before any score is computed; weights run +60 (or +70 for near-exact spelling) for name, +20 for district, +20 / +10 / 0 for phone and +15 / +5 / -10 for email, after deterministic E.164 phone equality executes first and unions 953 pairs — auto-merge requires score ≥ 85 and a positive identifier, 65–84 routes to stewardship review, below 65 stays separate, and conflicting non-empty emails hard-reject the pair, yielding 1,142 of 1,150 injected duplicates merged, 365 homonym pairs rejected, 110 rows held for review, and 5,000 raw rows resolving to 3,858 golden records.

How the cleanse worked. Standardisation always ran before matching, because scoring six phone formats would hide the clusters they belong to: an input mask plus E.164 collapse for phone, an alias dictionary with fuzzy matching at an 88 WRatio threshold for district, and label maps for gender, unit of measure, category and date. Every standardised value sits beside its original in a *_row column — 5,000 raw rows became 3,858 golden records with a merged_customer_ids audit trail. What could not be automated was flagged, not fixed: 141 rows sharing a duplicate SKU, 69 SKUs mapped to more than one product name and margin anomalies where selling price sits below cost stay open under stewardship — a machine must not choose between two products or reprice a shelf.

Validation rules. Twelve rules span customers, products and payments, mixing technical conditions (phone mask, PK uniqueness, RFC-5322-lite email, ISO-8601 dates) with business vocabularies (official district list, unit of measure in {kg, pcs, liters}, six-class merchandise hierarchy, one SKU = one product name, MoMo reference within 24 hours). Every rule declares an action on failure — block the save, quarantine the row, flag for steward or escalate — plus a severity, so no violation depends on someone noticing a report. VR-007 is the linchpin: normalized phone unique across golden records or the record sits in the review queue, with loyalty point posting blocked until identity resolves. Full catalogue VR-001...VR-012: Appendix J.

Root cause: the 8.4% stock variance. Book stock minus physical stock averages 8.4% across every store, reported simply as “nobody knows why”. Two properties frame the analysis: the variance is *systemic*, appearing at every store rather than one, which rules out a single-site explanation such as theft at one branch or one bad manager; and it is *unattributed*, because no store keeps an adjustment log, so the gap cannot yet be split between process loss, measurement error and capture error. Six cause categories — People, Method, Measurement, Systems, Data and Environment — were examined and every leaf cause classified by the type of fix it needs.

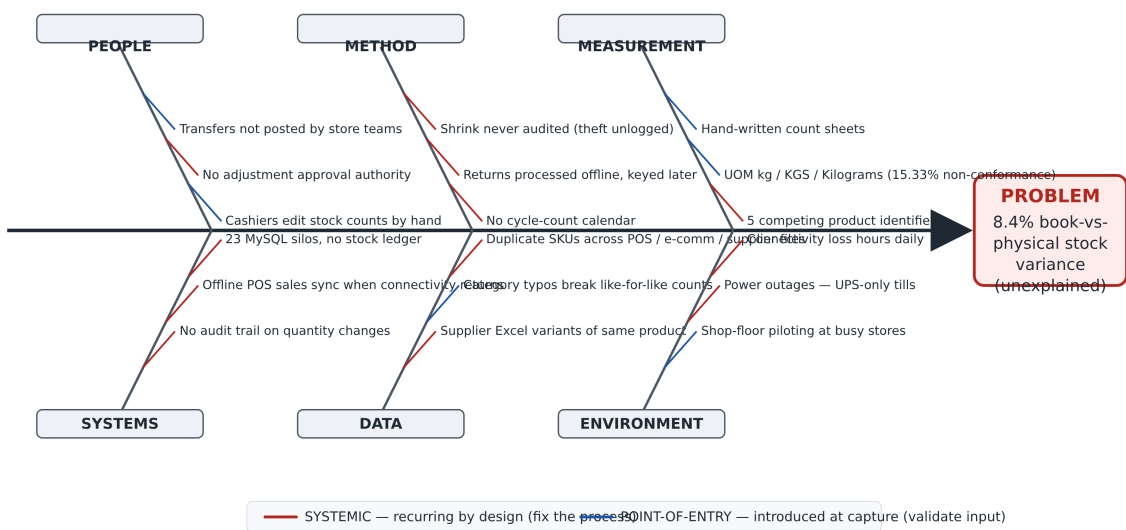


Figure 4: Fig. B2 — Ishikawa (fishbone) analysis of the 8.4% stock variance: red = systemic, blue = point-of-entry

Verdict: 11 systemic causes against 7 point-of-entry causes. That ratio is the finding — cleansing at entry would recover at most about 39% of the identified causes, while the remaining 61% are produced by process design and

regenerate the variance however carefully staff type, which is why a one-off stock-take cannot fix 8.4%. The first three fixes are: pull stock-adjust rights out of the cashier role and route every correction through a propose-approve-log workflow; make transfer posting mandatory with scan-out/scan-in and a per-transfer variance check; and put controlled entry lists for unit of measure, category and SKU on every form. Targets follow the same logic — book-to-physical variance at or below 2.0% by month 12 and 1.5% at 18 months.

What each class demands. Point-of-entry causes stop at the form — a validation list, a blocked field, a permission removed — and they are the minority. The systemic eleven need process design instead: an adjustment approval workflow with a retained log, a quantity-change audit table recording who, when, old and new value and reason, ABC cycle counts replacing the annual scramble, a single stock ledger so that “book stock” stops being 23 private opinions, and sequence-numbered store-and-forward so queued sales become visible latency rather than phantom stock. Both five-whys branches converge there — one on no named stock owner below head office, the other on no master data and no validation at capture — which makes the variance a governance symptom, not a counting problem.

Monitoring. Daily checks convert the rule catalogue into owned alerts with thresholds and escalation paths.

Metric	Threshold	Alert path	Owner
DQC-01 duplicate-person rate	> 1.0% daily; > 2.0% = P1	CRM Officer → Data Governance Council after 3 days above 2%	CRM Officer
DQC-05 product UOM / category conformance	< 99.0%	Nightly check → block non-conforming item setup in Odoo	Merchandising Officer
DQC-06 SKU uniqueness violations	> 0 (zero tolerance, nightly)	Collision report → quarantine batch, re-issue SKU	Merchandising Officer → IT Manager
DQC-07 ETL quarantine rate	> 0.5% or > 100 rows per run	On-call alert → inspect quarantine, fix source, replay	IT Operations Lead
DQC-08 MoMo refs pending > 24h	> 0 daily; > 50 = P1	Reconciliation queue → daily digest to CFO	Finance Reconciliation Officer

DQC-01...DQC-10 run as one daily suite; phone validity below 99%, district resolution below 99.5%, core-field completeness, future-dated registrations and weekly margin anomalies complete the set. Each check ships its own remediation command, so an alert arrives with the first step named; queue age is reviewed weekly so growth triggers a form fix at the offending store. Full DQ evidence — profiles, rules, monitoring and the fishbone source: Appendix J.

Think deeper. Each defect class has a root behaviour behind it, not a typing error. Duplicates and five identifiers come from systems that each mint their own IDs with no enterprise key, so the fix is capture-side enforcement: controlled pickers, an input mask and a golden key at signup. Unit and category errors come from free-text fields that reward speed, stopped by vocabularies on the form. Systemic variance comes from unowned processes — no approval, no audit table, no count calendar — so the fix that ends it is named stock ownership, an approver on every adjustment, and ABC cycle counts posted the same day.

2.3 Task B3 — Master Data Management Design

Style selection. Four MDM styles were tested against budget, connectivity, duplicate control and time-to-value.

Style	Verdict	Why
Registry	Rejected	No survivorship: every system keeps its own copy, so the 23% duplicate load regenerates at the next signup
Consolidation	Adopted	SQL + Python on the existing estate, built for batch sync, and the hard part is already delivered: one golden table, enforced survivorship, stewardship queue

Style	Verdict	Why
Coexistence	Rejected for now	Bidirectional propagation assumes links that are down for hours daily; last-writer-wins would overwrite verified goldens with clerk-typed variants
Centralized (transactional)	Rejected	Suites and the skills to run them sit outside the UGX 480,000,000 envelope, and a coordinator call per signup would block the till at ST19 in an outage

Golden-record survivorship.

Attribute	Winning source	Justification
full_name	Most complete registration record; tie → earliest registration date → lowest customer ID	The name a human recognises at the till; earliest is the name given when the relationship started
phone	Loyalty app E.164-verified number, else the most recent valid value	Phone is SRG's operational key for till lookup, MoMo linkage and loyalty SMS; OTP-verified beats merely typed
email	E-commerce checkout-validated address; conflicts flag review and are never silently picked	Only a checkout-proven address is guaranteed to reach the customer, and two different emails suggest two people
district	Latest POS-verified value checked against the official Uganda district list	Catchment analysis needs current residence; the official list keeps reporting stable across 127 raw labels
consent and contact preferences	CRM, by recency of consent capture	Consent must reflect the most recent evidenced opt-in or opt-out under DPPA s.7 and GDPR Art.7
loyalty tier and points balance	Loyalty platform	Points are a financial liability owned by the loyalty ledger; a second stored balance would compete with the truth

Matching rules and thresholds. Deterministic phone equality runs first on the standardised value, never on empty keys; probabilistic candidates are then blocked on canonical district and scored on name, district, phone and email. Auto-merge requires score ≥ 85 and a positive identifier match; 65–84 goes to stewardship review with a 48-hour steward SLA; below 65 stays as separate records; conflicting non-empty emails hard-reject the pair. Name similarity alone never merges.

The trade-off is deliberately asymmetric: a false merge is strictly costlier than a missed match. A missed match leaves a duplicate contact — annoying, visible and fixable later with full context. A false merge absorbs one customer's loyalty history and points into another's, corrupts consent records so one person's marketing opt-out can be inherited or overwritten by another, and causes a data-subject request to return a stranger's purchase history — breaches of DPPA s.7 and GDPR Art.7 accuracy duties that no audit trail fully repairs once the merge has propagated. That is why automation is capped at identifier-backed merges, why 365 homonym pairs were rejected rather than merged, and why the 110-row queue is a feature rather than a backlog: the design accepts a missed match as the price of avoiding irreversible privacy harm.

Hierarchies. Customer to household is a *soft* grouping — same normalized address or district, surname and shared phone with activity inside 90 days, stored as a confidence score 0–1 and never as an identity link. It may drive catchment counts, delivery batching and household-penetration metrics; it may never drive loyalty accrual, consent inheritance or single-customer-view roll-ups, because three Jinja students under a landlord's surname would otherwise exchange purchase histories. Product runs category to subcategory on the canonical six-class hierarchy — Beverages, Grains &

Cereals, Snacks, Household, Personal Care, Stationery — collapsing 30 raw labels, with one golden SKU per product and every legacy code kept as an alias: the “same product, five identifiers” case resolves to one golden SKU under VR-008, which flags 141 duplicate-SKU rows and 69 SKU-to-multi-name rows for stewardship and never auto-merges them.

Governance. *Attribute approval* runs quarterly: a steward submits business need, source system, PII classification and retention class; the Data Governance Council approves and a schema-change ticket follows, with a 10-working-day fast track for regulatory items. *Dispute resolution* starts with the domain steward inside 48 hours on evidence, escalates to the Council within five working days, and falls to a tie-break that retires after 12 months. *Propagation* lands in the next scheduled sync within 24 hours, or immediately and out-of-band for consent withdrawal, wrongful merge or breach-related suppression. Every merge stores merged_customer_ids and a stewardship flag in a read-only change log, so any decision can be undone and re-adjudicated; queue ageing reports weekly under DQC-01.

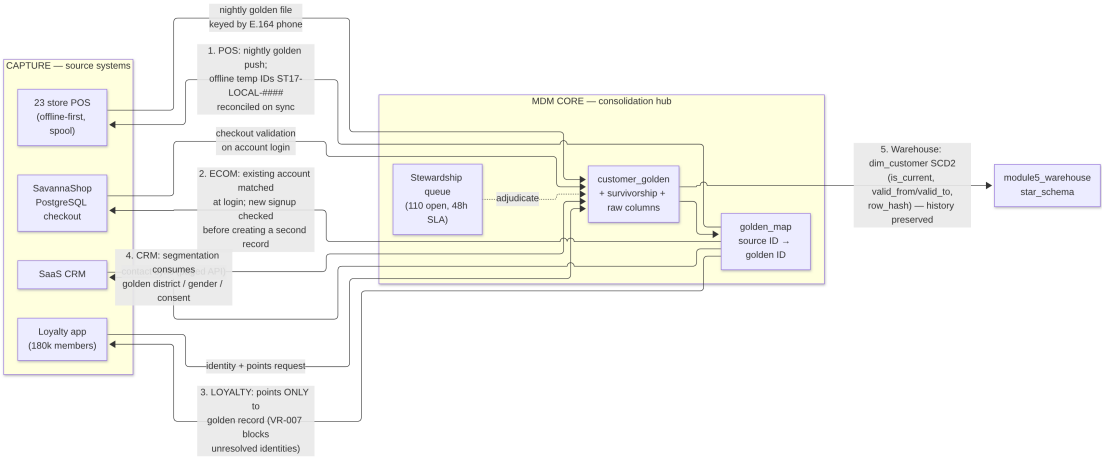


Figure 5: Fig. B3 — Golden-record integration flows back into POS, e-commerce, loyalty and CRM

Full MDM design: Appendix K.

Think deeper. The store manager creating quick local records during an outage is behaving rationally — blocking a sale to satisfy an MDM rule is a worse outcome than a duplicate. Technically, capture forms run offline on the same rules as the hub, issue namespaced temp IDs such as ST17-LOCAL-0042, and reconcile through the normal matchers on the next sync; walk-ins stay customer_sk = 0, never an invented identity, and points and marketing credit release only after a golden match. Politically, managers co-design the form, the KPI becomes “unreconciled local records over 48 hours” rather than a punishment for outages, and the steward answers within 48 hours, so cooperation survives the connectivity constraint.

2.4 Task B4 — Data Integration & Real-Time Architecture (Hands-On)

Star schema.

fact_sales sits at one row per sales line, keyed by sale_sk = SHA1(transaction_id), with additive UGX measures and returns carried as negative quantity — 500 lines totalling -UGX 10,224,221 (~3.9% of gross). It is fed from five sources — 23 MySQL POS, SavannaShop PostgreSQL, the loyalty cloud database, SaaS CRM and Odoo ERP — all landing in staging first. Load order is a hard rule: dim_date → dim_store → dim_payment_method → dim_product → dim_customer → fact_sales, dimensions always before facts.

Extraction methods.

Source	Method	Connectivity reality
23× MySQL POS (ST01–ST23)	Local CSV spool → SFTP, window 23:00–02:00	Offline > 3 hours defers to the next window; UPS tills keep capturing, spool replays idempotently
E-commerce PostgreSQL (SavannaShop)	CDC via logical replication / Debezium	HQ-side link is stable, so CDC decouples entirely from store connectivity
Loyalty cloud DB (180,000 members)	Nightly delta CSV via SFTP/API at 02:15	API rate limits respected; a weekly full snapshot acts as backstop

Source	Method	Connectivity reality
CRM SaaS	Paged REST API with updated_since cursor at 02:30	Throttled by contract; the cursor checkpoint resumes after a mid-run failure
Odoo ERP (HQ)	Scheduled export / RPC at 01:45	HQ LAN only — no wide-area dependency
<i>Supporting:</i> MoMo CSVs (MTN, Airtel)	Daily download to a drop folder	Pending refs age under DQC-08

Transformation and load sequence. Type coercion comes first: N/A, empty strings and null literals become SQL NULL, never a fake zero, and anything uncoercible such as UGX cheap in a quantity is quarantined while the batch continues. Currency strings strip to numeric, phone collapses from six variants to one E.164 form, district resolves from 127 raw labels to 42 canonical, dates normalise to ISO-8601, unit of measure maps to {kg, pcs, liters} and category maps to the six-class hierarchy. Dedupe and enrichment then remap source customer IDs to golden IDs through golden_map, COALESCE unresolved identities to customer_sk = 0, and read product price and cost from the SCD2 version valid at the moment of sale, with MoMo references stamped MATCHED, PENDING, MISSING or NOT_REQUIRED. Dimensions load next under SCD2 — close the old version when the row hash changes, insert the new one, keep exactly one current row — and only then does the fact load run, delete-then-insert per key under a single-writer advisory lock so offline store-sync replay cannot deadlock it. Post-load checks must pass before anything reaches BI: zero orphan product and customer foreign keys, row counts, quarantine rate and the control total of UGX 252,382,814.16 net across 10,000 lines at an average basket of UGX 25,238. Consumption is BI views over masking views with five default-deny RBAC roles; the pipeline runs on SQLite/Python and RBAC SQL is documented with expected-output evidence.

Diagnosis of the broken nightly job. The 11 March run left fact_sales unchanged for four days, blocking the 11-day monthly consolidation, and alerted a mailbox last opened a week earlier.

ID	Root cause	Evidence	Corrective action
RC-1	No schema or type contract between source and staging	invalid input syntax for type integer: "N/A" at COPY line 12044 — 0 of 21,562 rows staged	Staged landing with per-row coercion; bad rows to etl_quarantine, batch continues
RC-2	No surrogate key for unknown customers	63 walk-in rows against a NOT NULL fact foreign key → transaction abort	Insert customer_sk = 0 “Unknown / Walk-in” and COALESCE unknown keys
RC-3	Offline store-sync replay collides with the nightly ETL	DeadlockDetected, process 18442 vs 18501 on dim_store for ST17 Gulu	Advisory lock plus a 23:00–01:45 sync window; dimension updates ordered by key
RC-4	Silent “partial mode” fallback on the previous day’s staging	Log line 02:00:13; wrong results propagated for four days	Fail fast — non-zero exit, etl_run_log status FAILED, no stale reuse
RC-5	Dimensions loaded after facts	412 fact rows referencing SKUs absent from dim_product	Load SCD2 dimensions first, then facts; replay quarantined orphans afterwards
RC-6	Alerting to an unmonitored mailbox	Mailbox last opened seven days earlier; no run-state dashboard	Alert the on-call rotation by SMS/WhatsApp plus a 06:00 run-state check

Prevention is structural: a schema contract per source, quarantine instead of abort, idempotent replay, offline capture modelled as a designed state, single-writer discipline, and alerts a human reads — with the quarantine rate monitored under DQC-07. ETL workflow, diagnosis and ELT analysis: Appendix L.

ETL versus ELT for the cloud migration.

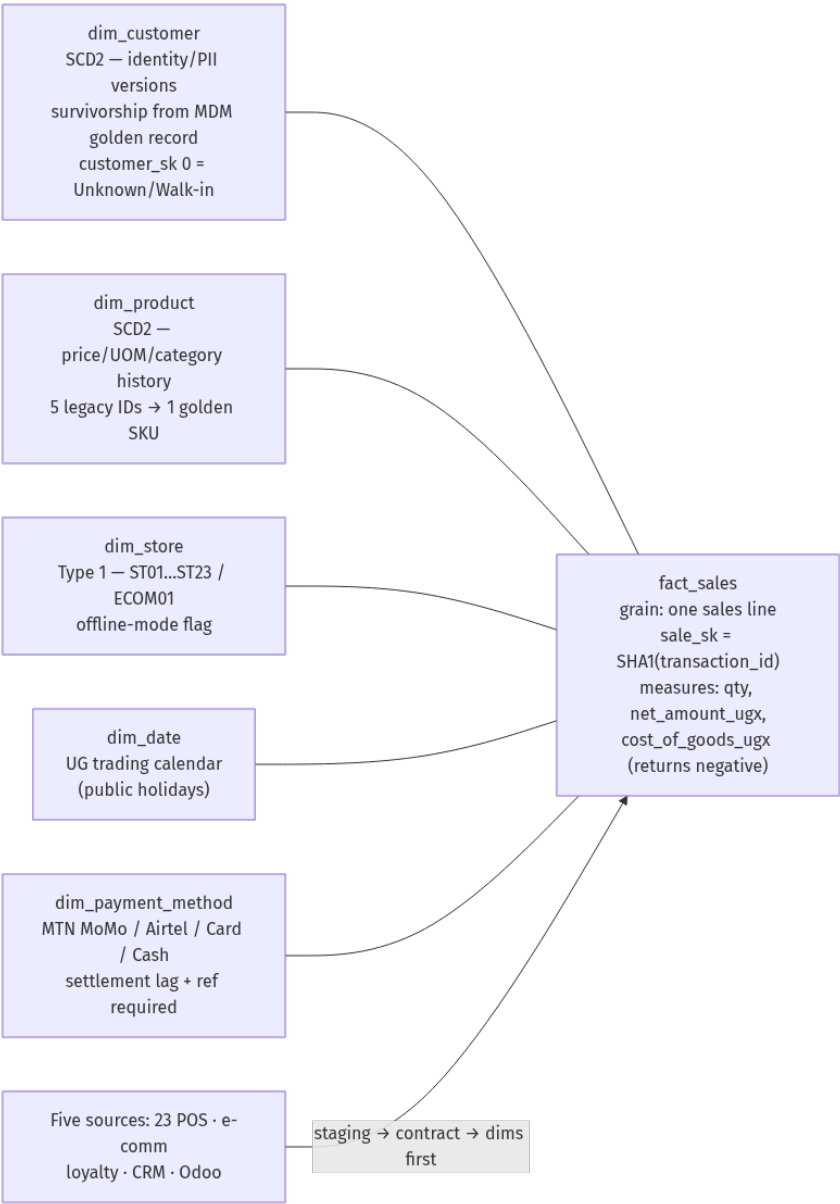


Figure 6: Fig. B4 — Star schema: fact_sales with five conformed dimensions; SCD2 on customer and product

Criterion	Verdict	Why
Cost inside the UGX 480,000,000 envelope	ETL now	pandas and SQL are already owned; an always-on cloud warehouse adds an indicative UGX 60–90M/yr that displaces something else
Skills and ops burden for four staff	ETL now	One pipeline, one run log, one alert rotation; warehouse modelling and dbt-style habits must be trained <i>before</i> adoption, not during
Connectivity and auditability	ETL now	Spools are validated before transit, so an outage delays a file rather than corrupting a cloud load; immutable landing plus control totals satisfy the PDPO audit
Latency and scalability at 23-store plus expansion volume	ELT after the triggers	A window-bound single node breaks at tens of millions of rows; migrate once cloud budget is approved, two staff ship a model unassisted, two pipelines hold 60 green runs and sites stay $\geq 99\%$ available for six months

Staged, this is a hybrid: file and ETL staging now, transformation-in-warehouse later, with the VR and DQC catalogue unchanged and only its runtime replaced.

Real-time, judged per use case.

Live stock visibility — near-real-time micro-batch, 30 to 60 seconds, not sub-second streaming. SKU-level availability comes from POS and CDC sales decrements plus Odoo receipts, while footfall contributes only store-level demand pressure, because zones map to categories and sensors cannot see SKUs. The consumer publishes store $\times$ SKU quantities to Redis, feeding the SavannaShop availability badge with a confidence flag and a handheld restock queue ranked by on-hand and browse minutes. Malformed events drop at the edge and a sequence gap raises a freshness alert, so an outage becomes labelled latency rather than a silent zero. The economics decide the cadence: a stock-out at ST07 makes the storefront promise an item that does not exist and loses the sale in-aisle, so cost is per-minute, not per-millisecond — and a 60-second-stale quantity sits inside the shrink envelope anyway, where the 8.4% variance surfaces as visible drift.

MoMo fraud patterns — a 5 to 15 minute micro-batch over a 24-hour sliding window, not real-time authorization. Mobile money carries 73.2% of revenue, and the rules that matter are velocity and pattern checks: one reference reused across more than one store in 24 hours, refund loops per cashier per day, off-hours baskets beyond three standard deviations, walk-in high-value combinations, and references still unsettled past 48 hours under DQC-08. State sits in per-reference and per-cashier counters, so a replayed spool cannot manufacture a hit. True real-time authorization would have to sit inside the MTN and Airtel gateway callback — a path SRG does not control — while settlement risk is T+1, so a 15-minute window catches the same losses as a 15-second one at a fraction of the operational cost. Alerts queue to the Finance Reconciliation Officer with a daily digest to the CFO and carry replayable event IDs; revisit only if measured fraud losses exceed the annualized cost of gateway integration. Full real-time architecture: Appendix M.

Think deeper. Real-time earns its keep where latency converts directly to revenue or loss: stock availability, where every minute the storefront promises an empty shelf costs a sale in one channel while stock sits in another, and the MoMo fraud window, where patterns are only detectable before the money is gone. Both pay a person making a decision. It burns budget where nothing changes inside the window: continuous Odoo replication on human-speed master data, sub-second analytics for a Board that reads monthly, and “real-time everything” across stores that drop links for hours, which would turn an honestly labelled batch dashboard into a silently wrong one.

Evidence: Appendices H–M; repo: module2_data_quality/, module3_etl/, module5_warehouse/.

3 Part C — Protection, Metadata & Insight

3.1 Task C1 — Metadata: Dictionary, Lineage & Catalog Strategy

The dictionary. The warehouse dictionary documents 25 core attributes across fact_sales, dim_customer, dim_product, dim_store, dim_date and dim_payment_method, pairing a plain-language business definition with technical metadata (column types, surrogate and business keys, SCD2 versioning, NUMERIC(14,2) money columns) and administrative metadata (classification, steward, source system). Each attribute carries one of three POL-001 sensitivity classes: Public (safe for external reporting), Confidential (internal business data whose leak harms competitiveness) and Restricted (personal or financial identifiers under DPPA 2019 s.25 and GDPR Art.4(1), reachable only by explicit grant plus masking). Restricted stays deliberately narrow — payment_ref, full_name, phone_e164, email, consent_gdpr_eu — which is what makes targeted masking and column-level grants possible instead of blanket encryption. Full dictionary: Appendix N.

Lineage. The Board reads one customer number each month: Monthly Active Customers (KPI-CRM-001), produced by a chain crossing 23 offline-capable POS databases, SavannaShop (ECOM01), a 180,000-member loyalty app, an MDM golden-record step and a star schema, in an estate with a documented history of silent failure (RC-1...RC-6, including four days of invisible failure). Lineage is therefore not documentation overhead but the control that makes the KPI defensible (DPPA s.3, GDPR Art.5(2)) and change impact-analysable. The nine documented hops condense to five stages, each carrying rule IDs, survivorship decisions and failure handling rather than folklore. Full lineage and impact analysis: Appendix O.

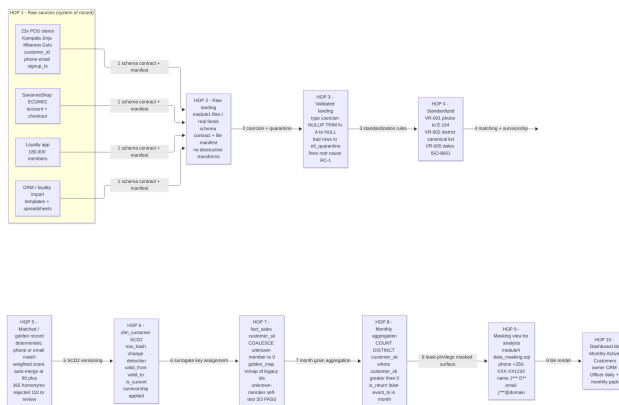


Figure 7: Fig. C1 — Lineage of the Board KPI “monthly active customers”: raw fields through every transformation to the dashboard

Hop	What happens	Control / evidence
1	Raw fields (customer_id, phone, email, signup_ts) from 23 POS stores, SavannaShop, the loyalty app and CRM imports land under a schema contract with manifest and batch ID — no destructive transforms	Contract violation rejects the whole file (RC-1: never partial-load); row counts and control totals captured; a missing file marks the run SOURCE_MISSING
2	Validated then standardised: type coercion, NULLIF/TRIM, “N/A” to NULL; phone to E.164 (6 variants to 1), district to the official list (127 to 42), dates to ISO-8601	Bad rows go to etl_quarantine with an error reason, never a silent fallback (RC-4); DQC-07 alerts above 0.5%; rule ID and before/after value stored per row
3	Golden record into dim_customer: deterministic phone or email match, auto-merge at score ≥ 90 , name similarity never auto-merges; row_hash opens and closes SCD2 versions	1,142 of 1,150 duplicates merged, 365 homonym pairs rejected, 110 to stewardship review, 5,000 $\rightarrow$ 3,858 golden records; dimensions load before facts (RC-5)

Hop	What happens	Control / evidence
4	fact_sales.customer_sk assignment, then month aggregation: COUNT(DISTINCT customer_sk) with customer_sk > 0, is_return = FALSE, event_ts in month (Africa/Kampala), close at T+2	COALESCE to 0 keeps walk-ins loadable while identity resolves; control-total mismatch halts the run (fail-fast, CA-4); etl_run_log records period and row counts
5	Least-privilege presentation: analysts read the masked view, the aggregate feeds the dashboard tile	Default-deny GRANTs, column REVOKE, store-scoped RLS; denied queries evidenced in the 15-test reference run (15/15 PASS); stale-data banner on the tile (RC-6)

Tagging taxonomy. Three tag classes travel with every dictionary row: domain, sensitivity and quality. Domain tags scope ownership and vocabulary (sales, customer, product, store, payment, calendar), sensitivity tags drive the GRANT matrix and the masking views (Public, Confidential, Restricted), and quality tags record how a value became trustworthy (standardized, mastered, derived).

Impact analysis. Proposed change CHG-ADDR-001 replaces free-text district TEXT with a structured address block and a dim_district foreign key, and the 15-dependency register shows this is not a column change. Six dependencies break hardest: the POS signup form at 23 offline stores (DEP-08), where a naive key turns a metadata edit into a checkout outage; row_hash inputs (DEP-03), where all 3,858 golden records would look changed in one run and restate history-dependent marts; the customers_masked view (DEP-04), which stops resolving for every analyst and could leak address_line1 and GPS as identifying data; dictionary row #14 and the DDL (DEP-05); three geo tiles splitting on legacy labels (DEP-06); and VR-002/DQC-03 (DEP-01), rewritten around the key. Effort: six small, eight medium, one large — 10–14 weeks for a four-person team. Full analysis: Appendix O.

Catalog verdict.

Option	Cost fit (25)	Team fit (20)	Glossary & lineage UX (15)	Weighted /100	Recommendation
OpenMetadata (self-hosted)	5	4	4	89.0	Adopt as the Phase 2 pilot at UGX 15–25M/yr
DataHub (self-hosted)	5	3	3	82.0	Hold as reserve option at the Phase 2 exit gate

Metadata-as-code scores 79.0 at near-zero licence cost and already runs as Phase 1; Collibra is rejected at indicative UGX 110M–220M per year — 23%–45% of the UGX 480,000,000 envelope — and Apache Atlas on stack and skills, not price. Budget: Phase 1 costs no licence; Phase 2 costs UGX 15–25M/yr (3.1%–5.2% of the envelope), no new FTE, one SQL-capable owner. Appendix P.

Metadata governance. Domain stewards own their glossary entries and dictionary rows — Marketing owns customer, Merchandising product, Finance payments, the CRM Officer board KPIs — while the EDM Consultant curates technical lineage and no edit is anonymous. Every change lands as a pull request naming the affected artifacts and DQ rule IDs, reviewed quarterly across all 25 attributes plus event-driven on any schema change, with disputes ruled in five working days and escalated unresolved to the Data Governance Council. The Task A2 charter supplies role names and POL-001 tags so one taxonomy governs classification, masking and catalog search; superseded entries are deprecated, not deleted.

Think deeper. A catalog cannot own a definition; a person must. The real asset is the rule that no term is edited anonymously, that each has one named steward, and that a challenge to Monthly Active Customers lands on a rule ID and an owner in a pull request rather than in a meeting. Buying stewardship workflows before a steward model exists automates a vacancy, and ingesting today's inconsistent sources would automate the inconsistency. Phase 1 therefore earns ownership — one owner per term, definitions that survive audit — and Phase 2's entry gate (two stable pipelines plus PDPO filing) makes the tool spend conditional on proven adoption. Ownership is the precondition for the catalog, not its output.

3.2 Task C2 — Security Risk Assessment, Access Controls & Privacy

Threat model. The asset-centred model applies STRIDE across eight assets and seven trust boundaries, weighting actors by SRG's realities. The realised class is theft: an unencrypted laptop holding 9,000 records (names, phones, purchase history) was stolen at Jinja, reported 11 days late and never notified — trust boundary TB-3 (portable media) has no control at all. Store connectivity is an environmental actor: 23 offline MySQL boxes sit offline hours daily, masking ransomware detection and driving duplicate captures. Insider risk is amplified by shared till logins, no leaver checklist and no export logging, so logs name nobody; accidental exposure runs through misdirected CSVs, phishing attachments and manual Excel edits. External classes — credential stuffing on 180,000 SavannaShop accounts, checkout skimming, SaaS breach without DPAs — rank below the realised endpoint exposure. Full diagram: Appendix Q.

Top eight risks (5×5, Likelihood × Impact).

ID	Risk	L	I	Score	Mitigation
R1	Stolen-device PII export (Jinja, realised): 9,000 records, unencrypted laptop	5	5	25	Mandatory FDE + export control (UGX 15M), 1-hour reporting rule, s.23 notification, retrospective PDPO engagement; ≤ 8 by month 6
R2	PDPO registration / notification failure (DPPA s.29, s.23)	5	4	20	PDPO registration month 1–3, DPO appointed (s.6), breach plan and register adopted
R9	Shadow HR/supplier Excel leakage — payroll and national IDs	4	5	20	Controlled stores, POL-001 file labels, encrypted laptops, training, need-to-know on national ID
R13	Systemic endpoint encryption gap — every laptop a potential Jinja	5	4	20	FDE and device compliance for export-capable devices; export blocked on non-compliant devices
R12	Key-person dependency: zero data-engineering capacity, tribal knowledge	4	4	16	Cross-train both SQL-capable staff, named deputy per artifact, quarterly knowledge transfer
R3	Ransomware on the 23 per-store MySQL boxes	3	5	15	Network segmentation, central patching, encrypted store backups, admin MFA (UGX 6M), quarterly threat-hunt (UGX 10M)

ID	Risk	L	I	Score	Mitigation
R6	Unexplained 8.4% stock variance from manual edits and offline capture	5	3	15	Store cycle counts, adjustment approval workflow, variance dashboard
R11	GDPR exposure via the EU partnership (Art.33/34, Art.44–49)	3	5	15	SCCs and transfer impact assessment before any EU flow, DPO appointed, 72-hour clock, DPIA signed

The amber band — R4 insider misuse, R5 MoMo reconciliation, R7 residual duplicates, R8 vendor breach, R10 sync collisions (10–12) — is reduced by controls already built, each with a residual target. The tail is correlation, not individual score: R12 degrades every other mitigation at once and R9 turns one phishing click into identity-theft harm — hence no green cell, since SRG cannot yet demonstrate registration, notification readiness or full-disk encryption.

Access control matrix (extract).

Role	Data object	Operation	Result
store_cashier	financial_reports (contains payroll)	SELECT	Denied — permission denied for table financial_reports (T01)
store_cashier	customers raw table	SELECT	Denied — permission denied for table customers (T02, T03)
store_cashier	customers_masked view	SELECT	Allowed as expected — 2 rows (T04)
store_manager	rows of another store (RLS)	SELECT	0 rows visible, expected 0 (T05, T08)
data_analyst	payroll_ugx column	SELECT	Denied — permission denied for column payroll_ugx (T11)
compliance_officer	full raw customer record / sales	SELECT / INSERT	SELECT allowed for audit (T14); INSERT denied — auditors never mutate (T15)

Access is proved, not asserted: `rbac_postgresql.sql` grants nothing by default, `rbac_test.sql` writes fifteen assertions into `srg.access_test_results`, and the committed reference capture shows 15 passed, 0 failed, every failed attempt denied by the database itself. This is documented-and-tested evidence, not a live-server claim: the expected output is committed in `rbac_test_expected_output.md` and reproduces verbatim on PostgreSQL 15/16, while no PostgreSQL server exists in the build environment, so `rbac_test.sql` was desk-checked statement by statement against documented privilege behaviour; the masking half ran on live data, 4/4 PASS. Appendix R.

Encryption and masking requirements.

Layer	Control	Standard / reference	Owner
At rest	FDE on any device able to export Restricted data, screen lock ≤ 10 min, remote wipe; cloud objects and backups encrypted, restore tested quarterly	AES-256 via BitLocker/LUKS under device-compliance policy; documented restore-test evidence	Head of IT; IT Operations Lead (restore)
In transit	TLS 1.2+ everywhere; WireGuard/OpenVPN tunnels store $\rightarrow$ HQ, SFTP with key auth where tunnels cannot hold, never an unencrypted fallback	TLS 1.2+ (RFC 8446 baseline), certificate lifecycle with expiry alerts; OWASP ASVS	Head of IT; IT Operations Lead (store links)
Key management	Central KMS, annual rotation, split custody, no developer access to production keys, break-glass tested annually	Cloud or self-hosted HSM-less KMS; dual control on key export; key register	Head of IT administers; CFO holds recovery-key escrow

Masking demonstration.

Field	Raw (compliance_officer / cdm_admin only)	Served to analysts
phone_e164	full E.164 number	+256-XXX-XX1234
email	full address	j***@domain
payment_ref	full MoMo / Airtel reference	MP*****89

Raw columns are reachable only by column-level GRANT to compliance_officer or cdm_admin, always audited; payment_ref is tokenised in analytics copies, keeping the last four characters for reconciliation.

DPIA verdict. DPIA-2026-001 covers the loyalty app's EU-facing rollout — 180,000 members, purchase monitoring and fulfilment sharing with a European distributor — under GDPR Art.35, alongside DPPA 2019 s.3, s.7, s.10 and s.20. Overall residual risk is LOW, conditional on ten measures (M-01...M-10) spanning masking, full-disk encryption, consent rework, human review of tier decisions, rights handling, retention purge and breach response. Two conditions block EU go-live: Standard Contractual Clauses plus a transfer impact assessment under GDPR Art.44–49 — Uganda has no adequacy decision — and a Data Protection Officer under DPPA s.6. While either is unmet the transfer residual stays HIGH and EU members are excluded; the assessment is reviewed 12 months after sign-off or on material change. Appendix S.

Breach notification timeline.

Clock	Obligation	Basis	Owner
≤ 1 hour	Discovery timestamp recorded, then escalation to the Incident Lead with a P1 ticket — investigating before reporting is prohibited	Internal target, abolishing the 11-day delay	Any staff $\rightarrow$ Head of IT
≤ 2 hours	Containment: wipe/disable, sessions revoked, credentials and keys rotated	DPPA 2019 s.20	Technical Containment
≤ 4 hours	Assessment: categories, record count, encryption at time of breach, risk	s.23(4) content readiness	DPO

Clock	Obligation	Basis	Owner
Same business day	Notify the Authority — “immediately notify the Authority” of the unauthorised access and remedial action, by registered or electronic mail	DPPA 2019 s.23	DPO
≤ 48 hours after direction	Notify data subjects if the Authority so decides	DPPA s.23(2)–(3), content per s.23(4)	Communications
≤ 72 hours from awareness	Notify the lead supervisory authority, with reasons for any delay; subjects without undue delay where risk is high	GDPR Art.33(1),(3); Art.34(1),(3)	DPO
Always, even if not notifying	Internal breach-register entry with facts, effects, remedial action	GDPR Art.33(5); DPPA s.3	DPO

The Jinja failure, rewritten as procedure. The 11-day delay and the missing notification are abolished by rule: hour 0 opens the clock, any staff member calls the on-call phone within one hour, reporting before investigating. Containment starts by hour 2, the hour-4 assessment rates 9,000 unencrypted records as high risk, and the PDPO is notified the same business day under s.23 with the remedial action taken; if EU loyalty members sat in the export, the Art.33 72-hour clock runs from awareness with Art.34 notice without undue delay. Data subjects are notified within 48 hours of PDPO direction (s.23(4)), the incident enters the breach register at hour 4 regardless of notifiability, remediation (FDE, export ban, retraining) is evidenced within seven days, with Council review at 30 days.

Audit checklist. The month-0 baseline runs 31 checks against DPPA 2019, GDPR and CCPA: 9 FAIL (29%), 19 PARTIAL (61%), 2 PASS (6%), 1 monitored N/A — failures are registration, DPO, endpoint encryption, s.23 notification, rights handling, SCCs, vendor DPAs and training. P1 in months 1–3 closes the audit-critical four — registration, DPO, full-disk encryption (UGX 15M) and breach plan plus register with the Jinja entry — then retrospective PDPO engagement on the unnotified breach. Appendix T.

Think deeper. Under a fixed envelope the omissions carry the argument. UGX 66,000,000 over 18 months — inside the UGX 480,000,000 envelope so catalog, cloud, licences and hires still fit — buys endpoint encryption (UGX 15M, closing R1, R13, R9), store tunnels, encrypted backup, MFA, a penetration test with PDPO readiness and an IR retainer. Not funded: enterprise DLP, since a four-person team has no SOC to triage alerts, while export approval, FDE-gated devices and masking-by-default block that vector; a 24/7 SOC, replaced by quarterly threat-hunts and the one-hour reporting clock; an on-prem HSM, since SRG holds no payment cryptography and cloud KMS with split custody costs about 1% as much; Public-tier field encryption, which protects nothing an attacker values; homegrown cryptography, prohibited outright; a zero-trust mesh until identity and FDE exist. Each omission keeps a named residual and its cheaper alternative — no risk dropped, none unsigned.

3.3 Task C3 — BI Dashboard & Emerging Technology Evaluation

Five strategic Board questions.

Question	Method	Output → decision
Q1 Which segments are churning, why, and what is the monthly revenue at risk?	RFM scoring plus cohort retention curves (SQL window functions)	Churn segment table, retention heatmap, revenue-at-risk waterfall → reactivation budget and new-customer floor
Q2 Which districts and categories are genuinely growing rather than merely shifting?	Contribution decomposition (new buyers, frequency, basket, price/mix) plus location quotient	Growth-contribution matrix and ranked double-down list → promo capex by district × category

Question	Method	Output → decision
Q3 What explains the 8.4% book-vs-physical variance, and which cells need new reorder rules?	Pareto analysis, variance waterfall by cause, deterministic safety-stock model	Variance attribution and reorder-policy change list → fund the task force, change reorder points
Q4 How much revenue sits in unreconciled mobile-money lines, and what fraud patterns appear?	Rule-based exception engine plus velocity analytics (VR-012 aging, duplicate refs)	Daily pending register and exception scorecard → 48-hour Finance sign-off SLA, provider escalation
Q5 Which expansion move is justified first: Kampala stores, Kenya, Rwanda or deeper e-commerce?	Catchment and location quotient, digital penetration, gravity-style demand index	Ranked expansion scorecard with gate conditions → capex sequence at gates G2–G4

Business questions and decision rationale: Appendix U.

Analytics workflow. Sources are the warehouse in `etl_demo.db` — `fact_sales` plus five dimensions, 10,000 lines for Jul–Dec 2024 — plus MoMo and Airtel statements, with an Odoo feed and footfall pilot to follow. Preparation runs once and is reused: duplicates 22.84% → 0.00% (5,000 → 3,858 golden records), phones to E.164, districts 127 → 42, UOM 15.33% → 100%, quarantine, idempotent loads, masking before analysis, SCD2 star schema. Methods stay inside SQL and pandas the team already has — RFM and cohorts, decomposition and location quotients, Pareto and variance waterfalls, exception rules, catchment indices — machine learning gated to later pilots. Outputs are the dashboard, growth and variance packs, daily pending register, expansion scorecard and monthly brief, each mapped to a named decision D1–D5 with one accountable owner.

Dashboard. Live at <https://ccosecret.github.io/srg-enterprise-data-management/>, the build carries month-range, city, category and payment-method filters; KPI cards, a multi-series monthly revenue line, a sorted category bar, a payment-mix donut, grouped new-versus-returning bars and a sortable store/city table; click-through drill-down from a table row to its categories; and one reset control — rendering 10,000 lines against the control total UGX 252,382,814.16 net, average basket UGX 25,238. Full specification and screenshots: Appendix V.

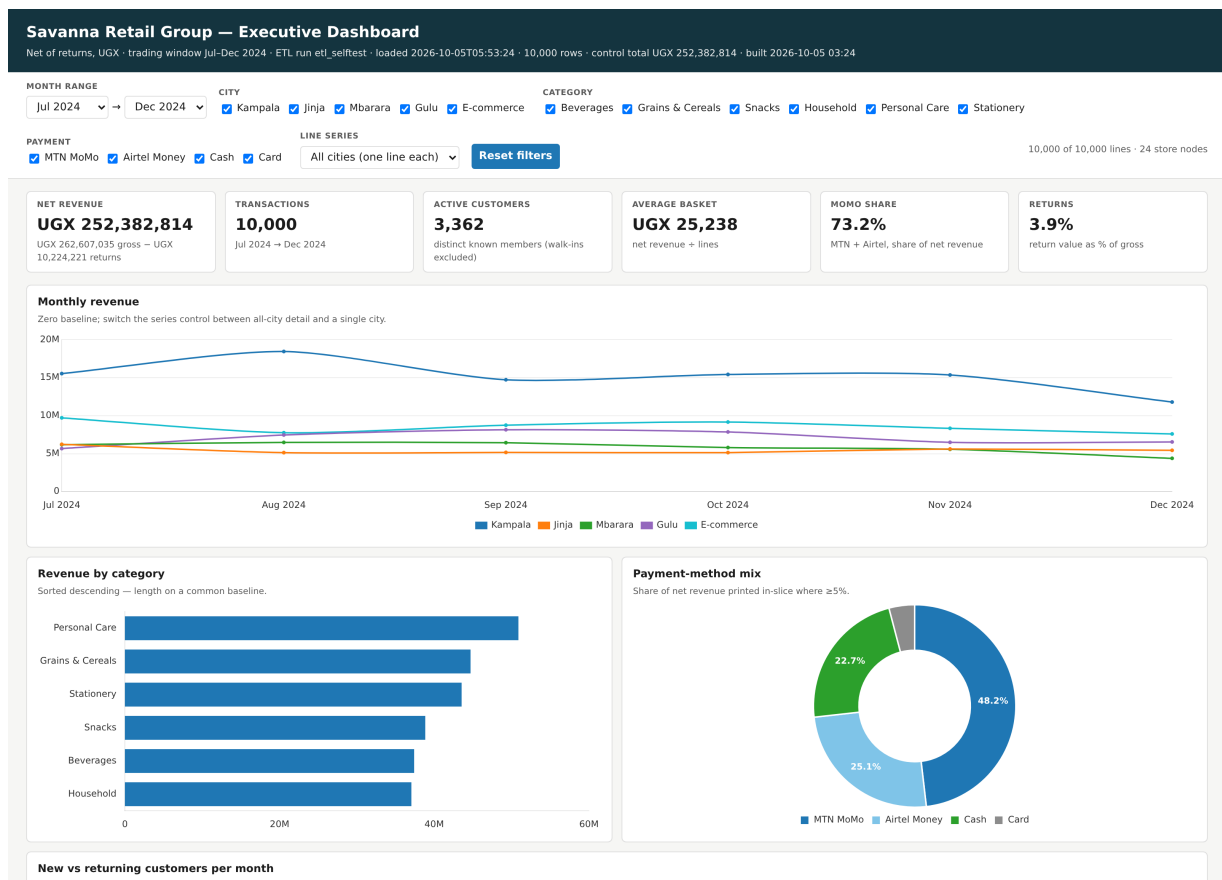


Figure 8: Fig. C2 — Published executive dashboard: KPI cards, monthly revenue trend, category and payment mix (live: <https://ccosecret.github.io/srg-enterprise-data-management/>)

Refresh is a build, not a query: `build_dashboard.py` reads only `etl_demo.db`, embeds every series as JSON into a self-contained HTML file, and refuses to publish unless the control total is UGX 252,382,814.16, so the previous page stays live rather than a half-built one; a git push redeploys via GitHub Pages with the run id in the header. Equally deliberate is logged decision D-13: the published HTML build substitutes for licensed BI tooling, carries the identical specification, and loads into Power BI without redesign.

Executive insight brief.

F1 — growth is running on old fuel. New known customers fell from 1,272 to 148 per month (−88%), the churn proxy stands at 69.4% (858 of 1,237 November actives bought nothing in December), and December revenue fell 13.6% month on month. *Actions:* Kampala/Jinja reactivation and referral campaign by M7; new-customer floor ≥ 600 per month and churn proxy $\leq 50\%$ by M9; unattributed revenue below 3% by M9 via till phone-capture.

F2 — cash is sitting in a reconciliation gap. Mobile money carries 73.2% of revenue while 849 of 7,385 MoMo lines (11.5%) lack payment references — $\approx$ UGX 21.2M of six-month revenue ($\approx$ UGX 3.54M/month) unconfirmed. *Actions:* stand up automated MoMo reconciliation — matching, not new plumbing, since the ETL already flags `PENDING_RECON`; enforce a 48-hour Finance sign-off SLA escalating above 50 pending/day (Finance/Reconciliation Officer, M5); zero lines pending beyond 24 hours by M6, pending share below 0.5% by M12.

F3 — channel demand outpaces stock control. ECOM01 delivers 20.3% of revenue from one node, about $5.9\times$ an average physical store's 3.47%, against 8.4% unexplained book-vs-physical variance and returns of −UGX 10,224,221 ($\sim 3.9\%$ of gross). *Actions:* variance task force with Odoo stock feeds, safety-stock rules on top-SKU and high-velocity cells, three-store footfall/POS pilot at M10–M12 (Merchandising Manager, M9); variance $\leq 5.0\%$ by M9 and $\leq 2.0\%$ by M12.

The Board is asked to approve the reconciliation programme and SLA, fund the task force and pilot, and adopt the segment targets. Appendix W.

Emerging technology verdicts.

Technology	Verdict	Justification
Cloud EDM stack — Azure (managed PostgreSQL, Data Factory, Power BI), 4.25/5	ADOPT — phased	Budget: cloud line capped at UGX 90,000,000 per 18 months, of which UGX 43,330,000 is planned. Skills: one accountable vendor, low-code BI for four staff with zero data engineers. Connectivity: no Ugandan region, so batch-first design to South Africa or Europe fits stores offline hours daily; migration waits for trigger T1–T6.
AI-driven trend — AI-powered data quality (ML anomaly detection)	PILOT — from month 12	Budget: subscription cost sits in the contingency line, no licence before gate G3. Skills: tuning and false-positive triage need capability still being built. Connectivity: neutral — batch profiling suits offline reality — but anomaly detection is only as good as the normal it learned, so VR-001...VR-012 and DQC-01...DQC-10 need six months of history first.

DataOps is adopted lite at near-zero licence cost because the pipeline already runs self-tests, quarantine and run-state logging; Data mesh is rejected outright — six domains inside one four-person team would charter the silos the warehouse removed. Appendix X.

Analytics maturity.

Dimension	Baseline level	Target M12 → M18
Strategy & decision alignment	L0 — no KPI tree, reporting 11 days late	L3 → L3
Data foundation & quality	L0 — defects unknown until profiled	L2+ → L3
Platform & architecture	L1 — silent nightly failures, no run-state visibility	L2+ → L3
Analytics & BI delivery	L0 — manual spreadsheet pack, no dashboard	L3 → L3
Security, privacy & compliance	L0/L1 — the incident itself; no RBAC, masking or SOP	L2+ → L3
People, skills & data culture	L0 — no stewards, no shared vocabulary	L2 → L2+

The composite baseline sits at about L0.3, and the realistic two-year path is:

- **By month 6 — composite L2, carried by artefacts already executed:** golden records cleansed (22.84% → 0.00%), 12 rules and 10 checks live, repaired pipeline self-test 3/3 PASS, 25-attribute dictionary, dashboard and brief adopted, RBAC and masking deployed with the notification SOP, stewards assigned, reporting lag 11 → ≤ 5 days.
- **By month 12 — L2.5 to L3, carried by organisational change:** three hires onboarded (Analytics/Data Engineer, BI Analyst, Data Steward), six staff certified, entry-point quality enforcement, Odoo stock feed closing the variance loop, reporting lag ≤ 3 days, PDPO audit passed, SCC pack for the distributor, churn and segment views used in trading meetings.
- **By month 18 and the year beyond — L3 sustained:** annual decision calendar, quality economics in UGX, cloud migration judged against triggers T1–T6, catalog and lineage automation, twice-yearly recertification; no dimension claims L4 inside that horizon — it would not survive audit.

Think deeper. The chart deleted was a 24-slice pie of store revenue shares, and it misled in three specific ways: with the top physical store at ≈4.1% and most stores in the 2–4% band, adjacent wedges differ by one or two degrees of arc, below the ranking threshold; pie reading depends on angle and area, the least accurate channel, so rounding noise read as movement and a stable estate looked volatile; and part-to-whole hides the decision variable — whether any store materially outperforms its peers, which none does at city indices of 0.94–1.04. The replacement, a sorted store/city table with printed values and click-through to category, reads length on a common baseline, makes flatness self-evident through sorting, and answers the follow-up question without a second page. 3-D bars, a dual-axis revenue-versus-customer chart and single-KPI gauges were rejected pre-build for the same reason: they spend ink distorting instead of encoding.

Evidence: Appendices N–X; repo: module4_security/, module5_warehouse/, module6_dashboard/.

4 Part D — Synthesis, Defense & Reflection

4.1 Task D1 — Integrated 18-Month EDM Strategy Roadmap

Mandate. The roadmap integrates the diagnostic baseline, the six workstreams and the governance model into a single 18-month sequence that closes every defect the assessment found: an unremediated breach, 23% duplicate customers, five product identifiers, an 11-day reporting lag and an 8.4% stock variance. It binds milestones, dependencies and gates to a non-negotiable envelope of UGX 480,000,000 — all-in for licences, cloud and hires — an IT team of four plus three planned hires, and a regulatory horizon in which the PDPO audit must fall inside 12 months alongside a European distributor partnership requiring GDPR-equivalent practice. Nothing is scheduled for its own sake: each phase ends in a binary gate, so evidence — not elapsed time — releases the next tranche of work, spend and headcount, and the M18 target state is one conformed warehouse on a ≤ 3 -day reporting lag, quality prevented at entry, and an operating model of four staff, three hires and five business stewards running analytics without external help.

Phased plan.

Phase	Months	Key milestones & dependencies	Governance gate
Phase 1 — Stabilise, Protect & Prove	M1–M6	M1 incident remediation (encryption + MDM + 72-hour breach SOP); M2 entry-point quality rules, duplicates below 1%; M3 platform verdict adopted — Azure in phases, triggers T1–T6 published, RBAC + masking live; M4 star schema load, dashboard v1; M5 MoMo reconciliation with 48-hour SLA, three hires onboarded; M6 quick-win proof with the monthly brief in Board routine. Depends on staggered recruitment (offers M3–M5) and on quality rules enforced at till, form and e-commerce capture	G2 (M6) — all eight quick wins evidenced; mid-phase G1 (M3) releases platform and security spend
Phase 2 — Industrialise & Comply	M7–M12	M7 churn operations plus reactivation/referral campaign and till phone capture; M8 Odoo stock feed live and the 5-to-1 product identifier unified; M9 safety-stock reorder rules, variance $\leq 5.0\%$; M10–M12 footfall + POS pilot in three stores and catchment re-score; M11 RoPA, breach register, SCCs and tabletop exercise; M12 PDPO audit passed, reporting ≤ 3 days, variance $\leq 2.0\%$. Depends on Odoo vendor access by M8, mobile-money statement exports from M5, and the auditor booked by M6	G3 (M12) — compliance evidenced and measurement confirmed

Phase	Months	Key milestones & dependencies	Governance gate
Phase 3 — Scale, Optimise & Expand	M13–M18	M13 cloud migration evaluated against triggers T1–T6; M14 margin feed for category profitability; M15 gated pilots (AI-DQ anomaly, churn and demand ML); M16 Kenya/Rwanda data-model readiness; M17 expansion decision paper; M18 maturity re-score, benefits review, roadmap v2. Depends on footfall evidence from M10–M12, a green G3, and live-feed baselines re-measured since M6	G4 (M18) — maturity L3, expansion decision taken, roadmap v2 commissioned

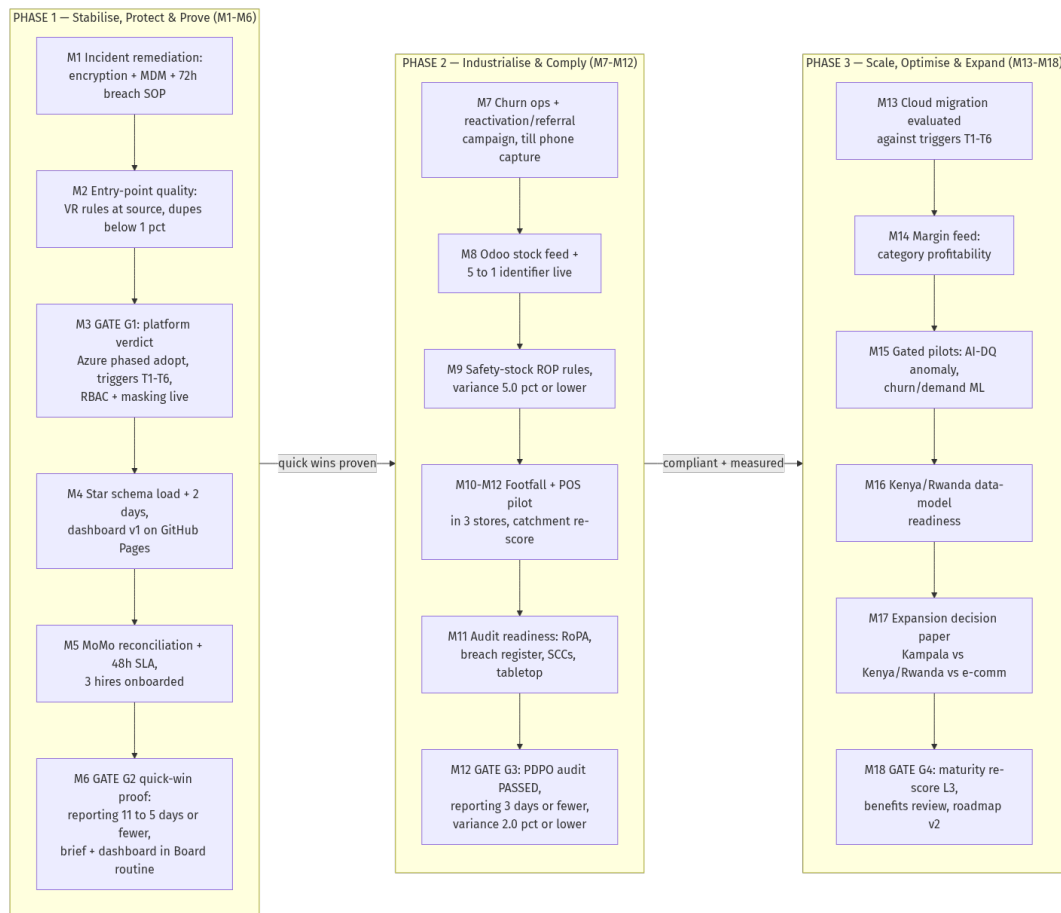


Figure 9: Fig. D1 — 18-month phased roadmap: quick wins by month 6, governance gates G1–G4

Month-6 quick wins (the Board requirement). Gate G2 is the Board’s proof that the money is working, and four wins must be plainly visible by month 6: all devices encrypted and under MDM, with the 72-hour breach-notification SOP signed and the Jinja theft referred for legal assessment; the KPI dashboard live at <https://cosecret.github.io/srg-enterprise-data-management/> with at least four weekly active readers; monthly reporting lag cut from 11 days to ≤5 days, evidenced by load timestamps in `etl_run_log`; and duplicates held below 1.0% on golden records after a measured 22.84% starting point, with DQC-01 publishing the number every day. The other four of the eight G2 items are tabled

alongside them at the gate, each with an artefact, an owner and a binary pass or fail, and anything unevidenced at G2 is re-planned rather than waived — the gate either opens Phase 2 or it does not.

Resource and budget allocation. Every line is itemised from unit costs; the category totals, the phase columns and the grand total reconcile exactly, so there is no over-spend lane — only contingency within the ceiling.

Category	Basis (explicit arithmetic)	M1–M6	M7–M12	M13–M18	Total
People — 3 staggered hires	Data Engineer 3,500,000/mo × 18 mo = 63,000,000 + BI Analyst 2,500,000/mo × 16 mo = 40,000,000 + Data Steward 2,000,000/mo × 14 mo = 28,000,000 → gross 131,000,000 + statutory on-costs and allowances 15% × 131,000,000 = 19,650,000	40,250,000	55,200,000	55,200,000	150,650,000
Training (capability & courses)	6 staff × 3 courses = 18 course-persons × UGX 900,000 local providers = 16,200,000 + certification exams and lab 1,800,000	8,000,000	6,000,000	4,000,000	18,000,000
Licences	Power BI Pro 5 users × 37,000/mo × 18 = 3,330,000 + DQ/monitoring tooling 3,670,000 + catalog pilot held at 8,000,000 headroom	3,500,000	5,750,000	5,750,000	15,000,000

Category	Basis (explicit arithmetic)	M1–M6	M7–M12	M13–M18	Total
Cloud (ceiling 90,000,000)	Phase 1 on-premises by design (5,000,000 pilot object storage); M7+ managed Postgres, object storage, egress, backup, monitoring itemised 43,330,000 + storage/egress headroom 16,670,000	5,000,000	27,500,000	27,500,000	60,000,000
Foundation & integration	3 source contracts/connectors 25,000,000 + Odoo stock feed 25,000,000 + footfall/POS pilot hardware for 3 stores 25,000,000 + UPS/offline-resilience kits 18,000,000 + identifier-unification tooling 12,000,000 = 105,000,000	35,000,000	45,000,000	25,000,000	105,000,000
Security & compliance	Endpoint encryption/MDM/VPN/MFA/backup slice items B1–B7 = 66,000,000 + GDPR/SCC legal opinion and breach counsel 6,000,000	36,000,000	24,000,000	12,000,000	72,000,000
Governance & change	Council operations, stewardship workshops, internal comms (board packs, training-of-trainers)	9,000,000	7,000,000	5,000,000	21,000,000
Contingency (8.0%)	Residual: 480,000,000 – 441,650,000	14,000,000	12,175,000	12,175,000	38,350,000
Programme total	150,750,000 + 182,625,000 + 146,625,000	150,750,000	182,625,000	146,625,000	480,000,000

Read strictly, UGX 480,000,000 is the **18-month programme total**: the envelope is stated annually in the scenario, but the roadmap plans to the stricter reading ($480,000,000 \div 18 = \text{UGX } 26,666,667$ per month) and no commitment assumes the upside of the annual reading. At 1 USD $\approx$ UGX 3,700 the envelope is roughly USD 129,730 for the whole programme of hires, licences, cloud, integration, security and compliance — and Year 1 (Phase 1 plus Phase 2) draws 333,375,000, cloud sits at 60,000,000 under its 90,000,000 ceiling, and licences total 15,000,000, so the plan also survives the looser annual reading without modification. Contingency of 38,350,000 (8.0%) is the residual after 441,650,000 of itemised commitment and is the only slack in the plan. Gate G1 (M3) must confirm payroll treatment of the existing 4 IT staff — carried by this budget they would cost $4 \times 2,500,000 \times 18 = 180,000,000$, exceeding contingency by 141,650,000 and forcing a re-scope; the standing assumptions behind that figure sit in Appendix A.

Risk mitigation and success metrics. Seven risks carry named owners and pre-agreed responses: a market undershoot on the 3,500,000 data-engineer salary is met by one senior hire plus two upskilled internal staff, with contract support funded from contingency; a cloud overrun is contained by the 90,000,000 cap and a 5,000,000 monthly spend alarm; scope creep into Kenya or Rwanda before G4 is blocked to data-model readiness only; key-person dependence is diluted by documentation-as-code, pair review and stewardship distributed to business roles; a PDPO finding on the original theft is met by the M1 legal assessment and a breach register built before the audit; quality regression at entry fires a P1 incident when DQC-01 exceeds 1.0% for three consecutive days; and off-sample Board decisions are prevented by a provenance footnote on every artefact plus a re-baseline from live feeds by M6. Pipeline integrity is binary — the dashboard build fails if the warehouse control total $\neq$ UGX 252,382,814.16 — and the KPI trajectory below is the scorecard the gates are read against.

KPI	Baseline (M0)	M6	M12	M18
Book-vs-physical stock variance	8.4%	$\leq 7\%$ (task force stood up)	$\leq 2.0\%$	$\leq 1.5\%$
Duplicate-person rate	23% (measured 22.84%)	$< 1.0\%$ (0.00% on golden)	$< 1.0\%$	$< 1.0\%$
Monthly reporting lag	11 days	≤ 5 days	≤ 3 days	≤ 3 days
Churn proxy (actives absent next month)	69.4%	$\leq 60\%$	$\leq 50\%$ (from M9)	$\leq 45\%$
Pending mobile-money lines	11.5% (849/7,385)	0 aged $> 24\text{h}$	$< 0.5\%$	$< 0.5\%$

Walk-in revenue (8.7% $\rightarrow$ $< 3\%$), new known customers per month (148 $\rightarrow$ ≥ 600), devices encrypted (0% $\rightarrow$ 100%) and composite maturity ($\approx \text{L0.3} \rightarrow \text{L3}$) are tracked alongside these five, each with a named owner and a monthly Steering review; the full trajectory, baselines and measurement sources are in Appendix Y.

Dependencies and governance checkpoints. Four dependencies gate the plan — recruitment at an 8–10 week lead time with offers M3–M5, Odoo stock-feed access by M8, MTN MoMo and Airtel Money statement exports from M5, and an auditor booked by M6 for the M12 slot — while power and connectivity are managed continuously through UPS windows, idempotent replay and advisory-lock scheduling. The gates convert those dependencies into binary decisions: **G1 (M3)** adopts the platform verdict, publishes triggers T1–T6, confirms the RBAC and masking test suite green, and settles payroll treatment of the existing four IT staff; **G2 (M6)** accepts or rejects the eight quick wins as Board evidence; **G3 (M12)** releases Phase 3 only if the PDPO audit has passed, reporting sits at ≤ 3 days, stock variance at $\leq 2.0\%$ and pending mobile-money below 0.5%; **G4 (M18)** re-scores maturity at L3, takes the expansion decision on footfall-backed evidence and commissions roadmap v2.

Coherence. The sequence is one causal chain, not six parallel projects. Governance feeds quality: the Council sets metric definitions and rule changes, stewards clear the queue against a 30-day SLA, and DQC-01 to DQC-10 are the only mechanism keeping entry-point discipline from decaying. Quality enables master data: with duplicates below 1.0% and one phone format, survivorship can produce a golden customer key and a golden product key — what turns 5,000 records into 3,858 and five identifiers into one. Master data enables integration: the Odoo feed, the mobile-money reconciliation and the e-commerce node can only land against keys that mean the same thing in every system, so the star schema loads in days rather than weeks. Metadata sustains the result — lineage, catalog and `etl_run_log` make ownership and freshness visible once external support ends. Security wraps the same records the model depends on, and analytics monetises them: a ≤ 3 -day lag plus the five Board questions turn controlled data into double-down lists, margin decisions and a footfall-backed expansion call. Each gate then restates the chain for the Board in the monthly brief, so a slip anywhere surfaces as a gate failure rather than a surprise at M18.

Think deeper. Halve the envelope to UGX 240,000,000 and the plan changes shape rather than shrinking evenly: People (150,650,000) and Security (72,000,000) alone consume 222,650,000, leaving 17,350,000 for cloud, foundation, licences, governance and contingency combined. The sacrifice ladder then applies in order — cloud stays on-premises, the footfall pilot slides and the expansion decision falls back on district and loyalty indices, the third hire is deferred, and Foundation collapses to the interim POS stock-ledger stop-gap. What a halved budget cannot change is the obligation set: incident remediation, the daily DQC checks and the PDPO audit date survive intact, because scope is negotiable and statutory duties are not — the envelope is contestable, the licence to operate is not.

4.2 Task D2 — Decision Log, Red-Team Critique & Reflective Essay

Decision log — eight defining entries. Full log (26 entries): Appendix Z.

ID	Decision	Alternatives rejected	Why it won (evidence)	What would change the mind
D-01	Treat the stolen-laptop incident as a reporting failure, not a device failure : adopt a 72-hour breach-assessment and notification SOP, and refer the theft (9,000 records, reported internally 11 days late, no notification) for legal assessment under DPPA 2019	Quiet remediation with no look-back; full immediate public disclosure	Eleven days of silence is itself the control failure; “no notification” is a live DPPA 2019 exposure and, for EU persons, GDPR Art.33/34; immediate disclosure risks overstating exposure before facts are known	Legal advice that no notification was due for the original event — the register, SOP and tabletop still stand as prevention; any lag in that chain escalates ahead of analytics at every Steering Group
D-08	Leave 110 records in the stewardship queue instead of forcing the metric to a clean number	Force-merge to report 0%; disclose the open queue (25.06% → 2.85% total flag)	Fabricated completeness is worse than an honest 2.85%; the queue carries a 30-day SLA and a named owner	DQC-01 showing a duplicate-person rate above 1.0% for three consecutive days, or a stewardship queue older than 30 days
D-12	Star schema with SCD2 on customer and product plus a 25-attribute classified data dictionary	Flat monthly tables; a dimensional model without history	Growth questions need point-in-time truth — a price change must be scored as price, not organic growth — and classification (Public/Confidential/Restricted) drives the GRANT matrix	Live evidence that no Board question needs point-in-time history; the model is re-tested against real question traffic at G3
D-13	Build the dashboard as self-contained static HTML (Chart.js + vanilla JS) published on GitHub Pages	Power BI now; a server-side web application	Zero licence, zero server, zero operations load for a four-person team; it opens offline on UPS power and holds no credentials in the browser; Power BI Pro stays budgeted at 3,330,000 per 18 months for interactive Board use	A requirement for role-scoped rows or controlled exports, which triggers the budgeted Power BI path; the public URL is re-reviewed before any external sharing

ID	Decision	Alternatives rejected	Why it won (evidence)	What would change the mind
D-17	Sequence the five Board questions churn → growth → stock → fraud → expansion , with all machine learning deferred to gated pilots	Start with an ML churn model; descriptive and diagnostic work first	Six months of history, 8.4% unexplained stock variance and 8.7% unattributed revenue would train a model on measurement error; descriptive SQL answers the Board now at SQL cost	Green G3 evidence after twelve months of post-cleanse history; twelve-month cohorts showing December non-return is normal seasonality would instead re-base the target
D-19	Hire 3 (Data Engineer, BI Analyst, Data Steward) rather than outsource to a consultancy	Outsource; hire only 2	150,650,000 of 480,000,000 (31.4%) builds permanent capability against the root cause — zero data-engineering in-house — while outsourcing repeats dependency and costs more than 8,000,000 per month for equivalent output	Recruitment failure: 3,500,000 may not attract a data-capable hire, so the fallback is one senior hire plus two upskilled internal staff, or an internal promotion at 1,000,000 per month (18,000,000, inside contingency) with the steward hire deferred
D-21	Phase 1 stays on-premises SQLite/PostgreSQL — no cloud migration until triggers T1–T6 fire	Migrate immediately; migrate on a fixed calendar date	Nothing to migrate: a 10,000-line extract of about 2.7 MB; cloud spend before value is waste, and triggers make migration a requirement-driven event rather than a date	T1–T6 firing on measured need, and a G1 challenge showing AWS or GCP beating Azure on EU terms, price or skills fit
D-26	No expansion capex (Kampala stores, Kenya, Rwanda) before a footfall-backed scorecard; M16 delivers data-model readiness only	Announce Kenya now; commit capital on warehouse evidence	City indices of 0.94–1.04 show revenue merely tracking store count, so no per-store winner exists to act on; ECOM01's 20.3% from one node argues for deepening the channel first	Independent footfall and POS evidence at G4 that separates catchment effects from store count — and, if the pilot stays inconclusive, a scorecard that presents both readings rather than one

Red-team critique. Full red-team dossier (15 findings): Appendix AA.

The target is SRG's own strategy and the evidence supporting it. Verdicts follow the dossier's convention: **Survives** = the attack fails on the evidence; **Qualified** = the claim holds only under stated conditions; **Overtaken** = the claim must change.

1. Budget — Qualified (RT-02, RT-12). The UGX 480,000,000 envelope balances only because it silently assumes the existing four IT staff stay on the corporate payroll. Move them inside the “all-in” line — $4 \times 2,500,000 \times 18 = 180,000,000$ — and the programme is short by 141,650,000 against a contingency of 38,350,000: insolvent as written. Optimism bias compounds it: six workstreams, three hires, an audit, an Odoo feed and a footfall pilot in 18 months, run by the team that let an ETL fail for four days unwatched. The rebuttal is procedural: the assumption is disclosed, nothing irreversible is committed before G1, and the deferral order — cloud, then footfall pilot, then third hire — is

pre-agreed. The verdict stays Qualified: two readings of the brief coexist until M3.

2. Change resistance — Survives, durability unproven (RT-11, RT-15). The hostile reading: quality was fixed by a batch cleanse, not by a process. The M7 till phone-capture change re-opens the entry point that created 23% duplicates, free-text habits (six phone formats, 127 district labels) return the moment dropdowns annoy staff, and 110 queued records can rot past their 30-day SLA. Survives, because the control detects exactly that regression — DQC-01 above 1.0% for three days is a P1 incident, VR-001 and VR-007 are enforced at capture, and “0.00%” is reported as state on golden records with capability measured separately. Concession: the first live intake month will likely breach 1.0% briefly, and the brief’s targets depend on Marketing executing from M7 — tracked as a G2 exit dependency.

3. Connectivity — Survives, already priced (RT-08, RT-14). No cloud region exists in Uganda: latency runs to South Africa or Europe, egress invoices cannot be forecast by a four-person team, and cloud does nothing for stores that drop offline for hours daily. On the weighted matrix connectivity scored 3 for every vendor, which makes the Azure verdict look like preference dressed as analysis; reporting-lag promises also collide with the nightly offline replay window. Both survive because Phase 1 never left the premises — cloud capped at 90,000,000 with a 5,000,000 monthly spend alarm, trigger T5 comparing real quotes against the run-rate, advisory lock and schedule window proven, lag measured from `etl_run_log`. Concession: an egress surprise at migration and occasional >3-day months remain possible.

4. Staff skills — Qualified (RT-12). The attack is blunt: 3,500,000 per month will not buy a senior data engineer, the firm starts with zero data-engineering capability, every BI artefact has a single owner, and a Gantt chart cannot show that nobody here has done this before. Qualified, because the gap is priced rather than wished away: 150,650,000 (31.4%) buys three hires, 18,000,000 buys training, and the mitigation is one senior hire plus two upskilled internal staff, staggered offers from M1 and stewardship distributed to business roles. Residual: if recruitment fails outright, the post goes to an internal SQL-capable promotion funded inside contingency, and the steward hire waits.

5. Political capture of governance — Overturned in part, otherwise Qualified (RT-10, RT-13, RT-03, RT-09, RT-01). Gates G2 to G4 are approved by the Board that wants a Kenya announcement, so who governs the governors? City indices of 0.94–1.04 have two readings — a balanced estate or an absence of measurement — yet the flat reading is used against Kampala densification; category rankings by revenue may crown the least profitable category while no margin feed exists until M14, and boards rarely un-hear a polished ranking; every figure rests on one six-month extract carrying seasonality artefacts such as the 69.4% churn proxy. Two findings are **Overturned**: “GDPR-equivalent” as a claim about RBAC and masking — RoPA, breach register, lawful basis and SCCs were forced into Phase 2 — and the original notification exposure, outranked by analytics until red-teaming forced it to M1. **Qualified** on expansion and evidence: no capex before G4, both scorecard readings shown, provenance footnoted, margin caveat printed.

The reflective essay The assumption that reframed the engagement

I arrived believing SRG’s problem was technical: 23% duplicates, five identifiers per product, an 11-day reporting lag, a failing nightly job. The Jinja laptop corrected me — an unencrypted export of 9,000 customer records stolen, reported internally 11 days late, never notified. The problem was never that the data was dirty; it was that nobody owned it. Every artefact I built afterwards is the *evidence* of that ownership, not merely a fix.

Uganda’s digital transformation, and what it demands of design

SRG trades in a Uganda where mobile money leapfrogged card rails: 73.2% of revenue now flows through MTN MoMo and Airtel Money — financial inclusion infrastructure built by telecoms, while business intelligence infrastructure barely exists. That asymmetry shaped my choices. I automated reconciliation against provider statements before building churn models, because payments were where value leaked (849 pending references, ≈UGX 21.2M). The Data Protection and Privacy Act 2019 is young, the PDPO’s enforcement capacity is still forming, and no mature precedent tells a Ugandan retailer what “adequate” looks like — so I designed to the statute’s explicit asks (register, notify *immediately*, document) rather than to a comfortable norm. Infrastructure shaped design too: hours-daily connectivity loss and unreliable power are not edge cases here, so the pipeline treats offline capture as a *designed state* — quarantine rather than abort, idempotent replay, `customer_sk = 0` for walk-ins instead of fabricated identities. Offline-first is not a compromise in Kampala; it is fit for context. The Kenya and Rwanda expansion taught the corollary: data models travel, legal regimes do not — portability of schema, not of compliance.

Data ethics, by the four choices they forced

Consent in the loyalty programme. With 180,000 members, the tempting design bundles points with marketing consent. I refused: consent must be recorded as a first-class, revocable attribute (DPPA s.7, GDPR Art.7), separable from contract performance for points (Art.6(1)(b)), with withdrawal honoured downstream in CRM, not just in a preferences table nobody reads. The credibility test is whether a member’s “no” actually stops a campaign.

Footfall sensor surveillance. The pilot design counts bodies, not identities: aggregate entrance/zone counts, dwell-time distributions, no facial recognition, no individual tracking, signage at store entrances, DPIA signed before hardware is installed. The ethics line is that the *store* is measured, not the *shopper or the stock clerk*. A cheap camera upgrade to individual recognition will be available and will look technically interesting; the governance charter is what will keep requiring a fresh decision before it.

Algorithmic bias in matching rules. Automated merge rules are where ethics quietly becomes arithmetic. Name-similarity ≥ 90 looks neutral until you note that mononyms and common surnames inflate similarity, and shared family phones mean rural and lower-income households are structurally over-merged — two people collapsed into one, with loyalty value and purchase history reassigned. That is why name similarity alone never auto-merges (identifier match required), why 365 homonym pairs were *correctly rejected*, and why 110 pairs sit in a stewardship queue: a false merge destroys one person's record irreversibly, so the asymmetric cost justifies the human gate.

AI fairness. Deferring machine learning (D-25) was partly an ethics decision, not only a competence one. A churn-propensity model trained on data where 8.7% of revenue is unattributed and 11.5% of payments unreconciled would learn *measurement gaps as behaviour* — and those gaps are not random: walk-in, cash-preferring, outage-affected customers are systematically the least measured, so any future scoring would encode their poverty as disengagement. Before any pilot ships, I committed to parity checks across districts and gender, human review before account-affecting decisions (GDPR Art.22), and published model card with known blind spots.

Career path, mapped to CDMP

My intended path is consultancy → **CDMP Associate within 12 months, then Professional**, with a longer aim of contributing to Uganda's PDPO-era capacity — the country needs practitioners who can explain Art.33 timelines to a store manager, not only lawyers who cite them. The mapping is direct: **Data Governance** (charter, RACI, POL-001/002/003), **Data Quality** (VR-001...012, DQC-01...10, before/after evidence), **Data Modeling & Architecture** (star schema, ER model, 1NF → 3NF), **Data Integration** (repaired ETL, quarantine, idempotency), **Security & Privacy** (RLS RBAC, masking, DPIA, breach plan), **Master Data** (golden record, survivorship), **BI & Analytics** (five questions, dashboard, insight brief), and **Metadata** (lineage, catalog decision) — which is also where my self-identified gap sits, and the reason the catalog pilot is on my own development plan, not only SRG's.

What I would carry forward

Two habits. First, honesty as a scorecard: 2.85% open quality flags reported instead of a fabricated 0%, “Stable (dedupe denominator shift)” instead of dressed-up improvement — credibility lives in the caveats. Second, sequencing: compliance milestones before analytics milestones, every time. Behind every unattributed line and pending payment reference is a customer who trusted the firm with a phone number — the same trust 9,000 of them gave, and lost, when a laptop left the Jinja store unencrypted. That is the sentence I will keep testing against every plan I write.

Evidence: Appendices Y-AA and A; repo: docs/.

APPENDICES

Appendices A–AA

Full registers, policies, matrices, specifications and execution evidence.
Excluded from the 40-page body limit under the submission requirements.

Appendix A — Assumptions Register

Assumptions Register (Portfolio-Wide)

Engagement: Project Savanna — Enterprise Data Management Turnaround **Template:** Appendix A of the assignment brief (Assumptions Register) **Owner:** EDM Consultant · **Review cadence:** at every governance gate (G1–G4, docs/D1_roadmap_18months.md) · **Status:** as of 2026-10-05

Every assumption below is *load-bearing*: a decision in this portfolio cites it. Each row records what is assumed, the evidence basis, what breaks if it is false, how/when it gets validated, and who owns the confirmation.

#	Assumption	Basis / evidence	If false → impact	Validation method & trigger	Owner	Status
AR-01	The UGX 480,000,000 envelope is a programme total (18 months), not annual — the stricter of the two possible readings of the scenario	Brief §3.4 states it annually; Task D1 says “within the UGX 480M envelope” — plan conservatively	If the Board confirms the annual reading (= UGX 720M over 18 months), the plan is under-spend, not over-spend : surplus becomes contingency and pulls Phase 3 cloud forward	Board confirmation at Gate G1	CFO	Open — plan built to stricter reading
AR-02	The existing 4 IT staff remain on corporate payroll and are <i>not</i> charged to this budget	D1 §D1.7: 4 × 2,500,000 × 18 = 180,000,000 would exceed the 38,350,000 contingency by 141,650,000	Roadmap requires re-scoping (hires frozen, Phase 3 deferred); budget arithmetic in D1 must be re-run	Payroll allocation confirmed at G1	CFO / Head of IT	Open — flagged at G1
AR-03	USD/UGX ≈ 3,700 holds for licence/cloud pricing	Market rate at planning; D1 uses 480,000,000 ÷ 3,700 ≈ USD 129,730	Licence/cloud lines re-price; contingency absorbs ±10%; beyond that re-baseline at G2	Quarterly FX check at G2/G3	Finance / EDM Consultant	Active
AR-04	The 18-month clock (M1–M18) is relative to programme start; no absolute calendar dates are committed	Brief gives duration, not start date	Milestone slips shift all downstream gates but not their dependencies	Programme start date fixed at G1	Programme sponsor	Active

#	Assumption	Basis / evidence	If false → impact	Validation method & trigger	Owner	Status
AR-05	The provided datasets are representative of SRG production data for the stated scale (5,000 customers / 1,200 products / 10,000 sales lines, Jul–Dec 2024)	Instructor-provided files per brief §3.5; profiling evidence <code>profile_beforeVR001...VR-</code>	Cleansing results and dashboard figures re-scale; rules 012 and monitoring thresholds transfer unchanged	Compare first production extract against profile distributions at M7	EDM Consultant	Active
AR-06	Control total UGX 252,382,814.16 (net, 10,000 lines) is the single reconciled revenue truth for the window	ETL self-test 3/3 PASS; <code>etl_run_log</code> ; guard in <code>build_dashboarddashb</code>	Any figure quoted to the Board must be re-derived; dashboard build refuses to publish (control-total guard)	Re-run pipeline self-test per release	IT Operations Lead	Verified (self-test PASS)
AR-07	The 180,000-member loyalty base and MoMo pending proxy (11.5%, 849 of 7,385 lines ≈ UGX 21.2M) are correct planning inputs	Scenario statement; <code>before_after_exposure</code> and C3 evidence	Fraud-question (Q4) <code>reconciled</code> reconciliation KPI scale proportionally	Reconcile against MTN/Airtel statements when feeds land (M8)	Finance / Reconciliation Officer	Active
AR-08	The instructor football stream file was unavailable ; <code>module7_realtime/football_stream/sample.json</code> (60 events) is a faithful substitute of the same schema	File absent at build time; substitute schema documented in repo	Real-time design (B4) is unaffected — architecture depends on event <i>shape</i> , <code>stream/sample.json</code> pilot must re-baseline with the real feed	Replace with authentic sample at pilot (M10)	EDM Consultant	Substituted — disclosed in repo

#	Assumption	Basis / evidence	If false → impact	Validation method & trigger	Owner	Status
AR-09	Power BI / Tableau Public are unavailable in this environment; the published HTML dashboard (https://ccosecret.github.io/enterprise-data-management/) is the approved substitute carrying the same spec (filters, 5+ visual types, drill-down)	Decision D-13 ; tool availability evidence	At SRG, the same dataset/measure definitions load into Power BI without redesign (spec in https://github.com/ccosecret/enterprise-data-management/blob/main/docs/C3_dashboard.md)	Re-confirm tooling choice with Board at G2	EDM Consultant / CFO	Substituted — decision logged D-13
AR-10	RBAC is proven by documented SQL + expected-output reference , not live database execution (no PostgreSQL server in the build environment)	module4_security.rbac_test_expected_output.m	By data masking scripts run against the target RDBMS; GRANT/REVOKE semantics are ANSI-standard — risk is low but <i>unproven until executed</i>	Execute test suite on staging DB at M6 (acceptance criterion in D1 Phase 1)	Head of IT	Open — execution required pre-production
AR-11	Matching thresholds (auto-merge ≥85, manual review 65–84, reject <65) are calibrated to SRG's data, validated against the dedupe run	dedupe_match_22.84% → 0.00% duplicate rate with manual review of the borderline band	If false, merge rate is discovered in audit, threshold moves up and review queue grows (capacity cost, not correctness cost)	Steward audit of 5% of auto-merges monthly for first quarter (B3 governance)	Data Steward (M5 hire) / EDM Consultant	Active

#	Assumption	Basis / evidence	If false → impact	Validation method & trigger	Owner	Status
AR-12	Household linkage is defensible only where address + payment instrument co-reside; elsewhere customer records stay distinct	B1 ER assumption set (3 assumptions + break scenarios documented)	Over-merge would destroy individual loyalty histories — ethics risk flagged in B1/C2 DPIA	Re-validate when loyalty app v2 ships (M9)	CRM Officer / Data Steward	Active
AR-13	Store connectivity loss (hours daily) and UPS-only power are normal operating conditions to design <i>around</i> , not fix	Brief §3.4 constraints; offline-mode flag in dim_store	Designs that assume always-on links (centralised real-time everywhere) fail acceptance tests	Confirm current outage pattern at G1 (site survey)	Head of IT	Active
AR-14	PDPO audit within 12 months and GDPR-equivalent expectations from the EU distributor are firm compliance deadlines	Brief §3.1; compliance register in docs/A2_compliance	DPPA/GDPR remediation dates in the register compress; risk R1/R2 rise to Critical	Written confirmation from partner due-diligence team at G2	Legal / EDM Consultant	Active
AR-15	DPPA citations used across the portfolio (Cap. 97: ss. 3,4,6,7,8,9,10,11,20,21,23,24,25,26,27,28,29,30,33) are correct as verified; breach notification = s.23 “immediately”	Verified against the Act’s published text	A mis-citation would undermine the register at audit; documenta-tion fix	Legal review sign-off at G1	Legal	Verified — legal sign-off pending

#	Assumption	Basis / evidence	If false → impact	Validation method & trigger	Owner	Status
AR-16	The scenario's problem statements (23% duplicates, 8.4% variance, 11-day close) are accurate baselines for KPI improvement claims	Brief §3.3; independently re-measured in profiling (22.84% duplicates)	Improvement percentages must be re-based on measured baselines — profiled values already used where they differ	First quarterly data-quality report re-measures all three	EDM Consultant	Verified (22.84% ≈ 23%)
AR-17	No machine learning in Months 1–12; predictive pilots only from M12–15 behind triggers T1–T6	Decision D-15/D-25; input data unverifiable (8.7% unattributed, 11.5% unreconciled)	If the Board mandates earlier ML, results are unauditable — recorded as an accepted-risk exception in the decision log	Trigger review at G3	Board / CFO	Active — deliberate deferral

How this register is used

- **Decision log** (docs/D2_decision_log.md) cites assumption IDs as *evidence* columns; where a decision flips an assumption's status (e.g., AR-09 substitution), the decision row and this register move together.
- **Red-team** (docs/D2_red_team.md) attacks AR-01, AR-02, AR-10 and AR-13 as its highest-severity targets — this register is the vulnerability surface, and the mitigations (G1 confirmations, staging execution, site survey) are the reconceived controls.
- **Gates G1–G4** in docs/D1_roadmap_18months.md carry the validation triggers; assumptions are *not* re-litigated outside gate reviews.
- Anything falsified here is a **change-control event**: the affected decision log entries re-open, and the budget/coherence narrative is re-derived before further spend.

Think-deeper alignment: an assumption that is never tested is a decision made by default. Every row above has a named owner, a trigger, and a failure mode — so “we assumed” can never be the end of an investigation.

Appendix B — EDM Diagnostic — Executive Briefing Memo to the Board

A1 — Executive Briefing Memo to the Board

To: Board of Directors, Savanna Retail Group (SRG) **From:** Enterprise Data Management Consultant **Date:** Month 1 of the 18-month EDM transformation programme **Subject:** Why our data problems are structural, not technical **Classification:** Confidential — Board distribution only **Annexes:** A1_data_lifecycle_map.md, A2_governance_charter.md, A2_policies.md, A2_compliance_register.md, A2_cfo_memo.md

Task A1 — The EDM Diagnostic (C1)

(a) Enterprise Data Management vs. traditional database management — tested against our own evidence The proposition before the Board is to hire two more database administrators. It is a plausible answer to a question we have

not yet asked: **what is broken at SRG — the engines, or the enterprise’s command of its data?**

Traditional **database management** administers engines: uptime, backups, indexes, query tuning, replication, patching, storage growth. It asks “*is the database healthy?*” **Enterprise data management (EDM)** governs the data across systems: policies, ownership, standards, quality loops, metadata, lifecycle, and cross-system meaning. It asks “*does ‘customer’, ‘product’ and ‘revenue’ mean one thing everywhere, and is a named person accountable for that?*”

Four pieces of our own evidence decide the question:

SRG symptom	What a DBA would do	What actually causes it
The same product carries 5 identifiers across POS, e-commerce and supplier files	Nothing — the identifiers sit in five healthy databases	No master-data standard, no product owner, no golden SKU (rule VR-008 did not exist)
~23% duplicate customer records; loyalty points posted to wrong members	Nothing — no query returns “too fast”	No shared customer identity key and no entry rules across 23 POS databases, e-commerce, loyalty and CRM
11-day monthly reporting cycle	Speed up each of 23 databases individually	Absent data architecture and absent KPI definitions — consolidation happens in Excel because no integrated layer exists
Board cannot answer segment growth/churn	Nothing	No conformed customer, product or revenue definitions to segment on

The decisive proof is the cleanse we have already executed. Taking confirmed duplicates from **22.84% → 0.00%** (total duplicate-flag rate 25.06% → 2.85%) required cross-system matching rules — 953 deterministic phone matches plus 189 fuzzy Levenshtein matches — a survivorship policy, **365 homonym pairs deliberately rejected** by the email-conflict rule, **110 pairs held in stewardship review**, and standardisation of 6 phone formats into 1 (E.164) and 127 district labels into 42, with product UOM conformance 15.33% → 100%. Not one index, tuning pass, backup or uptime improvement produced a single customer view. Those results came from *matching rules and stewardship decisions that had to be invented*, because SRG never had them.

Two more DBAs would, if anything, deepen the problem. They would keep the **23 per-store MySQL silos** healthier, faster and better backed up: better management of a *by-product*. Databases are containers; customer identity, product meaning and revenue definition are the assets. Hiring DBAs increases investment in the wrong asset class while the assets remain ownerless.

(b) Why the same symptoms return after every “clean-up exercise” Each clean-up so far has treated data as disposable output: extract, fix, admire, discard. Three control loops were missing, and each now has a name:

1. **No upstream enforcement.** The validation rules that now exist — **VR-001..VR-012** (E.164 phone mask, district dropdown, SKU uniqueness, controlled UOM vocabulary, MoMo payment_ref within 24h or PENDING) — existed at no capture point. A cashier could still type anything, so defects re-entered at source the day after cleansing.
2. **No data ownership.** Nobody was accountable for the customer, product or payment domain, so nobody was authorised to declare a field mandatory or to rule that two records are the same person. Quality cannot be owned by a committee of nobody.
3. **No monitoring.** The checks **DQC-01..DQC-10** (duplicate rate above 1%, phone validity below 99%, quarantine rate above 0.5%, MoMo references pending beyond 24h) did not exist, so drift stayed invisible until the next manual audit. The ETL diagnosis shows the identical pattern: root cause **RC-6**, alerts routed to an unmonitored mailbox, four days of silent failure and no owner of the nightly run.

The 8.4% stock variance, the duplicate customers and the 11-day report are therefore not three problems. They are one — *nobody owns data quality from creation to deletion* — surfacing in three places. Cleansing without enforcement is a recurring cost, not an improvement.

(c) Where this is documented next A1_data_lifecycle_map.md traces customer data across **creation → storage → usage → sharing → archiving → deletion**, naming the system, the stakeholder and the failure point at every stage. Its sharpest findings sit at *sharing* (e-mailed supplier Excels, manual MoMo CSV downloads, unencrypted laptop exports) and at *deletion* (no retention or erasure process at all, contrary to the DPPA 2019 (Cap.97) s.3 protection principles and

s.28 erasure right). The same file maps SRG across all eleven **DAMA-DMBOK** knowledge areas: two emerging (Data Quality, Data Security), five partial, and four effectively absent — Data Governance, Data Architecture, Documents & Content, and Reference & Master Data ownership.

Recommended Board actions

1. **Adopt the Data Governance Charter in Month 2** — a Council, seven domain owners and stewards drawn only from existing job titles; zero headcount, a fortnightly 30-minute stand-up.
2. **Approve POL-001 (Access & Classification) first, Month 2** — four-tier classification, default-deny grants, encrypted-export approval. This closes the exact path the unencrypted laptop walked out of, and addresses P1 gaps under DPPA s.20 and s.29.
3. **Bind quality at entry, Months 2–4** — VR-001..VR-012 on forms and inside the ETL quarantine; DQC-01..DQC-10 as a daily scorecard to the Council.
4. **One definition per KPI and one reporting layer by Month 6** — collapses the 11-day cycle and answers the Board’s segment-growth and churn question as the visible quick win.
5. **Fund it inside the UGX 480,000,000 envelope, phased** — Months 1–6 quick wins; PDPO-audit-ready by Month 12 (register under DPPA s.29, appoint the officer required by s.6).

Think-deeper answer *Why do the same symptoms keep returning after every clean-up? What does that say about data as a by-product versus a managed asset?*

Because cleaning is an **event applied to a stock**, while quality is a **property of a flow**. SRG scrubs the stock and then re-opens the taps: with no VR rules at capture, no owner and no DQC monitoring, the same defects re-enter within days — our own 22.84% duplicate rate was measured on data already “cleaned” in earlier exercises.

Treating data as a by-product means it is exhaust from selling: created incidentally by whoever typed it, owned by nobody, kept until inconvenient, repaired only when a report embarrasses someone, and deleted — if ever — by hand. That framing explains all three chronic symptoms at once: the 8.4% variance has no owner so it stays “unexplained”; the 11-day report persists because no one owns the *definition* of revenue; duplicates return because identity was never a rule, only a keystroke.

Treating data as a managed asset inverts each of those: creation under enforced rules, a named domain owner per domain, continuous measurement, scheduled retention and erasure, and retirement with evidence. The practical test the Board should ask after any cleansing: *what stops this recurring on Monday?* Today the honest answer is “nothing”. Task A2 exists to install that answer — ownership, entry rules, monitoring and a lifecycle — at a cost of hours and discipline, not headcount.

Appendix C — Customer Data Lifecycle Map & DAMA-DMBOK Gap Analysis

A1 — Data Lifecycle Map: Customer Data

Client: Savanna Retail Group (SRG) · **Prepared by:** Enterprise Data Management Consultant **Date:** Month 1 of the 18-month EDM programme · **Classification:** Confidential **Companion to:** A1_edm_diagnostic_memo.md (Task A1 executive briefing)

Task A1 — The EDM Diagnostic (C1)

(i) Customer data lifecycle — creation to deletion, with system, stakeholder and failure point at every stage
Reading note: every failure point above is a *control* that does not exist, not a *tool* that is missing — which is why the same defects recur after each clean-up exercise (see A1_edm_diagnostic_memo.md, section (b)).

(ii) DAMA-DMBOK knowledge-area mapping for SRG

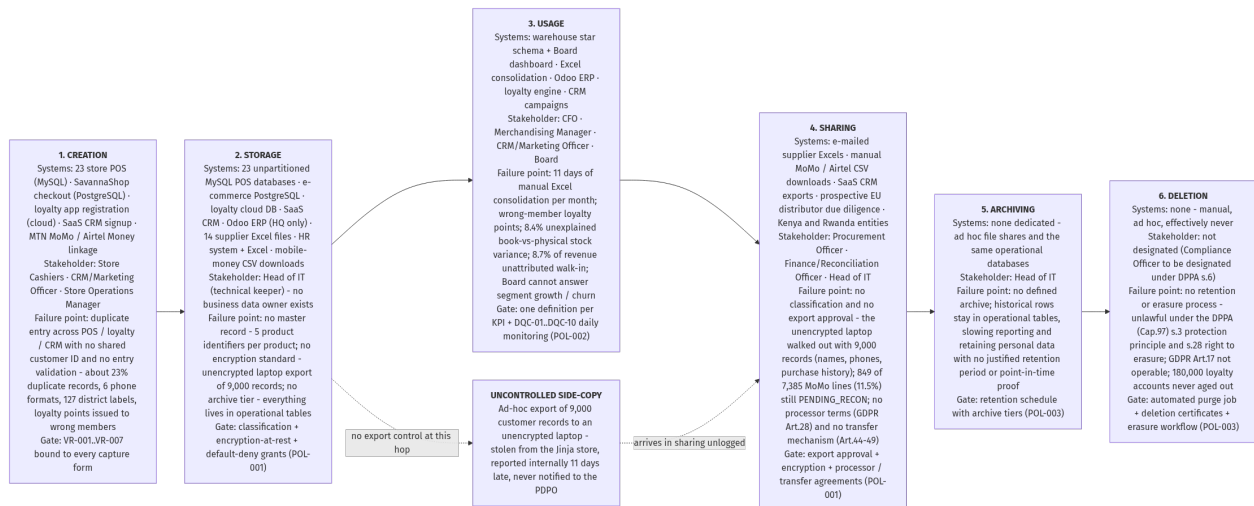


Figure 10: The A1 data lifecycle map diagram (1).

#	DAMA-DMBOK knowledge area	Status at SRG	Evidence (current state)	Function SRG lacks entirely
1	Data Governance	Absent	No charter, no council, no data owners, no decision rights; reporting takes 11 days with nobody accountable for definitions	Policy issuance, governance council, RACI decision rights, funding of data work
2	Data Architecture	Absent	8 siloed source systems (23 MySQL POS, e-commerce, loyalty, CRM, Odoo, HR/Excel, supplier Excel, MoMo CSV); no target architecture, no integration layer, no data flow design	Enterprise architecture blueprint, integration/consolidation layer, architecture standards
3	Data Modeling & Design	Partial	Warehouse star schema DDL with SCD2 dimensions and a 25-attribute data dictionary exist; operational models diverge (5 product identifiers, no canonical customer entity)	A single canonical/enterprise model and naming standard applied to POS, e-commerce and ERP — not just to the warehouse
4	Data Storage & Operations	Partial	UPS-backed POS keeps capturing; databases run, but 23 unpartitioned MySQL DBs, no archive tier, backups untested, connectivity outages force local-only records	Lifecycle-tiered storage, documented backup/restore and DR objectives, capacity and patch standards

#	DAMA-DMBOK knowledge area	Status at SRG	Evidence (current state)	Function SRG lacks entirely
5	Data Security	Partial (emerging)	RBAC with 5 roles, default-deny, column grants, row-level security and masking functions (+256-XXX-XX9332, S*** W**) built and tested; yet an unencrypted laptop left with 9,000 records	Classification policy, endpoint and export controls, access recertification, access/audit-log review
6	Data Integration & Interoperability	Partial (emerging)	Repaired ETL with schema contracts, quarantine, idempotency and a single-writer lock (self-test 3/3 PASS, 10,000 rows, control total UGX 252,382,814.16); but supplier data still arrives as 14 Excels and payments as manual CSVs	Scheduled integration of supplier/HR/CRM sources, data contracts enforced <i>at the source</i> , API/event standards
7	Documents & Content	Absent	14 supplier Excel files e-mailed between procurement officers; no document management, no version control, no records retention, no data-loss prevention	Content/records management, versioning and retention, DLP over e-mail and endpoints
8	Reference & Master Data	Partial (emerging)	Cleansing produced golden records (5,000 → 3,858) and a stewardship queue (110 held, 365 homonym pairs rejected); but no MDM system, no survivorship policy signed off, no product master	Named master-data owners, approved survivorship rules, authoritative hierarchy (product → category) maintained in Odoo
9	Metadata	Partial	Data dictionary of 25 classified attributes plus domain/sensitivity/quality tags; one KPI lineage traced by hand	An operational catalog with automated lineage, metadata standards in source systems, metadata review cadence

#	DAMA-DMBOK knowledge area	Status at SRG	Evidence (current state)	Function SRG lacks entirely
10	Data Warehousing & BI	Partial	Star schema loaded (10,000 lines; UGX 252,382,814 over Jul–Dec) and a Board dashboard exists; monthly management reporting still takes 11 days in Excel	Approved KPI definitions, self-service reporting, dashboard publication approval, single reporting layer
11	Data Quality	Present (emerging)	Profiling and cleansing executed (duplicates 22.84% → 0.00%), 12 validation rules VR-001..VR-012, 10 monitoring checks DQC-01..DQC-10 specified	Binding those rules at the point of capture, a stewardship loop with SLAs, and a monthly scorecard to the Council

(iii) Areas SRG lacks entirely, and the three most consequential gaps **Entirely absent:** Data Governance, Data Architecture, Documents & Content, and — in ownership terms rather than tooling terms — Reference & Master Data. Data Quality and Data Security are *emerging* only because artifacts now exist in the repository; they are not yet operating in production, which is the difference between a capability and a control.

Three most consequential gaps:

1. **No governance decision rights (DAMA area 1).** Every other gap is a symptom: quality rules exist but are not bound at entry because no domain owner may compel the stores; classification exists in the data dictionary but is not enforced because no one approves access. This is the multiplier — and the cheapest to close (Charter, Month 2).
2. **No architecture or integration layer (area 2).** This is the direct cause of the 11-day reporting cycle, the five product identifiers and the 23% duplicates: meaning cannot be reconciled across systems that were never designed to exchange it. It is also why every Board question requires an Excel project.
3. **No lifecycle end — archiving and deletion (areas 4 and 7, DPPA s.3 and s.28).** SRG cannot demonstrate how long it holds customer data, cannot honour erasure, and cannot answer a PDPO auditor within the 12-month window. Every additional export (like the Jinja copy) compounds an already unlawful retention position.

Think-deeper answer *Why do the same symptoms keep returning after every clean-up, and what does by-product versus managed asset mean on this map?*

The lifecycle makes the mechanism visible: clean-up exercises intervened **only in stage 3 (usage)** — a one-off fix to the reporting copy — while every defect was being manufactured in **stage 1 (creation)** and multiplied in **stage 2 (storage)** and **stage 4 (sharing)**. Stages 1, 4 and 6 had no control at all: no entry validation (VR-001..VR-012 absent), no export approval (the laptop), no retention or erasure (DPPA s.3, s.28). Re-cleansing is therefore guaranteed to fail: the map shows an unclosed loop, not a dirty dataset.

Treated as a **by-product**, customer data is exhaust from selling — created by whoever typed it, stored wherever it landed, shared by e-mail, archived by inertia, deleted never. That single assumption produces all six failure points on the diagram without any individual behaving badly. Treated as a **managed asset**, each stage acquires an owner, an enforced gate and a measurable standard: identity resolved at creation, classified and encrypted at storage, defined and monitored at usage, approved and contracted at sharing, tiered at archiving, and destroyed on schedule with a certificate.

The map also shows why this is cheap for SRG: the gates are mostly *technical* (form masks, quarantine, GRANTs, scheduled purge), not headcount. With a four-person IT team, control must live in the flow of work, not in a policy binder — which is precisely the operating assumption of the Charter and the three policies in Task A2.

Appendix D — Data Governance Charter, Operating Structure & RACI Matrix

A2 — Data Governance Charter

Client: Savanna Retail Group (SRG) · **Prepared by:** Enterprise Data Management Consultant (interim facilitator) **Date:** Month 1 of the 18-month EDM programme · **Proposed effective:** Month 2 (on Board resolution) · **Classification:** Confidential **Companions:** A2_policies.md (POL-001..POL-003) · A2_compliance_register.md · A2_cfo_memo.md

Task A2 — Governance Framework & Compliance Register (C2)

(i) Vision and principles **Vision.** *SRG’s data is owned by named people, defined once, validated at entry, protected by default and retired on schedule — so that any Board question can be answered from one trusted source within a day rather than eleven.*

Eight principles, sized for a four-person IT team and a ~200-staff retailer:

#	Principle	What it means at SRG
P1	Data is a managed asset, not a by-product	Every domain has an owner; data work is budgeted, measured and reported like inventory
P2	Enforce technically, not by poster	If a rule can be a constraint, a dropdown, a mask or a quarantine, it must be; documentation is the fallback, not the control
P3	One definition per KPI, one master per entity	“Revenue”, “active customer”, “stock on hand” defined once and signed by the Council; Odoo is product master, golden record is customer master
P4	Quality is built at entry, never cleaned after	VR-001..VR-012 bind at the form and the ETL gate; cleansing is remediation for defects, not the operating model
P5	Minimum viable documentation	Document only what code cannot enforce — decisions, owners, definitions; a 25-attribute dictionary beats a 300-page manual nobody reads
P6	Privacy by default	Masked until proven otherwise; default-deny access; classify before you grant; collect the minimum (DPPA s.3, GDPR Art.5, Art.25)
P7	Offline-tolerant controls	Stores lose connectivity for hours daily: validation queues locally, syncs later, and gaps (VR-012 PENDING) are designed states — not silent failures
P8	Ownership before tooling	No new platform, licence or hire is approved before the receiving domain has a named owner and steward

(ii) Scope In scope (governed domains):

Domain	Definition (one meaning)	Systems in scope	Domain Data Owner	Data Steward
Customer & Loyalty	One person = one golden record; 180,000 members + walk-ins	POS signups, SavannaShop, loyalty app, SaaS CRM	CRM/Marketing Officer	Store Operations Manager
Product	One product = one SKU (VR-008); hierarchy and attributes	Odoo (master), POS, e-commerce, supplier files	Merchandising Manager	Procurement Officer
Store & Organisation	Store codes ST01–ST23, ECOM01, cities, trading status	Odoo store master, warehouse dim_store	Store Operations Manager	Head of IT Operations
Supplier	Supplier identity, terms, lead times, contract status	14 Excel files → controlled repository	Procurement Officer	Finance/Reconciliation Officer
Price & Promotion	One shelf price at one moment (SCD2)	Odoo pricing, POS, e-commerce, promo approvals	Merchandising Manager	Finance/Reconciliation Officer
Transaction & Payment	Sale, return, MoMo/Airtel reference, reconciliation status	POS, e-commerce, MTN/Airtel gateways, warehouse	CFO	Finance/Reconciliation Officer
HR-restricted	Employment and payroll records (highest sensitivity)	HR system, payroll Excel	HR & Payroll Officer	Compliance Officer (DPO)

Out of scope / deferred (explicitly deferred, not rejected): raw footfall-sensor content and any biometric processing (deferred pending a DPIA, Month 12); HR analytics beyond operational payroll accuracy (deferred); predictive segmentation or automated customer decisions (blocked until DPPA s.27 / GDPR Art.22 review); full cloud migration and real-time streaming (evaluated in Part B/C); Kenya and Rwanda localisation (deferred until an entity is incorporated); enterprise document management rollout (pilot with supplier contracts only, Month 9).

(iii) Operating structure Data Governance Council. Executive sponsor: **Managing Director**. Chair: **CFO**. Members: Head of IT, Merchandising Manager, CRM/Marketing Officer, Store Operations Manager, Finance/Reconciliation Officer, Compliance Officer. Facilitator: **Enterprise Data Management Consultant (interim)**. The Council owns the policy set, resolves domain disputes and approves exceptions.

Data protection officer. DPPA 2019 (Cap.97) s.6 requires designation of a data protection officer. The Council recommends and the Board designates the **Compliance Officer as Data Protection Officer** in Month 1 (existing role, no hire), reporting independently to the Managing Director for breach matters. The DPO also owns PDPO registration (s.29) and audit response.

Domain Data Owners vs. Data Stewards. *Owners* are accountable for the domain's meaning, quality targets and access decisions; they approve exceptions and disputes. *Stewards* do the weekly work: run checks, triage the stewardship queue, propose rule changes. Both are mapped in the scope table above to **existing SRG job titles only** — no new headcount is required.

Cadence.

Rhythm	Body	Duration	Output
Fortnightly	Data stewards' stand-up	30 minutes	Open DQC alerts, stewardship queue (110 items today), blocked entries

Rhythm	Body	Duration	Output
Monthly	Data Governance Council	60 minutes	DQ scorecard, exception register, access changes, domain disputes
Quarterly	Board report	1 page	P1 gap closure, KPI trend, incident summary, budget vs. UGX 480M envelope
Ad hoc (within 24h)	Incident cell: Head of IT + DPO + domain owner	As needed	Breach assessment and notification decision (DPPA s.23, GDPR Art.33)

(iv) RACI matrix

Activity	Responsible	Accountable	Consulted	Informed
1. Customer record creation (POS / e-commerce / loyalty signup)	Store Cashiers	CRM/Marketing Officer	Store Operations Manager; Head of IT	Council
2. Master-data change approval — product (SKU, attributes, hierarchy)	Merchandising Manager	Merchandising Manager	Procurement Officer; Head of IT	Council; Store Operations Manager
3. Master-data change approval — price and promotions	Merchandising Manager	CFO	Finance/Reconciliation Officer	Store Operations Manager; Council
4. Breach declaration (e.g. stolen device / data loss)	Head of IT	Compliance Officer (DPO)	EDM Consultant; CFO	Managing Director; Council; Board
5. Retention and deletion execution (POL-003 purge jobs)	Head of IT Operations	Compliance Officer (DPO)	HR & Payroll Officer; Procurement Officer	Council; CRM/Marketing Officer
6. Quarterly access-grant recertification	Domain Data Owners	Head of IT	Compliance Officer (DPO)	Council
7. Data-quality rule exception approval (VR override)	Data Steward (domain)	Domain Data Owner	Head of IT	Council; EDM Consultant
8. ETL failure triage and quarantine release	Head of IT Operations	Head of IT	Finance/Reconciliation Officer; EDM Consultant	Domain Data Owners; Council if P1
9. KPI definition sign-off (“one definition per KPI”)	EDM Consultant (drafting)	CFO	CRM/Marketing Officer; Merchandising Manager; Head of IT	Board; Council
10. Mobile-money reconciliation sign-off (MTN / Airtel)	Finance/Reconciliation Officer	CFO	Head of IT	Managing Director; Council
11. Supplier file ingestion (14 Excels → controlled load)	Procurement Officer	CFO	Head of IT; Merchandising Manager	Finance/Reconciliation Officer; Council

Activity	Responsible	Accountable	Consulted	Informed
12. PDPO registration and audit response (DPPA s.29, s.30)	Compliance Officer (DPO)	Managing Director	EDM Consultant; Head of IT; external counsel	Board; Council
13. Loyalty points dispute resolution	Store Operations Manager	CRM/Marketing Officer	Finance/Reconciliation Officer	Council; store managers
14. Dashboard publication approval (Board-facing)	EDM Consultant	CFO	Domain Data Owners	Board; Council
15. Schema / data-model change approval	Head of IT Operations	Head of IT	EDM Consultant; Domain Data Owners	Council
16. Erasure or access request from a data subject (DPPA s.24, s.28; GDPR Art.15, Art.17)	Compliance Officer (DPO)	Domain Data Owner	Head of IT; Finance/Reconciliation Officer (statutory retention)	Council; Managing Director

(v) Charter adoption mechanics

- **Approval:** one-page charter issued for signature by the Managing Director and all Council members in **Month 2**; ratified as a standing Board item in the same month. Policies POL-001..POL-003 (A2_policies.md) are annexes and take effect on the same resolution.
- **Review:** annually, or within 10 working days of a material change (new country, new processing, incident, regulatory change); interim amendments by Council majority, recorded in a decision log.
- **Resourcing:** no new headcount. Effort is absorbed by existing roles — estimated 2–4 hours per Council member per month — and funded from the UGX 480,000,000 envelope (tooling and encryption, not salaries).
- **Success measures (reported quarterly):** duplicate-person rate below 1.0% sustained (DQC-01); management reporting cycle from 11 days to 2 days or fewer by Month 6; access recertification at or above 95% completion within 10 working days; breach internally reported within 24 hours and notified to the Authority immediately on confirmation; PDPO registration completed by Month 2 and audit-ready by Month 12; zero P1 compliance gaps open beyond 30 days; every in-scope domain with a named owner and zero unresolved stewardship items older than 14 days.

Think-deeper answer Which single policy, enforced from day one, would have prevented the Jinja laptop incident? Which would be violated daily by SRG's own staff habits — and how do you make it enforceable rather than decorative?

Preventer: POL-001 (Data Access & Classification). The incident was not a sophisticated attack; it was an unapproved copy leaving the estate. POL-001 breaks that chain at three points that each existed in the incident: (1) `full_name`, `phone`, `email`, `payment_ref` and `purchase history` are **Restricted** and may not be extracted en masse without Head of IT + Compliance approval — the 9,000-record export would never have been authorised; (2) the export above 100 Restricted records must be **encrypted at rest and in transit, logged and time-expiring** — an encrypted laptop is a non-event rather than a breach; (3) **default-deny plus masked analytics views** mean routine work never needs raw PII at all, removing the justification for the copy. Classification also creates the duty that was missing most: knowing *what* left, so that the 11-day reporting delay and the absent notification (DPPA s.23) become impossible — you cannot assess a breach you cannot inventory.

Daily violation: POL-002 (Data Quality) — read broadly as **access and capture hygiene**. Cashiers will keep typing free-text phones and districts during rushes; procurement will keep e-mailing supplier Excels; staff will keep exporting “just to check” into spreadsheets; stores with outages will keep creating local customer records. Every one of these is rational, invisible and repeated dozens of times a day. A policy relying on goodwill dies in week two.

Making it enforceable — four controls, no goodwill required:

1. **Deny-by-default GRANT/REVOKE scripts** (already built: 5 roles, column grants, row-level security, 15-test assertion suite). Absence of a grant is the default; access exists only where a business case was approved, and quarterly recertification removes what is stale.
2. **Masking views as the only analytic surface** (+256-XXX-XX9332, S*** W**, s***@srg.co.ug, AU*****51) — staff physically cannot see raw PII in reports, so there is nothing worth copying to a laptop.

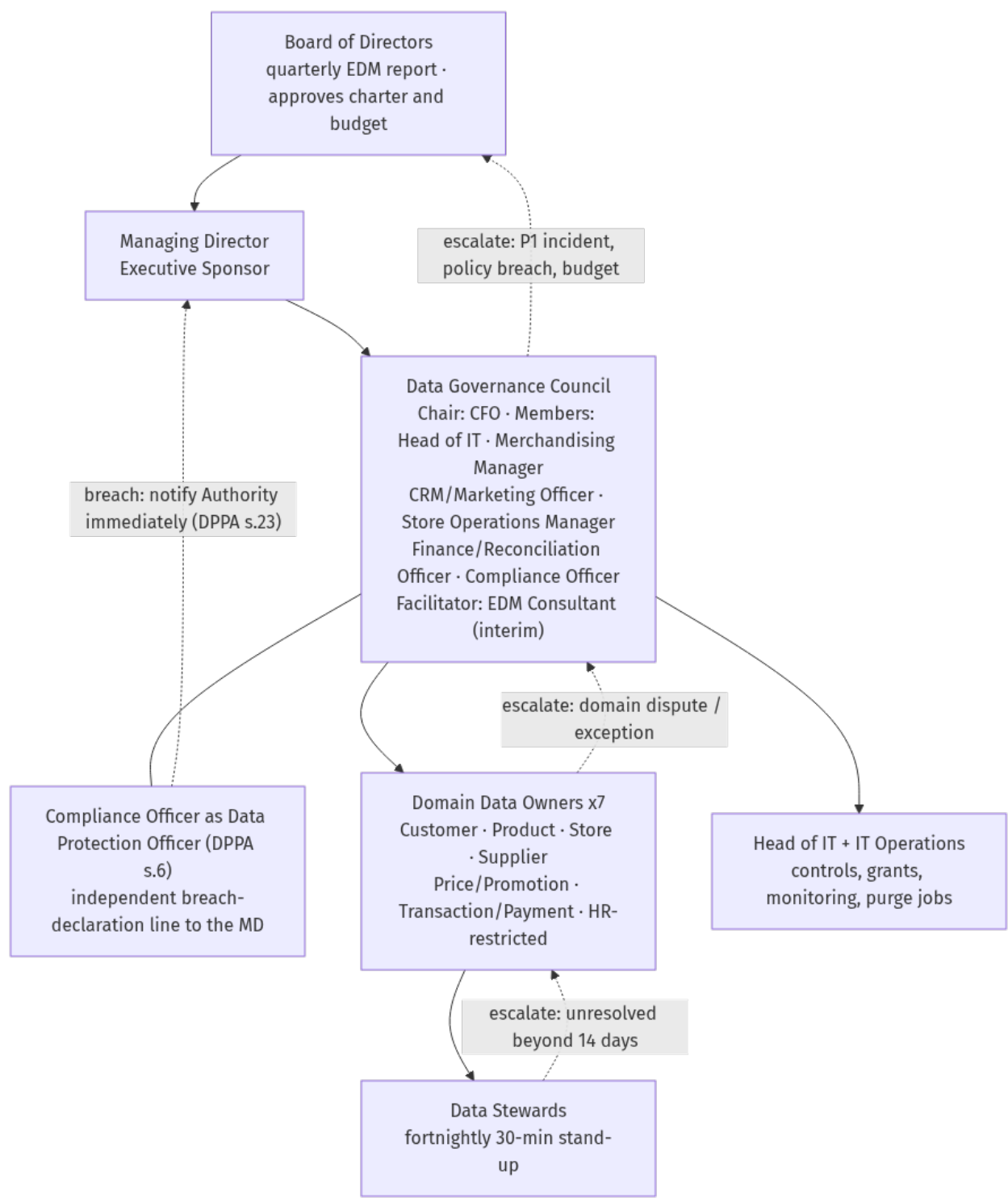


Figure 11: The A2 governance charter diagram (1).

- 3. **Export approval workflow with mandatory encryption and expiry**, enforced outside the database: a ticket, dual approval, an encrypted container, a 7-day TTL and an audit entry; unencrypted extracts of Restricted data fail the workflow.
- 4. **Entry validation plus ETL quarantine plus a store scorecard**: VR-001..VR-012 block or quarantine at capture (no batch aborts, no silent passes), DQC-01..DQC-10 alert the on-call rotation daily (never an unmonitored mailbox — root cause RC-6), and duplicate rate, completeness and MoMo-pending aging are published per store and attached to store-manager KPIs. Non-compliance becomes visible to a manager with authority — which is where enforcement actually lives.

Appendix E — Three Enforceable Data Policies (Access & Classification, Quality, Retention)

A2 — Data Policies (POL-001 · POL-002 · POL-003)

Client: Savanna Retail Group (SRG) · **Prepared by:** Enterprise Data Management Consultant **Date:** Month 1 of the 18-month EDM programme · **Proposed effective:** Month 2 · **Classification:** Confidential **Annex to:** A2_governance_charter.md · **Supporting evidence:** module2_data_quality/output/ (VR/DQC catalogues), module3_etl/ (quarantine, run audit), module4_security/ (RBAC, masking)

Task A2 — Governance Framework & Compliance Register (C2)

POL-001 — Data Access & Classification

Field	Value
Policy ID / title	POL-001 — Data Access & Classification
Owner	Head of IT (day-to-day control owner); Compliance Officer / Data Protection Officer (DPPA s.6) owns the classification taxonomy
Approver	Data Governance Council, ratified by the Managing Director (Month 2)
Effective	Month 2; full attribute coverage by Month 3
Scope	All SRG data at rest, in transit and on endpoints in every domain in the Charter: 23 POS databases, e-commerce PostgreSQL, loyalty cloud DB, SaaS CRM, Odoo ERP, HR/payroll, supplier files, mobile-money extracts, warehouse and dashboards. Applies to employees, contractors, and any processor (GDPR Art.28).

Requirements (measurable)

- 1. Every attribute in the data dictionary and every new data store is tagged with exactly **one of four tiers** before production release; **100% coverage by Month 3**, verified by a metadata report.
- 2. **Classification tiers with SRG examples:**

Tier	Definition	SRG examples	Default access
Public	Safe for external publication	product_name, shelf price, store addresses and opening hours, published KPIs	Open
Confidential	Internal commercial data; leak harms competitiveness, not a person	transaction_id, district, sales aggregates, supplier lead times, pricing logic, promo calendar	Named staff by role

Tier	Definition	SRG examples	Default access
Restricted	Personal, financial or identifying data (DPPA “personal data”, GDPR Art.4(1))	full_name, phone, email, payment_ref, loyalty history, consent flags, HR salary, national IDs	Explicit GRANT only, masked by default
Prohibited	Data SRG must not collect, store or transmit	passwords/PINs/OTPs, full card PAN and CVV, special personal data (DPPA s.9), children’s data without guardian consent (DPPA s.8), data with no lawful basis (DPPA s.7)	Not collected; discovered instances quarantined and destroyed within 5 working days, with a record

- 3. **Default deny.** No role, service account or new database receives access without an explicit GRANT. Target: **0 standing ad-hoc grants**; all grants traceable to a role in the RBAC matrix.
- 4. **Masked by default for analytics.** Any role other than compliance_officer/cdm_admin reads Restricted columns only through masking views: phone +256-XXX-XX9332, name S*** W**, e-mail s***@srg.co.ug, payment reference AU*****51 (executed evidence: module4_security/output/masking_demo_output.txt, 4/4 validation checks PASS).
- 5. **Quarterly access recertification** within **10 working days** of each quarter start, at **≥95% completion**; revocations executed within **2 working days** of sign-off.
- 6. **Encrypted export rule.** Extracts of more than **100 Restricted records** require prior written approval from the **Head of IT and the Compliance Officer (DPO)**; the export must be encrypted at rest (AES-256 or equivalent), password-delivered out-of-band, logged, and expire within **7 days**. Exports of Prohibited data are never permitted.
- 7. **Endpoint control:** full-disk encryption and a screen-lock policy on every device that has touched Restricted data; **≥98% compliance** on the monthly check.
- 8. **Audit logging:** reads of Restricted columns are logged and reviewed monthly; logs retained **12 months**.

Enforcement mechanism. *Technical:* GRANT/REVOKE scripts (default-deny, column-level grants, row-level security — module4_security/rbac_postgresql.sql, 15-test assertion suite rbac_test.sql); masking views (data_masking.sql); database audit logging; export workflow tooling that refuses unencrypted containers. *Procedural:* recertification campaign, export approval ticket, monthly log review by the DPO.

Exceptions. Written, logged in the exceptions register, time-bound to a maximum of 90 days, approved by the Council; break-glass access permitted to the Head of IT with post-hoc justification inside 24 hours. Prohibited-data exceptions are not grantable.

Review cadence. Semi-annual, and immediately after any incident or regulatory change.

Violation handling. Unauthorised access or unencrypted export: report to Head of IT and DPO within 24 hours; disciplinary process under HR rules; where Restricted data is exposed, run the breach assessment (DPPA s.23 / GDPR Art.33) and notify the Authority immediately on confirmation; repeat or wilful violations escalate to the Managing Director.

POL-002 — Data Quality

Field	Value
Policy ID / title	POL-002 — Data Quality
Owner	Head of IT (control operation); Domain Data Owners (quality targets); CRM/Marketing Officer (customer domain)
Approver	Data Governance Council (Month 2)
Effective	Month 2 for ETL enforcement; Month 4 for 100% of capture forms

Field	Value
Scope	All customer, product, store, supplier, price/promotion and transaction/payment data at capture, in integration and at publication. HR-restricted data is in scope for validation only (no profiling of salary content).

Requirements (measurable)

- Entry-time validation.** Rules **VR-001..VR-012** are bound at capture, enforced client-side *and* server-side: phone masked to E.164 with save blocked on failure (VR-001), district limited to a dropdown of the 42 official values (VR-002), primary-key and golden-record uniqueness rejected or routed to the stewardship queue (VR-004, VR-007), SKU collisions rejected (VR-008), UOM constrained to {kg, pcs, liters} (VR-009), category constrained to the master hierarchy (VR-010), price-below-cost flagged with approver identity (VR-011), MoMo payment_ref populated within 24 hours or transaction held as PENDING (VR-012).
- Monitoring.** Checks **DQC-01..DQC-10** run **daily at 06:00** with defined thresholds (duplicate-person rate >1.0%; phone validity <99.0%; district resolution <99.5%; core-field completeness phone <92%; UOM/category conformance <99.0%; SKU uniqueness violations >0; quarantine rate >0.5% or >100 rows; MoMo refs pending >24h; future-dated registrations >0; margin anomalies >0 weekly). Alerts go to the on-call rotation by SMS/WhatsApp and to the Council dashboard — **never to an unmonitored mailbox** (root cause RC-6).
- Remediation SLAs.** Critical: <**24 hours** (identity, primary-key, revenue-attributed defects). High: <**3 working days** (phone validity, UOM/category conformance, MoMo pending). Medium: <**10 working days** (format and enrichment defects). SLA breaches escalate automatically at the next Council meeting.
- ETL gate.** Every load validates against schema contracts; failing rows are **quarantined with a reason code and replayed** — no batch aborts and no silent partial-mode fallback (root cause RC-4); quarantine contents visible to stewards within 24 hours.
- Monthly DQ scorecard** to the Council: duplicate rate, phone validity, core-field completeness, conformance, quarantine rate, MoMo-pending aging — published **per store** and per channel.
- No direct production data edits** (manual UPDATE/DELETE outside application code) without an approved ticket naming record count, rows affected and business reason; target **0 unticketed edits per month**, reviewed monthly.
- Offline-tolerant capture.** Forms validate locally during connectivity outages and sync queued entries later; offline rows are admitted with an explicit state (customer_sk = 0, PENDING_RECON) rather than degraded data.

Enforcement mechanism. *Technical:* form validation with blocked saves; ETL quarantine table with reason codes and run audit (module3_etl/srg_etl_pipeline.py); daily monitoring jobs with alerting; database permissions that deny ad-hoc UPDATE/DELETE outside application roles; idempotent re-runs so fixes are replayable. *Procedural:* stewardship queue triage at the fortnightly stand-up; store scorecard attached to store-manager performance KPIs; ticket gate for production edits.

Exceptions. Domain Data Owner approval, capped at 30 days, logged with a compensating check; **no exception** permitted for VR-004 (primary-key integrity), VR-007 (customer identity) or VR-008 (SKU uniqueness).

Review cadence. Quarterly (thresholds and rules), or immediately after a P1 incident.

Violation handling. Repeated threshold breaches at a store trigger a corrective-action review with the Store Operations Manager; unticketed production edits are treated as a P2 incident (investigated within 3 working days); defects that reach Board reporting uncorrected escalate to the CFO as an accountability failure.

POL-003 — Retention & Deletion

Field	Value
Policy ID / title	POL-003 — Retention & Deletion
Owner	Compliance Officer / Data Protection Officer (schedule and erasure workflow); Head of IT Operations (purge jobs)
Approver	Data Governance Council, ratified by the Board (Month 3)
Effective	Month 3 (schedule published) · Month 4 (automated purge) · Month 6 (erasure self-service)

Field	Value
Scope	All records in operational systems, the warehouse, backups, e-mail/file shares, supplier and HR repositories — including the 180,000 loyalty accounts and ad-hoc extracts.

Requirements (measurable)

1. **Retention schedule** published and enforced:

Record class	Retention period	Basis	Disposal method	Owner
Transaction and sales records (incl. MoMo references)	7 years from transaction	Tax, audit and dispute evidence	Automated purge + deletion certificate	Finance/Reconciliation Officer
Loyalty account data	24 months after inactivity (last purchase, login or contact)	Storage limitation (DPPA s.3; GDPR Art.5(1)(e))	Anonymise, then purge	CRM/Marketing Officer
Marketing consent / contactability record	24 months after last response	Consent freshness (DPPA s.7; GDPR Art.7)	Purge contact, retain consent evidence 3 years	CRM/Marketing Officer
Supplier contracts and procurement records	6 years after contract end	Contractual and statutory limitation	Purge + certificate	Procurement Officer
HR and payroll records	Per statutory Employment Act record-keeping (confirm exact periods with counsel)	Employment and tax law	Restricted purge + certificate	HR & Payroll Officer
Backups	90 days rolling	Operational recovery only	Cryptographic erasure at cycle end	Head of IT Operations
ETL quarantine payloads	12 months	Defect diagnosis and audit trail	Automated purge + log entry	Head of IT Operations

- Automated purge job** runs monthly; every execution emits a **deletion certificate** (record class, count, basis, job ID, operator, timestamp) retained for 7 years and summarised at the quarterly Board report.
- Erasure workflow (DPPA s.28, GDPR Art.17)**. Intake via a single published channel → identity verification → acknowledgement within **5 working days** → fulfilment within **30 days** across POS, e-commerce, loyalty, CRM and warehouse. Where a record must be kept (e.g. 7-year transaction history), the response applies **partial erasure/anonymisation** and states exactly what is retained and why.
- Lawful-refusal path**. Where erasure is refused (statutory retention, tax, legal claim), issue a **written justification citing the specific ground**, notify the data subject of the decision and of their right to **appeal to the Data Governance Council within 14 days**; the Council decides within 30 days and records the outcome in a refusal register.
- Prohibited data and end-of-life extracts** (including any copy such as the Jinja export) are destroyed within **5 working days** of identification, with a certificate.

Enforcement mechanism. *Technical:* scheduled purge jobs (cron/pg_cron) with append-only job logs; anonymisation scripts that are idempotent; backups expiring on a 90-day policy; access revocation triggered automatically on account inactivity at 24 months. *Procedural:* quarterly **spot audit of 10 records per domain** against the schedule, tabled at the Council with certificates; refusal register reviewed by the DPO.

Exceptions. Legal hold (litigation, audit, investigation) approved by the Managing Director and the DPO, recorded with an expiry date and reviewed every 90 days; no other exception to a statutory retention period.

Review cadence. Annual, plus immediate review on any new processing, new market (Kenya/Rwanda) or regulatory change.

Violation handling. Failure to execute a scheduled deletion or an approved erasure request is a **P1 incident**: reported to the Council and the DPO within 24 hours, assessed for notification under DPPA s.23 / GDPR Art.33, and remediated with a certificate within 5 working days. Repeated failures by a domain trigger an owner review by the Managing Director.

Think-deeper answer *How do these policies become enforceable rather than decorative?*

By binding each one to a control that fails closed. POL-001 is enforced by databases that grant nothing by default and expose Restricted columns only through masking views — so non-compliance is physically unavailable, not merely discouraged; the export workflow refuses unencrypted containers and caps extracts at 100 records without dual approval, which is precisely the control the 9,000-record laptop copy would have tripped. POL-002 is enforced at the two points where defects are born: the capture form (blocked saves on VR-001..VR-012) and the nightly load (quarantine with reason codes, no batch abort, no silent fallback), with DQC-01..DQC-10 alerting an on-call rotation rather than an unmonitored mailbox — and with consequences attached per store, because a scorecard nobody sees is not a control. POL-003 is enforced by jobs, not intentions: a monthly purge that cannot be skipped, deletion certificates that cannot be back-dated, and a quarterly spot audit that samples ten records per domain and asks for the certificate. The three together form a closed loop — **prevent (validation, grants) → detect (monitoring, recertification, audit) → correct (SLA, purge, escalation)** — which is the minimum viable governance that a four-person IT team can actually run.

Appendix F — Compliance Obligations & Gap Register (DPPA 2019 / GDPR / CCPA)

A2 — Compliance Obligations & Gap Register

Client: Savanna Retail Group (SRG) · **Prepared by:** Enterprise Data Management Consultant **Date:** Month 1 of the 18-month EDM programme · **Classification:** Confidential · **Review:** monthly at the Data Governance Council **Frameworks:** Uganda Data Protection and Privacy Act (DPPA) 2019 / Cap.97 · EU GDPR (European distributor due diligence) · CCPA/CPRA (comparative reference) **Verification note:** section numbering per Cap. 97 consolidated text — verify against official gazette before external use.

Task A2 — Governance Framework & Compliance Register (C2)

Priority narrative (read this first)

#	Priority theme	Rows covered	Why it is P1 now
1	Registration and accountability before the PDPO audit	CMP-01, CMP-02, CMP-03	SRG processes 180,000 loyalty members and is not registered with the PDPO (s.29) and has no designated officer (s.6). An audit is expected within 12 months; an unregistered controller has no defensible starting position.
2	The Jinja incident is still an open breach	CMP-04, CMP-05	9,000 records left on an unencrypted laptop, reported internally 11 days late, never notified. DPPA s.23 requires immediate notification to the Authority; s.20 required the security measures that were absent. Every month of delay compounds the finding.

#	Priority theme	Rows covered	Why it is P1 now
3	Lawful basis and evidence of consent	CMP-06, CMP-07, CMP-08	Loyalty marketing runs on unrecorded consent (s.7 / Art.7), there are no records of processing (Art.30), and the EU-facing rollout has had no DPIA (Art.35). Without these three, the European distributor's due-diligence team fails SRG on day one.
4	Cross-border readiness for the EU partnership	CMP-09, CMP-10, CMP-11	No 72-hour procedure (Art.33/34), no transfer mechanism such as SCCs (Art.44–49), and no documented purposes or lawful bases (Art.5/Art.6). These are the three questions every EU counterparty asks first.

Scoring: Risk = Likelihood × Impact, each 1–5 (P1 = 20–25 or statutory deadline now; P2 = 12–19; P3 = below 12 or prospective).

Obligations and gap register

ID	Frame-work & citation	Require-ment	Current SRG practice	Gap	Risk (L×I, 1–5)	Priority	Remedia-tion (artifact-linked)	Owner	Target
CMP-01	DPPA 2019 (Cap.97) s.29 — data protection register	Con-trollers/pro-cessors must register with the PDPO	No regis-tration; process-ing 180,000 mem-bers, e-commerce and app data	Unregis-tered con-troller; audit-critical failure	5 × 5 = 25	P1	Registra-tion pack from A1_data_li (DPO) + module5_warehouse/data_dictionary.md; file and retain acknowl-edge-ment	Compli-ance Officer (DPO)	Month 2
CMP-02	DPPA s.4 (estab-lishment of PDPO) and s.30 (public access to register)	Recog-nise the Author-ity's register; be in-spectable and veri-fiable	Nobody at SRG has verified registra-tion status	No evidence of standing for any audit	4 × 4 = 16	P1	DPO verifies entry on the public register and files the confir-mation in the audit pack	Compli-ance Officer (DPO)	Month 2

ID	Frame- work & citation	Require- ment	Current SRG practice	Gap	Risk (L×I, 1–5)	Priority	Remedia- tion (artifact- linked)	Owner	Target
CMP-03	DPPA s.6 — data pro- tection officer	Desig- nate a data pro- tection officer	No DPO; breach and consent decisions unowned	Account- ability vacuum	$5 \times 4 = 20$	P1	Board designa- tion letter: Compli- ance Officer as DPO, independ- ent breach line to the MD (Charter §iii)	Manag- ing Director	Month 1
CMP-04	DPPA s.23 incl. s.23(4) — breach notifica- tion	Notify the Au- thority immedi- ately; the Author- ity decides on data- subject notifica- tion; pre- scribed content	Jinja incident: internal report 11 days late, no noti- fication ever made	Missed immedi- ate notifica- tion; incom- plete incident record	$5 \times 5 = 25$	P1	Breach response proce- dure + s.23(4) notifica- tion template; retro- spective legal review of the Jinja incident; incident- cell drill (Charter §iii)	Head of IT + DPO	Month 1
CMP-05	DPPA s.20 and s.21 — security mea- sures (con- troller and pro- cessor)	Appro- priate technical and organisa- tional mea- sures, includ- ing devices	No endpoint encryp- tion, no export approval, unen- crypted 9,000- record export	Direct cause of the Jinja incident	$5 \times 5 = 25$	P1	POL- 001: four tiers, default- deny, encrypted- export approval; build on module4_security/ RBAC (5 roles, 15 tests) and masking outputs	Head of IT	Month 3

ID	Frame- work & citation	Require- ment	Current SRG practice	Gap	Risk (L×I, 1–5)	Priority	Remedia- tion (artifact- linked)	Owner	Target
CMP-06	DPPA s.7 and GDPR Art.7 — consent	Consent to collect and process, demon- strable and with- drawable	Loyalty and POS signups record no consent; no consent ledger	Lawful- ness of 180,000- member market- ing un- proven	$4 \times 4 = 16$	P1	Consent capture at every signup + consent ledger (field consent_gdpr_eu already in dim_customer); re- permission cam- paign	CRM/Mar- keting Officer	Month 4
CMP-07	GDPR Art.30 — records of pro- cessing (ROPA)	Written record of purposes, cate- gories, recipi- ents, transfers, retention	None; compli- ance cannot describe any pro- cessing activity	Audit failure; blocks due diligence	$4 \times 4 = 16$	P1	Build ROPA from the 25- attribute data dic- tionary, lifecycle map and POL- 003 schedule	Compli- ance Officer (DPO)	Month 5
CMP-08	GDPR Art.35 — DPIA	Assess high-risk process- ing before it starts	EU- facing loyalty rollout and footfall sensors planned with no assess- ment	High- risk process- ing launched blind	$4 \times 4 = 16$	P1	DPIA for the loyalty app EU rollout (Ap- pendix D tem- plate); sensor DPIA at Month 12	EDM Consul- tant + DPO	Month 6

ID	Frame- work & citation	Require- ment	Current SRG practice	Gap	Risk (L×I, 1–5)	Priority	Remedia- tion (artifact- linked)	Owner	Target
CMP-09	GDPR Art.33 (72 hours) and Art.34 (high- risk subject notifica- tion)	Notify the supervi- sory authority within 72 hours; notify subjects where risk is high	No pro- cedure of any kind	Hard deadline would be missed on day one of EU data flows	$5 \times 5 = 25$	P1	Dual- timeline breach proce- dure: DPPA “immedi- ately” + GDPR 72-hour clock, decision tree, tem- plates, on-call roster	Head of IT + DPO	Month 2
CMP-10	GDPR Art.44–49 — inter- national transfers	Valid transfer mecha- nism (SCCs plus transfer assess- ment)	Euro- pean distribu- tor would receive data with no mech- anism	Partner- ship poten- tially unlawful at signature	$4 \times 4 = 16$	P1	Transfer inven- tory; execute Standard Contrac- tual Clauses with the distribu- tor; data- residency state- ment	CFO + DPO	Month 6
CMP-11	DPPA s.3 prin- ciples; GDPR Art.4(1) defini- tions and Art.5 princi- ples	Lawful- ness, fairness, trans- parency, purpose and storage limita- tion, integrity, account- ability	Purposes never stated; personal data kept indefi- nitely	Founda- tional gap underpin- ning every row above	$4 \times 4 = 16$	P2	Charter P6; POL- 003 schedule; pub- lished privacy notice	Compli- ance Officer (DPO)	Month 4
CMP-12	GDPR Art.6 — lawful bases	A docu- mented lawful basis per purpose	No purpose- to-basis mapping	Cannot defend any pro- cessing if chal- lenged	$4 \times 4 = 16$	P2	Lawful- basis column added to the ROPA	Compli- ance Officer (DPO)	Month 5

ID	Frame- work & citation	Require- ment	Current SRG practice	Gap	Risk (L×I, 1–5)	Priority	Remedia- tion (artifact- linked)	Owner	Target
CMP-13	DPPA s.10 (pro- tection of privacy) and s.11 (collec- tion from the data subject)	Collect from the subject; protect privacy during process- ing	Signup forms collect more than the transac- tion needs; third- party list sources unveri- fied	Over- collection and unverifi- able prove- nance	$3 \times 3 = 9$	P2	Data- minimisation review of POS, checkout and loyalty forms; prove- nance declara- tion per source	CRM/Mar- keting Officer	Month 5
CMP-14	DPPA s.24 — right of access	Provide the personal data held on request	No channel, no SLA, no cross- system extrac- tion	Cannot satisfy a member request across 8 silos	$4 \times 3 = 12$	P2	DSAR work- flow + self- service extract from the golden record; internal SLA 30 days	Compli- ance Officer (DPO)	Month 7
CMP-15	DPPA s.28 and GDPR Art.16 / Art.17 — rectifi- cation and erasure	Correct inaccu- rate data; erase on request	23% du- plicates make records demon- strably wrong; no cor- rection or erasure path	Rights not operable at all	$4 \times 4 = 16$	P2	POL- 003 erasure work- flow incl. lawful- refusal and appeal path; steward- ship queue as the cor- rection channel	Domain Data Owners	Month 6
CMP-16	DPPA s.25 and GDPR Art.21 — prevent process- ing / objec- tion	Halt pro- cessing on objec- tion	No opt-out mecha- nism exists	Objec- tions cannot be hon- oured	$3 \times 3 = 9$	P2	Suppres- sion list in CRM keyed to the golden record	CRM/Mar- keting Officer	Month 8

ID	Frame- work & citation	Require- ment	Current SRG practice	Gap	Risk (L×I, 1–5)	Priority	Remedia- tion (artifact- linked)	Owner	Target
CMP-17	DPPA s.26 — direct market- ing	Market- ing rules and opt-outs hon- oured	23% du- plicates mean members mes- saged after opting out, and twice	Consent integrity failure visible to members	$3 \times 4 = 12$	P2	Suppres- sion keyed to golden record; cam- paigns drawn only from cleansed deduped set (0.00% con- firmed dupes)	CRM/Mar- keting Officer	Month 6
CMP-18	DPPA s.8 — chil- dren's data	Addi- tional protec- tion / guardian consent	Loyalty app has no age gate across 180,000 members	Possible unlawful collec- tion of chil- dren's data	$3 \times 4 = 12$	P2	Age gate and under-18 flag at signup; purge of any con- firmed minors with cer- tificates	CRM/Mar- keting Officer + DPO	Month 7
CMP-19	DPPA s.9 — special personal data	Prohib- ited cate- gories must not be pro- cessed	HR Excel plus free-text notes may hold health or other sensitive content	Prohib- ited process- ing in unman- aged files	$3 \times 5 = 15$	P2	HR file audit; Prohib- ited tier under POL- 001; HR domain re- stricted to 2 named users with column grants	HR & Payroll Officer	Month 5

ID	Frame- work & citation	Require- ment	Current SRG practice	Gap	Risk (L×I, 1–5)	Priority	Remedia- tion (artifact- linked)	Owner	Target
CMP-20	DPPA s.27 and GDPR Art.22 — auto- mated decisions	Safe- guards for solely auto- mated decisions with sig- nificant effects	Loyalty tiering auto- matic; planned targeting without human review	Unre- viewed auto- mated treat- ment of members	$2 \times 4 = 8$	P3	Docu- ment decision logic; manda- tory human check- point before any denial of benefit	CRM/Mar- keting Officer	Month 12
CMP-21	GDPR Art.13 / Art.14 — trans- parency	Provide privacy informa- tion at and after collec- tion	No notice at POS, checkout or in the app	Trans- parency failure for EU and Ugandan users alike	$4 \times 3 = 12$	P2	Layered one-page notice plus in-app and checkout text, reviewed with counsel	Compli- ance Officer (DPO)	Month 5
CMP-22	GDPR Art.15 / Art.20 ; CCPA §1798.100 (right to know) and §1798.130 (45-day response, 12- month look- back)	Access, portabil- ity and disclo- sure of the cate- gories collected	No channel; CCPA applica- bility untested	Cannot respond within 45 days or supply a 12- month lookback	$3 \times 3 = 9$	P2	Portabil- ity extract (CSV) from the golden record; docu- mented CCPA applica- bility test	Compli- ance Officer (DPO)	Month 8
CMP-23	GDPR Art.25 — data protec- tion by design	Embed protec- tions at design time	Partial: default- deny RBAC, masking and classifi- cation built (module4_security/)	Applied to the ware- house only, not to new features	$3 \times 4 = 12$	P2	Design- review gate inside schema change approval (Charter RACI #15)	Head of IT	Month 6

ID	Frame- work & citation	Require- ment	Current SRG practice	Gap	Risk (L×I, 1–5)	Priority	Remedia- tion (artifact- linked)	Owner	Target
CMP-24	GDPR Art.28 — pro- cessors	Written data- processing terms with each pro- cessor	SaaS CRM, loyalty cloud vendor and dis- tributors under no written terms	Proces- sor failure is SRG's failure	$4 \times 3 = 12$	P2	Execute Art.28 clauses with all proces- sors; record recipi- ents in the ROPA	CFO + DPO	Month 7
CMP-25	GDPR Art.32 — security of pro- cessing	Appro- priate technical and organisa- tional security	Same endpoint gap as CMP-05; no MFA on adminis- trative access; no key manage- ment	Techni- cal control gap at the database bound- ary	$4 \times 4 = 16$	P2	Encryp- tion at rest/in transit, MFA for admin roles, key rotation — se- quenced with POL- 001	Head of IT	Month 6
CMP-26	GDPR Art.83 — adminis- trative fines	Up to EUR 20 million or 4% of total world- wide annual turnover	Expo- sure crys- tallises only if EU data flows before remedia- tion	Tail risk quanti- fied in A2_cfo_memo.md	$2 \times 5 = 10$	P2	Close every EU- readiness P1 row before distribu- tor data flows	Manag- ing Director	Month 9
CMP-27	CCPA §1798.140 — appli- cability thresh- olds	USD 25M revenue / 100,000 con- sumers / 50% revenue from selling	Below thresh- olds today; expan- sion unassessed	Applica- bility not moni- tored as the business grows	$1 \times 5 = 5$	P3	Annual applica- bility test recorded in this register	CFO	Month 12

ID	Frame- work & citation	Require- ment	Current SRG practice	Gap	Risk (L×I, 1–5)	Priority	Remedia- tion (artifact- linked)	Owner	Target
CMP-28	CCPA §1798.105 delete, §1798.120 opt-out of sale/shar- ing, §1798.150 private right of action (USD 100–750 per con- sumer per incident), §1798.155 adminis- trative fines	Compar- ative bench- mark for deletion, opt-out and liability	No sale or sharing of data today	Prospec- tive exposure if data is ever shared for ad- vertising	$2 \times 4 = 8$	P3	Adopt the SRG- standard policy (already stronger than the thresh- old via POL- 003); re-test annually	Compli- ance Officer (DPO)	Month 12

How this register is operated

- **Closure evidence:** a row closes only when the remediation artifact exists and has been demonstrated at the Council — for example CMP-05 closes on the export-approval workflow plus the RBAC test suite run, not on a statement of intent.
- **Escalation:** any P1 open beyond 30 days is reported to the Board in the quarterly report with a named owner and a recovery date.
- **Audit path (Month 12):** registration evidence (CMP-01/02), DPO designation (CMP-03), breach procedure and drill (CMP-04/09), ROPA (CMP-07), DPIA (CMP-08), POL-001..POL-003 execution records and deletion certificates constitute the PDPO audit pack.

Think-deeper answer Which single policy would have prevented the Jinja incident, which is violated daily, and how is that made enforceable?

The register answers this mechanically. **POL-001 (Access & Classification)** is the preventer: rows CMP-05 and CMP-04 both resolve to it — Restricted classification of full_name, phone, email, payment_ref and purchase history removes the “no one knew it was sensitive” defence, default-deny means no standing right to export, and the export-approval gate (more than 100 Restricted records, dual approval, encryption, 7-day expiry) intercepts the exact 9,000-record copy that left Jinja. **POL-002 (Data Quality and capture hygiene)** is the one violated daily: free-text entry, e-mailed supplier Excels, ad-hoc spreadsheets and unticketed production edits recur dozens of times a day because each is individually convenient. Its enforcement in this register is visible in the linkage: CMP-06, CMP-07 and CMP-21 are all *evidence* obligations that only survive if entry-time consent capture, ROPA fields and masking are enforced by forms, quarantine and GRANTS rather than by instruction — and in the closure rule that a gap is not closed until a demonstrable control exists.

Appendix G — CFO Rebuttal Memo — The Cost of Inaction

A2 — Memorandum to the Chief Financial Officer

To: Chief Financial Officer, Savanna Retail Group (SRG) **From:** Enterprise Data Management Consultant **Date:** Month 1 of the 18-month EDM programme **Subject:** Governance is not bureaucracy — the absence of it already has a price tag **Classification:** Confidential

Task A2 — Governance Framework & Compliance Register (C2) You called governance bureaucracy. Below is what its absence has already cost, priced in our own currency.

1. The Jinja incident, priced. *ASSUMPTIONS (consultant estimates, to be validated):* customer notification at UGX 6,000 per record-contact for an SMS + letter campaign; incident-response and forensics retainer UGX 15,000,000; internal staff time at 6 people × 15 days × UGX 250,000 fully loaded. Arithmetic: $9,000 \times 6,000 = \text{UGX } 54,000,000$; plus **UGX 15,000,000**; plus $6 \times 15 \times 250,000 = \text{UGX } 22,500,000 \rightarrow \text{UGX } 91,500,000 direct, equal to 19% of our UGX 480,000,000 annual data budget — spent replacing data, not building anything. Worse, the response we skipped: the theft was reported internally **11 days late** and **no breach notification was ever made**, against DPPA 2019 (Cap.97) s.23, which requires the Authority to be notified *immediately*. Then: compensation exposure under DPPA Part VII (s.33, compensation for failure to comply — **verify with counsel**), a PDPO investigation in the audit expected within 12 months, and the loss of trust of members of a 180,000-member programme.$

2. The European partnership, priced. The UK Information Commissioner fined **Marriott International GBP 18.4 million (October 2020)** after a breach rooted in acquired Starwood systems that lacked adequate security **due diligence**. Illustrative conversion: $18.4\text{M} \times \sim 1.27 \text{ USD/GBP} \times 3,700 \text{ UGX/USD} \approx \text{UGX } 86 \text{ billion}$ — roughly 180 times our entire annual data budget. It is the closest possible analogue to what we are doing: integrating with systems we have not assessed inherits their liability. Our distributor's due-diligence team is asking that question about *us* right now.

3. What one control gap costs at our scale. The ICO fined **British Airways GBP 20 million (October 2020, GDPR Art.83)** after about **400,000 customers** were affected by a web-skimming attack — a single control gap producing roughly **UGX 94 billion**. The GDPR ceiling is EUR 20 million or **4% of global annual turnover**, whichever is higher. Mid-market retailers are not exempt; they are the affordable target.

4. The monthly drag. Reporting: $4 \text{ staff} \times 11 \text{ days} \times 12 \text{ months} = 528 \text{ person-days} \times \text{UGX } 150,000 = \text{UGX } 79,200,000$ **per year** to build one month's report. Duplicates: $23\% \text{ of } 180,000 \approx 41,400 \text{ duplicate profiles} \times 4 \text{ campaigns} \times \text{UGX } 150 \text{ per SMS} = \text{UGX } 24,840,000$ **per year** of contact wasted, some of it to people who already opted out. Stock variance: annualised revenue $\text{UGX } 504.8\text{M} \times \sim 70\% \text{ cost of goods} = \text{UGX } 353.3\text{M} \times 8.4\% = \text{UGX } 29,700,000$ **per year** unexplained. Total drag $\approx \text{UGX } 133,700,000$ **yearly — 28% of the data budget**, plus the one-off UGX 91.5M incident: **UGX 225M+, about 47% of the annual envelope, spent on the absence of governance**. And the same gap hides money we have already collected: 849 of 7,385 mobile-money lines (11.5%) sit unexplained as PENDING — cash received that finance cannot yet prove it received.

The ask. No new money. Phase 1 (Months 1–6) commits roughly **UGX 96M — 20% of the existing UGX 480,000,000 envelope** — to classification and encryption tooling, the export-approval workflow, entry validation, and one consolidated reporting layer. Board-visible results by Month 6: reporting cycle cut from 11 days to 2 or fewer, duplicates held below 1%, PDPO registration filed (DPPA s.29), and a signed evidence trail for the distributor.

The rebuttal. Without classification and access rules, every future export is another 9,000-record laptop waiting to happen. The cheapest line on this page is POL-001; the most expensive is doing nothing.

Think-deeper answer POL-001 (Access & Classification) is the single policy that would have prevented Jinja: the 9,000 records were Restricted, the export required dual approval and encryption, and the copy would never have left. POL-002 is the one staff break daily — free-text entry, e-mailed supplier files, ad-hoc exports. Making both enforceable rather than decorative means controls that fail closed: default-deny grants, masking views, a workflow that refuses unencrypted extracts, ETL quarantine instead of silent passes, and a store quality scorecard attached to manager KPIs. Every month we skip them, we re-book the UGX 91.5M.

Appendix H — Architecture Selection — Weighted Trade-Off Decision

Task B1 — Architecture & Data Modeling (C3)

Client: Savanna Retail Group (SRG) — Kampala, Uganda **Deliverable:** Part B(i) — Enterprise data architecture pattern decision **Author:** Lead Enterprise Data Management Consultant **Budget envelope:** UGX 480,000,000/yr (~USD 130,000 @ UGX 3,700/USD) · **Team:** 4 IT staff (2 SQL-capable, 0 data-engineering experience) · **Horizon:** quick wins by month 6, PDPO audit ≤ 12 months

Task B1(i) — Architecture Pattern Decision (C3)

1. Recommendation (headline) **Adopt a HUB-AND-SPOKE architecture:** one central governed core (staging → warehouse → golden customer/product records, hosted HQ-side “cloud-lite”) fed by offline-first spokes (23 store POS + SavannaShop + loyalty app + CRM + Odoo), with store-side local buffering and scheduled sync windows. **Weighted score: 4.35 / 5.00** — first on every constraint that is non-negotiable (connectivity, skills, budget, month-6 deadline).

2. The four candidate patterns in SRG terms

Pattern	What it means at SRG	Structural signature
Centralized	All 23 POS databases, e-commerce, loyalty and CRM stream directly into one HQ platform; stores are thin clients with no local persistence	1 core, 0 spokes, synchronous always-on links
Decentralized	Each store/system keeps owning its data; integrations are point-to-point; reporting is assembled locally per store/domain	N autonomous nodes, $N \times (N-1)$ point-to-point links
Federated	Domain owners (store ops, e-commerce, loyalty, supply chain) publish their own conformed data products to shared standards; central team sets definitions only	N domains, standards bus, no single physical core
Hub-and-spoke	Central governed core (staging, warehouse, golden records, DQ rules); spokes capture locally, buffer offline, sync in defined windows	1 core + N offline-tolerant spokes, asynchronous replication

3. Evaluation criteria and weight justification Weights are derived directly from the constraint set, not from generic architecture scorecards.

#	Criterion	Weight	Justification from SRG constraints
C1	Resilience under intermittent connectivity	25%	“Several stores lose connectivity for hours daily” is a <i>hard</i> physical constraint (also power risk, UPS-backed POS). Any pattern that assumes an always-on link fails at ST07/ST17-class stores before it fails anywhere else. Highest weight because it is the least negotiable.
C2	Fit for the 4-person team’s skills	20%	2 of 4 staff write SQL, none have data-engineering experience. A pattern whose daily operation requires streaming/JDBC/enterprise tooling staffing does not survive contact with the roster.

#	Criterion	Weight	Justification from SRG constraints
C3	Budget fit (UGX 480M/yr, all-in)	20%	Licences + cloud + hires share one envelope; ~USD 130k/yr cannot carry an enterprise MDM/integration suite <i>and</i> the connectivity remediation <i>and</i> the hires.
C4	Time-to-value by month 6	15%	Board explicitly expects visible quick wins by month 6; a pattern with a long platform-build phase scores poorly regardless of elegance.
C5	Single version of truth	10%	Real but <i>recoverable</i> — a delayed-but-governed core (golden records, star schema) restores one truth, whereas connectivity outages cannot be negotiated away. Weighted below C1–C4 deliberately.
C6	Scalability to Kenya/Rwanda + EU distributor	10%	Expansion and GDPR-equivalent due diligence are 12–18 month concerns, not month-6 concerns; the pattern must not paint SRG into a corner, but must not drive today's design either.
Total		100%	

Scores are 1 (worst) – 5 (best).

4. Weighted trade-off matrix

Criterion	Wt.	Centralized	Decentralized	Federated	Hub-and-spoke
C1 Resilience under intermittent connectivity	25%	1	5	4	4
C2 Fit for 4-person team skills	20%	3	2	2	4
C3 Budget fit (UGX 480M envelope)	20%	2	3	3	5
C4 Time-to-value by month 6	15%	2	3	2	5

Criterion	Wt.	Centralized	Decentralized	Federated	Hub-and-spoke
C5 Single version of truth	10%	5	1	3	4
C6 Scalability to Kenya/Rwanda	10%	4	2	5	4
Weighted total (Σ score $\times$ weight)	100%	2.45	3.00	3.10	4.35
Rank		4	3	2	1

Worked example (hub-and-spoke): $(4 \times 25 + 4 \times 20 + 5 \times 20 + 5 \times 15 + 4 \times 10 + 4 \times 10) / 100 = 435/100 = 4.35$.

5. Why the scores fall where they do

Pattern	Evidence-based reasoning
Centralized (2.45)	Scores 1 on C1 because synchronous central capture converts every store outage into lost/queued sales: an ST17 (Mbarara) store offline 3 hours cannot write to HQ at all, and SRG's own failure log already shows what happens when a central batch assumes connectivity — the nightly job aborted entirely (<code>etl_diagnosis.md</code> , 0 of 21,562 rows staged). Scores 2 on C3/C4 because network remediation across 23 sites is a capex project that consumes the month-6 window before a single dashboard ships. Its one genuine strength — C5 = 5 — is real but unattainable without C1/C3/C4 being solved first.
Decentralized (3.00)	Scores 5 on C1 (a store that cannot reach anyone still sells) — this is the pattern SRG <i>already runs</i> , and the results are on the record: 23 MySQL silos, ~23% duplicate customers, “same product, 5 identifiers”, 11-day monthly consolidation, 8.4% book-to-physical stock variance. Scoring it 1 on C5 is not hypothetical; it is the current-state diagnosis. It also fails C2 (four staff cannot maintain 23 divergent schemas plus 8 side-channel Excel processes).
Federated (3.10)	Scales best (C6 = 5) and tolerates locality (C1 = 4), but demands domain ownership maturity, published data contracts per domain, and stewardship capacity SRG does not possess — no data owners, no stewards, no catalog (Part A2 defines them <i>as an outcome</i> of this programme). Scoring 2 on C2/C4: federation's governance scaffolding is exactly the multi-quarter programme that misses month 6. It is the right <i>destination</i> posture for year 3, not the year-1 backbone.

Pattern	Evidence-based reasoning
Hub-and-spoke (4.35)	Offline-first spokes absorb outages (spool → sync), so C1 = 4 rather than 5 — the central core is a single point of failure, mitigated by replayable spools, immutable raw landing and UPS/cloud-lite redundancy, not eliminated. C2 = 4: one pipeline, SQL + pandas, one run log — the team can operate it. C3 = 5: no 23× infrastructure, no enterprise licence. C4 = 5: cleansed golden records + star schema + quarantine-hardened pipeline are demonstrably deliverable inside the first two quarters (built and self-tested in this repository: 10,000 rows, control total UGX 252,382,814.16, 3/3 self-tests PASS). C5 = 4, not 5: spoke-local records may diverge for hours until the sync window reconciles them.

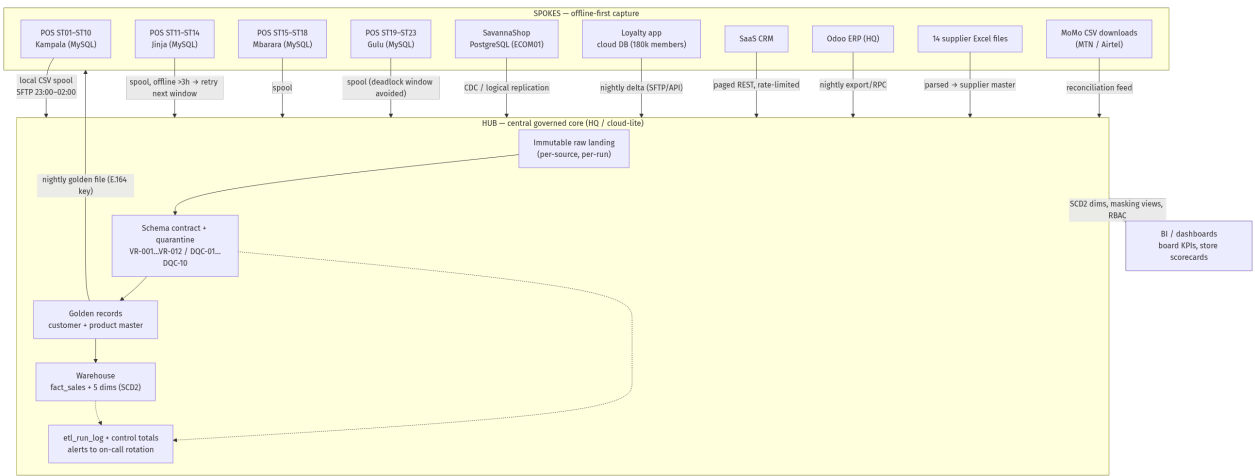


Figure 12: The B1 architecture decision diagram (1).

6. Recommended topology

7. How the recommendation maps to what was actually built

Hub-and-spoke design commitment	Implemented evidence in this repository
Spokes capture offline and sync later	srg_etl_pipeline.py: walk-in/offline rows load with customer_sk = 0 (“Unknown / Walk-in”) instead of aborting; missing MoMo refs become payment_ref='PENDING_RECON', reconciliation_status='PENDING' — offline capture is a <i>designed state</i> , not an error
Single central pipeline, one version of truth	module3_etl → module5_warehouse/star_schema_ddl.sql: 5 conformed sources → fact_sales + dim_customer/dim_product (SCD2) + dim_store/dim_date/dim_payment_method
Asynchronous, windowed sync (never synchronous always-on)	Nightly sync window 23:00–02:00 with single-writer advisory lock so offline store-sync replay (ST17) cannot deadlock the ETL (fix for RC-3)
Fail-visible core, not fail-silent	Quarantine table + etl_run_log + post-load control total (UGX 252,382,814.16) replace the diagnosed “partial mode” stale-fallback anti-pattern (RC-4)

Hub-and-spoke design commitment	Implemented evidence in this repository
Golden records at the hub, distributed back to spokes	Module 2 survivorship (5,000 → 3,858 golden customer records; merged_customer_ids audit trail) consumed by dim_customer; nightly golden file keyed by E.164 phone
Governed core accessible to a 4-person team	pandas + SQLAlchemy + SQL they already have; sqlfluff-validated SQL; no unattended streaming platform in the critical path

8. Rejected alternatives — summary

Alternative	Rejected because	What would change the verdict
Pure centralized	Requires always-on links SRG does not have; a single bad file aborts the whole batch (proven: RC-1, 0 rows staged); network remediation eats the month-6 window and the UGX envelope	Ubiquitous, metered, resilient store links + verified 99.5% site availability for 6 consecutive months
Pure decentralized	Is the current disease: 23 silos → ~23% duplicate customers, 5 identifiers per product, 11-day closes, 8.4% stock variance; scales as $O(N^2)$ links	Never — it contradicts the brief's definition of the problem
Federated / data-mesh style	Needs domain ownership, stewardship and data-product skills SRG lacks; governance scaffolding overruns month 6; C2/C4 scores reflect that	Mature stewardship (≥ 12 months of operating the A2 charter) and ≥ 2 SQL staff cross-trained on contracts/CI
Enterprise commercial integration/MDM suite	Licence + skills cost falls outside a UGX 480M envelope already carrying cloud, licences and hires (see Task B3 rejected-alternatives analysis)	A funded, separate licence line approved by the Board and a trained hire

9. Assumptions register (this decision rests on)

#	Assumption	If false →
A1	Store outages are <i>hours per day</i> , not days per week; spool-and-replay remains viable	Spoke storage grows unbounded; must add store-level persistent queue capacity (SQLite spool) and raise C1 weighting
A2	Existing MySQL POS + PostgreSQL e-comm + SQL-capable staff can be reused without replacement	Budget line and timeline re-baseline; possibly justifies centralization on new SaaS POS
A3	Nightly windows (23:00–02:00) are acceptable for management reporting; sub-hour latency only needed for the two use cases in Task B4(v)	Real-time paths multiply → broker ops burden exceeds 4-person capacity
A4	The 480M UGX envelope is nominal, not elastic; no separate connectivity capex line exists	Centralized/wide-area options re-enter the matrix
A5	Kenya/Rwanda entry is 12+ months out and will reuse the same core with new spokes	C6 weight rises; federation posture may become justified earlier

#	Assumption	If false →
A6	Board accepts “governed core, eventually consistent spokes” as one version of truth (goldens + warehouse, not synchronous mirroring)	C5 must be re-scored; might force higher centralization

Think-deeper answer The four patterns are not competing ideologies — they are different answers to *where you pay the consistency-vs-availability tax*. SRG has already paid the availability tax by accident (23 silos, 22.84% duplicates, 5 identifiers per product, an 11-day close), which is why “decentralized” scores 1 on single-version-of-truth: that score is measured, not assumed. Centralized architecture asks SRG to pre-pay a tax it cannot afford — always-on links, network capex, platform skills — before collecting any return, and the programme would show nothing by month 6 except remediation. Hub-and-spoke is the deliberate engineering compromise: it accepts *bounded* inconsistency (spoke-local records may be up to one sync window stale) and buys, in exchange, capture that never stops at the till and a single governed core that a four-person SQL team can actually run. The decisive evidence is in the repo itself: the repaired pipeline treats an offline walk-in as a first-class state (`customer_sk = 0`) rather than a failure, and treats a central-batch abort (RC-1: 0 of 21,562 rows staged) as the defect class to eliminate. If store connectivity later stabilises above ~99% for six months, the correct move is *not* to switch patterns — it is to tighten the sync window (hourly micro-batch) inside the same topology, which is precisely the escalation path documented in Task B4(v).

Appendix I — ER Model & Normalization (1NF → 2NF → 3NF)

Task B1 — Architecture & Data Modeling (C3)

Client: Savanna Retail Group (SRG) — Kampala, Uganda **Deliverable:** Part B(ii) — Conceptual & logical ER model for the consolidated operational core (Customer, Product, Store, Order, OrderLine, Payment, Supplier, LoyaltyAccount) **Notation:** Crow’s Foot (conceptual narrative → logical erDiagram) **Design horizon:** feeds module5_warehouse/star_schema_ddl.sql (fact_sales + dim_customer/dim_product SCD2); identity layer governed by Task B3 MDM golden records

Task B1(ii) — Conceptual ER Model (C3)

1. Conceptual entity–relationship narrative

Entity	Key business attributes	Relationships (words, cardinality, optionality)
Customer	customer_id (PK, global), full_name, phone_e164 (UK), email, district, gender, registration_date, consent_marketing, golden-record status	A Customer places Order(s): 1:M , optional on the customer side — an Order may be a walk-in with no customer (0..1), so Customer → Order is <i>optional</i> . A Customer holds at most one LoyaltyAccount: 1:0..1 . A Customer is served by the CRM/loyalty systems (1:M contact/consent records). A Customer may belong to a Household (soft, non-identifying, 1:M — see §3-A1).
Product	product_id (PK), sku (UK), product_name, category, subcategory, unit_of_measure, cost_ugx, selling_price_ugx, supplier_id (FK)	A Product is supplied by exactly one Supplier in the operational model: M:1 , mandatory (each line must resolve a source). A Product appears in OrderLine(s): 1:M , optional (new SKU may have no sales yet). A Product is versioned by warehouse dim_product SCD2 rows (1:M versions).

Entity	Key business attributes	Relationships (words, cardinality, optionality)
Store	store_id (PK: ST01...ST23, ECOM01), store_name, store_type (PHYSICAL/ECOMMERCE), city, district, region, has_pos_offline_mode	A Store records Order(s): 1:M , mandatory per order (every order belongs to exactly one selling location, including ECOM01). A Store is reconciled by MoMo settlement files (1:M).
Order	order_id (PK, e.g. TXN...), store_id (FK), customer_id (FK, nullable), order_ts, channel, order_status, total_amount_ugx	An Order contains OrderLine(s): 1:M , mandatory (an order with zero lines has no economic substance — rejected by validation). An Order is settled by Payment(s): 1:M (split tender: MoMo + cash), optional at capture time (offline orders may have 0 payments until reconciliation). An Order is placed by at most one Customer (0..1).
OrderLine	order_id + line_no (composite PK), product_id (FK), quantity (negative = return), unit_price_ugx, discount_ugx, line_net_ugx	An OrderLine references exactly one Product: M:1 , mandatory. An OrderLine belongs to exactly one Order: M:1 , mandatory (identifying).
Payment	payment_id (PK), order_id (FK), payment_method (MTN MoMo / Airtel Money / Card / Cash), payment_ref (UK when present), amount_ugx, paid_ts, reconciliation_status (MATCHED/PENDING/MISSING/NOT_REQUIRED)	A Payment settles exactly one Order: M:1 , mandatory. Payments reconcile against provider settlement feeds (M:1 match, optional until MoMo CSV arrives).
Supplier	supplier_id (PK), supplier_name, supplier_phone, supplier_email, district, lead_time_days, source_file_ref (one of 14 Excel masters)	A Supplier supplies Product(s): 1:M , optional (a newly onboarded supplier may have no SKUs). A Supplier is merged from 14 Excel files into one golden supplier record (M:1 survivorship, Task B3 pattern reused).
LoyaltyAccount	loyalty_id (PK), customer_id (FK, UK), membership_no, tier (Gold/Silver/Bronze/None), points_balance, enrolled_ts, app_device_id	A LoyaltyAccount belongs to at most one golden Customer: M:1 , mandatory <i>from the account side</i> (no account without an owner) — Customer side optional (walk-ins hold none). Points are attributed only to the golden record (fixes “points issued to wrong members”).

2. Logical ER model (Crow’s Foot) Reading the diagram: every order resolves to exactly one selling location (Store ||--o{ Order) but only zero-or-one customer (Customer |o--o{ Order) so a walk-in sale never violates the model; an order always has ≥1 line (Order ||--|{ OrderLine); lines are the only place prices are frozen (OrderLine }o--|| Product with SCD2 dim_product supplying the contemporaneous price); mobile-money split tenders are represented as multiple Payment rows per Order rather than nullable columns.

3. Assumptions embedded in this model

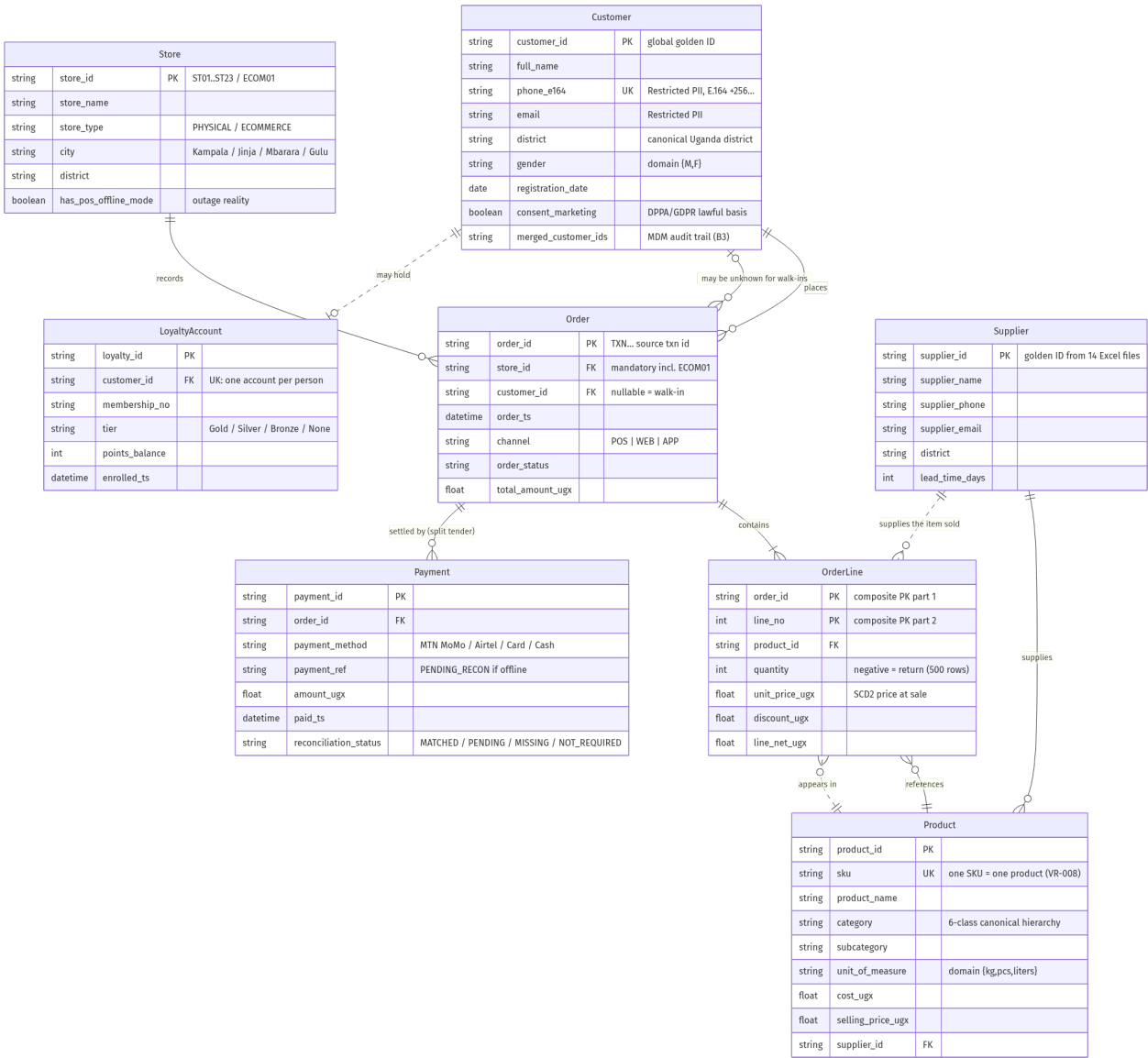


Figure 13: The B1 er model diagram (1).

#	Assumption made by the model	Where it is encoded	Real SRG situation where it breaks
A1	A household is a defensible grouping of customers (shared address + surname)	Optional Household grouping off Customer (soft, non-identifying)	In Jinja, three unrelated students rent rooms in the same house and share the landlord's surname on deliveries; a shared phone line is common in households where one handset serves 4–5 family members — household inference would wrongly group them and leak one member's purchase history to another at the till
A2	One customer = one phone number (unique phone_e164)	Customer.phone_e164 UK + MDM deterministic key	A family in Mbarara calls from whichever handset answers; the same +2567... appears for father, daughter and the shop's business account — uniqueness would force merges of distinct people (exactly the 365 homonym pairs the email-conflict rule protects)
A3	One product = one supplier	Product.supplier_id FK, M:1 mandatory	During the 2024 sugar shortage, the same SKU “Kakira Sugar 1kg” was dual-sourced (Kakira + an importer) with different costs; a single mandatory supplier FK would either falsify cost/margin history or block item setup
A4	One order = one payment (in the reader's intuition)	Broken deliberately: Order -- o{ Payment is 1:M	Split tender is the norm, not the exception: a customer pays UGX 40,000 of a UGX 62,000 basket by Airtel Money and the rest in cash — and offline, payment rows arrive <i>after</i> the order in a later sync window (0 payments at capture)
A5	A store = a physical location	Store.store_id with store_type	ECOM01 has no city, no doors, no stock of its own, and it fulfils from other stores' back-rooms — yet the Board reports “sales by store”, so it must still exist as a Store row with store_type = ECOMMERCE

#	Assumption made by the model	Where it is encoded	Real SRG situation where it breaks
A6	Order lines are one per product per order (grain = line, not product)	Composite PK order_id + line_no	Promotional bundles (“buy 2 sugar + 1 soap at UGX 15,000”) and loyalty-free-gift lines have no standalone unit_price_ugx; naive line grain either invents prices or loses the bundle
A7	Identity is stable across systems (customer_id is global)	Customer.customer_id PK	SRG has no global ID today — POS CUST1..., e-commerce checkout emails, loyalty membership_no, CRM contact IDs; without Task B3 golden records + golden_map remapping, one human appears 3–4 times and loyalty points land on the wrong member

4. Model-to-warehouse alignment

ER entity	Warehouse object	Notes
OrderLine	fact_sales (grain: one row per sales line; sale_sk = SHA1(transaction_id))	Additive UGX measures, returns as negative quantity (500 rows)
Customer	dim_customer SCD2 (customer_sk, is_current, valid_from/valid_to)	Survivorship applied upstream by MDM; customer_sk = 0 = Unknown/Walk-in
Product	dim_product SCD2	Price snapshot at time of sale preserved
Store	dim_store (Type 1 + relocation note)	store_bk = ST01...ST23 / ECOM01
Payment	dim_payment_method + fact_sales.payment_ref / reconciliation_status	MoMo refs may be PENDING
Supplier	dim_product.supplier_bk + supplier master (B3 crosswalk)	Supplier detail is a conformed reference, not a fact dimension in v1
LoyaltyAccount	dim_customer.loyalty_tier (+ loyalty points in loyalty platform)	Points remain in the loyalty system of record; warehouse carries the tier snapshot

Think-deeper answer Three embedded assumptions and where each breaks at SRG (the full table of seven is §3; these are the three with the sharpest failure modes):

1. **“One customer = one phone number.”** Encoded as phone_e164 UK and reused as the MDM deterministic matching key. *Breaks in Jinja:* shared family handsets — one +2567... number legitimately belongs to several people. Left unchecked, phone-uniqueness would collapse them into one golden record, mis-allocating loyalty value between family members. The implemented rule already defends against this: phone equality alone only ever *raises a score*; auto-merge still requires the full threshold (score ≥ 90 **and** a positive identifier), email conflict is a hard reject, and 365 homonym pairs were rejected rather than merged.
2. **“One product = one supplier.”** Encoded as a mandatory M:1 FK. *Breaks during shortages:* dual-sourced sugar and flour mean the same SKU arrives with two supplier IDs and two costs within one week. The model must either version the assignment (SCD2 supplier on the product, price snapshot in cost_ugx per version) or allow a sourcing table; asserting a single supplier falsifies margin analysis that the Pricing Analyst uses for VR-011.

3. **“A customer may belong to a household.”** Encoded as a soft, non-identifying grouping — deliberately *not* an identity relationship. *Breaks with student tenants and shared addresses in Jinja/Mbarara*: same house, same surname as registered by the landlord, unrelated occupants. This is precisely why Task B3 specifies household as a **low-confidence soft grouping that never merges identities**: merging would link one person’s purchase history to another’s, corrupting consent records (DPPA s.7 / GDPR Art.7) — a privacy breach, not just a data-quality defect.

The deeper pattern: every assumption above is safe *only because* it is modelled as optional, versioned, or soft. The failures all occur when an assumption is silently promoted to a constraint (UNIQUE, mandatory FK, or identity merge). That is the general rule for SRG’s ER design — model the exception you have already observed, not the textbook case you expect.

Task B1 — Architecture & Data Modeling (C3)

Client: Savanna Retail Group (SRG) — Kampala, Uganda **Deliverable:** Part B(iii) — Normalization 1NF → 2NF → 3NF of the sales extract; Part B(iv) — justified denormalization with performance-vs-integrity trade-off memo **Source artefact:** SRG_sales_extract_unnormalized (composite extract standing in for the 23 POS + e-commerce + app exports feeding module3_etl)

Task B1(iii) — Normalization (C3)

1. The unnormalized extract (as received) SRG_sales_extract_unnormalized — four representative rows out of the batch. Note the four defect classes called out in the brief: a **repeating multi-value group** (items/unit_prices cells), **partial dependencies** (customer/store attributes repeated on every line), **transitive dependencies** (district → region; product → supplier), and **mixed-formatted fields**.

tx_id	tx_date	store_id	store_name	store_city	customer_name	customer_id	customer_phone	customer_district	customer_region	items (multi-value)	unit_prices (multi-pay-ment)	payment_method	supplier_name	supplier_phone	order_to_line
TXN900007080247	2024-03-10 10:42	ST07	Kampala	Okello J.	CUST00008077	8008077	Kampala 123-4567	Central	COC1000X;KAK1000X	MTN AM28904361	MoMo	Sugar Industries Ltd	41 420 111	UGX 12,500	
TXN90000408012	2024-03-07 12:12 11:05	ST17	Gulu	Aciro Betty	CUST00002256	2256723699	City 332	North-ern	EXE195300	Cash (empty)	Nile Stationers Ltd	0752 111 222	UGX 12,500		
TXN900008080247	2024-03-18 18:33	ST17	Gulu	Aciro Betty	(empty)	Walk-in	(empty)	Gulu City	North-ern	KAK1000X;SUC4410X	Air-tel 8,000 Money	(empty)	Kakira+256 Sugar Industries Ltd	41 420 111	UGX 28,500
TXN90000408007	2024-03-08 09:15	COMS1	(online) Shop	web_checkout	CUST00002256	2256723699	Kye-bambe 369 9332	Gulu City	North-ern	COC1000X;EXE195300	Air-tel 2,500 Money	AUTH8395	Bottlers Ltd	1031 5566	UGX 12,500

Violations inventory (what is wrong, precisely):

Violation	Evidence in the sample	Formal problem
Repeating group	items holds 2–3 code×qty pairs per row; unit_prices mirrors it	Not atomic — row semantics depend on parsing a delimited string

Violation	Evidence in the sample	Formal problem
Partial dependency	customer_name/customer_phone/customer_id is dependent on a proper subset of the candidate key repeat on every row and depend on tx_id alone , not on the full line key	Attributes dependent on a proper subset of the candidate key
Transitive dependency #1	customer_district → customer_region (Kampala → Central; Gulu City → Northern) — region is reached <i>through</i> district	Non-key → non-key dependency: update anomaly (renaming a region touches every sales row)
Transitive dependency #2	supplier_name/supplier_phone reached via items → product → supplier_id → supplier	Supplier phone change would require editing every historical sales line
Mixed formats	12/07/2024 vs 2024-07-12; 077-123-4567 vs 256723699332 vs +256 72 369 9332; UGX 15,000 vs 12500	Attribute domains not enforced (companion defect — resolved by the Module 2 standardizers, not by normalization alone)
Derived value stored	order_total duplicates Σ(line amounts)	Insert/update anomaly: total drifts when a line is edited (500 return rows make this live)

2. First Normal Form (1NF) Action taken:

- Made every value atomic** — split each items/unit_prices pair into one row per line, assigned line_no (1, 2, 3...); qty and unit_price_ugx become single-valued columns.
- Removed the repeating group** — one row per (transaction × product line).
- Composite primary key: PK = (tx_id, line_no)** — transaction-level attributes (tx_date, store_id, customer_id, payment_*) now depend on tx_id, a *part* of the key (see 2NF); line-level attributes (product_id, qty, unit_price_ugx) depend on the whole key.
- Format normalization (date → ISO-8601, phone → E.164, price → numeric UGX) executed in the same pass by the Module 2 standardizers — noted separately because **1NF is structural; format consistency is a data-quality (VR-001/VR-005) concern**, but both are applied before load.

1NF result (TXN90000101 exploded):

tx_id	line_no	tx_date	store_id	cus- tomer_id	cus- tomer_name	prod- uct_id	qty	unit_price_ugx	cus- tomer_district	cus- tomer_region	supplier_name
TXN900001	0101	2024-07-12T10:42	ST07	CUST1000088	Sam- pebwa Wasswa	COC10012		15000.00	Kam- pala	Central	KLE Bot- tlers Ltd
TXN900002	0101	2024-07-12T10:42	ST07	CUST1000088	Sam- pebwa Wasswa	KAK10021		12500.00	Kam- pala	Central	Kakira Sugar Indus- tries

Rationale: the row now states exactly one fact at one grain — *one product line of one transaction*. Every non-key attribute is single-valued, and (tx_id, line_no) uniquely determines all others (no ambiguity from parsing "COC1001×2; KAK1002×1"). Note also what the explosion exposes: the UNF extract carried **one** supplier cell for a two-product basket (Kakira Sugar Industries) — correct for at most one line. Resolving product_id per line (COC1001 → KLE Bottlers Ltd, KAK1002 → Kakira Sugar Industries) is the first visible step of the transitive dependency removed in 3NF. The grain is now identical to warehouse.fact_sales (one row per sales line), so 1NF is the contract between the extract and the warehouse.

3. Second Normal Form (2NF) Definition applied: 1NF + no partial dependencies (no attribute may depend on only *part* of the composite key).

What moved where, and why it violated:

Attributes moved out	New relation & key	Dependency that violated 2NF
customer_name, customer_phone, customer_district, customer_region	Customer (customer_id PK)	Functionally dependent on customer_id, which is known from tx_id alone → depends on part of the key (tx_id, line_no), not the key itself. Repetition across all lines of TXN90000101 (and every other of Robert Kyebambe's transactions) means a name correction would have to touch every historical row
store_name, store_city, cashier_name	Store (store_id PK; cashier held as store_id + shift attribute)	Dependent on store_id key. ST17's city appearing on 10,000+ sales rows is pure redundancy; a store rename (or the ECOM01 → "SavannaShop" rebrand) becomes a mass update
payment_method, payment_ref	Payment (tx_id PK, 1:M resolved to payment line keys)	Transaction-level, not line-level; duplicated across lines of the same basket — and with split tender (MoMo + cash) the single column cannot even represent the truth

Remains after 2NF: tx_id, line_no, tx_date, store_id, cashier?, customer_id, product_id, qty, unit_price_ugx, payment... — all now dependent on the *whole* key or on non-key attributes (addressed in 3NF).

Rationale: 2NF here is not academic tidiness — it is what stops SRG's observed "same customer, differently spelled on line 2" drift, because a customer attribute now exists in exactly one place, keyed by customer_id.

4. Third Normal Form (3NF) Definition applied: 2NF + no transitive dependencies (non-key attribute must not determine another non-key attribute).

What moved where, and why it violated:

Dependency removed	Move	Violation explained
customer_district → customer_region	District reference table District (district PK, region, canonical name per official Uganda district list) — Customer keeps only customer_district FK	Region was <i>reached through</i> district. If Gulu were re-assigned in a boundary review, SRG would have to rewrite every sales and customer row carrying "Northern" (127 raw district labels before cleansing proves how volatile this domain is)
product_id → supplier_name, supplier_phone	Supplier (supplier_id PK) reached via Product.supplier_id FK	Transitive through the line: line → product → supplier. A supplier's phone changing (or, in the shortage scenario, one SKU dual-sourced) must not require editing historical fact rows
product_id → product_name, category, unit_of_measure	Product (product_id PK, sku UK, canonical 6-class category)	Same class: product name corrections ("Kakvra Sugar" typo in the raw file) belong on the product master, not on 10,000 sales lines
order_total (stored derived)	Dropped — computed as Σ line_net_ugx at query time	Storing a derived measure is an update anomaly waiting to fire on the 500 return rows

Explicit price-snapshot decision (not a violation): *unit_price_ugx stays on the line.* Its determinant is not *product_id* alone but (*product, transaction, time*) — the price *at time of sale*. Deleting it would break margin analysis (the warehouse stores *unit_price_ugx, cost_of_goods_ugx* per line against the SCD2 product version valid at *event_ts*; *dim_product* versions price changes via *valid_from/valid_to*). A copied-at-write fact value is a snapshot, not a transitive dependency; its integrity is protected by immutability (facts are never UPDATED; corrections are new versions/returns).

3NF result set: Customer(*customer_id* PK), Store(*store_id* PK), District(*district* PK), Product(*product_id* PK), Supplier(*supplier_id* PK), Payment(*payment_id* PK, *tx_id* FK), SalesLine(*tx_id, line_no* PK, *store_id* FK, *customer_id* FK, *product_id* FK, *qty, unit_price_ugx*).

Rationale: every non-key column now depends on *the key, the whole key, and nothing but the key*. Update anomalies are confined to masters (Customer/Product/Supplier/District), which is exactly where SRG's stewardship and validation rules VR-001...VR-012 operate.

5. Normalization summary (audit trail)

Step	Normal form	Operation	Violation class removed	SRG defect it prevents
0	UNF	—	multi-value cells, mixed formats	"COC1001×2; KAK1002×1" parsing errors; UGX 50,000 vs 50000 COPY aborts (RC-1)
1	1NF	Atomic rows, PK=(<i>tx_id, line_no</i>)	Repeating groups	Line-level sales can't be counted/aggregated reliably
2	2NF	Customer / Store / Payment extracted	Partial dependencies	Customer field drift across a customer's own transactions; store rename mass-update
3	3NF	District, Product, Supplier extracted; derived total dropped	Transitive dependencies	Region re-mapping storms; supplier phone change rewriting history; total-vs-lines drift on returns

Task B1(iv) — Justified Denormalization for Reporting (C3)

6. The proposal Add two conformed labels to the reporting layer — *category_label* (6-class merchandise hierarchy) and *store_city* — as a nightly-rebuilt denormalized reporting view over the star schema (optionally materialized into *fact_sales_reporting* for the BI tools):

```
-- Reporting projection: labels are DECORATIONS on facts, never the source of truth
CREATE OR REPLACE VIEW bi.v_fact_sales_denorm AS
SELECT f.sale_sk, f.transaction_id, f.event_ts, f.date_sk,
       f.quantity, f.net_amount_ugx, f.cost_of_goods_ugx, f.is_return,
       f.reconciliation_status,
       p.category AS category_label,      -- from dim_product version valid AT f.event_ts
       p.subcategory,
       s.city AS store_city,              -- from dim_store (Type 1)
       s.store_bk, s.store_type,
       c.district AS customer_district    -- masked per RBAC before BI sees PII
```

```

FROM warehouse.fact_sales f
JOIN warehouse.dim_product p ON p.product_sk = f.product_sk
JOIN warehouse.dim_store s ON s.store_sk = f.store_sk
JOIN warehouse.dim_customer c ON c.customer_sk = f.customer_sk;

```

(Grain is unchanged — one row per sales line. Only *labels* are carried, reached through the SCD2 versions already stamped on the fact.)

7. Trade-off memo: performance vs. integrity

	Position
To	Board Reporting; Store Operations; Finance (month-end)
From	Lead Enterprise Data Management Consultant
Subject	Denormalizing category/city onto fact rows — performance vs. integrity

Benefits (why we do it):

#	Benefit	Quantified/observed
B1	Single-scan dashboards for a 4-person team	A “sales by category × city” card becomes one table scan; no 3-way join gymnastics to maintain when one of the two SQL-capable staff is on leave
B2	Fewer joins on large facts	Facts grow ~10k lines/6 months today and into the 10s of millions across 23 stores + e-comm once Odoo/POS history is backfilled; star joins to 3 large SCD2 dims (customer 3,858 → 180k members) dominate BI latency
B3	BI-tool simplicity / tool-agnostic performance	Power BI/Tableau extracts and live connections both prefer flat wide tables; label columns let a business user build a matrix without understanding surrogate keys or <code>is_current</code>
B4	Downstream stability	Dashboards bind to stable column names (<code>category_label</code>), so a dim refactor doesn’t break 14 published report pages

Costs (what we pay):

#	Cost	Reality at SRG
C1	Stale labels if populated from a non-SCD2 source (e.g., POS current category, not the version valid at sale)	History would silently rewrite: Q3 Beverages sales would appear under the new category after an item re-categorisation
C2	Storage growth	~15–25% wider fact rows; acceptable at 10k–100M rows, but materializing <i>all</i> label columns would eventually dwarf measures

#	Cost	Reality at SRG
C3	Update anomaly risk returns	If anyone UPDATES category_label in place, source-of-truth ambiguity follows — the exact anomaly class 3NF removed
C4	Masking/RBAC interplay	customer_district on a wide table must pass through the masking views (module4_security/data_masking.sql) or it becomes a PII leak path into BI

Mitigations (how integrity is retained):

Cost	Mitigation
C1	Labels are always derived from the SCD2 dim version valid at f.event_ts (join on product_sk stamped at load — never re-joined to is_current), so re-categorisation cannot rewrite history
C3	The view (or nightly-materialized table) is rebuildable by one idempotent job — it is a <i>projection</i> , never edited in place; source of truth stays 3NF/star_schema_ddl.sql
C2	Materialize only if the nightly rebuild cost exceeds the query cost; default = view over indexed dims (facts already carry product_sk/store_sk indexes)
C4	BI connects through the masking views; customer_district is coarse-grained (district, not address) and column grants apply as in the RBAC matrix

Decision: *Approved* as a nightly-rebuildable reporting view — **performance is bought with a decoration, not with a copy of the truth.** Revisit if fact volume forces materialization; the mitigations make that a cost decision, not a correctness decision.

Think-deeper answer Normalization did not fail to prevent SRG’s 23% duplicates — normalization was never the layer where they were created. Every violation above is *inside* one table or *between* a table and its masters; SRG’s duplicates arise *between* systems (POS record + e-commerce checkout + loyalty signup + CRM import each create their own customer_id), which no 1NF–3NF pass can see, because 3NF constrains structure within a single schema, not identity across schemas. That is precisely why the fix sequence is 3NF → (B2) cleansing → (B3) MDM golden records → (B4) warehouse: the model gives each system a clean shape, the golden record gives the enterprise one person, and only integration makes the two agree. The second lesson is about the price snapshot: keeping unit_price_ugx on the line while everything else moved to masters shows that the correct question is never “is it normalized?” but “what is the grain of the fact, and what is the grain of the master?” — a price is neither a duplicate of the product master nor safe inside it: it is a property of the *event*, frozen at write time, exactly as dim_product’s valid_from/valid_to freezes it for history.

Appendix J — Data Quality Evidence — Profiling, Before/After Metrics, Validation Rules, Monitoring & Root Cause

Task B2.4 — Root-Cause Analysis: The 8.4% Book-vs-Physical Stock Variance

Client: Savanna Retail Group (SRG) — Kampala, Uganda **Competency:** C4 (Data Quality) — hands-on **Evidence base:** module2_data_quality/output/stock_variance_fishbone.svg (generated by make_fishbone.py), module2_data_quality/output/before_after_metrics.md, validation_rules.md (VR-001...VR-012), dq_monitoring_spec.md (DQC-01...DQC-10), module3_etl/etl_diagnosis.md (RC-1...RC-6), docs/C2_threat_model_risk_(R6)

1. The problem, stated as a measurable defect Book stock (what Odoo/the POS believes) minus physical stock (what a count finds) across all stores averages **8.4% variance** — reported in the scenario as “*nobody knows why*”. Two properties drive the analysis:

- 1. The variance is **systemic** — it appears at every store, not one, which rules out a single-site explanation (theft at one branch, one bad manager).
- 2. It is **unattributed** — no store keeps an adjustment log, so the gap cannot currently be split between *process loss*, *measurement error*, and *capture error*. That split is exactly what this analysis sets up.

2. Fishbone (Ishikawa) diagram Six cause categories are examined — People, Method, Measurement, Systems, Data, Environment — and every leaf cause is classified by fix type:

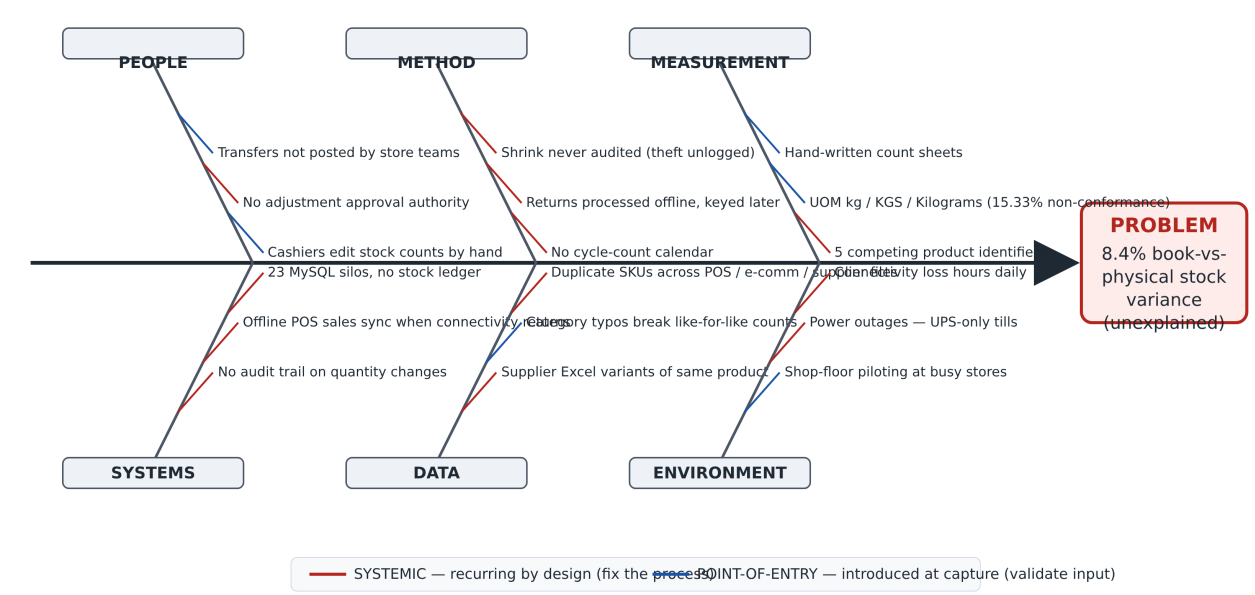


Figure 14: Figure B2.1 — Ishikawa (fishbone) analysis of the 8.4% stock variance. Red = systemic cause (fix the process); blue = point-of-entry cause (validate at capture). Source: module2_data_quality/output/stock_variance_fishbone.svg, generated by make_fishbone.py.

The diagram distinguishes the two classes the brief demands: **systemic causes** (red — design defects that will keep producing variance no matter how careful individuals are) versus **point-of-entry causes** (blue — defects introduced at the moment of capture and stoppable by validation).

3. Cause classification

#	Cause (from diagram)	Class	Why it produces variance	Fix that stops it
1	Cashiers edit stock counts by hand at the till	Point-of-entry	A count “corrected” to match expectation silently changes book stock	POS stock-adjust permission removed from cashier role; adjustment approval workflow (RBAC, data_masking.sql principle extended to Odoo)
2	No adjustment approval authority	Systemic	Anyone may post a correction, so errors and cover-ups are indistinguishable	Adjustment workflow: staff propose → store manager approves → log retained

#	Cause (from diagram)	Class	Why it produces variance	Fix that stops it
3	Inter-store transfers not posted by store teams	Point-of-entry	Goods physically move; neither side's book stock follows → both stores diverge in opposite directions	Transfer document with mandatory scan-out/scan-in; DQC variance check per transfer
4	No cycle-count calendar	Systemic	Detection happens only at the annual/periodic count — too late to attribute cause	ABC cycle counts (A monthly, B quarterly, C annually); variance dashboard per store from month 4 (D1 quick win)
5	Returns processed offline, keyed later	Systemic	The 500 return lines (–UGX 10,224,221) re-enter days late; book stock disagrees with shelf in the interim	Returns posted at point of return via the same ETL contract; quarantine if late (RC-1/RC-4 fix)
6	Shrink never audited (theft unlogged)	Systemic	Shrinkage has no book entry at all — it accumulates as variance by definition	Shrink allowance surfaced as drift in the real-time consumer (B4_realtime_architecture.md) + monthly shrink report to Store Operations Manager
7	Five competing product identifiers	Systemic	The same SKU counts under different IDs at different stores — books compare non-comparable quantities	Crosswalk to golden SKU (B3 MDM); VR-001...VR-007 at capture; DQC-06 SKU uniqueness
8	UOM kg / KGS / Kilograms typed freely (15.33% non-conformance pre-cleanse)	Point-of-entry	A 2 kg bag entered as “2” while another store enters “2,000 g” — unit errors scale into valuation errors	UOM standardisation list in entry forms (VR-004); conformance DQC-04 (100% after cleanse)
9	Hand-written count sheets	Point-of-entry	Transcription errors enter book stock a second time	Tablet count forms with validation; count variance sign-off
10	23 MySQL silos, no unified stock ledger	Systemic	No single quantity exists to compare against — “book stock” is 23 private opinions	Warehouse fact_sales + Odoo feed (M8) as the single stock ledger
11	Offline POS sales sync when connectivity returns	Systemic	Hours of sales invisible to book stock → phantom stock → stock-outs and overstock both explained	Store-and-forward with sequence numbers; lag surfaced, not hidden (PENDING_RECON pattern applied to stock)

#	Cause (from diagram)	Class	Why it produces variance	Fix that stops it
12	No audit trail on quantity changes	Systemic	Nobody can split the 8.4% into causes <i>today</i> — the measurement itself is missing	Quantity-change audit table (who/when/old/new/reason) — prerequisite for attribution
13	Duplicate SKUs across POS / e-commerce / supplier files	Systemic	Physical goods counted once, books recorded under 2+ identities	Dedupe + golden product (B2 cleanse: composite validity 3.25% → 100%)
14	Category typos break like-for-like counts	Point-of-entry	Category-level roll-ups double-count one class and miss another	Standardised category list (VR-005); 22% → 100% conformance
15	Supplier Excel variants of the same product	Systemic	Goods-in books a description the stores do not use	Supplier file contract → golden SKU mapping at ingestion
16	Connectivity loss hours daily (store reality)	Systemic	Everything queued syncs in a burst; partial states are visible to customers but not to books	Sequence-numbered replay + lag KPI (see #11)
17	Power outages — UPS-only tills	Systemic	A till that dies mid-transaction loses the stock movement entirely	Transaction journal persisted locally, replayed on restart (ETL idempotency pattern RC-4)
18	Shop-floor piloting at busy stores	Point-of-entry	Stock lifted without a sale recorded — honest shoppers, broken books	CCTV-linked cycle counts at high-shrink stores; adjustment approval (#2)

Class split: 11 systemic, 7 point-of-entry. That ratio is the finding: cleansing at entry (blue) would recover at most ~39% of the identified causes; the remaining 61% are produced by *process design* and will regenerate the variance no matter how carefully staff type. This is why a one-off stock-take cannot fix 8.4%.

4. Five-Whys (two branches, showing where they converge) **Branch A — a counted unit is simply missing (shrink/wastage path):**

1. *Why is stock missing?* It left the store without a book entry.
2. *Why without a book entry?* No adjustment/shrink transaction type is used at store level.
3. *Why not?* No one is accountable — adjustments have no approval authority.
4. *Why no authority?* The operating model never assigned stock ownership below HQ.
5. *Why?* Inventory was managed as a finance number, not an operational one → **root: no named stock owner in the governance model (fixed by A2 ownership roles + D1 KPI ownership).**

Branch B — a counted unit is present but mis-booked (measurement path):

1. *Why does book ≠ shelf?* The booked quantity is under a different ID/UOM than the counted one.
2. *Why?* Five product IDs and free-text UOM were never reconciled.
3. *Why not?* Each system validated its own entries only — no enterprise keys.
4. *Why?* No master data and no entry validation existed (23% duplicate customers are the same disease in customer space).
5. *Why?* Data was a by-product, not a managed asset → **root: no MDM, no validation at capture (fixed by B3 golden record + VR-001...VR-012).**

Both branches converge on the same conclusion as Task A1: the variance is a **governance** symptom, not a counting problem.

5. Systemic vs point-of-entry: what gets done first

	Point-of-entry causes (7)	Systemic causes (11)
Stop-the-bleeding (M1–M6)	Entry validation lists (UOM, category, SKU), removal of cashier stock-edit rights, mandatory transfer posting	Adjustment approval workflow, quantity-change audit table, quarantine + replay for offline syncs
Structural fix (M4–M12)	Tablet count forms	Single stock ledger (Odoo feed M8), golden SKU crosswalk, sequence-numbered store-and-forward
Detection	VR checks at capture block the defect	DQC-06/DQC-07 daily variance thresholds alert the on-call rotation
Target	Validity/conformance 100% at entry	Book-vs-physical variance $\leq 2.0\%$ by M12 (D1 KPI), $\leq 1.5\%$ at 18 months

6. Process changes (not data fixes) — the brief's explicit demand

1. **Ownership, not correction.** Stock ownership moves into the A2 operating structure: Merchandising Owner + Store Operations Manager hold the variance KPI; adjustments require an approver (name in POL-001 enforcement column).
2. **Count as routine.** ABC cycle counts replace the annual scramble; counts are posted the same day (no sheet transcription).
3. **Every movement is a transaction.** Transfers, returns, shrink, adjustments all become typed events consumed by the repaired ETL — the same idempotent, quarantined contract that fixed RC-1...RC-6 for sales.
4. **Variance becomes visible per store.** The real-time stock consumer surfaces *drift* (book vs projected) within 30–60 s of a sync, so a store manager sees divergence before the count does.
5. **Attribution before punishment.** The audit table exists first so shrink can be *measured*; until 8.4% is decomposed into the five buckets, no store is judged on the number — this is also the change-management safeguard against under-reporting.

7. Think-deeper answer The defect classes look like typing problems, but the causal chain runs through process and incentive design. The blue (point-of-entry) causes stop at the form: a validation list, a blocked field, a permission removed. The red (systemic) causes regenerate themselves — an unowned process produces variance *by design*, then a “clean-up exercise” repairs the number, and six months later the same stores report the same gap, because nothing about the creation, approval, or audit of stock movements changed. That is the identical pattern A1 documents for customers (23% duplicates returning after every cleanse): **cleansing without enforcement is a recurring cost, not an improvement.** The process changes that end it are unglamorous — named owners, an approval step, an audit table, a count calendar — and they are precisely the cheap, technical controls the four-person IT team can run, because they live in the flow of work rather than in a policy binder.

Related evidence: docs/B2... portfolio section; full metrics in module2_data_quality/output/before_after_metrics.md; monitoring in dq_monitoring_spec.md (DQC-01...DQC-10); remediation sequencing in docs/D1_roadmap_18months.md (stock workstream, M4–M12).

SRG Data Quality Profile - BEFORE Cleansing

SRG_Customers - BEFORE cleansing

Dimension	Metric	Value
Uniqueness	Confirmed duplicate rows - auto-matched by rules (%)	22.84
Uniqueness	Open stewardship review rows - suspected duplicates (count)	111
Uniqueness	Total duplicate-person flag rate (confirmed + open review, %)	25.06
Uniqueness	Exact duplicate rows (all fields except ID, %)	14.88

Dimension	Metric	Value
Uniqueness	Unique customer_id (%)	100.0
Completeness	Present values: full_name (%)	100.0
Completeness	Present values: phone_number (%)	90.28
Completeness	Present values: email (%)	93.6
Completeness	Present values: district (%)	99.76
Completeness	Present values: registration_date (%)	94.7
Completeness	Present values: gender (%)	84.56
Completeness	Cell-level completeness across 6 fields (%)	93.82
Consistency	Distinct phone format variants (count)	6
Consistency	Records in dominant phone format (%)	25.7
Consistency	Distinct date format variants (count)	3
Consistency	Records in ISO-8601 date format (%)	54.4
Consistency	Distinct raw district labels (count)	127
Consistency	Distinct gender label variants (count)	4
Timeliness	Registration date parseable (%)	94.7
Timeliness	Dates not in the future (%)	94.7
Timeliness	Records registered <= 4 years ago (%)	59.62
Accuracy	District stored as official name (no repair needed, %)	89.8
Accuracy	Phone is plausible Ugandan MSISDN (%)	90.28
Accuracy	Gender stored in canonical domain {M,F} (%)	32.88
Validity	Phone already in E.164 (+2567XXXXXXXX) (%)	22.76
Validity	Email RFC-5322 lite conforming (or null) (%)	92.94
Validity	Registration date conforming (%)	94.7
Validity	Gender value conforming (%)	84.56
Validity	Composite record validity - all 4 rules pass (%)	17.3

SRG_Products - BEFORE cleansing

Dimension	Metric	Value
Uniqueness	Rows sharing a duplicate SKU (count)	141
Uniqueness	product_id unique and non-null (%)	97.0
Uniqueness	Exact duplicate rows (all fields except ID, %)	3.0
Completeness	Present values: sku (%)	97.0
Completeness	Present values: product_name (%)	97.0
Completeness	Present values: category (%)	98.17
Completeness	Present values: unit_of_measure (%)	97.0
Completeness	Present values: cost_ugx (%)	97.0
Completeness	Present values: selling_price_ugx (%)	97.0
Completeness	Cell-level completeness across 6 fields (%)	97.19

Dimension	Metric	Value
Consistency	Distinct unit-of-measure labels (count)	18
Consistency	Distinct category labels (count)	30
Consistency	Price stored as free-text currency string (%)	3.83
Consistency	SKUs mapped to >1 product name (count)	69
Timeliness	Refreshable via key: product_id AND SKU present (%) [proxy - source has no last_updated column]	97.0
Accuracy	Selling price below cost - margin anomaly (%)	5.17
Accuracy	Prices parseable to numeric (%)	97.0
Accuracy	Cost and price non-negative (%)	97.0
Validity	Unit of measure in {kg, pcs, liters} (%)	15.33
Validity	Category in master list (%)	22.0
Validity	SKU matches ¹ {3,10}\$ (%)	97.0
Validity	Composite product validity - all rules pass (%)	3.25

Think-deeper answer (Task B2): why did each phone pattern form, and what did the cleaning decision reveal about data ownership? (The task’s “18% of phones are malformed” is illustrative; SRG’s measured equivalent is worse — **77.24% of present phone numbers are not E.164-conforming, only 25.7% share one dominant format, 6 format variants coexist, and 9.72% are absent entirely.** Each pattern has a different upstream cause, and therefore a different owner.)

1. Absent phones (9.72%) — a capture design that rewarded speed, not identity. The POS signup screen makes the phone field optional because store queues must move: during the hours-daily connectivity drops, staff skip optional fields to keep selling. That is not carelessness, it is an incentive working exactly as designed — and no KPI anywhere said “records with a reachable phone.” Completeness was nobody’s job, so completeness decayed.

2. Six format variants, 22.76% in E.164 — three channels, three private conventions, zero standards. The loyalty app emits locally formatted numbers through a masked input; the CRM accepts free text, so agents typed +256 772 369 9332, 07723699332 and 0772 3699332 side by side; supplier and Excel imports pasted whatever the source held. A format is a standard, and a standard is an owned artifact — SRG had no phone standard (no input mask, no entry validation, no reference rule), so each system expressed “correct” differently and the ambiguity surfaced only when records met during dedupe. The cleaning decision — normalize to E.164 both at capture and over the back-catalog — looked like a regex, but it forced the governance question nobody had answered: *who owns the canonical form?* Resolution: the customer-domain steward (CRM/Marketing Officer) owns the standard, enforced technically as VR-001 at form and ETL boundaries; IT owns the plumbing, business owns the meaning. That split is what docs/A2_governance_charter.md later formalises.

3. The same phone on many customer_ids (feeding the 22.84% duplicate rate) — offline capture with no identity reconciliation. Outage-period sales create local records on the store box; when connectivity returns the customer also registers through the app or e-commerce, and a second identity is born. No golden-key reconciliation existed across channels, stores were measured on queue time, and the loyalty team — not the stores — discovered points landing on the wrong member. The discoverer was not the owner, and identity resolution was left to no one.

4. What the cleaning itself revealed. Technically the phone fix was the easiest in the module — a variant map and a normaliser. The hard part was that no department would claim the field as theirs until the numbers forced the conversation (“who is accountable for 9,000 unreachable customers?”). And even a phone-led match had limits: 365 homonym pairs were rejected because phones are shared across family members, which is why a stewardship queue (110 pairs) exists at

¹A-Z0-9

all — ownership is sometimes a *judgement call per record*, not a rule per column. The durable lesson: cleansing without a named owner and capture-time enforcement is a mood, not a state; the defects re-enter at the first busy queue on the first day after go-live. Hence binding entry rules (POL-002), stewardship assignments, and DQC-01 as the alarm that would catch the regression.

SRG Before vs After Quality Metrics

Before vs After Quality Metrics (exact %, computed by the same functions on both states)

Dataset	Dimension	Metric	Before (%)	After (%)	Delta (pp)	Status
Customers	Uniqueness	Confirmed duplicate rows - auto-matched by rules (%)	22.84	0.0	-22.84	Improved
Customers	Uniqueness	Open stewardship review rows - suspected duplicates (count)	111	110	-1	Improved
Customers	Uniqueness	Total duplicate-person flag rate (confirmed + open review, %)	25.06	2.85	-22.21	Improved
Customers	Uniqueness	Exact duplicate rows (all fields except ID, %)	14.88	0.29	-14.59	Improved
Customers	Uniqueness	Unique customer_id (%)	100.0	100.0	0.0	No change
Customers	Completeness	Present values: full_name (%)	100.0	100.0	0.0	No change
Customers	Completeness	Present values: phone_number (%)	90.28	91.96	1.68	Improved
Customers	Completeness	Present values: email (%)	93.6	93.26	-0.34	Stable (dedupe denominator shift)
Customers	Completeness	Present values: district (%)	99.76	99.59	-0.17	Stable (dedupe denominator shift)
Customers	Completeness	Present values: registration_date (%)	94.7	94.53	-0.17	Stable (dedupe denominator shift)
Customers	Completeness	Present values: gender (%)	84.56	84.47	-0.09	Stable (dedupe denominator shift)

Dataset	Dimension	Metric	Before (%)	After (%)	Delta (pp)	Status
Customers	Completeness	Cell-level completeness across 6 fields (%)	93.82	93.97	0.15	Improved
Customers	Consistency	Distinct phone format variants (count)	6	1	-5	Improved
Customers	Consistency	Records in dominant phone format (%)	25.7	91.96	66.26	Improved
Customers	Consistency	Distinct date format variants (count)	3	1	-2	Improved
Customers	Consistency	Records in ISO-8601 date format (%)	54.4	94.53	40.13	Improved
Customers	Consistency	Distinct raw district labels (count)	127	42	-85	Improved
Customers	Consistency	Distinct gender label variants (count)	4	2	-2	Improved
Customers	Timeliness	Registration date parseable (%)	94.7	94.53	-0.17	Stable (dedupe denominator shift)
Customers	Timeliness	Dates not in the future (%)	94.7	94.53	-0.17	Stable (dedupe denominator shift)
Customers	Timeliness	Records registered <= 4 years ago (%)	59.62	59.62	0.0	Monitored (aging)
Customers	Accuracy	District stored as official name (no repair needed, %)	89.8	99.4	9.6	Improved
Customers	Accuracy	Phone is plausible Ugandan MSISDN (%)	90.28	91.96	1.68	Improved
Customers	Accuracy	Gender stored in canonical domain {M,F} (%)	32.88	100.0	67.12	Improved
Customers	Validity	Phone already in E.164 (+2567XXXXXXX) (%)	22.76	91.96	69.2	Improved

Dataset	Dimension	Metric	Before (%)	After (%)	Delta (pp)	Status
Customers	Validity	Email RFC-5322 lite conforming (or null) (%)	92.94	93.21	0.27	Improved
Customers	Validity	Registration date conforming (%)	94.7	94.53	-0.17	Stable (dedupe denominator shift)
Customers	Validity	Gender value conforming (%)	84.56	84.47	-0.09	Stable (dedupe denominator shift)
Customers	Validity	Composite record validity - all 4 rules pass (%)	17.3	68.51	51.21	Improved
Products	Uniqueness	Rows sharing a duplicate SKU (count)	141	141	0	Flagged (VR-008 stewardship)
Products	Uniqueness	product_id unique and non-null (%)	97.0	100.0	3.0	Improved
Products	Uniqueness	Exact duplicate rows (all fields except ID, %)	3.0	0.0	-3.0	Improved
Products	Completeness	Present values: sku (%)	97.0	100.0	3.0	Improved
Products	Completeness	Present values: product_name (%)	97.0	100.0	3.0	Improved
Products	Completeness	Present values: category (%)	98.17	100.0	1.83	Improved
Products	Completeness	Present values: unit_of_measure (%)	97.0	100.0	3.0	Improved
Products	Completeness	Present values: cost_ugx (%)	97.0	100.0	3.0	Improved
Products	Completeness	Present values: selling_price_ugx (%)	97.0	100.0	3.0	Improved
Products	Completeness	Cell-level completeness across 6 fields (%)	97.19	100.0	2.81	Improved
Products	Consistency	Distinct unit-of-measure labels (count)	18	3	-15	Improved

Dataset	Dimension	Metric	Before (%)	After (%)	Delta (pp)	Status
Products	Consistency	Distinct category labels (count)	30	6	-24	Improved
Products	Consistency	Price stored as free-text currency string (%)	3.83	0.0	-3.83	Improved
Products	Consistency	SKUs mapped to >1 product name (count)	69	69	0	Flagged (VR-008 stewardship)
Products	Timeliness	Refreshable via key: product_id AND SKU present (%) [proxy - source has no last_updated column]	97.0	100.0	3.0	Improved
Products	Accuracy	Selling price below cost - margin anomaly (%)	5.17	5.33	0.16	Flagged (manual, by design)
Products	Accuracy	Prices parseable to numeric (%)	97.0	100.0	3.0	Improved
Products	Accuracy	Cost and price non-negative (%)	97.0	100.0	3.0	Improved
Products	Validity	Unit of measure in {kg, pcs, liters} (%)	15.33	100.0	84.67	Improved
Products	Validity	Category in master list (%)	22.0	100.0	78.0	Improved
Products	Validity	SKU matches ² {3,10}\$ (%)	97.0	100.0	3.0	Improved
Products	Validity	Composite product validity - all rules pass (%)	3.25	100.0	96.75	Improved

Validation Rules Catalog (12 rules: technical + business)

Rule ID	Field	Type	Condition	Action on Failure	Failure Severity
VR-001	cus-tomers.phone_number	Technical	phone_number must match ^(+256	0)7[0-9]{8}\$ after input-mask normalization	Block save; re-render input with +256 mask; log to dq_violation_log

²A-Z0-9

Rule ID	Field	Type	Condition	Action on Failure	Failure Severity
VR-002	customers.district	Business	district must be a member of the official Uganda district reference list (dropdown only, free text disabled)	Block save; force selection from reference list; steward notified for legacy values	Medium
VR-003	customers.email	Technical	email IS NULL OR email ~ ³ +@[A-Za-z0-9.-]+.[A-Za-z]{2,}\$	Allow save but quarantine from campaign exports; nightly re-validation	Medium
VR-004	customers.customer_id	Technical	PRIMARY KEY: NOT NULL AND unique across operational + MDM stores	Reject insert; abort load batch; page on-call data engineer	Critical
VR-005	customers.registration_date	Business	registration_date <= CUR-RENT_DATE AND registration_date >= '2000-01-01' AND stored as ISO-8601	Block save (future/backdated signup); default to CUR-RENT_DATE on retry	High
VR-006	customers.full_name	Technical	TRIM(full_name) length >= 2 AND full_name ~ ⁴ + '\$'	Block save; inline prompt (no single-letter placeholder names)	Medium
VR-007	customers (golden record)	Business	NORMALIZED(phone_number) unique across golden records OR record is in stewardship review queue	Route to MDM matching queue (auto-merge >= 90 score, else steward); block loyalty point posting until resolved	Critical
VR-008	products.sku	Technical	sku NOT NULL AND unique among active products (one SKU = one product name)	Reject insert; raise SKU-collision ticket to merchandising; quarantine batch	Critical
VR-009	products.unit_of_measure	Business	unit_of_measure IN ('kg', 'pcs', 'liters') - controlled vocabulary enforced at POS/e-commerce item setup	Block save; show UOM picker; existing violations auto-mapped by cleansing script	High

³A-Za-z0-9._%+-⁴A-Za-z.-

Rule ID	Field	Type	Condition	Action on Failure	Failure Severity
VR-010	products.category	Business	category IN master merchandise hierarchy (Beverages, Grains & Cereals, Snacks, Household, Personal Care, Stationery)	Block save; enforce hierarchy picker; fuzzy-matched values need steward approval	High
VR-011	products.selling_price_ugx / cost_ugx	Business	selling_price_ugx >= cost_ugx UNLESS promo_flag = TRUE AND promo_approved_by IS NOT NULL	Warn at entry; nightly margin-anomaly report to Pricing Analyst; never auto-correct	Medium
VR-012	sales.payment_ref (Mobile Money)	Business	payment_method IN ('MTN MoMo', 'Airtel Money') implies payment_ref populated within 24h of capture OR reconciliation_status = 'PENDING'	Permit capture offline (store outages) but quarantine transaction from revenue reports until ref arrives; escalate if aged > 24h	High

Continuous Data Quality Monitoring Spec (daily automated checks)

Check ID	Metric	Alert Threshold	Escalation Role	Remediation Script
DQC-01	Customer duplicate-person rate	> 1.0% daily; > 2.0% = P1 incident	CRM Officer -> Data Governance Council (if > 2% for 3 days)	python module2_data_quality/dq_assessment_cleansing.py -stage dedupe && open MDM review queue
DQC-02	Phone E.164 validity rate	< 99.0%	CRM Officer (entry-point fix) / IT Operations Lead (integration fix)	python scripts/dq_check.py -metric phone_validity; re-run standardize_phone() backfill

Check ID	Metric	Alert Threshold	Escalation Role	Remediation Script
DQC-03	District resolution rate	< 99.5% or any new unresolved label pattern > 50 rows/day	Data Steward (Marketing Officer)	python module2_data_quality/dq_assessment_cleansing.py --stage profile; add alias to DIS-TRICT_VARIANTS after steward approval
DQC-04	Core-field completeness (phone, email, district)	phone < 92%; email < 85%; district < 99%	CRM Officer -> Store Manager (data capture at POS)	python scripts/dq_check.py --metric completeness; launch capture-form fix at offending stores
DQC-05	Product UOM / category conformance	< 99.0% (any new row entering non-conforming)	Merchandising Officer	python module2_data_quality/dq_assessment_cleansing.py --stage products; block non-conforming item setup in Odoo
DQC-06	SKU uniqueness violations	> 0 (zero tolerance, nightly)	Merchandising Officer -> IT Manager	SQL: sku_collision_report.sql; quarantine batch and re-issue SKU
DQC-07	ETL quarantine rate	> 0.5% or > 100 rows in one run	IT Operations Lead (2 on-call engineers)	python module3_etl/srg_etl_pipeline.py --inspect-quarantine; fix source, replay from quarantine
DQC-08	Mobile-money payment refs pending > 24h	> 0 daily; > 50 = P1 (revenue integrity)	Finance Reconciliation Officer -> CFO	SQL: reconcile_momo_pending.sql (match provider CSV downloads); auto-close or write off with approval
DQC-09	Future-dated / unparseable registration dates	> 0 per run	CRM Officer	python scripts/dq_check.py --metric dates; block offending registration form
DQC-10	Margin-anomaly products (selling < cost)	> 0 weekly review; > 25 rows = escalate	Pricing Analyst -> Finance Manager	SQL: margin_anomaly_report.sql; business decision - never auto-corrected by ETL

Appendix K — Customer Master Data Management Design

Task B3 — Master Data Management Design (C5)

Client: Savanna Retail Group (SRG) — Kampala, Uganda **Deliverable:** Customer MDM solution — style selection, golden-record schema with survivorship, matching rules, hierarchies + integration flows, governance process **Evidence base:** module2_data_quality/ (profiling, standardization, dedupe, dedupe_match_log.json, SRG_Customers_clean.csv), module3_etl/srg_etl_pipeline.py (golden_map_remap), module5_warehouse/star_schema_ddl (dim_customer SCD2) **Scale:** 23 POS DBs + SavannaShop + loyalty app (180,000 members) + SaaS CRM + Odoo; measured duplicate load **23%** (22.84% auto-matchable of 5,000 sampled records)

Task B3.1 — MDM Style Selection & Rejected-Alternatives Analysis (C5)

1.1 The four styles, scored against SRG's constraints

Style	Mechanism	Budget fit (UGX 480M/yr, 4 staff)	Connectivity fit (hours-daily outages)	Duplicate control (23% dupes)	Time-to-value (month 6)	Verdict
Registry	Index of match keys + pointers; each system keeps its own record; no golden master	5 (cheap index)	5 (nothing to sync centrally)	1 — no survivorship enforcement; every system keeps its own copy, so duplicates <i>regenerate</i> the moment a store clerk types a new signup	4 (fast to stand up)	Rejected
Consolidation	Periodic extract from all systems → match → survivorship → golden record; <i>source systems stay authoritative for capture</i>	4 (SQL + Python only — exactly the team's skills)	5 — built for batch/scheduled sync: spool at the store, consolidate in the nightly window	3–4 — golden record with enforced survivorship + stewardship queue; bounded by sync lag	5 — Module 2 already delivers the hard part (implemented, executed)	Recommended
Coexistence	Golden record propagated <i>back</i> bidirectionally to every source; writes flow both ways continuously	2 (needs bidirectional sync services + conflict resolution per system × 23 stores)	1 — continuous propagation assumes links that are down for hours; conflict queues explode offline	4 (strongest enforcement once running)	1 (build the sync fabric first)	Rejected now

Style	Mechanism	Budget fit (UGX 480M/yr, 4 staff)	Connectivity fit (hours-daily outages)	Duplicate control (23% dups)	Time-to-value (month 6)	Verdict
Centralized (transac- tional) MDM	The MDM hub is the write path — all systems must call it to create/update a customer	1 — commercial suites (Informatica MDM, Profisee, Stibo) licence + implementa- tion typically exceeds the entire UGX 480M envelope before any cloud/hire cost; needs skills SRG does not have	2 — a blocked POS signup at ST19 (Gulu) during an outage blocks the till	5	1	Rejected

1.2 Recommendation Adopt a CONSOLIDATION-style MDM, implemented pragmatically in-database: a central golden record with attribute-level survivorship and a stewardship queue, built in SQL + Python on the existing PostgreSQL/SQLite estate — *not* an enterprise MDM product.

Design commitments that make this a real consolidation hub rather than a registry:

1. **One physical golden table** (`customer_golden`) — not an index of pointers. Survivorship is *enforced at merge time*, so a merged-away record cannot be re-read by any consumer.
2. **Persistent survivorship rules** (§1.3) applied by the pipeline, not by each consuming system's ad-hoc logic.
3. **Stewardship queue as a first-class table** — 110 open rows are visible work items with owners and SLAs, not silently dropped candidates (VR-007: normalized phone unique across golden records *or* record in the review queue).
4. **Reversible merges** — `merged_customer_ids` audit trail on every survivor row; any merge can be un-done and re-adjudicated.

Rejected-alternatives summary (what would change each verdict):

Rejected	Reason (evidence)	Revisit when
Centralized commercial MDM	Licence + skills cost outside the envelope; write-path coupling breaks the offline till (a coordinator call per signup is impossible at ST19 during outages)	Board funds a separate licence line and a trained hire exists — note this would still fail the connectivity test
Coexistence	Requires mature bidirectional golden sync + conflict-resolution SRG does not have; with 23 offline stores, “last writer wins” would overwrite verified golden data with clerk-typed variants every day	≥12 months of stable consolidation runs + store links ≥99% for 6 months
Pure registry	No survivorship enforcement → the 23% returns; DQC-01 (duplicate-person rate > 1%) would alarm permanently; nothing prevents loyalty points attaching to the wrong member	Only if source systems could be <i>forced</i> to consume match keys at write time — which is, in effect, coexistence

1.3 Survivorship rules actually implemented (consistency with Module 2) Applied at merge time, deterministic and idempotent across re-runs:

1. **Most complete record wins** — non-null count across full_name, phone_e164, email, district_std, gender_std, registration_date_iso.
2. **Tie** → **earliest registration_date** (golden record keeps the longest relationship history).
3. **Tie** → **lowest customer_id** (deterministic; re-running the pipeline yields the same survivor).

All losing-row values are preserved: originals sit in *_raw columns (phone_number_raw, district_raw, registration_date_raw, gender_raw), merged-away identifiers in merged_customer_ids.

Task B3.2 — Golden-Record Schema & Attribute-Level Survivorship (C5)

2.1 Attribute, winning source, rule, justification

Attribute	Winning source	Survivorship / standardization rule	Business justification
full_name	The most complete registration record (source with all name parts present); tie → earliest registration_date ; further tie → lowest customer_id	Trim/case-normalize; must pass VR-006 (≥2 chars, letters/dots/dashes)	The name a human recognizes at the till; earliest registration is the name the customer gave when the relationship started and is what loyalty/CRM correspondence uses
phone	Loyalty app E.164-verified number wins (app has verified the handset via OTP); else most recent valid value	Standardized to +2567XXXXXXX — all 6 input variants (+2567..., 077..., 2567..., 7..., '+256 77 123 4567', 077-123-4567) collapse to 1 (measured: 6 variants → 1)	Phone is SRG's operational key (till lookup, MoMo linkage, loyalty SMS). Verified-at-capture beats merely-typed; E.164 makes the deterministic match key portable across POS/e-comm/loyalty
email	E-commerce checkout-validated address wins (it has completed a real transaction verification); conflicts flag review — never silently picked	Lower-cased, VR-003 RFC-5322-lite validation; a conflicting email on a match candidate is a hard reject (homonym protection, §3.3)	A checkout-validated email is the only one proven to reach the customer; but two <i>different</i> emails on two records is evidence they may be two people — automation must not choose
address / district	Latest POS-verified value checked against the official Uganda district reference list	Alias dictionary → fuzzy (≥88 WRatio) → steward queue; 127 raw labels → 42 canonical; region derived from District table (3NF)	District drives catchment/staffing analysis; “latest verified” reflects reality after relocations, while the official list keeps reporting stable
preferences (marketing consent, contact channel)	CRM wins	Recency of consent capture; consent_marketing/consent_e164 booleans carry lawful basis	Consent records must reflect the <i>most recent</i> , evidence of opt-in/out (DPPA 2019 / GDPR Art.7) — recency is the only defensible ordering for consent

Attribute	Winning source	Survivorship / standardization rule	Business justification
loyalty tier & points balance	Loyalty platform wins	System of record for points; golden record stores the tier snapshot only	Points are a financial liability owned by the loyalty ledger; duplicating balances into MDM would create a second, competing truth
customer_id (golden key)	MDM itself	Stable global ID; all source IDs mapped via golden_map (see §4.3)	One human = one ID; source systems keep their local IDs as aliases
*_raw columns	—	Originals always preserved beside standardized values	Auditability for PDPO/DPPA data-subject requests: SRG must show what was stored, what was changed, when and why

2.2 Golden-record table shape (as produced by the cleansing pipeline) module2_data_quality/output/SRG_Customers_clean. columns demonstrate the schema in operation: standardized fields (phone_e164, district_std, registration_date_iso, gender_std) + originals (phone_number_raw, district_raw, registration_date_raw, gender_raw) + MDM control columns (merged_customer_ids, stewardship_flag). Result: **5,000 raw rows** → **3,858 golden records**, duplicate-person rate **22.84%** → **0.00%**, total flag rate 25.06% → 2.85%.

Task B3.3 — Matching Rules (C5)

3.1 Deterministic layer (executed first)

Rule	Key	Effect (measured)
R1 — normalized phone equality	phone_e164 (E.164, non-empty)	953 unions — every pair of records sharing a verified +2567... number is clustered for merge; this is the workhorse given 90%+ phone availability after cleansing

Deterministic keys never fire on empty values (an empty phone is *missing evidence*, not shared evidence) and operate on the standardized value only — matching before standardization would lose the 6-format variant clusters.

3.2 Probabilistic weighted scoring (exactly as implemented) Candidate generation is **blocked on canonical district** (comparison scope control — Uganda districts are stable and 99.4% resolved post-cleansing) and requires **name token/Levenshtein similarity ≥ 90** before any score is computed.

Signal	Weight	Tiers
Name similarity	+60 base (token-sort ratio ≥ 90)	+70 when similarity ≥ 97 (near-exact spelling) — i.e. 60 + (10 if sim ≥ 97 else 0)
District match	+20	Mandatory by the blocking key (both records resolved to the same canonical district)
Phone	+20 exact E.164 equality	+10 partial/neutral evidence (one side missing — same national base, never contradicting); 0 for differing non-empty numbers

Signal	Weight	Tiers
Email	+15 exact equality	+5 one side missing; -10 conflicting emails (both present, different)

Decision gates:

Gate	Condition	Outcome
Auto-merge	score $\geq$ 90 AND a positive identifier match exists (equal phone or equal email)	Cluster-merge with survivorship; name similarity alone never auto-merges
Stewardship queue	$65 \leq \text{score} < 90$ (or ≥ 90 without any positive identifier)	Human adjudication; stewardship_flag = 'REVIEW: possible duplicate'
Hard reject (homonym protection)	Conflicting non-empty emails on a high-name-similarity pair	Rejected outright — counted, not merged: 365 homonym pairs rejected
Below band	score < 65	Left as separate records (assumed different people)

3.3 Justifying the thresholds with measured outcomes

Measured result (dedupe_match_log.json, before_after_metrics.md)	Figure
Duplicate rows injected into the sample (ground truth, injection_report.json)	1,150
Rows actually merged	1,142 (964 clusters: 953 deterministic phone + 189 fuzzy auto)
Homonym pairs correctly rejected by the email-conflict rule	365
Pairs/rows held in stewardship review (no fabricated merges)	110
Duplicate-person rate before → after	22.84% → 0.00%

The trade-off is deliberately asymmetric: **a false merge is strictly costlier than a missed match.**

	False merge (two people become one)	Missed match (one person stays two records)
Business	One customer's loyalty history and points are absorbed into another's; wrong-member points are <i>created</i> (the defect SRG reported)	Duplicate contact — annoying, visible, fixable
Privacy/law	Corrupts consent records: marketing opt-out of Person A may be inherited/overwritten for Person B — breaches DPPA s.7 and GDPR Art.7 accuracy/lawful-basis duties; a data-subject request then returns <i>another person's</i> purchase history	No rights are destroyed; the record is simply incomplete
Reversibility	Only if someone notices; merge has already propagated to loyalty/CRM	Always — steward merges it later with full context

	False merge (two people become one)	Missed match (one person stays two records)
Operational stance	Prevented by construction (threshold ≥ 90 + mandatory positive identifier + email-conflict hard reject)	Accepted — routed to the stewardship queue under VR-007

Hence: automation is capped at high-confidence, identifier-backed merges; the 110-row queue with a 48-hour steward SLA is a *feature*, not a backlog. This is also why loyalty point posting is blocked for unresolved identities (VR-007 action clause).

Ethics controls built into the rule set: (i) no merge without a positive identifier; (ii) email conflict stops automation cold (homonyms — 365 cases — are invisible to name+district scoring); (iii) every merge stores merged_customer_ids (the losing IDs) so any merge can be **un-done** and re-adjudicated; (iv) fairness note for the reflective record — deterministic reliance on phone equality under-serves customers with shared family handsets, which is exactly why those cases land in review rather than being auto-resolved either way.

Task B3.4 — Master Data Hierarchies & Integration Flows (C5)

4.1 Customer → Household (soft, low-confidence)

Rule	Value
Grouping key	Same normalized address/district + surname + shared phone , activity within 90 days
Confidence	Stored as a score 0–1 , never as an identity link — household_id is a soft attribute, no merge, no shared golden record
Permitted uses	Catchment/household marketing <i>counts</i> , delivery batching, Board “household penetration” metrics
Forbidden uses	Loyalty accrual, consent inheritance, identity resolution, single-customer-view roll-ups
Justification	Household is genuinely useful for retail catchment analysis, but SRG’s real households are noisy: shared family handsets, student tenants under a landlord’s surname, and (Jinja) multi-generational homes with one delivery phone

Break scenario (why identity merge is forbidden): three students in a Jinja rental share the landlord’s surname *and* the house phone; the grouping correctly fires — but merging them would move one student’s snack purchases into another’s loyalty ledger and let one person’s marketing opt-out silently suppress the others. Soft grouping keeps the analytic value and refuses the privacy damage.

4.2 Product → Category → Subcategory + identifier crosswalk Canonical **6-class merchandise hierarchy** (matches CATEGORY_MAP/VR-010, measured 30 raw labels → 6):

Category	Representative subcategories
Beverages	Juices, Soft drinks, Water
Grains & Cereals	Maize flour, Rice, Sugar, Beans
Snacks	Biscuits, Crisps, Confectionery
Household	Detergents, Paper products, Candles
Personal Care	Soap, Oral care, Sanitary
Stationery	Exercise books, Pens, Paper

Product identifier crosswalk: one golden SKU per product, with every legacy code mapped as an alias — the reported “same product, 5 identifiers” case (POS KAK1002, e-commerce SUG-KAK-1K, Odoo 100234, supplier Excel KSL/1kg, app sugar-kakira-1kg → **golden SKU KAK1002**). Enforced by VR-008 (one SKU = one product name; 141 duplicate-SKU rows and 69 SKU → multi-name rows are *flagged for stewardship*, never auto-merged — same false-merge asymmetry as customers).

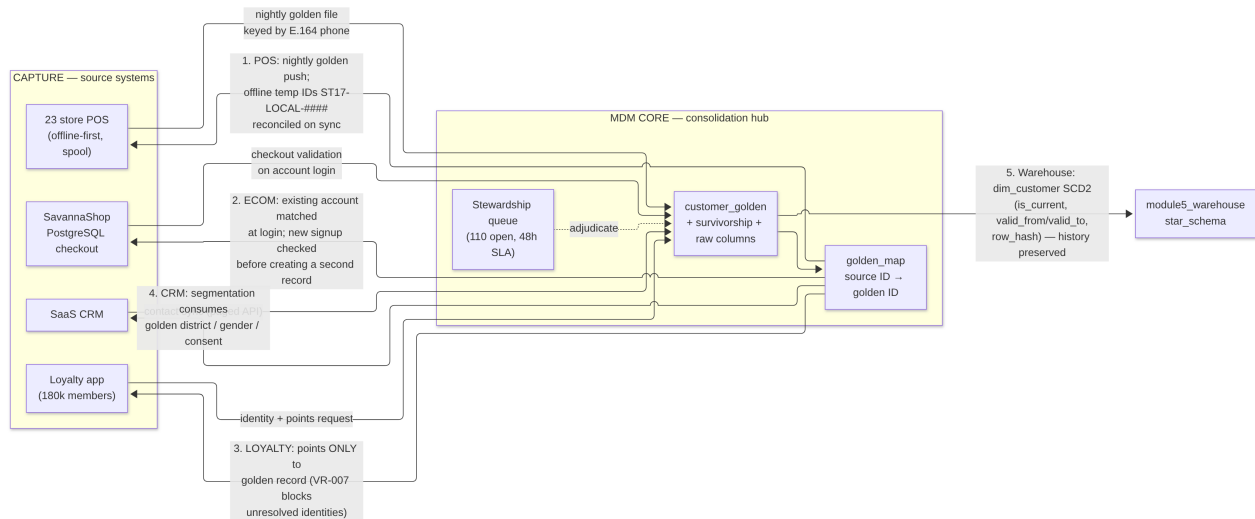


Figure 15: The B3 mdm design diagram (1).

4.3 Integration flows (golden record back into the business)

Flow	Mechanism	Defect it fixes
POS	Nightly golden file keyed by E.164 phone pushed to each store; offline signups get a local temp ID (ST17-LOCAL-####) that reconciles to the golden ID on sync (golden_map remap in srg_etl_pipeline.py)	Points/sales booked against phantom local records; walk-ins stay customer_sk = 0 (Unknown/Walk-in) instead of fabricated identities
E-commerce	Checkout validates the account login against the golden record before insert; near-match → link, conflict → steward queue	SavannaShop re-registering existing loyalty members
Loyalty	Points attributed only to the golden record ; posting blocked while identity unresolved (VR-007)	“Loyalty points issued to wrong members” — SRG’s reported symptom
CRM	Segmentation consumes golden district/gender/consent fields	Segment reports built on stale CRM copies; consent drift
Warehouse	dim_customer SCD2 receives golden versions (row_hash change detection) — history stays queryable as-of any date	Re-hiding history after a merge; supports PDPO data-subject requests

Task B3.5 — MDM Governance Process (C5)

Process	Who	Steps	SLA
New attribute approval	Proposer: any domain steward; Approver: Data Governance Council (existing staff, quarterly cycle per Part A2)	1) Steward submits business need, source system, PII classification, retention class → 2) Council reviews at quarterly meeting (or fast-track for regulatory items) → 3) Approved → ETL/schema-change ticket raised against customer_golden + consuming systems → 4) ETL change deployed with a data contract update → 5) Change log entry	Quarterly cycle; regulatory fast-track ≤ 10 working days
Stewardship dispute resolution (e.g., “these two records are the same person?”)	Domain steward for the data domain (customer → CRM Officer)	1) Steward decides within 48h with evidence (source screenshots, call logs) → 2) Unresolved/escalated → Data Governance Council → 3) If Council is deadlocked (e.g., cross-domain or first-year tie) → Lead EDM Consultant tie-break, <i>initially only</i> , with written rationale — role retires after 12 months	48h steward; 5 working days Council
Propagation SLA (golden change → consumers)	IT Operations Lead	Normal: golden change lands in the next scheduled sync ≤ 24h . Critical corrections (consent withdrawal, wrongful merge, breach-related suppression): immediate — pushed out-of-band to loyalty + CRM, warehouse re-versions via SCD2 same run	≤ 24h normal; immediate critical
Change log	Owned by MDM pipeline + steward	Every merge/un-merge stores merged_customer_ids, stewardship_flag, timestamp, etl_run_id; attribute edits carry before/after (*_raw vs standardized); log is read-only to all roles except Data Steward Admin	Immutable; retained per DPPA retention policy
Queue monitoring	DQC-01 (duplicate-person rate > 1% daily, > 2% = P1)	Stewardship queue depth and age reported weekly; queue growth is treated as a <i>capture-quality</i> signal, triggering form fixes at the offending store	Weekly review

Think-deeper answer The store manager who keeps creating “quick” local customer records during outages — resolved technically *and* politically.

Why the manager is right: blocking the sale to satisfy an MDM rule would be a worse business outcome than a duplicate record. During a 3-hour Gulu outage the till must keep taking money; the manager’s “quick record” is rational behaviour under a constraint the central system ignored. The design must therefore treat offline capture as a **designed state**, not as non-compliance — the same principle that made `customer_sk = 0` (walk-in) a first-class value in the repaired ETL.

Technical resolution (none of this requires the network):

1. **Offline-first capture forms with local validation** — the POS form runs locally (SQLite) and enforces the *same* rules as the hub: VR-001 phone mask (+2567...), district dropdown from the canonical list, VR-006 name check. Quality is enforced at the edge, so nothing is accepted offline that would be rejected online.
2. **Temp local IDs, explicitly namespaced** — ST17-LOCAL-0042. The ID announces itself as provisional; it cannot collide with golden IDs, and it carries `source_system + pending_reconciliation` flags.
3. **Reconciliation on reconnect** — during the nightly sync window the temp record runs through the standard matchers (§3): it resolves to an existing golden record (attributes merged under survivorship) or, if genuinely new, is minted a golden ID; `golden_map` remaps every transaction and points posted under the temp ID (the same remap mechanism `srg_etl_pipeline.py` applies to merged_customer_ids).
4. **Walk-ins get `customer_sk = 0` / “Unknown — walk-in”**, never a fabricated identity. A sale without a resolvable customer is *legitimate*; a sale with an invented customer is a future duplicate.
5. **Benefits activate only after golden match** — loyalty points and marketing attribution are gated on a resolved golden ID (VR-007 blocks point posting for unresolved identities). This aligns incentives: the *customer* now asks the cashier to do the lookup properly, which gives the manager a reason to reconcile rather than to invent.

Political resolution:

1. **Do not block the sale** — said explicitly and publicly; the MDM programme is not going to be the reason a customer walks out of ST17.
2. **Co-design the capture form** — the store managers who live through the outages specify the offline fields (they will drop the district free-text in favour of a dropdown once they see it removes their evening clean-up). Ownership converts resistors into reviewers.
3. **Measure the right thing** — replace punishment for outage behaviour with the KPI “**unreconciled local records > 48h**” per store. The metric blames the *process* (a sync that didn’t run, a form that wasn’t fixed), not the outage. Under DQC-01 it rolls up weekly to the Council.
4. **Stewardship SLA back to the stores** — if a store submits a temp record for adjudication, the steward answers within 48h (§B3.5). Nothing kills cooperation faster than sending records into a void; nothing builds it faster than a 48-hour reply.
5. **Recognition, not blame** — publish “cleanest records” per store on the same board as sales; stores with zero unresolved temp records after 48h get called out in the monthly ops meeting. The manager who previously blocked the form becomes the reference user.

Why this does not break the MDM design: no bypass of survivorship (temp IDs reconcile through the same matching gates), no identity fabrication (walk-ins remain Unknown), no ungoverned attributes (the co-designed form is the data contract), and the political layer simply moves the enforcement point from “block at capture” to “reconcile on sync + measure ageing” — which is the only posture compatible with hours-daily connectivity loss.

Appendix L — ETL Workflow, Job Diagnosis & ETL vs ELT Decision

Task B4 — Data Integration & Real-Time Architecture (C6)

Client: Savanna Retail Group (SRG) — Kampala, Uganda **Deliverable:** Part B4(i) — star-schema warehouse design reference; Part B4(ii) — complete ETL workflow documentation (diagram, extraction matrix, transformation rules, load sequencing, implemented core transformations) **Evidence base:** `module3_etl/srg_etl_pipeline.py` (repaired pipeline, executed, self-test 3/3 PASS), `module3_etl/etl_diagnosis.md` (RC-1...RC-6), `module5_warehouse/star_schema_ddl.sql`, `module2_data_quality/output/validation_rules.md` (VR-001...VR-012), `dq_monitoring_spec.md` (DQC-01...DQC-10)

Task B4(i) — Star-Schema Warehouse Fed by Five Sources (C6) Design and DDL live in module5_warehouse/star_schema_ddl.sql
shape summary:

Object	Grain / role	Fed by
fact_sales	One row per sales line (sale_sk = SHA1(transaction_id)); additive UGX measures; returns = negative quantity	All five sources via staging
dim_customer (SCD2)	One row per identity version (is_current, valid_from/valid_to, row_hash)	MDM golden record (Task B3)
dim_product (SCD2)	One row per product version — price/UOM/category history frozen at time of sale	Product master + 5-ID crosswalk
dim_store	Type 1 + relocation note; store_bk = ST01...ST23 / ECOM01	Store master (offline flag has_pos_offline_mode)
dim_date	UG trading calendar incl. public holidays	Static
dim_payment_method	MTN MoMo / Airtel Money / Card / Cash; settlement_lag_days, requires_payment_ref	Payment reference data

Load order (hard rule): dim_date → dim_store → dim_payment_method → dim_product → dim_customer → fact_sales.

Task B4(ii) — Complete ETL Workflow (C6)

(a) End-to-end workflow diagram **Offline-store spooling, explicitly annotated:** each store's POS writes to a local spool during the day; the sync worker uploads in the 23:00–02:00 window; if a store has been offline > 3 hours the batch defers to the *next* window rather than half-applying; replay is serialized against the ETL by the single-writer advisory lock (fix for RC-3, the ST17 deadlock).

(b) Extraction method per source (honouring connectivity reality)

#	Source	Volume/shape	Extraction method	Window / cadence	Connectivity handling
1	23× MySQL POS (ST01–ST23)	~10k lines/6 months sample → full estate much larger	Local CSV spool → SFTP (agent on store box; plain files, no long-lived DB connections)	23:00–02:00 nightly	Stores offline > 3 h → retry next window; UPS-backed POS keeps capturing; spool is immutable and idempotently replayable; sync replay serialized vs ETL

#	Source	Volume/shape	Extraction method	Window / cadence	Connectivity handling
2	E-commerce PostgreSQL (SavannaShop)	Continuous	CDC via logical replication / Debezium	Near-real-time into raw landing (micro-batch downstream)	Data centre link is HQ-side and stable; CDC decouples from store connectivity entirely
3	Loyalty cloud DB	180k members, daily deltas	Nightly delta CSV via SFTP/API	02:15	API rate limits respected; full snapshot weekly as reconciliation backstop
4	CRM SaaS	Contact/consent records	Paged REST API with rate limiting + updated_since cursor	02:30, paged	Throttled by contract; cursor checkpoint resumes after mid-run failure
5	Odoo ERP (HQ)	Item master, purchase costs	Scheduled export / RPC (server-side, HQ LAN)	01:45	HQ-local; no WAN dependency
—	<i>Supporting: MoMo provider CSVs (MTN/Airtel)</i>	Daily settlement	Manual download → drop folder (automated later)	Daily AM	PENDING refs age via DQC-08 until matched
—	<i>Supporting: 14 supplier Excel files</i>	Ad-hoc	Parsed to supplier master on change	Weekly/on change	Never loaded raw into facts

(c) Transformation rules

#	Rule	From → To	Failure behaviour
T1	Type coercion	'N/A', '', 'null' → NULL (never → 0 / fake values)	Uncoercible ('UGX cheap' in quantity) → quarantine SCHEMA_TYPE, batch continues (fixes RC-1)
T2	Currency/price strip	'UGX 50,000', '11,500' → 50000.0 / 11500.0 numeric	Non-numeric → quarantine
T3	Phone → E.164	077-123-4567, 2567..., 7..., '+256 77 ...' → +2567XXXXXXX (6 variants → 1)	Unrepairable → keep raw + phone_status=invalid (VR-001 monitoring, DQC-02)
T4	District → canonical list	127 raw labels → 42 official (alias dict → fuzzy ≥88 → steward)	UNRESOLVED → stewardship, never fabricated (DQC-03)
T5	Date → ISO-8601	12/07/2024, 2024-07-12, 07/08/2024 → 2024-07-12T...	Unparseable → quarantine VR-005 (e.g. 31/02/2024)
T6	Gender → domain	Male/M/male, F/female/... → {M,F}	Unmapped → keep raw, flag (100% conformance achieved in Module 2)

#	Rule	From → To	Failure behaviour
T7	UOM → domain	kg/KGS/Kilograms/... → {kg, pcs, liters} (label-mapped; g/ml <i>values</i> flagged for source fix, not silently scaled)	Non-conforming new rows → DQC-05 alert
T8	Category → 6-class	30 raw labels → Beverages, Grains & Cereals, Snacks, Household, Personal Care, Stationery (alias + fuzzy ≥85)	Unresolved → steward (VR-010)
T9	Golden-record ID remap	source customer_id → golden ID via golden_map (merged_customer_ids on survivor)	Unknown ID → COALESCE(customer_sk, 0) Unknown/Walk-in (fixes RC-2)
T10	Dedupe keys	Deterministic phone_e164 equality; fuzzy name ≥90 blocked on district, auto-merge ≥90 + positive identifier (Task B3)	Score band 65–90 → stewardship queue; email conflict → reject
T11	Lookup enrichment	unit_price_ugx/cost from dim_product version valid at sale; store attributes from dim_store	Missing product → quarantine VR-008, replay after dim refresh (fixes RC-5)
T12	MoMo payment_ref status	ref present → MATCHED; MoMo without ref (offline) → payment_ref='PENDING_RECORD'), reconciliation_status='PENDING'; non-MoMo → NOT_REQUIRED; provider file lost → MISSING	Never blocks revenue load; aged refs escalate via DQC-08 (> 24 h, > 50 =
T13	Returns	quantity negative (500 rows), is_return = TRUE	Sign flip validated; control totals computed on signed values
T14	Contract enforcement per source	Schema JSON published with each extract; loader refuses files failing the contract <i>before</i> touching the database	Contract breach → halt that source only, alert on-call (VR-004/VR-008 enforced at the boundary)

(d) Load sequencing, idempotency, freshness

Control	Rule	Evidence / lesson
Dimensions ALWAYS before facts	dim_date → dim_store → dim_payment_method → dim_product (SCD2) → dim_customer (SCD2) → fact_sales (stated in star_schema_ddl.sql footer)	RC-5: dimensions loaded after facts produced 412 SKU orphans ; now orphan FKs are quarantined and replayed after the dim refresh, never FK-crash
Quarantine, never abort	Bad rows → etl_quarantine (run_id, rule, payload, error, replayed_flag); valid rows proceed; -- replay-quarantine re-loads after source fix	Self-test: 6/6 injected bad rows quarantined, batch still loaded 10,000 rows

Control	Rule	Evidence / lesson
Idempotent re-runs	sale_sk = SHA1(transaction_id) → delete-then-insert per key set; dimension upserts keyed by row_hash	Self-test TEST 1: rows before = 10,000, after re-run = 10,000 → PASS
Single-writer discipline	Advisory lock (pg_advisory_lock(hashtext('dim_store_key_id')), dialect-aware fallback) around shared-dimension writes; store-sync replay confined to 23:00–01:45; dim_store updates ordered by store_sk	RC-3: ST17 sync replay deadlocked strongly enforced
Fail fast, no silent fallback	The diagnosed job’s “partial mode” (reusing yesterday’s staging) is removed ; a failed run marks etl_run_log.status = FAILED, exits non-zero	RC-4: stale-data masking propagated wrong results for 4 days
Post-load checks	fact_orphan_product_fks = 0, fact_orphan_customer_fks = 0, control_total_net_amount_ugx matches source, row counts, pending-MoMo count	Executed: control total UGX 252,382,814.16 OK, 849 pending MoMo refs, 500 returns, 10,000/10,000 loaded
Freshness SLA + monitoring	SLA: staging by 02:30, warehouse by 03:30, BI views by 04:00; breach → alert. DQC-07 quarantine rate > 0.5% or > 100 rows/run → IT Operations Lead; DQC-08 pending MoMo > 24 h → Finance	RC-6: prior job alerted to an unmonitored mailbox — alerts now go to the on-call rotation (SMS/WhatsApp) + 06:00 run-state check
Run audit	etl_run_log: run_id, started/finished, status, rows_read/loaded/quarantined, control total, error detail	Every number in this document is traceable to a run row

(e) Implemented core transformations **Executable pipeline:** module3_etl/srg_etl_pipeline.py — pandas + SQLAlchemy, dialect-aware (PostgreSQL/SQLite), executed in this environment:

```
[TEST 1] idempotency: rows before=10000 after re-run=10000 -> PASS
[TEST 2] bad rows quarantined: 6/6 (rows in etl_quarantine=6) -> PASS
[TEST 3] mobile-money missing ref handled gracefully (PENDING_RECON) -> PASS
ALL TESTS PASS
[POST-LOAD CHECKS] fact_orphan_product_fks=0 OK, fact_orphan_customer_fks=0 OK,
control_total_net_amount_ugx=252382814.16 OK
```

Warehouse target: module5_warehouse/star_schema_ddl.sql (ANSI, sqlfluff-validated; load order in file footer).

Warehouse-side SCD2 upsert pattern for dim_product — clearly labelled: this is the *warehouse-side* pattern applied by the dim-load step (the pipeline’s pandas equivalent uses row_hash comparison on product_bk):

```
-- WAREHOUSE-SIDE PATTERN: SCD2 upsert for dim_product (PostgreSQL 15/16, ANSI MERGE-style)
-- Change detection = row_hash of the business payload; unchanged rows are untouched.
WITH src AS (
  SELECT p.product_bk,
         p.sku, p.product_name, p.category, p.subcategory,
         p.unit_of_measure, p.cost_ugx, p.selling_price_ugx, p.supplier_bk,
         encode(digest(concat_ws('|', p.product_bk, p.sku, p.product_name,
                                p.category, p.subcategory, p.unit_of_measure,
                                p.cost_ugx, p.selling_price_ugx, p.supplier_bk),
```

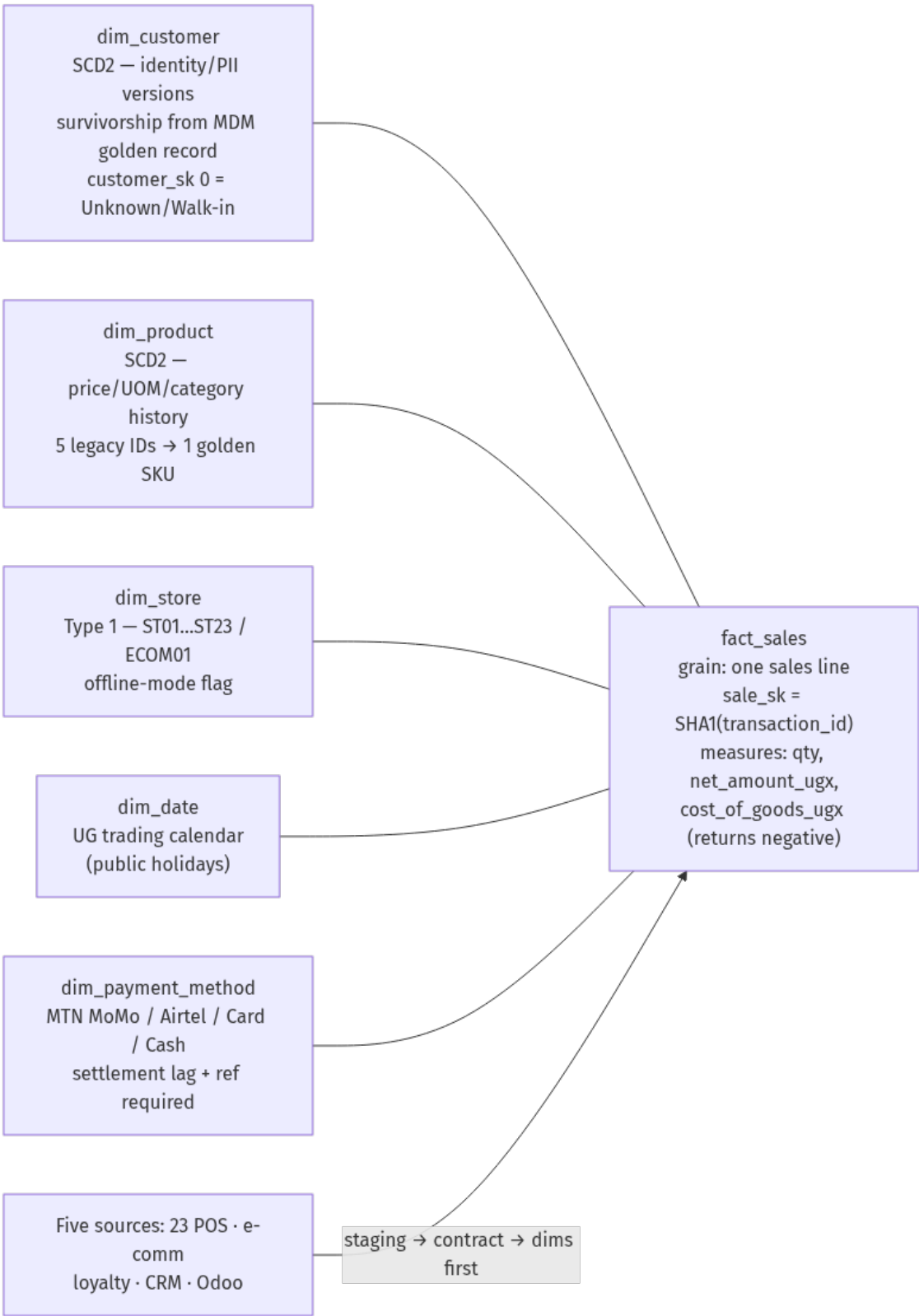


Figure 16: The B4 etl workflow diagram (1).

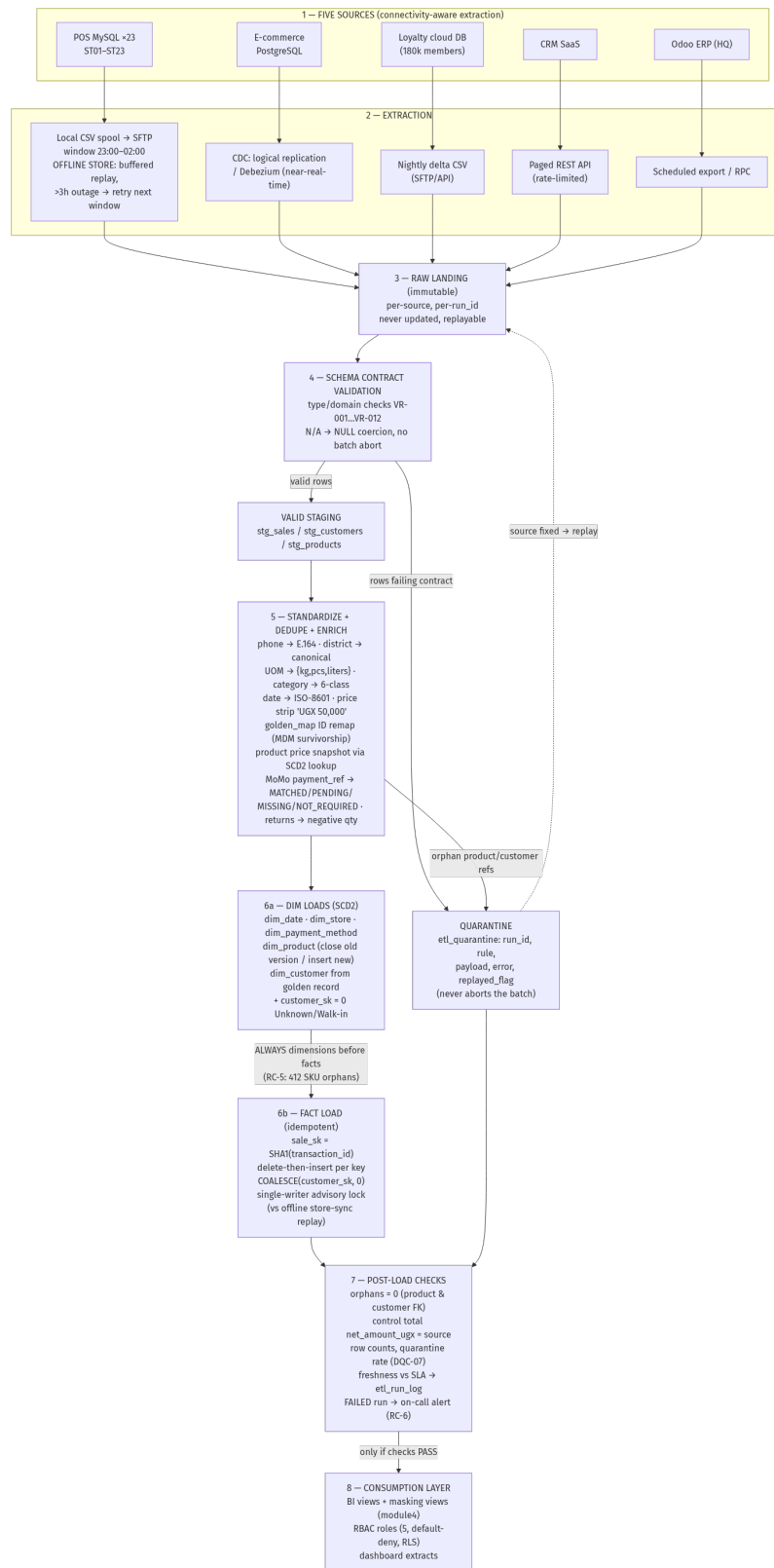


Figure 17: The B4 etl workflow diagram (2).

```

        'sha1'), 'hex') AS row_hash,
        p.etl_run_id
    FROM staging.stg_products p -- validated, post-contract rows only
),
changed AS (
    SELECT s.*
    FROM src s
    LEFT JOIN warehouse.dim_product d
        ON d.product_bk = s.product_bk
        AND d.is_current -- compare against CURRENT version only
    WHERE d.product_sk IS NULL -- brand new product
        OR d.row_hash <> s.row_hash -- attribute change -> new version
)
-- 1) CLOSE the old version (valid_to = now) only when the hash changed
UPDATE warehouse.dim_product d
SET valid_to = now(),
    is_current = FALSE,
    etl_run_id = c.etl_run_id
FROM changed c
WHERE d.product_bk = c.product_bk
    AND d.is_current;

-- 2) INSERT the new version (or the very first version) as current
INSERT INTO warehouse.dim_product (
    product_sk, product_bk, sku, product_name, category, subcategory,
    unit_of_measure, cost_ugx, selling_price_ugx, supplier_bk,
    valid_from, valid_to, is_current, row_hash, source_system, etl_run_id)
SELECT nextval('warehouse.seq_product_sk'), c.product_bk, c.sku, c.product_name,
    c.category, c.subcategory, c.unit_of_measure, c.cost_ugx,
    c.selling_price_ugx, c.supplier_bk,
    now(), '9999-12-31 00:00:00+00', TRUE, c.row_hash, 'POS', c.etl_run_id
FROM changed c;
-- Invariant: exactly one is_current row per product_bk;
-- historical fact rows keep the product_sk valid AT TIME OF SALE (never re-pointed).
```

Why SCD2 for product and customer, Type 1 for store: price/category/UOM changes and identity changes **rewrite history** if kept current-only (margin analysis, PDPO subject requests), while store attributes rarely redefine the past (store_relocation_note records the exception).

Think-deeper answer Every element of this workflow answers a defect that SRG actually exhibited, which is why the design reads as a sequence of lessons: contracts before load (**RC-1**), unknown-member as a state rather than an error (**RC-2**), a lock window between sync replay and the ETL (**RC-3**), fail-fast instead of “partial mode” (**RC-4**), dimensions before facts (**RC-5**, 412 orphans), and alerts a human reads (**RC-6**). The deeper point is that an ETL workflow is not a data-movement diagram — it is a *control system*: immutable landing for replay, quarantine for containment, idempotency for re-runs, control totals for proof, and a run log for accountability. Move any control and the corresponding failure returns silently: without the control total, a run that loads 9,000 of 10,000 rows “succeeds”; without etl_run_log, RC-6’s four days of invisibility recur; without quarantine, one 'N/A' aborts the whole night. For a four-person team, controls are also the only scalable form of diligence — they work at 03:00 without anyone watching.

Task B4 — Data Integration & Real-Time Architecture (C6)

Client: Savanna Retail Group (SRG) — Kampala, Uganda **Deliverable:** Part B4(iii) — ETL vs ELT decision matrix for the present state and the future cloud migration **Budget frame:** UGX 480,000,000/yr all-in (licences + cloud + hires, ≈ USD 130,000 @ UGX 3,700) — every option below is priced against this single envelope **Current estate:** 23 offline-tolerant MySQL POS + PostgreSQL e-comm + cloud loyalty + SaaS CRM + Odoo; team of 4 (2 SQL, 0 data-engineering); warehouse on PostgreSQL/SQLite today

Task B4(iii) — ETL vs ELT Decision Matrix (C6)

1. Definitions as applied at SRG

Mode	Where transformation happens	SRG concrete form
ETL (Extract–Transform–Load)	Transform in an intermediate staging layer <i>before</i> the warehouse load	Files/CDC → immutable raw landing → validation, standardization, dedupe, enrichment (pandas/SQL) → load dims/facts — i.e. <code>srg_etl_pipeline.py</code> as built
ELT (Extract–Load–Transform)	Raw data loaded first; transformation executes <i>inside</i> the target warehouse	Files/CDC → raw tables in cloud warehouse → SQL/dbt models (contracts, tests, materializations) build dims/facts
Hybrid	Both, staged in time	Phase 1 (now): file/ETL staging on-prem-ish, offline-first. Phase 2 (post-triggers): raw lands in cloud warehouse, transformation moves there as dbt-style SQL — same rules, new runtime

2. Decision matrix (scores 1 = worst ... 5 = best; justification per row)

#	Criterion	ETL (now)	ELT (cloud)	Hybrid (staged)	Justification for the scores
1	Latency	3	5	4	ETL is window-bound (spool 23:00–02:00, warehouse by 03:30) — fine for Board KPIs, weak for CDC e-comm events. ELT loads raw instantly and transforms continuously → 5. Hybrid inherits ETL latency in Phase 1, near-ELT after cutover → 4

#	Criterion	ETL (now)	ELT (cloud)	Hybrid (staged)	Justification for the scores
2	Cost (within UGX 480M)	4	3	4	ETL runs on commodity SQL + pandas already owned — near-zero marginal licence cost, and only <i>cleaned</i> rows cross the WAN (egress minimized). ELT requires an always-on cloud warehouse compute line carved from the same envelope (indicative UGX 60–90M/yr, ~USD 16–24k, displacing something else) plus raw-volume egress. Hybrid stages that spend until it is justified
3	Scalability	2	5	4	Single-node pandas scales by lengthening the window; at 10s of millions of fact rows (23 stores + Kenya/Rwanda) the window eventually breaks. ELT scales elastically with the warehouse → 5. Hybrid gets there in Phase 2 → 4

#	Criterion	ETL (now)	ELT (cloud)	Hybrid (staged)	Justification for the scores
4	Complexity / ops burden (4 staff)	4	3	3	ETL = one pipeline, one etl_run_log, one alert rotation — operable by 2 SQL-capable people. ELT adds warehouse modelling, orchestration, test suites and tool upgrades to the same four people. Hybrid carries <i>both</i> stacks during transition → 3 (deliberate, time-boxed cost)
5	SRG skills fit	5	2	3	ETL is pandas + SQL they already write (validated: self-test 3/3 PASS). ELT assumes dbt/warehouse-SQL/CI habits that do not exist yet — must be trained <i>before</i> adoption, not during. Hybrid = ETL now, training runway before cutover → 3
6	Connectivity / offline fit	5	2	4	Stores spool CSV → SFTP and are validated <i>before</i> wide-area transit; an outage delays a file, it never corrupts a cloud load. ELT's "stream raw upward" posture assumes links several stores lose for hours daily. Hybrid keeps store-side spooling forever → 4

#	Criterion	ETL (now)	ELT (cloud)	Hybrid (staged)	Justification for the scores
7	Auditability (PDPO ≤ 12 months)	5	4	5	ETL today already has immutable raw landing + per-row quarantine + etl_run_log + control totals (UGX 252,382,814.16) — every figure reproducible. ELT preserves raw in-warehouse (good lineage) but transform logic lives in many SQL models that need tooling to trace for an auditor → 4. Hybrid keeps immutable landing <i>and</i> warehouse lineage → 5
8	Time-to-value by month 6	5	2	4	ETL path is built and evidenced now (quarantine, idempotency, SCD2 dims, dashboards feedable). ELT re-platforms working code before month 6 → 2. Hybrid delivers with ETL, converts later → 4
9	Future cloud-migration fit	2	5	4	Hand-rolled Python does not lift to a managed stack as cleanly as SQL models do; but because transformations are <i>specified</i> as rules + tests (VR/DQC catalog), porting them is a rewrite, not a redesign → ETL 2, ELT 5, Hybrid 4

#	Criterion	ETL (now)	ELT (cloud)	Hybrid (staged)	Justification for the scores
	Total (max 45)	35	29	35	ETL wins <i>today</i> ; ELT wins <i>after</i> the triggers; hybrid is the staged path that gets SRG from the first number to the second without a re-platform gamble

3. Recommendation Stage it: run file/ETL staging now; convert to ELT-style transformation-in-warehouse only when the trigger conditions below are all met. Hybrid is not fence-sitting — it is two explicit decisions with a gate between them.

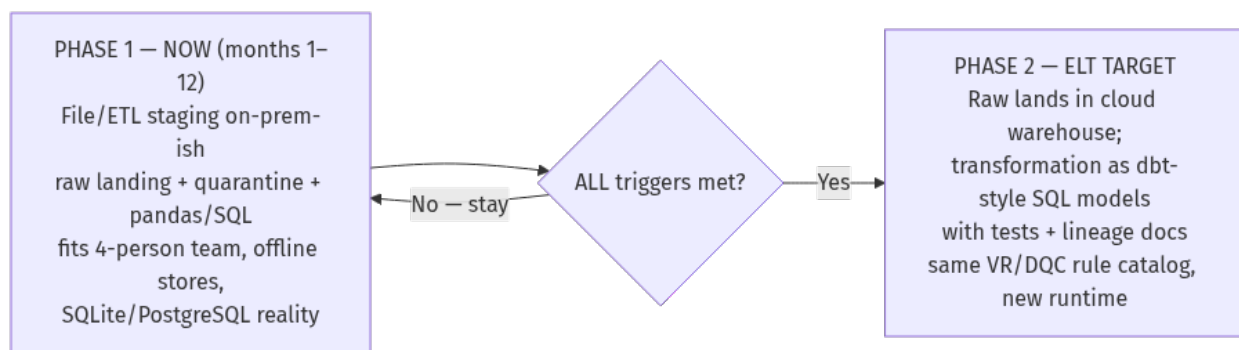


Figure 18: The B4 etl vs elt diagram (1).

Why not ELT now: re-platforming a *working, evidenced* pipeline (3/3 self-tests, control totals, RC-1...RC-6 fixes) into a cloud warehouse before month 6 spends scarce budget and the only two SQL-capable staff on migration instead of on the Board's quick wins — and still cannot fix store connectivity, which is the binding constraint on both latency and cost.

Why not ETL forever: single-node windows eventually break at 23-store-plus-expansion volume, and hand-rolled Python accumulates maintenance debt for a team that should be spending its hours on rules, not runners.

4. Migration trigger conditions (all must hold)

#	Trigger	Measurable test	Owner
T1	Cloud budget line approved	Board approves a discrete warehouse/compute line (indicative UGX 60–90M/yr) <i>within</i> the UGX 480M envelope, with the offsetting item named	CFO + Board
T2	Staff trained	≥ 2 of the 4 IT staff complete warehouse-SQL + dbt-style modelling training and ship one model to production unassisted	IT Operations Lead

#	Trigger	Measurable test	Owner
T3	≥ 2 stable pipelines	Two pipelines (POS spool + e-comm CDC) with ≥ 60 consecutive green runs, quarantine rate < 0.5% (DQC-07), zero unmonitored failures (RC-6 regression test)	IT Operations Lead
T4	Connectivity improved	≥ 99% site-availability for 6 consecutive months across the 23 stores (measured by spool upload success) — otherwise Phase 2 merely moves the bottleneck	IT Manager
T5 (<i>supporting</i>)	Volume pressure	Fact volume or query SLA proves the single-node window is the constraint (e.g., load window > 4 h sustained)	Consultant

5. Target tooling pattern On trigger, adopt **dbt-style transformation-in-warehouse** (declarative SQL models, automated tests mapped 1:1 to VR-001...VR-012 and DQC-01...DQC-10, lineage documentation generated per model, incremental materialization replacing hand-rolled delete-then-insert). The *rules do not change* — only their runtime. This is why the rule catalog is documented as portable specifications rather than embedded Python: conversion is a translation exercise with an existing test suite (control totals, orphan checks, idempotency tests) to prove parity.

Think-deeper answer The real question in “ETL vs ELT” at SRG is not technical — it is *who is paying for latency nobody consumes*. ELT’s score-5 latency and scalability are only worth their cloud line if the business has a consumer for sub-hour data; today it does not (board KPIs are monthly, churn scoring nightly, fraud reviewed in 5–15-minute windows — Task B4(v)). Paying an always-on compute line from the same UGX 480M envelope to transform raw data faster than anyone reads it would be a cost with no return. Conversely, ETL’s score-2 scalability has a fuse: it burns at 23-store-plus-Kenya/Rwanda volume, and the correct engineering response is the pre-registered trigger table above — so the decision today does not lock the decision tomorrow. That is the test of a real architecture decision: it names, in advance, the evidence that would overturn it.

Module 3 — ETL Error Diagnosis: `etl_error_log.txt` (Task B4.4)

Analyst: Lead Enterprise Data Management Consultant **Log date:** 2025-03-11, nightly run `etl_20250311_020000` (02:00–02:52 EAT) **Business impact:** `warehouse.fact_sales` unchanged for 4 consecutive days; management reporting is 2 days stale; monthly management consolidation (currently 11 days) cannot close.

1. Reasoning Trail — What the Log Actually Says

#	Timestamp	Log Evidence	Interpretation
1	02:00:12–13	InvalidTextRepresentation invalid input syntax for type integer: "N/A" at COPY staging.stg_sales, LINE 12044	The staging table declares customer_id INTEGER, but at least one source (an offline POS or the e-commerce export) writes the literal string N/A for unknown customers. The whole COPY batch aborts at row 12,044 — PostgreSQL COPY is all-or-nothing, so 0 of 21,562 rows were staged.
2	02:00:13	Falling back: continuing with 'partial mode' (staging retains previous batch ...)	The job's "fallback" silently continues with yesterday's staging data — the pipeline reports progress while processing stale input. This masks failure #1 and guarantees wrong results downstream.
3	02:00:15	412 fact rows reference SKU not found in dim_product (orphans)	Products created in POS/e-commerce after the last dim_product refresh are not yet SCD2-versioned in the warehouse. The warning itself says the load "will fail if orphans > 0" — a known, unhandled condition.
4	02:00:16	NULL customer_id in staging rows: 63 (walk-in / offline-capture rows)	Offline capture during connectivity outages legitimately produces unknown customers. The pipeline inserts NULL into fact_sales.customer_sk, which is NOT NULL.
5	02:52:41	ForeignKeyViolation / NOT NULL: fact_sales.customer_sk ... ROWS REJECTED: 63 of 21,562	Root-cause error #2: no customer_sk = 0 ("Unknown / Walk-in Customer") member exists in dim_customer, and no COALESCE(s.customer_sk, 0) is applied. The load aborts, warehouse unchanged.

#	Timestamp	Log Evidence	Interpretation
6	02:52:42	DeadlockDetected ... Process 18442 (nightly_etl) vs Process 18501 (sync_worker_3, offline POS sync replay, store ST17)	Root-cause error #3: offline store-sync replay collides with the nightly ETL. Both transactions UPDATE dim_store for store_sk=17 (Gulu), but in opposite order relative to other locks. Stores lose connectivity for hours daily, so their buffered transactions replay at night — exactly when the ETL runs. Lock ordering is not consistent and there is no application-level lock window.
7	02:52:42	No rows loaded ... stale D-1 data for the 4th consecutive day + alert to an unmonitored mailbox (last opened 7 days earlier)	Organizational failure: the run fails, alerts go nowhere, and no human notices for days.

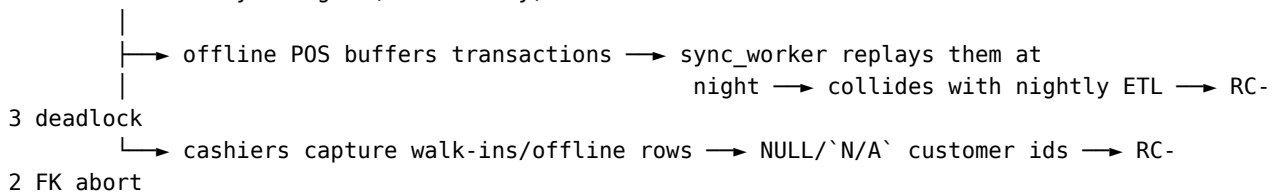
2. Root Causes (ranked by contribution)

Rank	Root Cause	Type	Evidence	Consequence
RC-1	No schema validation / type contract between source and staging. Sources freely write N/A, empty strings, and free-text into typed columns; staging uses strict COPY.	Data-contract gap (technical)	Lines 02:00:13 ("N/A" → integer)	Entire batch aborts → 0 rows staged
RC-2	Missing surrogate-key handling for unknown customers. No dim_customer row with customer_sk = 0, no COALESCE, and NOT NULL on the FK. Offline capture (a <i>designed</i> behavior for outages) therefore breaks the load.	Modelling/design gap	Lines 02:00:16 + 02:52:41 (63 rows)	Transaction aborts → warehouse unchanged

Rank	Root Cause	Type	Evidence	Consequence
RC-3	Write collision between offline store-sync replay and nightly ETL (deadlock on dim_store, inconsistent lock order, no scheduling window).	Concurrency/scheduling gap (connectivity-driven)	Lines 02:52:42 (Process 18442 vs 18501, ST17 Gulu)	Run terminates mid-load
RC-4	Silent “partial mode” fallback that continues with the previous day’s staging data instead of failing fast.	Orchestration anti-pattern	Line 02:00:13	Failures masked; wrong data propagates
RC-5	Unhandled SKU orphans — dim_product SCD2 refresh ordering is wrong (dimension must load <i>before</i> the fact).	Load-sequencing gap	Line 02:00:15 (412 rows)	Would abort at FK check
RC-6	Alerting to an unmonitored mailbox; no run-state dashboard.	Process/monitoring gap	Line 02:52:42 (last open: 2025-03-04)	4 days of invisible failure

Causal chain (why these recur at SRG specifically)

Store connectivity outages (hours daily)



No data contract between 23 POS databases + e-comm + loyalty → RC-1 type mismatches

Job written as "best effort" (fallback instead of fail-fast) → RC-4 masks RC-1

Dimension load ordered after fact load → RC-5 orphans

Alerts to unmonitored inbox, no one owns the run → RC-6 nobody notices

3. Corrective Actions (fix now)

ID	Action	Fixes	Effort
CA-1	Replace strict COPY with staged landing + per-row validation : coerce types with NULLIF(TRIM(x), 'N/A'), reject bad rows to etl_quarantine table with error reason, load the rest.	RC-1	S

ID	Action	Fixes	Effort
CA-2	Insert customer_sk = 0 (“Unknown / Walk-in Customer”) and product_sk = 0 members into dimensions; COALESCE unknown keys in the fact load; keep NOT NULL on the fact FK.	RC-2	S
CA-3	Lock window / single writer: ETL takes pg_advisory_lock(hashtext('dim_store')); store-sync replay runs 23:00–01:45 only; ETL takes the same advisory lock before mutating shared dimensions; all dim_store updates ordered by store_sk.	RC-3	M
CA-4	Fail fast: remove silent fallback; quarantine + halt with non-zero exit; run state persisted to etl_run_log and surfaced on a dashboard.	RC-4	S
CA-5	Reorder load: dimensions first (SCD2), then facts; reprocess orphans from quarantine after dim_product refresh.	RC-5	S
CA-6	Alert to on-call rotation (SMS/WhatsApp for the 4-person team), plus daily 06:00 run-state check by the IT Operations Lead.	RC-6	S

4. Prevention (stop it recurring)

1. **Data contracts per source** — schema JSON published with each extract; the loader refuses files that fail the contract *before* touching the database (this is validation rule VR-004/VR-008 from Module 2 enforced at the pipeline boundary).
2. **Quarantine, never abort** — bad rows are never dropped silently and never block good rows; quarantine rate is a monitored metric (DQC-07, threshold > 0.5%).
3. **Idempotent, replayable runs** — every run is keyed by run_id + natural business keys, so a failed day is replayed without duplicates (implemented in srg_etl_pipeline.py).
4. **Design for the outage reality** — unknown-customer path (customer_sk = 0) is a first-class state, not an error, because offline capture is expected behavior at SRG.
5. **Single-writer discipline** — advisory locks + a sync-vs-ETL schedule window remove the deadlock class entirely, not just this instance.
6. **Alerting that a human reads** — 4-person team, so alerts go to the on-call rotation, and the run dashboard is part of the 06:00 morning routine.

Appendix M — Real-Time Integration Architecture (Footfall & Mobile-Money Streams)

Task B4 — Data Integration & Real-Time Architecture (C6)

Client: Savanna Retail Group (SRG) — Kampala, Uganda **Deliverable:** Part B4(v) — real-time integration design around the in-store footfall sensor stream, with a justified batch-vs-stream verdict **per use case** (not “real-time for everything”) **Sample artefact:** module7_realtime/footfall_stream_sample.json — *see the provenance note in §1; the instructor-provided footfall file was not available in this build environment, so a representative sample matching this design was generated and validated instead* **Board context:** the Board has asked for “real-time everything” — §7 answers that request with numbers

Task B4(v) — Real-Time Integration Architecture (C6)

1. Input stream: footfall sensor sample

Item	Detail
File	module7_realtime/footfall_stream_sample.json (JSON object with _comment provenance note + events[])
Provenance	Honest disclosure: the instructor-provided footfall_stream_sample.json was not present in this environment; the committed file is a clearly-labelled representative sample generated to this design (~60 events), not a copy of the original
Fields	event_id, sensor_id (e.g. ST07-D00R-1, ST07-ZONE-B), store_id (physical stores only: ST07, ST17 — ECOM01-NA carries no door sensors), site (city), ts (ISO-8601 +03:00), zone (entrance / aisle_snacks / aisle_beverages / till / exit), direction (in/out), count (1–40), dwell_seconds, edge_seq (monotonic — proves offline spool ordering), quality (ok for most; a few suspect/duplicate records and one null-count record for robustness discussion)
Design lessons encoded	edge_seq gaps = offline store buffering; quality flags drive the dedupe/drop rules in §3; null count demonstrates contract validation at the gateway, not downstream

2. Streaming component architecture Component choices and why (budget + skills tested):

Component	Choice	Justification	Rejected
Edge gateway	Store PC/UPS box writing JSON spool + SQLite , validating the event contract locally	Store outages are hours-daily: the spool <i>is</i> the system of record until upload; SQLite needs no ops staff; edge_seq makes replay idempotent	Cloud IoT ingress per store (needs links that don’t exist; recurring cost from the 480M envelope)
Transport to HQ	HTTPS/SFTP batch in the existing 23:00–02:00 window (near-real-time only where the link is proven stable)	Reuses the proven spool pattern from the POS ETL — one operational habit, not two	Per-store persistent MQTT sessions (reconnection storms, another daemon to babysit at 23 sites)

Component	Choice	Justification	Rejected
HQ broker	Redpanda, single node, Kafka API (indicative: commodity HQ box, no licence)	Kafka-compatible semantics (partitions, replay, consumer groups) with no ZooKeeper, no JVM tuning — the ops profile fits 4 non-DE staff; replay is exactly what the offline-gap story requires	Full Kafka + ZooKeeper (ops burden exceeds team capacity); cloud Pub/Sub or Confluent (licence + egress inside UGX 480M); MQTT as the <i>central</i> broker (weak replay/consumer-group story for CDC integration — acceptable as an edge protocol, not as the HQ spine)
CDC path	Debezium on e-commerce PostgreSQL , publishing to the same broker	HQ-side, stable link; stock moves and orders feed the availability consumer without polling	Polling e-comm DB from stream jobs (latency + load on the storefront)
Availability sink	Redis	Sub-second key/value lookup (store×SKU) for storefront badge + handhelds; trivial client libraries	Serving queries straight off the warehouse (seconds-to-minutes, wrong tool for a lookup)
Fraud sink	Alert queue table + daily digest	Matches the 5–15 min verdict (\$5) and the Finance officer's workflow	Real-time card-style authorization UI nobody staffs 24/7

3. Stream processing logic (contract-aware)

- Gateway contract validation:** drop/re-flag malformed events *at the edge* (null count, quality ∈ {suspect, duplicate}, non-monotonic edge_seq) — the stream never carries what the warehouse ETL would quarantine anyway.
- Duplicate suppression:** key on (sensor_id, edge_seq); gateway stamps upload batches so replayed spools after an outage don't double-count footfall.
- Gap detection:** edge_seq discontinuity → freshness alert (stream analogue of DQC-07); outages become *visible latency*, not silent zeros.
- Aggregation:** zone dwell + door in/out → per-store per-15-min footfall and per-zone browse minutes; SKU-level signals only where a zone → category mapping exists (realistic: **zones map to categories, not to individual SKUs**).

4. Use case 1 — LIVE STOCK VISIBILITY

Element	Design
Question answered	“Can SavannaShop promise this item, and which store should get restocked first?”
Signal A — footfall	Door/zone counts → store-level demand pressure: browse minutes in aisle_snacks vs completed till visits → footprint → browse conversion estimates (category-level proxy, not SKU-level — sensors cannot see SKUs)
Signal B — actual stock	SKU-level availability comes from POS/CDC: sales decrements (Debezium on e-comm stock moves + POS sales stream) + inbound deliveries from Odoo
Processing	Availability consumer, 30–60 second micro-batch: $\text{on_hand}(t) = \text{last_odoo_qty} - \sum \text{sales} + \sum \text{receipts}, \text{ clamped } \geq 0, \text{ with a shrink allowance (SRG's unexplained 8.4\% book-vs-physical variance gets surfaced here as drift, not hidden)}$

Element	Design
Output	Redis store:SKU → qty/status → (1) e-commerce availability badge with confidence flag; (2) handheld “restock priority” queue ranked by on-hand and footfall pressure
Batch vs stream verdict	NEAR-real-time micro-batch (30–60 s) — not sub-second streaming. Justification: a stock-out at ST07 makes SavannaShop promise an item that doesn’t exist <i>and</i> loses the sale in-aisle — cost is per-minute, not per-millisecond. Sub-second adds cost (broker ops, always-on consumers) with zero incremental business value; a 60-second stale qty is within the shrink/noise envelope anyway

5. Use case 2 — MoMo FRAUD PATTERN DETECTION

Element	Design
Question answered	“Is this mobile-money transaction one of the patterns SRG already loses money to?”
Input	momo.tx topic: payment_ref, amount, store, timestamp, cashier, basket size; plus refund events; reconciles with the PENDING_RECON/MISSING states from the ETL
Rules (velocity & pattern)	R1 same payment_ref reused across >1 store within 24 h; R2 refund-then-refund loops (refund > N per cashier/day); R3 off-hours basket outliers (value > $\mu + 3\sigma$ for that store-hour, zoned against the 01:02-timestamp anomaly class in the sample data); R4 walk-in (customer_sk = 0) + high-value basket combinations; R5 MoMo ref never settles (MISSING beyond 48 h — DQC-08 escalation)
Processing	Rules consumer in a 5–15 minute micro-batch over a 24 h sliding window; state = per-ref/cashier counters in Redis/SQLite
Output	Alert queue → Finance Reconciliation Officer (+ daily digest to CFO); alert carries replayable event IDs for evidence
Batch vs stream verdict	5–15 minute micro-batch — not real-time authorization. Justification: true real-time authorization means sitting <i>inside</i> the payment gateway callback — a path SRG does not control (MTN MTN/Airtel rails, merchant API tiers); building/buying it fails cost-benefit now. Fraud <i>settlement</i> risk is T+1, so a 15-minute window catches the same losses a 15-second window does, at a fraction of the ops cost. Escalation trigger: only if measured fraud losses exceed an agreed annual threshold (fraud loss > the annualized cost of gateway integration) does SRG revisit real-time auth

6. Other SRG use cases — classified honestly

Use case	Right cadence	Why not faster
Footfall for staffing/shift decisions	Hourly batch	Rosters change by the shift; a manager reading 15-minute footfall changes nothing intra-hour

Use case	Right cadence	Why not faster
Churn scoring (180k loyalty members)	Nightly	Next-best-offer emails/SMS go out daily; sub-hour churn scores would still be acted on tomorrow
Board KPIs / monthly reporting	Daily (monthly close)	The Board consumes monthly; today's close takes 11 days — a <i>daily</i> close is the actual win
MoMo reconciliation	Daily provider file + 15-min fraud window	Settlement is T+1 regardless
Warehouse back-fills / history loads	Batch nights	No consumer waits on them
Price updates	Hourly push to POS	Tills cache prices; minutes add nothing

7. When NOT to go real-time (cost reasons)

"Real-time" proposal	Verdict	Cost reason
Real-time everything across 23 stores	Reject	Several stores are offline hours daily — true real-time is a lie at the edge : the stream would silently report "no events" as "no activity". Every store would need resilient links (WAN capex + recurring) that break the UGX 480M envelope
Real-time ERP (Odoo) replication	Reject	Master/stock data changes at human speed; replicating it continuously buys nothing and adds another always-on integration to maintain with 4 staff
Sub-second analytics for monthly reporting	Reject	Consumer of the data reads it monthly; the entire broker/consumer/monitoring burden would be paid for an audience of a slide deck
24/7 streaming ops coverage	Reject (for now)	Streaming infrastructure that nobody watches at 03:00 is RC-6 (alerts to an unmonitored mailbox) reborn at a higher price; broker + consumers + gap monitoring is a real ops load for a team with zero data-engineering experience
Egress/latency economics	Caution	Continuous sensor egress from 23 sites = recurring cost inside the same envelope; spooling moves bulk transfer to one nightly window
What is approved	Pilot	Footfall pilot, 3 stores, indicative UGX 45–50M (sensors + edge gateways + pilot integration), treated as a roadmap pilot line item — sized to prove (or disprove) the footprint → browse signal before any chain-wide rollout

8. Budget & sequencing note Footfall pilot (3 stores) ≈ **UGX 45–50M indicative**, drawn against the programme roadmap budget, deliberately structured so a failed pilot caps the loss at that line. Broker, CDC and the two consumers run on existing HQ infrastructure (Redpanda single node, Redis) — no per-event cloud fees. Phase gate: pilot metrics

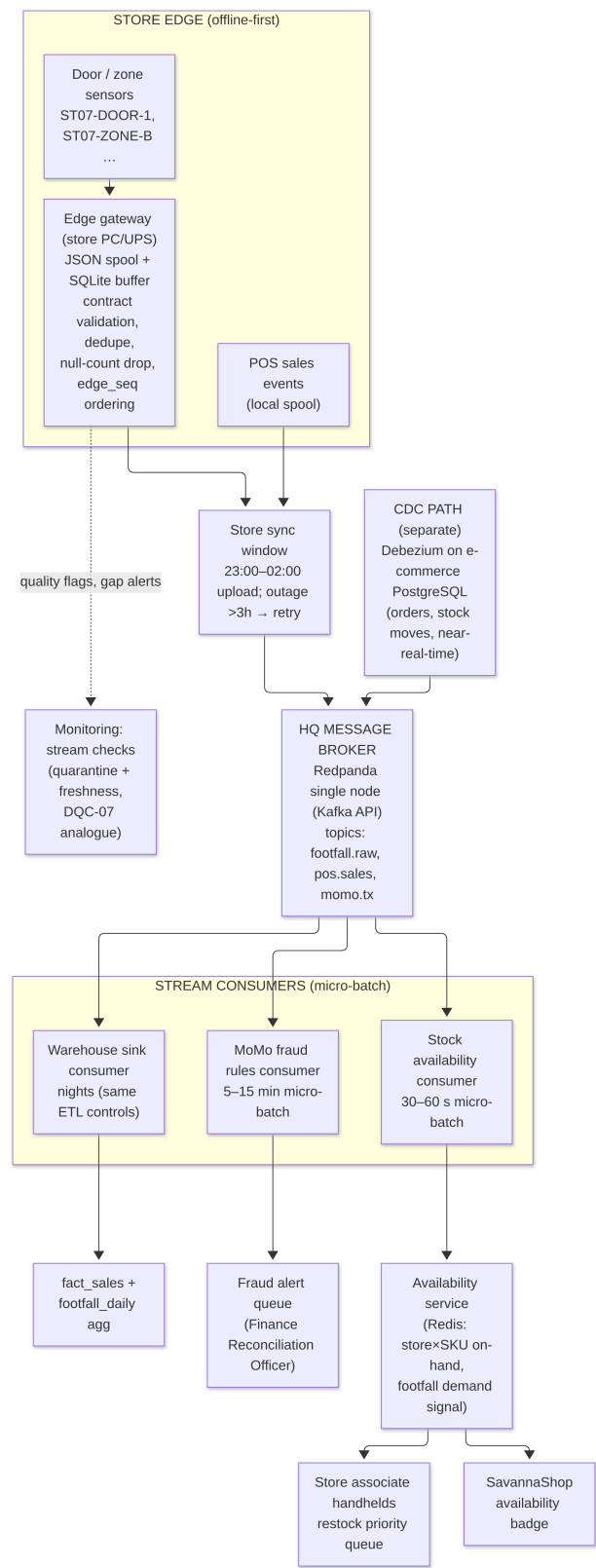


Figure 19: The B4 realtime architecture diagram (1).

(event completeness, gap rate, conversion-signal usefulness) decide whether store 4–23 get sensors, **before** any “real-time everything” conversation resumes.

Think-deeper answer **Where real-time genuinely creates value at SRG:** (1) **Stock availability** — every minute a shelf is empty *and* SavannaShop still promises the item, SRG loses a sale in one channel while holding stock in another; the 30–60 s micro-batch closes that gap at trivial cost, and it is the one place where latency converts directly to revenue. (2) **The fraud window** — MoMo fraud patterns (ref reuse across stores, refund loops, off-hours outliers) are only detectable *within* the window before the money is gone; 5–15 minutes captures the same economic loss as sub-second because settlement is T+1, so the value is in *bounded* freshness, not maximum freshness. In both cases the paying customer of latency is a person making a decision — a shopper checking availability, an officer approving a refund.

Where real-time burns the entire budget for no return: (a) **Real-time ERP replication** — Odoo data changes on human timescales; continuous replication is a permanently-on integration with zero decision attached, and it is the kind of always-on component that fails first in a country where stores drop links for hours. (b) **“Real-time everything” across offline stores** — the edge makes it physically impossible: an offline store cannot stream, so the “real-time” dashboard silently becomes a *wrong-time* dashboard, which is worse than an honestly-labeled batch one (it is RC-4’s stale-fallback anti-pattern at Board scale). (c) **Sub-second analytics for monthly reporting** — the audience reads monthly; here the full cost stack (broker ops, 24/7 monitoring, egress, training for 4 non-DE staff) is incurred to serve a consumer whose decision cadence is 30 days. The precision test for the Board: *name the person, their decision, and the cost of being 15 minutes late*. If the answer is “the monthly pack,” the correct cadence is daily-close, not streaming — and the UGX 45–50M pilot line, not a chain-wide real-time programme, is the honest next step.

Appendix N — Warehouse Data Dictionary (25 Classified Attributes)

SRG Warehouse Data Dictionary (Task C1.1)

Scope: 25 core attributes of the warehouse star schema (star_schema_ddl.sql) **Metadata types covered:** business (definition, owner), technical (type, key), administrative (classification, source system, steward) **Classification taxonomy:** Public (safe for external dashboards/reports) · Confidential (internal business data; leak harms competitiveness, not a person directly) · Restricted (personal/financial identifiers — Uganda DPPA 2019 s.25 “personal data”, GDPR Art.4(1), access only by explicit grant + masking)

#	Table	Column	Data Type	Business Definition	Classification	Primary Source System
1	fact_sales	sale_sk	BIGINT (PK)	Deterministic surrogate key = SHA1(transaction_id); makes loads idempotent	Public	Derived (ETL-generated)
2	fact_sales	transaction_id	TEXT (UQ)	Source receipt/transaction number printed to the customer; traceability hop back to POS/e-comm	Confidential	Legacy POS / SavannaShop e-commerce
3	fact_sales	quantity	INTEGER	Units sold on the line; negative values are customer returns (never deleted — returns are facts too)	Confidential	Legacy POS / e-commerce

#	Table	Column	Data Type	Business Definition	Classification	Primary Source System
4	fact_sales	unit_price_ugx	NUMERIC(14,2)	Price per unit charged at the moment of sale (snapshot from dim_product SCD2 version valid then)	Confidential	Legacy POS / e-commerce
5	fact_sales	net_amount_ugx	NUMERIC(14,2)	Line revenue after discounts, in UGX; additive KPI base for all sales reporting	Confidential	Derived (quantity × price – discount)
6	fact_sales	payment_ref	TEXT	Mobile-money/card transaction reference used for provider reconciliation	Restricted	MTN MoMo / Airtel Money gateway, bank acquirer
7	fact_sales	reconciliation_status	TEXT (CHECK)	Whether payment_ref matched a provider statement: MATCHED / PENDING / MISSING / NOT_REQUIRED	Confidential	Derived (ETL + finance reconciliation)
8	fact_sales	event_ts	TIMESTAMP	Business event time of the sale (not load time) — drives dim_date key and outage-aware reporting	Confidential	Legacy POS / e-commerce / loyalty app
9	dim_customer	customer_sk	BIGINT (PK)	Surrogate identity version key; 0 = “Unknown / Walk-in Customer” (offline capture path)	Public	Derived (ETL-generated)

#	Table	Column	Data Type	Business Definition	Classification	Primary Source System
10	dim_customer	customer_bk	TEXT	Source business identifier (CUST...) joining CRM, loyalty and MDM golden record	Confidential	CRM (SaaS) / Loyalty platform
11	dim_customer	full_name	TEXT	Customer's registered name on the golden record (survivorship: most complete → earliest)	Restricted	CRM / Loyalty registration
12	dim_customer	phone_e164	TEXT	Mobile number standardized to E.164 +2567XXXXXXX; primary contact + loyalty ID link	Restricted	Loyalty app / POS signup / e-commerce checkout
13	dim_customer	email	TEXT	Email address (lowercased, validated); campaign channel + account login	Restricted	E-commerce / CRM
14	dim_customer	district	TEXT	Official Ugandan district of residence (canonical list); geographic segmentation	Confidential	POS signup (enriched/cleansed by ETL)
15	dim_customer	loyalty_tier	TEXT	Current loyalty tier (Gold/Silver/Bronze/None) used for segment-growth analysis	Confidential	Loyalty platform
16	dim_customer	consent_gdpr_eu	BOOLEAN	Lawful basis flag for EU-person data processing (GDPR Art.6 consent/contract)	Restricted	CRM consent capture / Loyalty app T&C

#	Table	Column	Data Type	Business Definition	Classification	Primary Source System
17	dim_product	product_sk	BIGINT (PK)	Surrogate key of the product VERSION valid at sale time (SCD2)	Public	Derived (ETL-generated)
18	dim_product	sku	TEXT	Stock-keeping unit code shared by POS, e-commerce and supplier files (one SKU = one product, VR-008)	Confidential	ERP/Odoo (master), POS, e-commerce
19	dim_product	product_name	TEXT	Human-readable product title shown on receipts and dashboards	Public	ERP/Odoo (master)
20	dim_product	category	TEXT	Canonical merchandise class (Beverages, Grains & Cereals, Snacks, Household, Personal Care, Stationery)	Public	ERP/Odoo (master hierarchy)
21	dim_product	selling_price_ugx	NUMERIC(14,2)	Current shelf/online price in UGX; SCD2-versioned so history never rewrites	Confidential	ERP/Odoo pricing / e-commerce
22	dim_store	store_bk	TEXT	Store code ST01–ST23, ECOM01 — conformed across all five sources	Public	ERP/Odoo store master
23	dim_store	city	TEXT	Trading city (Kampala, Jinja, Mbarara, Gulu) for regional roll-ups	Public	ERP/Odoo store master

#	Table	Column	Data Type	Business Definition	Classification	Primary Source System
24	dim_date	date_sk	INTEGER	Warehouse calendar key (yyyymmdd) for every fact row; supports week/quarter/holiday slicing	Public	Derived (ETL calendar build)
25	dim_payment_method	payment_bk	TEXT	Conformed payment code (MTN_MOMO, AIR-TEL_MOMO, CARD, CASH) used to join payments to facts	Confidential	Payment gateways / POS tender types

Tagging taxonomy applied to the dictionary (Task C1.3)

Tag class	Values in use	Where enforced
Domain	sales, customer, product, store, payment, finance, calendar	Table/column COMMENTS in star_schema_ddl.sql
Sensitivity	Public, Confidential, Restricted	GRANT matrix (rbac_postgresql.sql), masking views (data_masking.sql), COMMENT ON
Quality	standardized (phone/district/UOM), mastered (MDM golden record), derived (surrogate keys, control totals)	dq status columns from Module 2, etl_quarantine outcomes

Lineage note (feeds Task C1.2) monthly active customers KPI=COUNT(DISTINCT dim_customer.customer_sk) on fact_sales where dim_date in month and transaction_id is not a return → sources: Loyalty app signup + POS capture → cleansed (dq_assessment_cleansing.py) → MDM survivorship (srg_etl_pipeline.py golden map) → dim_customer SCD2 → fact_sales → dashboard.

Appendix O — KPI Lineage (Monthly Active Customers) & Address-Schema Impact Analysis

Task C1 Deliverable — KPI Lineage & Metadata for “Monthly Active Customers (MAC)”

Task C1 — Metadata Management (C7) **Client:** Savanna Retail Group (SRG) · **Prepared by:** Lead Enterprise Data Management Consultant **Status:** Draft for Data Governance Council · **Version:** 1.0 **Scope:** End-to-end, board-level KPI lineage for *Monthly Active Customers (MAC)* — definition, hop-by-hop lineage, metadata payload, and the metadata storage model. **Regulatory anchor:** Uganda Data Protection and Privacy Act 2019 (Cap. 97), s.3 principles, s.20 security measures, s.28 rectification/erasure (Cap. 97 consolidated numbering — verify against official gazette before external use); GDPR Art.5 (integrity & accountability), Art.30 (records of processing), Art.32 (security) where EU-resident members are in scope. **Related deliverables:** docs/C1_impact_analysis.md, docs/C1_catalog_tools.md, module5_warehouse/star_schema_ddl.sql, module5_warehouse/data_dictionary.md, module2_data_quality/output/validation_rules.md, module2_data_quality/module3_etl/srg_etl_pipeline.py, module4_security/data_masking.sql.

1. Why a board KPI needs documented lineage SRG’s board reads one customer number every month, yet the number is produced by a chain that crosses 23 offline-capable POS databases, SavannaShop (ECOM01), a 180,000-member loyalty app, an MDM golden-record step, and a star schema — with a documented history of silent failure (root causes RC-1...RC-6 in `module3_etl/etl_diagnosis.md`, incl. 4 days of invisible failure). Lineage for MAC is therefore not documentation overhead; it is the control that makes the KPI **defensible** (DPPA s.3 accountability; GDPR Art.5(2) accountability principle) and **impact-analysable** (see `docs/C1_impact_analysis.md`).

2. KPI definition — Monthly Active Customers (MAC)

2.1 Definition table

Attribute	Definition
KPI ID	KPI-CRM-001
KPI name	Monthly Active Customers (MAC)
Business question	How many distinct identified customers transacted with SRG in the calendar month?
Numerator	COUNT(DISTINCT <code>fact_sales.customer_sk</code>) where <code>customer_sk > 0</code> AND <code>is_return = FALSE</code> AND <code>event_ts >= month_start</code> AND <code>event_ts < month_end</code> (next month 00:00)
Denominator	None — MAC is an absolute count (not a rate). For derived rates the denominator is stated explicitly, e.g. MAC-30d retention = customers active in month $n-1$ who are also in month n , $\div$ active in $n-1$
Filter — walk-ins	<code>customer_sk = 0</code> (“Unknown / Walk-in Customer”, created by CA-2 in <code>module3_etl/srg_etl_pipeline.py</code>) is excluded by design and this exclusion is recorded in the KPI metadata (see §2.3)
Filter — returns	<code>is_return = FALSE</code> (Jul–Dec 2024 baseline contains 500 return lines totalling –UGX 10,224,221)
Time grain	Calendar month, timezone Africa/Kampala (UTC+3); <code>event_ts</code> is the <i>business event</i> timestamp, never <code>load_ts</code>
Owner (accountable)	CRM Officer — definition, interpretation, board commentary
Data steward (custodian)	Data Steward (Marketing Officer) for customer-domain glossary entries; EDM Consultant for technical lineage
Approver of definition changes	Data Governance Council (per Task A2 charter); changes land as a PR against <code>data_dictionary.md</code> + this file
Cadence	Monthly board pack (closed T+2 business days after month-end for offline sync catch-up); dashboard tile refreshes daily with a rolling 30-day variant MAC-30d
Source of record	<code>module5_warehouse/star_schema_ddl.sql</code> → <code>fact_sales dim_customer(is_current = TRUE)</code>
Refresh mechanism	Nightly <code>module3_etl/srg_etl_pipeline.py</code> (idempotent, advisory-locked, <code>etl_run_log</code> audited); aggregation job reads only from the warehouse
Presentation surface	Dashboard tile “Monthly Active Customers” via the analyst masking view (<code>module4_security/data_masking.sql</code>) — raw PII never reaches the tile

Attribute	Definition
Baseline (Jul–Dec 2024)	10,000 sales lines · UGX 252,382,814 net revenue · avg basket UGX 25,238 · repeat buyers 2,447 of 3,362 known customers (72.8%) driving 90.1% of known-customer transactions · new known customers 1,272 → 148/month (–88%) · 69.4% of November’s 1,237 active customers did not buy in December

2.2 Edge cases (must be visible in the KPI metadata, not folklore)

#	Edge case	Treatment	Business consequence if mishandled
E1	Walk-in / unattributed transactions — 8.0% of lines, 8.7% of revenue	Excluded from MAC (customer_sk = 0); disclosed on every board slide as an attribution caveat	MAC understates true buyer count; a dashboard that silently mixed walk-ins in would <i>overstate</i> growth month-over-month
E2	Duplicate identities pre-MDM — 22.84% confirmed duplicate persons before cleansing	MAC is computed only on golden-record-surviving customer_sk (dedupe: 1,142/1,150 merged, 365 homonym pairs rejected, 110 in stewardship review; 5,000 → 3,858 golden records)	Pre-MDM MAC inflated ~1.2×; loyalty points misposted (the 23% duplicate problem)
E3	Residual open duplicate flags — 2.85%	Excluded from auto-merge; records remain flagged; if merged later, SCD2 retro-amends the golden map and MAC restates	Small restatement risk — Council must be told when restatement > 1%
E4	Offline capture crossing month boundary (stores lose connectivity hours daily)	Month close held at T+2 ; event_ts governs, not sync time; replay is idempotent (ETL self-test 1/3 PASS: 10,000 rows before and after re-run)	Late rows double-counted or lost → MAC drift
E5	Returns and exchanges	is_return = FALSE	A return must not deactivate a customer
E6	MoMo PENDING_RECON payment refs — 849 of 7,385 MoMo lines (11.5%)	Payment reconciliation status does not gate customer activity: the transaction occurred; revenue reporting quarantine (VR-012) is a separate concern	Confusing revenue-integrity flags with activity would swing MAC by up to 11.5% of lines
E7	SCD2 mid-month identity change / golden remap	Customer counted once via surrogate key; historical fact rows remapped through the golden map (srg_etl_pipeline.py)	One member counted twice after a profile merge
E8	Loyalty member with no purchase	Not active — MAC measures <i>transactions</i> , not app logins; logins tracked separately as KPI-CRM-002 (candidate)	Conflating the two would mask the –88% new-customer decline

#	Edge case	Treatment	Business consequence if mishandled
E9	Timezone / late-night trades	event_ts normalised to Africa/Kampala; 00:00–03:00 boundary handling documented	Border rows shift between months

2.3 Known limitations (disclosed, not hidden)

- 1. **Walk-in bias:** MAC excludes ~8.7% of revenue-generating interactions; the true “people who bought” number is higher than MAC. Fix path: loyalty phone-capture at POS (target ≥ 95% attribution, monitored by DQC-04).
- 2. **Segment/churn blindness today:** SRG “cannot answer segment growth/churn” — MAC is a top-level count; segment-level MAC requires dim_customer attributes (district, gender, tier) which depend on the address change in docs/C1_impact_analysis.md.
- 3. **Identity debt:** 110 stewardship-review rows and 2.85% open flags mean a small MAC restatement window until the review queue clears.

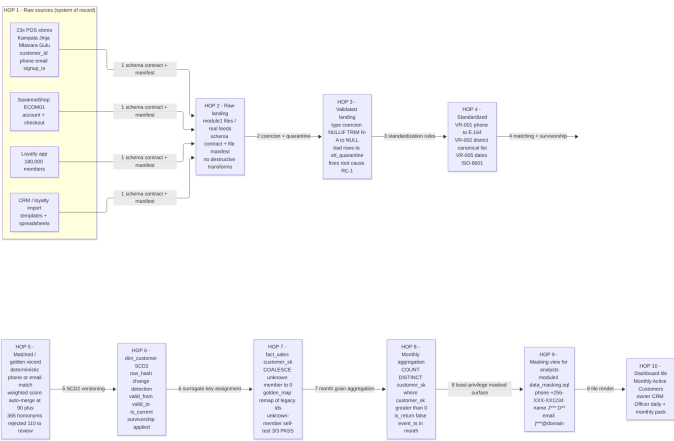


Figure 20: The C1 lineage kpi diagram (1).

3. Lineage diagram — raw sources to dashboard tile

4. Hop-by-hop annotation table

Hop	From → To	System / artifact	Transformation (rule IDs / survivorship)	Metadata captured	Failure handling
1	POS / ECOM01 / loyalty / CRM raw fields (customer_id, phone, email, signup_ts) → raw landing	23× POS MySQL, SavannaShop, loyalty platform, CRM templates → module1_synthetic_data_test in build; real feeds in production	No transformation. Ingest under a schema contract (column names, types, nullability, batch ID)	Source system ID, extract timestamp, row count, control totals, contract version, PII classification tag (POL-001) per column	Contract violation → reject whole file, alert IT Operations Lead (RC-1 lesson: never partial-load); no file → retain last-known-good and mark run SOURCE_MISSING in etl_run_log
2	Raw landing → validated staging	module3_etl/srg_type_validation.py	Type validation: NULLIF (TRIM(x), 'N/A') → empty string → NULL, per-row validation; bad rows → etl_quarantine with error reason	Validation rule per row, error code, quarantine reason, run ID, idempotency key	Quarantine (never silent fallback — RC-4 removed); DQC-07 alerts if quarantine > 0.5% or >100 rows/run; replay from quarantine after source fix
3	Validated → standardized	module2_data_quality (standardize stage)	VR-001 phone → single E.164 format (6 variants → 1); VR-002 district → official Uganda list (127 → 42 labels); VR-005 dates → ISO-8601 (3 formats → 1; 54.4% → 94.5% ISO); UOM and category controlled vocabularies	Rule ID defined before/after value, rule version, standardization timestamp, steward alias approval	Rule failure → block/quarantine per rule severity table; district alias not in map → DQC-03 alert → Data Steward adds alias after approval

Hop	From → To	System / artifact	Transformation (rule IDs / survivorship)	Metadata captured	Failure handling
4	Standardized → matched / golden record	MDM stage in dq_assessment_cluster (deterministic phone/email + weighted score)	Auto-merge requires a positive identifier match (equal phone or email) or score ≥ 90; name similarity alone never auto-merges ; 1,142/1,150 dupes merged, 365 homonym pairs rejected by email-conflict rule, 110 rows → stewardship review ; 5,000 → 3,858 golden records	Match rule ID, match score, cluster ID, survivorship decision per field (e.g. <i>district: latest POS-verified</i>), merge audit trail, reviewer identity for manual merges	Unresolved cluster → review queue; VR-007 blocks loyalty point posting until resolved; DQC-01 escalates to Council if duplicate rate > 2% for 3 days
5	Golden record → dim_customer SCD2	module5_warehouse	row-hash schema_ddl change detection; unchanged → no write; changed → close current row (valid_to, is_current = FALSE) and open new row (valid_from); survivorship applied upstream in the golden map	SCD2 version number, valid_from/valid_to, row_hash, load batch ID, source-system provenance per attribute	Dimension loads before facts (RC-5 fix, CA-5); shared-dimension writes take single-writer advisory lock (RC-3 fix); FK check failure aborts transaction (no orphans)
6	dim_customer → fact_sales.customer_sk	srg_etl_pipeline fact load	COALESCE(customer_id, 0) unknown/walk-in → customer_sk = 0; legacy duplicate ids remapped through golden_map (MDM survivorship)	Unknown-member flag, golden-map version, remap count per run, orphan count (must be 0)	Missing customer_sk = 0 member previously aborted offline rows (RC-2, CA-2); now rows load with revenue preserved while identity is resolved later

Hop	From → To	System / artifact	Transformation (rule IDs / survivorship)	Metadata captured	Failure handling
7	Fact rows → monthly aggregate	Aggregation job over fact_sales	COUNT(DISTINCT customer_sk) with customer_sk > 0, is_return = FALSE, event_ts within calendar month (Africa/Kampala); month close held at T+2 for offline sync	Aggregation SQL version, KPI definition version, period start/end, run timestamp, row count in/out, late-arriving row count	Control-total mismatch → halt (fail-fast, CA-4); etl_run_log + 06:00 run-state check (CA-6); never publish a partial month
8	Aggregate → analyst surface	module4_security view + rbac_postgresql.roles	Analyst read the masked view only: phone → +256-XXX-XX1234, name → J*** D**, email → j***@domain; raw columns reachable only by compliance_officer / cdm_admin via column-level GRANT (default-deny)	Role used, view name, columns exposed, masking-function version, query audit (pg audit log)	Denied query → denied (15-test rbac_test.sql reference output 15/15 PASS; data_masking_demo.py 4/4 checks on live data); attempt to bypass the view → access review escalation
9	Analyst surface → dashboard tile	BI dashboard tile “Monthly Active Customers”	Render KPI-CRM-001; show walk-in exclusion footnote + last-refresh timestamp; rolling MAC - 30d variant labelled separately	Tile ID, KPI ID/definition version, data-as-of timestamp, owner, last definition change (PR reference)	Stale-data guard: if etl_run_log shows failed run, tile shows “data as of ” banner (RC-6 lesson: no silent stale data)

5. Which metadata types ride along

Metadata type	Examples travelling with MAC	Recorded where (today)
Technical	Column names/types, schema contract, quarantine error codes, row_hash, SCD2 validity columns, surrogate keys, SQL/job version, run IDs, control totals, masking-function definitions	star_schema_ddl.sql, srg_etl_pipeline.py comments + etl_run_log, validation_rules.md, dq_monitoring_spec.md

Metadata type	Examples travelling with MAC	Recorded where (today)
Business	KPI definition & exclusions (walk-ins, returns), golden-record survivorship rules, controlled vocabularies (district list, UOM, category), glossary terms (customer, member, active, walk-in), segment definitions	This file (§2), <code>data_dictionary.md</code> (25 attributes: meaning + business name), README glossary
Administrative	Ownership (CRM Officer), steward (Marketing Officer), approval (Data Governance Council), classification tags (Public/Confidential/Restricted from <code>data_dictionary.md</code> = POL-001 sensitivity tags), retention (POL-003), lawful-basis/consent reference (DPPA s.7; GDPR Art.6/7), review cycle	<code>data_dictionary.md</code> classification column + tagging taxonomy (domain/sensitivity/quality); Task A2 charter for role names
Operational	DQC-01...DQC-10 results, alert thresholds, escalation roles, remediation commands	<code>module2_data_quality/output/dq_monitoring_</code>
Lineage	The 9 hops above, hop owners, transform rule IDs	Today: this document + ETL code annotations; future: catalog (below)

6. Where lineage is stored: today vs future

	Today (Phase 1 — metadata-as-code)	Future (Phase 2 — catalog pilot)
Storage	This GitHub repo: <code>docs/*.md</code> , <code>module5_warehouse/data_dictionary.md</code> , ER/star-schema DDL, ETL inline annotations, README glossary	Self-hosted OpenMetadata or DataHub (see <code>docs/C1_catalog_tools.md</code> for the weighted evaluation and budget line)
Change control	Pull request reviewed by the EDM Consultant; domain steward owns their glossary rows; quarterly dictionary review + event-driven review on schema change	Same PR flow, but the catalog ingests column-level lineage automatically from the Python ETL; PR bot attaches lineage diff to the change request
Strengths	~zero licence cost inside the UGX 480,000,000/yr envelope; versioned with the code it describes; works for a 4-person IT team	Searchable glossary, automated column lineage, DQ-result surfaces, API for RoPA export (GDPR Art.30)
Weakness	No UI/search; lineage is read-as-text; manual hop maintenance	Hosting/setup indicatively UGX 15–25M/yr all-in; needs 1 stable owner

Rule: the KPI definition in §2 is the *single source of truth*; any tool rendering MAC must link back to KPI-CRM-001 in this file (and later, to the catalog entry seeded from it).

Think-deeper answer Prompt (implicit): if MAC excludes 8.7% of revenue and 2.85% of identities are still flagged, is a “clean” KPI actually honest?

Yes — provided the impurities are *declared metadata*, not buried footnotes. Three arguments: (1) **A disclosed exclusion beats an undocumented inclusion.** The pre-MDM count would have included ~23% duplicate identities, i.e. a KPI that rose while real customer growth fell (new known customers 1,272 → 148/month). That is the failure mode that destroys board trust; excluding walk-ins instead biases the number *downward by a known, measured amount* (8.0% of lines / 8.7%

of revenue) and the gap itself is the CRM capture KPI. (2) **Lineage converts disagreement into engineering.** Once hops 1–9 carry rule IDs (VR-001/002/005, survivorship, COALESCE-to-0), a challenge to MAC becomes a challenge to a named rule with an owner — resolvable in a pull request rather than a meeting. (3) **The residual is bounded and monitored.** DQC-01 caps the duplicate rate at 1.0% (2.0% = P1 incident), DQC-03 caps district resolution at 99.5%, so the 2.85% open flags cannot silently grow. The honest position for the board: MAC is *defensible and directional*, exact to $\pm$ the disclosed walk-in band, and the roadmap to shrink that band is the loyalty-capture and stewardship-queue work already scheduled — not a cosmetic redefinition.

Task C1 Deliverable — Change Impact Analysis: Customer Address Schema Restructure

Task C1 — Metadata Management (C7) · **Client:** Savanna Retail Group (SRG) · **Prepared by:** Lead Enterprise Data Management Consultant · **Status:** Draft for Data Governance Council · **Version:** 1.0 · **Proposed change ID:** CHG-ADDR-001 — replace single free-text `district TEXT` with a structured address block. · **Classification:** Confidential (internal) · **Regulatory anchor:** DPPA 2019 (Cap. 97) s.3 (accuracy/principles), s.11 (collection from data subject), s.24/s.28 (access, rectification); GDPR Art.5(1)(d) accuracy, Art.16 rectification, Art.25 protection by design where EU members are in scope (Cap. 97 consolidated numbering — verify against official gazette before external use). · **Cross-references:** docs/C1_lineage_kpi.md (KPI-CRM-001 lineage hops 3–6), docs/C1_catalog_tools.md (catalog change record), Task A2 charter (steward/Council roles, POL-001 tags).

1. Change description

Field	Value
Change ID	CHG-ADDR-001
From	<code>district TEXT</code> (free text; standardised post-hoc to the official district list, 127 raw labels → 42 canonical)
To	<code>address_line1 TEXT NULL</code> , <code>address_line2 TEXT NULL</code> , <code>city TEXT NULL</code> , <code>district TEXT REFERENCES dim_district(district_code)</code> (FK to official list), <code>region TEXT</code> (lookup from district — Northern/Eastern/Central/Western), <code>postal_code TEXT NULL</code> , <code>gps_lat/gps_lon NUMERIC NULL optional, opt-in only</code>
Why	Free text is why SRG had 127 district labels; a FK enforces VR-002 <i>structurally</i> instead of by rule; region unlocks trade-area/logistics zone reporting; structured lines enable delivery routing for the omnichannel model
New reference table	<code>dim_district</code> (<code>district_code</code> PK, <code>district_name</code> , <code>region</code> , <code>valid_from</code> , <code>valid_to</code>) seeded from the official Uganda district list (42 labels after cleansing)
Privacy note	Address fields are Confidential ; precise GPS stays opt-in (no silent collection — DPPA s.7/s.11; GDPR Art.6(1)(a) + Art.25 for app consent; see docs/C2_dpia_loyalty_app.md §3 minimisation)
Default risk rating	MEDIUM-HIGH: touches capture forms, MDM, ETL, security views, warehouse, and 3 dashboard surfaces

2. **Dependency analysis** · Impact counts (summary): **15 downstream dependencies** · **3 dashboard tiles/filters** · **3 data-quality rules/checks** (VR-002, DQC-03, DQC-04) · **6 code paths/SQL artifacts** · **4 capture forms/templates** · **2 report packs** · **1 data-dictionary row (#14)** · **1 survivorship rule** · **1 MDM attribute policy**.

Dependency ID	Downstream artifact / process	Current usage	What breaks	Change required	Owner	Effort
DEP-01	module2_data_quality + before_after_profile_metric — “District stored as official name” + DISTRICT_VARIANTS variant maps (127 → 42 labels) + VR-002 + DQC-03	Profiling output / counts distinct metrics; standardisation maps variants → canonical; VR-002 validates membership of the official list; DQC-03 alerts at < 99.5% resolution	With FK, before map “distinct raw labels” and “alias map” become vestigial — but removing them too early breaks legacy-row backfill and re-profiling of pre-migration data ; DQC-03’s “new unresolved label pattern > 50 rows/day” trigger can no longer fire (input is constrained), giving false green	Keep alias map for backfill only; rewrite VR-002 as “FK resolves AND district = dim_district.district_name”; re-baseline DQC-03 to FK-violation count + orphan count (threshold: > 0 = incident); add DQC-04 field split (city, region completeness)	Data Steward (Marketing Officer) + EDM Consultant	M
DEP-02	module2_data_quality survivorship rule “district: latest POS-verified”	Identify merging duplicate identities, district value from the most recent POS-verified record wins	Merged records mix old free-text district with new FK value → survivorship compares incompatible types; a stale free-text value could beat a valid FK	Version the survivorship rule: after cutover, survivorship selects the latest valid FK row ; free-text rows are auto-downgraded to “unverified” and never win	EDM Consultant	S

Dependency ID	Downstream artifact / process	Current usage	What breaks	Change required	Owner	Effort
DEP-03	module3_etl/sr — dim_customer load (SCD2, row_hash)	Reads pipeline cleansed customer files, computes row_hash, opens/closes SCD2 versions; golden-map remap	New columns change row_hash inputs → every existing customer row looks “changed” → mass SCD2 version churn (3,858 golden records re-versioned in one run, bloating history and restating history-dependent marts)	Add columns to the hash <i>selectively</i> (hash new fields only after backfill verified); staged rollout flag; pre/post row-count control totals; dimensions still load before facts (CA-5)	IT Operations Lead (SQL-capable)	M
DEP-04	module4_security — customers_masked view (district passthrough) + rbac_postgres RLS	Analytics on non-identifying district (comment: “ <i>geographic district is non-identifying</i> ”); RLS scopes by store_sk	View column list no longer resolves (SQL error for every analyst role); new columns address_line1/2 and GPS are identifying and would leak through an unchanged passthrough; masking demo expectations shift	Extend view with new columns explicitly classified: district, city, region pass through; address_line1/2, gps_* masked/omitted for data_analyst, raw only via column GRANT to compliance_officer/cdm_admin; RLS logic unaffected (store-scoped, not address-scoped) — regression-test only	Head of IT	M

Dependency ID	Downstream artifact / process	Current usage	What breaks	Change required	Owner	Effort
DEP-05	module5_warehouse — dim_customer + data_dictionary row #14 (dim_customer.TEXT, Confidential, “POS signup (enriched/cleansed by ETL)”) data_dictionary	Used in source DDL + 25-attribute dictionary classification	DDL.sql dictionary row #14 and tagging taxonomy become wrong; geo segmentation metadata stale; catalog seed (Phase 1) inherits the error	Extend DDL (new columns + dim_district + FK); split dictionary row #14 into rows #14a–#14g with per-attribute classification (address_line1/2 = Restricted-adjacent Confidential, GPS = Restricted); update source/lineage hop notes	EDM Consultant	M
DEP-06	Dashboard district/geo filters — 3 tiles (revenue by district/city map, store trade-area comparison, customer-home-district mix)	Filter/group on free-text district	Any tile grouping by raw text splits on legacy variants; new city/region fields not present historically → blank groups; KPI footnotes in docs/C1_lineage_kpi.md (walk-in caveat) unaffected but geo tiles must re-point	Re-point to canonical FK/dim_district backfill-dependent tiles get a “geo completeness from ” banner; retire one free-text filter	CRM Officer (tile owner) + EDM Consultant	S
DEP-07	MDM golden record (match + survivorship + review queue)	District used as corroborating attribute in the weighted score and in stewardship review display	Type mismatch in scoring inputs; stewards see blank district for migrated rows if backfill lags → wrong review decisions	Add structured address to golden-record display; hold district’s score weight at 0 until backfill verified ≥ 99.5%	EDM Consultant	S

Dependency ID	Downstream artifact / process	Current usage	What breaks	Change required	Owner	Effort
DEP-08	POS signup form (23 stores, offline-capable)	Free-text or loosely-typed district entry at till	Form writes column that no longer exists / can't satisfy FK offline → checkout blocked during outages (stores are already offline hours daily)	Drop-down/alias picker (VR-002 intent made structural), offline-friendly : store district <i>code</i> locally, queue FK resolution on sync; keep free-text fallback disabled after cutover; cashier retraining	Retail Systems Manager	L
DEP-09	E-commerce checkout (SavannaShop ECOM01)	Address block for delivery; district free text	Checkout API contract break → failed orders; address validation latency	Version the API (additive first, deprecate old field after 1 ETL cycle); server-side district picker; validate against <code>dim_district</code>	E-commerce Lead (SQL-capable)	M
DEP-10	CRM import template (spreadsheets + SaaS CRM)	Analysts import member lists with district column	Imports rejected by FK → campaign uploads fail silently downstream	Re-issue template with <code>district_code</code> + <code>city</code> + <code>region</code> + data-validation dropdowns; add template version column; reject stale templates at load (schema contract, hop 1)	CRM Officer	S

Dependency ID	Downstream artifact / process	Current usage	What breaks	Change required	Owner	Effort
DEP-11	Loyalty profile capture (app / in-store forms)	Profile completion screen stores district; 180k members	Profile save failures; existing members keep old free-text value until they edit	App: structured picker; do not force re-entry — migrate server-side; in-app edit triggers the new format	CRM Officer + Product Owner	M
DEP-12	Delivery / logistics zone reports	Manual zone assignment from district text	Misrouted deliveries where legacy variants differ; region not available → zones re-cut	Rebuild zone mapping on <code>dim_district.region</code> ; validate 100% of active delivery addresses post-backfill	Logistics Officer	M
DEP-13	Store trade-area reports (customer home district → store trade area)	Group customers by district text, then by store	Grouping splits on legacy labels; double counting across 42 vs 127 labels	Recut on canonical FK; restate Jul–Dec 2024 trade-area baselines; document restatement in board pack	Merchandising Officer + EDM Consultant	S
DEP-14	module4_security_test_rbac_mysql_appends column list	15/15 test RBAC fixture inserts <code>district</code> value; MySQL appendix lists district in column grants	Fixture INSERT fails → test suite red; appendix GRANTS miss new identifying columns (privilege gaps)	Update fixtures and both GRANT scripts; re-run suite (reference evidence: 15/15 PASS → must stay 15/15 PASS on PostgreSQL 15/16)	Head of IT	S
DEP-15	Monitoring: scripts/dq_checks district metrics used by DQC-03/DQC-04 + <code>dq_monitoring_spec.md</code>	Daily district completion & checks with remediation commands	Metrics measure the old reality; alerts either fire permanently or never fire	Re-point metrics to FK/orphan logic; update escalation text and remediation commands in <code>dq_monitoring_spec.md</code> ; keep DQC-03 threshold at 99.5%	IT Operations Lead	S

Effort totals: S = 6 · M = 8 · L = 1 (POS form). Calendar estimate with SRG's 4-person IT team (2 SQL-capable, 0

data-engineering): **10–14 weeks elapsed**, POS form on the critical path.

3. Migration plan

Phase	Weeks	Activities	Exit criteria (gate)
P0 — Prep & design	1–2	Council approval (Task A2 charter); create <code>dim_district</code> seeded from the 42 canonical districts + region lookup; freeze the address contract (column list, nullability, codes); classify new attributes in <code>data_dictionary.md</code> (POL-001 tags); notify all 15 dependency owners (<code>docs/C1_catalog_tools.md</code> governance process)	Signed change record; <code>dim_district</code> reviewed by Data Steward; API/form designs agreed
P1 — Dual-write	3–5	Ship additive schema (new columns nullable , old district retained); POS/ECOM/CRM/loyalty write both old text and new structured fields; dashboard unchanged; ETL loads both	7 days of dual-write with ≥ 99% of new signups carrying a valid <code>district_code</code> ; zero checkout/form outages
P2 — Backfill	6–8	Backfill district FK from the official list using the existing alias map (127 → 42); derive region from <code>dim_district</code> lookup; city from store/delivery profile where derivable, else NULL (never fabricated); unmatched → stewardship queue; re-run standardisation stage of <code>module2_data_quality/dq_assessment_cleansing.py</code>	≥ 99.5% FK resolution (DQC-03 threshold); 0 unmatched rows left silently ; backfill report to Council
P3 — Rule & view update	8–9	Rewrite VR-002 (FK + name equality); re-baseline DQC-03/DQC-04; extend <code>customers_masked</code> view (passthrough for district/city/region, suppression for address lines/GPS); update <code>rbac_test.sql</code> fixtures + MySQL appendix; update survivorship rule (DEP-02)	Rule tests green; RBAC suite 15/15 PASS (reference procedure on PostgreSQL 15/16); masking demo still 4/4 checks

Phase	Weeks	Activities	Exit criteria (gate)
P4 — Cutover	10	Make district FK NOT NULL for new rows; disable free-text entry at all 4 capture points; re-point the 3 dashboard tiles; rebuild delivery zones + trade-area reports; update dictionary rows #14a–#14g; PR merged (metadata-as-code change control)	All gates P1–P3 green; tiles show no blank groups; Logistics sign-off on zones
P5 — Monitor & close	11–14	Daily DQC-03 (FK/orphan) + DQC-04 watch for 30 days; row_hash churn monitored in etl_run_log; hold rollback switch (old column retained) for 30 days post-cutover; then deprecate free-text column (drop only after one full quarterly dictionary review)	30 days with zero P1 DQ incidents attributable to address; Council closes CHG-ADDR-001

4. Validation queries

-- V1: FK integrity – must return 0 rows after cutover

```
SELECT c.customer_sk, c.district
FROM dim_customer c
LEFT JOIN dim_district d ON d.district_name = c.district AND d.valid_to IS NULL
WHERE c.is_current AND c.district IS NOT NULL AND d.district_code IS NULL;
```

-- V2: Backfill coverage (gate: >= 99.5%)

```
SELECT COUNT(*) FILTER (WHERE district_code IS NULL) * 100.0 / COUNT(*) AS pct_unresolved
FROM dim_customer WHERE is_current;
```

-- V3: Region derivability – no customer without a region after P2

```
SELECT COUNT(*) AS missing_region FROM dim_customer WHERE is_current AND region IS NULL;
```

-- V4: SCD2 churn guard – version-per-customer must stay ~1 (alert if > 1.05 avg)

```
SELECT COUNT(*) * 1.0 / NULLIF(COUNT(DISTINCT customer_sk), 0) AS versions_per_customer
FROM dim_customer;
```

-- V5: Fact integrity – no orphan facts, unknown-member band unchanged

```
SELECT COUNT(*) AS orphan_facts FROM fact_sales f
LEFT JOIN dim_customer c ON c.customer_sk = f.customer_sk
WHERE c.customer_sk IS NULL;
```

-- V6: Legacy label leakage (raw landing) – expect 0 after P4

```
SELECT COUNT(*) FROM raw_customers
WHERE district IS NOT NULL AND district_code IS NULL;
```

-- V7: Re-run the district profile metric for before/after evidence

-- python module2_data_quality/dq_assessment_cleansing.py --stage profile

-- V8: Monitoring re-baseline evidence

-- DQC-03 = FK violation count + orphan count; DQC-04 = city/region completeness

5. Rollback plan

Trigger	Action	Data safety
Cutover-day SQL/view failure, > 1% checkout or POS signup failures, FK constraint blocking offline sync replay, tile outage > 2h	Revert to Phase P1 state: re-enable free-text writes, point views/tiles back to legacy district, restore prior VR-002 and DQC-03 definitions from git, revert API version	Old district TEXT column is retained and maintained through P5 — no data loss; dual-written rows remain compatible in both shapes
Partial failure (e.g., only POS offline-sync broken)	Feature-flag the FK enforcement off for offline queue only; online paths stay on new schema; fix forward within 48h	Quarantine table keeps rejected rows; replay after fix (never silent drop)
Backfill produced wrong district mapping	Restore from pre-P2 snapshot of dim_customer + raw landing (backup taken at P2 start), correct alias map, re-run backfill	SCD2 history preserved; correction is a new version, not an overwrite
Rollback after cutover	Council notified within 4h; incident logged; monitoring reverts to legacy DQC-03 for the rollback window	Rollback decision + reason recorded in change register (accountability, DPPA s.3)

Rollback owner: Head of IT (Incident Lead per docs/C2_breach_response_plan.md roles). **Authority to roll back:** Head of IT, no waiting for Council (Council informed, not consulted, to protect the 4-hour target).

6. Communication to affected owners

Audience	Channel & timing	Message	Owner
Data Governance Council	Change review, week 0; gate reviews weeks 5, 9, 14	Approve CHG-ADDR-001, Effort totals, rollback authority, restatement policy	EDM Consultant
15 dependency owners (DEP-01...DEP-15)	Dependency notice pack + 45-min walkthrough, week 1; reminder 5 working days before cutover	What changes in <i>their</i> artifact, dates, their action, and the escalation path	EDM Consultant
Store managers (23 stores)	Ops briefing + 1-page till notice, week 8; cashier micro-training at cutover	New district picker, offline behaviour, what to do if the list is missing (do not free-type)	Retail Systems Manager
IT team of 4	Sprint planning weeks 1–2; runbook handover week 10	Runbook: validation queries V1–V8, rollback switch, monitoring re-baseline	Head of IT
Finance / Logistics / Merchandising	Report re-cut notice, week 9	Trade-area and zone baselines restated for Jul–Dec 2024; figures change <i>because</i> definitions changed, not because sales changed	EDM Consultant
CRM / Marketing	Template re-issue, week 5	New import template version; old templates rejected from week 10	CRM Officer
EU distributor partner (GDPR Art.13/14 transparency)	Partner notice before cutover if address fields are shared for fulfilment	Field-level change, lawful basis unchanged, updated Art.30 record entry	DPO (once appointed — see docs/C2_compliance_audit_checklist_CHK-02)

Metadata rule for this change: no artifact in the table above is “done” until its row in `module5_warehouse/data_dictionary.md` and its lineage hop in `docs/C1_lineage_kpi.md` are updated in the same pull request (metadata-as-code, see `docs/C1_catalog_tools.md`).

Think-deeper answer **Prompt:** is this “just a column change”? What does the dependency table reveal that a naive migration would miss?

It is not — and the register exposes three traps a naive migration hits. **First, the row_hash trap (DEP-03):** adding columns to `dim_customer` makes every one of the 3,858 golden records look *changed* in one nightly run, generating 3,858 SCD2 versions, restating history-dependent marts, and destroying trust in `valid_from/valid_to` — the fix (staged hashing, gated by verified backfill) is invisible unless you understand SCD2 semantics. **Second, the offline trap (DEP-08):** SRG loses connectivity hours daily, so an FK enforced naively at the till turns a metadata change into a *checkout outage* — the constraint must be satisfied asynchronously at sync time, which inverts the usual “just add the constraint” advice. **Third, the security trap (DEP-04):** a masking view that passed through `district` because it was “non-identifying” will, if extended carelessly, pass through `address_line1` and `GPS` — a confidentiality regression introduced by a *data-modeling* change, caught only because classification metadata (POL-001 tags) rides along with the schema. The broader lesson: in SRG’s state of maturity, the real cost of a schema change is not the DDL — it is the **15 artifacts whose metadata must change in the same pull request**, which is precisely the argument for the catalog investment sequenced in `docs/C1_catalog_tools.md`.

Appendix P — Data Catalog Taxonomy & Metadata Tool Evaluation

Task C1 Deliverable — Metadata Catalog & Tooling Recommendation

Task C1 — Metadata Management (C7) **Client:** Savanna Retail Group (SRG) · **Prepared by:** Lead Enterprise Data Management Consultant **Status:** Draft for Data Governance Council · **Version:** 1.0 **Decision requested:** approve the staged lightweight metadata approach (Phase 1 metadata-as-code → Phase 2 self-hosted catalog pilot) and reject Apache Atlas and Collibra. **Budget envelope:** UGX 480,000,000/year (~USD 130,000; 1 USD ≈ UGX 3,700) covering licences, cloud and hires; IT team of 4 (2 SQL-capable, **zero data-engineering**); quick wins required by month 6; expansion to Kenya/Rwanda + European distributor partnership requiring GDPR-equivalent practice. **Cross-references:** `docs/C1_lineage_kpi.md` (lineage to be catalogued), `docs/C1_impact_analysis.md` (catalog as change-control surface), Task A2 charter (steward/Council roles, POL-001 classification tags), `module5_warehouse/data_dictionary.md` (seed content).

1. Evaluation criteria (weights sum to 100)

#	Criterion	Weight	Why it matters at SRG
C1	Cost within budget	25	Every shilling spent on tooling competes with stores, cloud, and hires inside UGX 480M/yr
C2	Operable by a 4-person team (0 data engineers)	20	A tool nobody can run becomes shelfware; Java/Hadoop ops skills do not exist in-house
C3	Integrations with PostgreSQL / MySQL / Python ETL	20	SRG’s real stack: 23× MySQL POS, PostgreSQL warehouse, <code>srg_etl_pipeline.py</code> (SQLAlchemy)
C4	Business glossary + lineage UX	15	Stewards and the Council must <i>use</i> it; 23% duplicate-customer history proves glossary gaps hurt

#	Criterion	Weight	Why it matters at SRG
C5	Community / support	10	No vendor SLA at Phase 1 price points; community is the support model
C6	Cloud-readiness / Kenya–Rwanda scalability	10	Multi-country rollout within 18 months; catalog must scale with the estate, not precede it
	Total	100	

Scoring: 1 = does not meet · 5 = fully meets. **Weighted total = $\Sigma(\text{weight} \times \text{score}) \div 5$, out of 100.**

2. Weighted comparison

Option	C1 Cost (25)	C2 Team fit (20)	C3 Integrations (20)	C4 Glossary/lineage UX (15)	C5 Community (10)	C6 Cloud/scale (10)	Weighted total /100
OpenMeta-data (self-hosted, Phase 2 target)	5	4	5	4	4	4	89.0
DataHub (self-hosted, runner-up)	5	3	5	3	4	4	82.0
Metadata-as-code in this repo (Phase 1)	5	5	3	2	4	4	79.0
Atlan (commercial SaaS — considered)	2	4	5	5	3	5	77.0
Collibra (commercial — considered)	1	3	4	5	4	5	66.0
Alation (commercial — considered)	2	3	4	4	3	4	64.0
Apache Atlas (OSS — considered)	3	1	2	2	3	2	43.0

Scoring notes: Collibra scores 1 on cost because indicative enterprise licensing of **USD 30k–60k+/yr** $\approx$ **UGX 110M–220M/yr** is 23%–46% of the entire UGX 480M envelope; its governance/workflow UX is genuinely the best in class (5) — which is exactly the capability SRG cannot yet exploit without a mature steward model. Atlan/Alation pricing is not published; scored at commercial-SaaS parity with Collibra-class budgets (assumed mid-to-high five figures USD) —

a figure SRG cannot verify, hence 2. Apache Atlas scores 1 on team fit (Hadoop/Java operational burden) and 2 on integrations (native strength is HDFS/Kafka/Hive, not PostgreSQL/MySQL/Python). DataHub scores 3 on team fit (more moving parts: GMS + search/indexing + event bus) and 3 on glossary UX versus OpenMetadata's faster-improving UI.

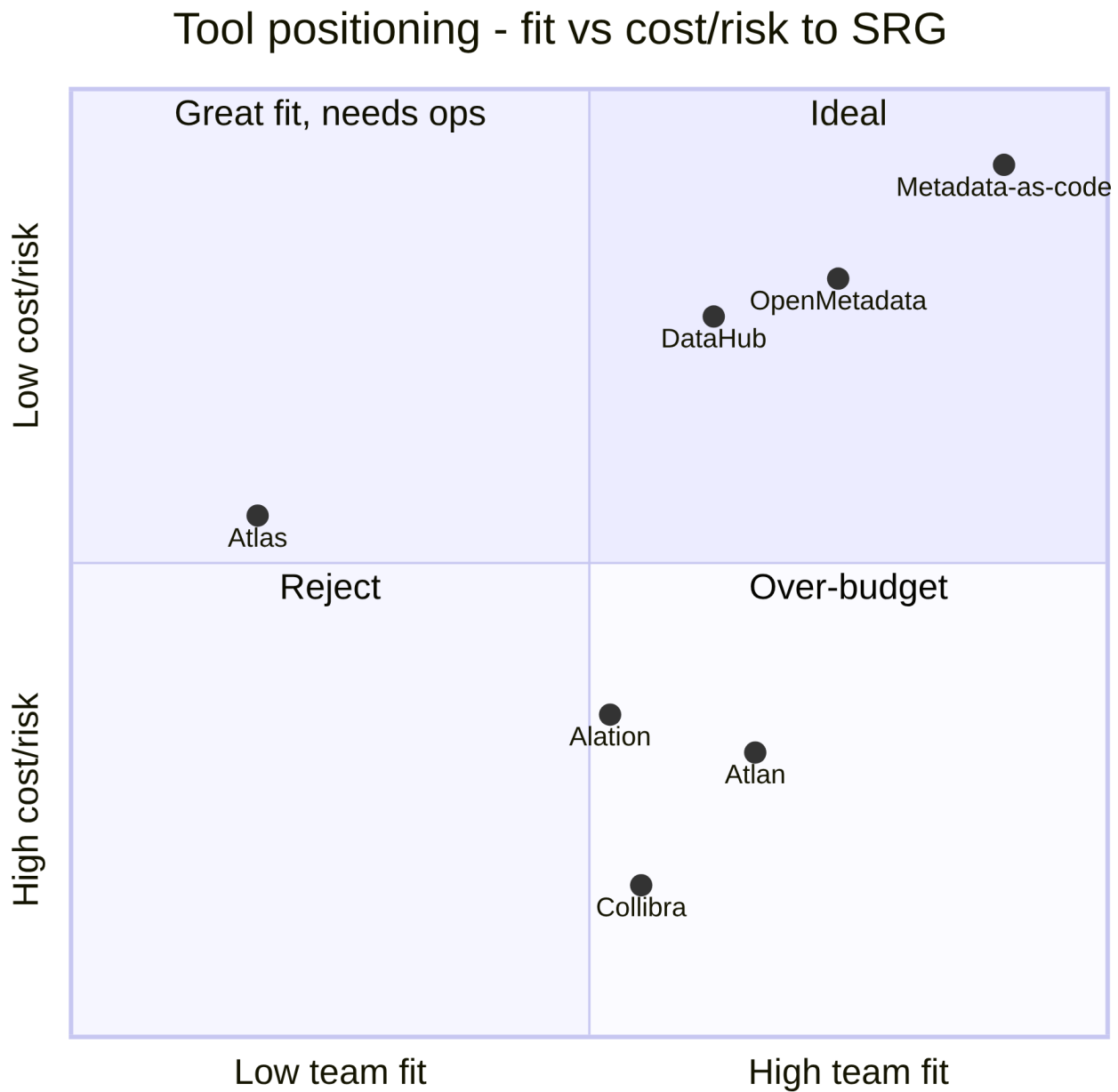


Figure 21: The C1 catalog tools diagram (1).

3. Alternatives considered and rejected (with reasons)

Option	Considered for	Decision	Reason
Apache Atlas	Free, strong lineage, mature business-metadata model	Reject — explicit	Requires the HDFS/Kafka/Hive ecosystem SRG does not have and will not build; Java operations burden for a 4-person team with zero data-engineering staff; no first-class PostgreSQL/MySQL/Python-ETL story; lineage would need custom hooks into <code>srg_etl_pipeline.py</code> . Stack mismatch, not price, is decisive
Collibra	Strongest governance workflows, stewardship UI, lineage UX	Reject — explicit	Indicative enterprise licensing USD 30k–60k+/yr ≈ UGX 110M–220M/yr = up to ~45% of the entire UGX 480M budget . That spend would land before SRG has an operating steward model, a catalogue of pipelines, or a completed PDPO registration — buying maturity tooling for a maturity level the client cannot yet exploit
Atlan / Alation	Modern SaaS catalog UX	Considered, not shortlisted	Commercial SaaS pricing at Collibra-class budgets (unpublished); UX advantage does not offset budget weight C1 or the need to first prove glossary adoption
DataHub	OSS, strong lineage ingestion, PostgreSQL/MySQL connectors	Reserve option (Phase 2 shortlist)	Excellent technical fit; heavier runtime and glossary UX slightly behind OpenMetadata for SRG's business-user stewards
Purview / cloud-native catalog	Bundled with cloud	Deferred	Locks the catalog to one cloud before SRG's Kenya/Rwanda cloud decision; revisit at Phase 2 exit
No catalog at all (status quo)	Zero cost	Reject	Status quo already costs money: 23% duplicate customers, 11-day monthly reporting, five product identifiers, no answer to segment growth/churn

4. Recommendation — staged lightweight approach

Phase 1 (months 1–9): “metadata-as-code” in this GitHub repo — ~zero licence cost

Component	Location	Content
Data dictionary	module5_warehouse/data_dictionary	5 attributes with classification (Public/Confidential/Restricted), source systems, tagging taxonomy (domain/sensitivity/quality)
ER / star-schema models	module5_warehouse/star_schema_ddl	fact sales + 5 dims, SCD2 customer/product — the model is the technical metadata
Business glossary	README.md glossary section + docs/	KPI definitions (docs/C1_lineage_kpi.md §2: walk-in exclusion, golden record, active customer), controlled vocabularies (42 districts, UOM, categories)
Lineage	docs/C1_lineage_kpi.md hop table + module3_etl/srg_etl_pipeline.py annotations	9 hops with VR/DQC rule IDs and failure handling
DQ metadata	module2_data_quality/output/validation_rule01.md, dq_monitoring_spec.md	VR-001 rule, DQC-01...DQC-10 with owners and thresholds
Change control	Git pull requests	Impact analysis (docs/C1_impact_analysis.md) attached to every schema change

Why Phase 1 first: SRG’s metadata does not need a *platform* yet; it needs *discipline* — single-sourced definitions, PR-based change control, and one owner per glossary entry. A catalog ingested today from inconsistent sources would automate the inconsistency. Cost: **UGX ~0 licence**; ~0.2 FTE EDM Consultant time; fits the “quick wins by month 6” constraint (dictionary + glossary + lineage live in month 1–2).

Phase 2 (months 10–18): pilot OpenMetadata or DataHub self-hosted

- **Trigger (entry gate):** ≥ 2 pipelines stable — (1) srg_etl_pipeline.py green for 60 consecutive days with quarantine < 0.5% (DQC-07), (2) a second governed feed (DQ monitoring or the address-migration ETL from docs/C1_impact_analysis.md) running with documented owners; PDPO registration filed (CHK-01) so the catalog’s register/RoPA exports have a compliance home.
- **Scope:** ingest PostgreSQL schema + MySQL POS metadata, Python-ETL column lineage, glossary seeded from Phase 1, sensitivity tags mapped 1:1 to POL-001 classification tags.
- **Indicative cost:** **UGX 15–25M/yr all-in** (cloud instance/VM, storage, backup, minor setup effort) = **3.1%–5.2% of the UGX 480M envelope**; no new FTE — one of the 2 SQL-capable staff becomes catalog owner with vendor/community support.
- **Exit gate (month 18):** ≥ 80% of warehouse tables with automated column lineage; glossary adoption by all domain stewards; DQ results (DQC-01...10) surfacing in the catalog; Council uses the catalog as the system of record for change approvals.

Budget justification against the UGX 480M envelope

Line	UGX/yr	% of 480M	Verdict
Colibra (indicative)	110M–220M	23%–45%	Rejected — would crowd out endpoint encryption, backup, and the DPO hire (see docs/C2_encryption_masking_spec.md §b)
Phase 1 metadata-as-code	~0	~0%	Approved
Phase 2 self-hosted catalog	15–25M	3%–5%	Approved for pilot , funded from the platform/cloud line
Apache Atlas	Licence 0, but opex of senior Java/Hadoop time SRG does not have	n/a	Rejected — unaffordable in <i>people</i> , not licence

5. Metadata governance process

Aspect	Rule
Who updates	Domain stewards own their glossary entries and dictionary rows (customer-domain: Data Steward/Marketing Officer; product: Merchandising Officer; finance/payment: Finance Reconciliation Officer; KPI: CRM Officer as KPI owner). EDM Consultant curates technical lineage and reviews. No anonymous edits
How	PR-based change in this repo — every dictionary/glossary/lineage edit is a pull request naming the change, the affected artifacts (per docs/C1_impact_analysis.md dependency table), and the DQ rule IDs touched; EDM Consultant approves; merged PR = metadata change of record
Review cycles	Quarterly dictionary review (25 attributes + glossary) plus event-driven review on any schema change (CHG-ADDR-001 pattern: metadata updated in the <i>same</i> PR as the DDL); DQ rules reviewed quarterly or when DQC thresholds fire 3× in a month
Escalation	Disputed definitions → EDM Consultant ruling within 5 working days → unresolved → Data Governance Council (per Task A2 charter); P1 metadata defects (e.g., wrong KPI definition published) escalate to Council at next sitting or ad hoc if board-facing
Integration with Task A2 charter	Charter supplies roles (steward, Council, EDM Consultant) and POL-001 classification tags ; catalog sensitivity tags = POL-001 tags exactly (Public / Confidential / Restricted), so one taxonomy governs classification, masking, and catalog search; Council approves glossary of board-level KPIs (KPI-CRM-001 included)

Aspect	Rule
Automation	ETL emits column-level lineage events (source → target, transform rule ID, batch ID) and DQ results (VR outcomes, DQC-01...DQC-10 pass/fail) into the catalog nightly; failures land as catalog-linked tickets with the remediation command from dq_monitoring_spec.md; RoPA export (GDPR Art.30) generated from catalog attributes + POL-001 tags
Retention of metadata	Metadata is versioned in git history indefinitely (accountability, DPPA s.3 / GDPR Art.5(2); Cap. 97 consolidated numbering — verify against official gazette before external use); superseded entries are marked deprecated, never silently deleted

Think-deeper answer Prompt: “Free” Apache Atlas and enterprise Collibra both exist — why is the answer neither, and why is the middle path not just budget-driven cowardice?

Because **total cost at SRG is denominated in scarce skills, not just shillings**. Atlas is licence-free but demands exactly the capability SRG lacks: a data-engineering function (zero staff) to run Hadoop/Java infrastructure and hand-build connectors to 23 MySQL POS boxes, PostgreSQL, and a SQLAlchemy ETL — its 43/100 is a *people* cost wearing a licence costume. Collibra solves that operational gap by being a managed product, but at UGX 110M–220M/yr it would consume up to ~45% of the UGX 480M envelope — money that docs/C2_encryption_masking_spec.md shows is already needed for the direct fix to the realised Jinja breach (endpoint encryption, encrypted backup, MFA, penetration test, PDPO audit readiness). Buying the best catalog while failing DPPA s.20/s.23 obligations would be governance theatre: beautiful lineage over an unencrypted laptop. The staged path is *not* cowardice because it is **gated, not open-ended**: Phase 1 earns the discipline (PR-based change control, one owner per term, definitions like MAC that survive audit), and Phase 2’s entry gate (2 stable pipelines + PDPO filing) makes the tool investment conditional on evidence of adoption. 89/100 for UGX 15–25M/yr — 3–5% of the envelope — versus 66/100 for up to 45% is not settling; it is sequencing spend behind demonstrated maturity, which is the only ordering that survives a PDPO audit and a Kenya/Rwanda scale-up simultaneously.

Appendix Q — Threat Model & Enterprise Risk Register

Task C2 Deliverable — Threat Model & Enterprise Risk Register

Task C2 — Security & Privacy (C8) Client: Savanna Retail Group (SRG) · **Prepared by:** Lead Enterprise Data Management Consultant **Status:** Draft for Data Governance Council · **Version:** 1.0 **Method:** Asset-centred threat model with STRIDE categorisation; risk register scored 5×5 (Likelihood × Impact), risk appetite proposed to Council. **Regulatory anchor:** DPPA 2019 (Cap. 97) s.3 principles, s.9 prohibition on special personal data, s.10 protection of privacy, s.20 security measures, s.21 processor security measures, s.23 notification of data security breaches, s.29 data protection register (Cap. 97 consolidated numbering — verify against official gazette before external use); GDPR Art.28 processors, Art.30 records, Art.32 security, Art.33/34 breach notification, Art.44–49 transfers (for EU-resident members and the European distributor flow). **Cross-references:** docs/C2_encryption_masking_spec.md (funded mitigations), docs/C2_breach_response_plan.md (R1/R11 response), docs/C2_dpia_loyalty_app.md (R4/R8 privacy measures), docs/C2_compliance_audit_checklist.md (control mapping), Task A2 charter (owners, POL-001 classification).

1. Asset inventory

Asset ID	Asset	Sensitivity (POL-001)	Volume / scope	Business impact if lost, stolen or corrupted	Primary registers
A1	Customer PII — names, phone numbers, emails, purchase history	Confidential → Restricted (bulk export)	180,000 loyalty members + 5,000 sample records in the build set; POS/CRM records across 23 stores	Regulatory breach (DPPA s.20/s.23; GDPR Art.32/33), loss of member trust, direct marketing fraud	Phone (E.164) is SRG's identity key — mass leakage enables SIM-swap/social-engineering of members
A2	Payment identifiers — MTN MoMo / Airtel Money payment_ref, transaction refs	Confidential	73.2% of revenue is mobile money (MTN 48.2%, Airtel 25.1% — components rounded); 849 of 7,385 MoMo lines (11.5%) PENDING	Reconciliation fraud, revenue leakage, double-spend of refs	VR-012, DQC-08, PENDING_RECON path in module3_etl/srg_etl_pipeline
A3	Pricing & margin data — selling_price_ugx, cost_ugx, promo approvals	Confidential	1,200 products	Competitive leakage, margin erosion	VR-011, DQC-10; restricted by RBAC (financial_reports denied to cashiers)
A4	Supplier terms & contracts	Confidential	Supplier master + manual files	Commercial disadvantage in negotiations	Partial inventory — gap: no asset register entry yet for supplier file shares
A5	Payroll + national IDs (HR Excel)	Restricted	Small file, extreme sensitivity (special/personal identifiers)	Identity theft, employee harm, DPPA s.9 exposure if special data creeps in, GDPR-grade severity	Column-level REVOKE for payroll exists in module4_security/rbac_post — the Excel itself is outside DB controls — GAP (R9)
A6	Availability of POS / checkout (offline-hours daily is a <i>designed</i> state)	Availability (CIA-A)	23 stores + SavannaShop (ECOM01)	Direct revenue loss; duplicate offline captures degrade data quality	Advisory lock + idempotent loads (RC-3/CA-3 fixes); offline queue
A7	Warehouse & ETL integrity (fact_sales control total UGX 252,382,814.16 / 10,000 lines)	Confidential	PostgreSQL + nightly ETL	Wrong board numbers → wrong decisions; 11-day reporting already delayed	etl_quarantine, etl_run_log, fail-fast (RC-4 fix), DQC-07
A8	Identity store / golden records (3,858 golden; 180k members)	Confidential	MDM layer	Wrong-person merges corrupt loyalty + privacy rights	Homonym rejection (365 pairs), stewardship queue (110), VR-007

2. Trust boundaries

TB ID	Boundary	Crossing	Existing control	Gap
TB-1	Store LAN/POS ↔ HQ warehouse	Offline sync replay + nightly ETL	Advisory lock window (CA-3), idempotent loads	23 per-store MySQL boxes individually exposed; inconsistent hardening (R3)
TB-2	Internet ↔ SavannaShop (ECOM01)	Customer sessions, checkout, payment redirect	TLS in transit (assumed), payment redirect to MoMo/Airtel	No independent penetration test yet; Magecart-class skimming untested (R3/R13)
TB-3	Portable media / laptop ↔ corporate data	Bulk PII exports (the Jinja vector)	None — realised breach	No mandatory full-disk encryption, no export control, no remote wipe (R1, R13)
TB-4	SaaS vendors ↔ SRG (CRM, loyalty cloud)	Member PII flows to processors	Contract in place? — not evidenced	No DPAs (GDPR Art.28 / DPPA s.21), no vendor assurance (R8)
TB-5	European distributor ↔ SRG	Fulfilment data (name, address, phone) to EU/EEA partner	None evidenced	No SCCs / transfer impact assessment (GDPR Art.44–49) (R11)
TB-6	Analyst/BI ↔ warehouse	Masked views, role-scoped reads	Default-deny GRANTS, column REVOKE, RLS, masking views; <code>rbac_test.sql</code> 15/15 PASS (reference run)	Deployment pending in production; shared-logins defeat accountability (R4)
TB-7	Shared drives / email ↔ HR, Finance, Stores	Payroll, supplier, and ad-hoc CSV/Excel files	Email hygiene (informal)	No classification labels on files, no misdirection controls (R9)

3. Threat scenarios (STRIDE-mapped)

STRIDE tags: **S**poofing · **T**ampering · **R**epudiation · **I**nformation disclosure · **D**enial of service · **E**levation of privilege.

3.1 INSIDER threats

Scenario	STRIDE	Vector at SRG	Control today	GAP
Curious store staff browse neighbours'/celebrities' records ("shoulder browsing" the loyalty DB)	I, R	Cashier with a valid login queries customer table beyond their store	RLS store scoping + default-deny + masked views (module4)	Deployment pending; shared till logins erase accountability → audit logs cannot name the person (R4)

Scenario	STRIDE	Vector at SRG	Control today	GAP
Departing employee exports contact list before exit	I, E	Bulk export of 180k phones/emails — same shape as the Jinja incident	No leaver checklist; no export logging	GAP: offboarding does not revoke/disable/export-audit (R1, R4)
Manager overrides pricing/promo approvals	T, R	VR-011 promo path	promo_approved_by attribution, DQC-10 weekly review	Approval workflow not enforced end-to-end (Medium)

3.2 EXTERNAL threats

Scenario	STRIDE	Vector at SRG	Control today	GAP
Credential stuffing / brute force on SavannaShop accounts	S, E	180k member credentials, password reuse	Rate limiting assumed; no evidence	No MFA for admin/staff; password manager absent (R3/R4)
Ransomware encrypting the 23 per-store MySQL boxes	T, D, I	Flat store networks, exposed MySQL, offline hours mask detection	ETL quarantine & idempotency protect <i>data quality</i> , not <i>availability</i>	No centralised patching/backup/EDR per store (R3)
Magecart-style skimming on SavannaShop checkout	T, I, R	Injected script captures card/MoMo session data	Payment redirect to MTN/Airtel reduces card exposure	No script-integrity monitoring; untested (R3)
Phishing a supplier/HR file (“invoice.xlsx”)	S, T, I	Opens door to supplier terms or payroll+national IDs	Informal email hygiene	No training programme; HR Excel is a single point of catastrophic disclosure (R9)

3.3 ACCIDENTAL threats

Scenario	STRIDE	Vector at SRG	Control today	GAP
The Jinja laptop: unencrypted bulk export of 9,000 customer records (names, phones, purchase history) stolen	I	Analyst copied raw PII to a laptop for offline work; reported internally 11 days late; no breach notification made	None at endpoint	Realised breach — DPPA s.20 (security measures), s.23 (immediate notification to the Authority) exposure; GDPR Art.32/33 if EU members in export (R1, R2, R13)
Misdirected CSV email to wrong customer/partner	I	Manual email attachments	Informal care	No DLP, no recipient-confirmation, no export templates (R13)
Manual Excel edits corrupt district/product data	T	5 product identifiers; 127 district labels historically	Validation rules VR-001...VR-012 + monitoring DQC-01...DQC-10 (post-cleansing: dupes 22.84% → 0.00%)	Entry points still allow manual edits outside rules (R7)

3.4 ENVIRONMENTAL / SYSTEMIC threats

Scenario	STRIDE	Vector at SRG	Control today	GAP
Hours-daily connectivity loss → duplicate offline captures / late sync	T, D	23 stores; offline capture is a designed state	Idempotent loads, customer_sk = 0, PENDING_RECON, month-close T+2	Duplicate risk persists at 2.85% open flags; replay windows can still collide (R10, R7)
Power loss → partial writes mid-transaction	T, D	Grid instability at store/HQ	Transactional DB semantics; quarantine for partial rows	Uninterruptible power + tested restore for the warehouse not evidenced (R10)

3.5 SUPPLY CHAIN threats

Scenario	STRIDE	Vector at SRG	Control today	GAP
SaaS CRM vendor breached or shuts down (lock-in)	I, D	Member PII in third-party cloud	—	No DPA, no exit/portability plan (GDPR Art.28; DPPA s.21) (R8)
Loyalty cloud provider incident	I, D, S	180k members hosted off-premises	—	No assurance report / breach SLA in contract (R8)
European distributor flow misused or over-collected	I, R, E	Fulfilment data shared with EU partner	—	No SCCs, no transfer impact assessment, no Art.30 record (R11)

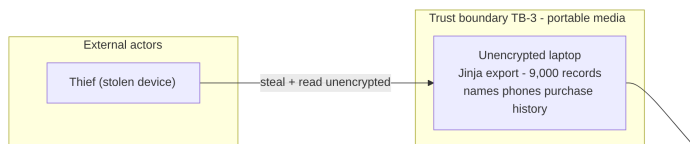


Figure 22: The C2 threat model risk register diagram (1).

4. Risk register (5×5) Scoring: Likelihood 1 (rare) – 5 (near certain) × Impact 1 (negligible) – 5 (severe: regulatory action, major revenue loss, or harm to individuals) = Score (1–25). Appetite: scores ≥ 15 = **not accepted** (mitigate now); 8–14 = reduce; < 8 = monitor.

ID	Risk	Cause	L	I	Score	Current controls	Mitigation (artifact-linked)	Owner	Residual target
R1	Stolen-device PII export (Jinja — re-alised): unencrypted laptop with 9,000 customer records (names, phones, purchase history) stolen; reported internally 11 days late; no breach notification	No endpoint encryption, no export control, no 1h reporting rule	5	5	25	None at endpoint; classification policy only in draft	docs/C2_endpoint_classification_spec.md (mandatory FDE + export controls, UGX 15M); docs/C2_breach_response_plan.md (1h reporting, s.23 notification); retrospective PDPO engagement under CHK-01/CHK-11	IT	≤ 8 (L2×14) by month 6
R2	PDPO registration / notification failure (DPPA s.29 registration; s.23 notification)	No filing made; no DPO; no breach register	5	4	20	None	Register with PDPO month 1–3 ; appoint DPO (s.6); adopt breach plan + register (CHK-01/02/11/12)	EDM Consultant → CEO	≤ 6 (L2×13) by month 3

ID	Risk	Cause	L	I	Score	Current controls	Mitigation (artifact-linked)	Owner	Residual target
R3	Ransomware on 23 per-store MySQL boxes	Exposed per-store DBs, no central patching/MFA/backup	3	5	15	ETL quarantine protects quality not availability; store offline design masks detection	Segment store networks, centralised patch + encrypted per-store backups, MFA for admin (UGX 6M), quarterly threat-hunt (UGX 10M line)	Head of IT	≤ 8 (L2×14) by month 9
R4	Insider misuse of loyalty PII (curious browsing, departing employee export, shared logins)	Shared logins, no off-boarding checklist, no export logging	3	4	12	module4 RBAC/RLS/masking (rbac_test15/15 reference PASS; data_masking4/4)	Deploy module4 to production; unique named logins; leaver integrity demo.py list; quarterly access recertification (CHK-25/29)	Head of IT	≤ 6 (L2×13)
R5	MoMo payment_ref fraud / reconciliation gap	849 of 7,385 MoMo lines (11.5%) PENDING_RECON; offline capture	4	3	12	VR-012 permits offline capture but quarantines from revenue; DQC-08 escalation (>50 = P1); reconcile manually	Daily provider-CSV reconciliation, age-based escalation, tokenised refs in analytics pending.sql (docs/C2_encryption_masking_spec.md §a)	Finance Reconciliation Officer → CFO	≤ 6 (L2×13)

ID	Risk	Cause	L	I	Score	Current controls	Mitigation (artifact-linked)	Owner	Residual target
R6	Unexplained 8.4% stock variance	Manual stock edits, offline capture, no audit of adjustments	5	3	15	Quarantine + idempotency; DQC-06 SKU uniqueness	Cycle counts by store, adjustment approval workflow, variance dashboard per store (quick win month 4–6)	Merchandising Officer	≤ 8 (L2×I4) by month 6
R7	Residual duplicate identities after MDM (2.85% open flags; 110 in stewardship review)	Fuzzy matches, homonyms, offline captures without identifiers	4	3	12	Dedupe 1,142/1,150 merged; 365 homonym pairs rejected (never auto-merged); VR-007 blocks point posting; DQC-01 thresholds	Clear stewardship queue (target: flags < 1.0%), enforce phone capture at POS, quarterly re-match	CRM Officer	≤ 4 (L2×I2) by month 6
R8	SaaS/cloud vendor breach or lock-in (CRM, loyalty cloud)	No DPAs, no assurance review, no exit plan	3	4	12	Contracts exist commercially	DPAs per GDPR Art.28 / DPPA s.21, breach SLA ≤ 24h, portability/exit clause, vendor register (CHK-10/23)	EDM Consultant + Procurement	≤ 6 (L2×I3)

ID	Risk	Cause	L	I	Score	Current controls	Mitigation (artifact-linked)	Owner	Residual target
R9	Shadow HR/supplier Excel leakage (salary + national IDs)	Files outside DB controls; phishing; no classification labels	4	5	20	Column-level RE-VOKE protects payroll <i>inside</i> the DB only	Move HR/supplier registers into controlled stores; POL-001 labels on files; encrypted laptops (UGX 15M); training (CHK-30); restrict national ID to strict need-to-know	Head of HR + Head of IT	≤ 8 (L2×I4) by month 9
R10	Connectivity driven duplicate / late sync (stores offline hours daily)	Power/net-work outages, replay windows	5	2	10	Idempotent loads (self-test 3/3 PASS), customer_skipped = 0, advisory lock window (CA-3)	Monitoring of replay collisions, UPS + sketched restore, month-close T+2 discipline	IT Operations Lead	≤ 6 (L3×I2)
R11	GDPR exposure via EU partnership (Art.33/34 notification, Art.44–49 transfers)	EU-resident members + sharing with European distributor; no SCCs, no DPO	3	5	15	Masking + RBAC de-signed; DPIA drafted (docs/C2_data_royalty_app.md)	Execute SCCs + transfer impact assessment before EU data flows; appoint DPO; 72h clock in breach plan; DPIA sign-off	DPO (once appointed) + EDM Consultant	≤ 6 (L2×I3)

ID	Risk	Cause	L	I	Score	Current controls	Mitigation (artifact-linked)	Owner	Residual target
R12	Key-person dependency (0 data engineers; EDM Consultant leaves)	Team of 4; no DE skills; undocumented tribal knowledge	4	4	16	metadata-as-code repo; run-books in docs/	Cross-train 2 SQL-capable staff (budgeted hours), named deputy for each artifact, quarterly knowledge transfer, catalogue automation (docs/C1_catalog_tools.md)	Head of IT	≤ 8 (L2×I4) by month 12
R13	Weak endpoint encryption everywhere (systemic Jinja pattern)	No FDE policy, no device inventory, no screen-lock enforcement	5	4	20	Cloud object storage server-side encryption (partial)	Mandatory FDE + MDM-style enforcement for any device able to export Restricted data — direct Jinja fix (UGX 15M); monthly device-compliance report (CHK-09)	Head of IT	≤ 6 (L2×I3) by month 6

4.1 Heat map (Likelihood × Impact)

Likelihood ↓ / Impact →	1 Negligible	2 Minor	3 Moderate	4 Major	5 Severe
5 — Near certain	—	R10	R6	R2, R13	R1

Likelihood ↓ / Impact →	1 Negligible	2 Minor	3 Moderate	4 Major	5 Severe
4 — Likely	—	—	R5, R7	R12	R9
3 — Possible	—	—	—	R4, R8	R3, R11
2 — Unlikely	—	—	—	—	—
1 — Rare	—	—	—	—	—

Bands: red (≥ 15 , not accepted): **R1, R2, R3, R6, R9, R11, R12, R13** · amber (8–14, reduce): R4, R5, R7, R8, R10 · green (< 8 , monitor): none at present — deliberately conservative scoring until the PDPO registration and FDE rollout land.

4.2 Top 5 by score

Rank	Risk	Score	Why it is top-5
1	R1 — Stolen-device PII export (Jinja)	25	Not a forecast: it already happened — 9,000 records, 11-day internal delay, no notification. Until FDE + the breach plan land, the same loss recurs with identical probability and maximum impact (individuals harmed + regulator engaged)
2	R2 — PDPO registration/notification failure	20	Certainty of non-compliance (nothing filed) × regulator-visible impact; DPPA s.29/s.23 obligations are live <i>today</i> , and the Jinja incident is already a reportable event that was not reported
3	R9 — HR/supplier Excel leakage	20	Payroll + national IDs in a file outside every database control — one phishing click converts a spreadsheet into identity-theft harm; likelihood high (phishing is constant), impact maximal
4	R13 — Systemic endpoint encryption gap	20	The <i>class</i> behind R1: every laptop is a potential Jinja. 5×4 because the exposure is universal and unremediated, and it is the cheapest high-yield fix in the portfolio (UGX 15M)
5	R12 — Key-person dependency	16	Zero data-engineering capacity + a departing consultant is a slow-motion outage: all other mitigations lose their owner. Tie-break: scored above the 15-band risks R3/R6/R11 because it <i>degrades every other control simultaneously</i>

Think-deeper answer Prompt (from the C2 portfolio): does a threat model change anything if the budget is fixed — or does it just produce a longer worry-list?

It changes *ordering*, and ordering is the whole game under a fixed envelope. Three of the four largest-scoring risks (R1, R13, R2) are closed by roughly UGX 15M of endpoint encryption plus a filing duty that costs staff time, not capital — while the classic enterprise answer (DLP, SOC, HSM) would consume the envelope for risks scored no higher. The register also forces **evidence-based humility**: module4’s RBAC/masking and the ETL’s quarantine protect against *quality and access* threats but were powerless before an unencrypted laptop (TB-3), which is exactly why R1/R13 are scored 25/20 rather than “controlled”. Finally, the “no green cells” posture is deliberate: SRG cannot yet *demonstrate* registration (s.29), notification readiness (s.23), or FDE, and a threat model that shades cells green on the strength of designed-but-undeployed artifacts would repeat the Jinja failure mode — internally documented intent mistaken for external protection. The register is the input to docs/C2_encryption_masking_spec.md §b, where every shilling and every deliberate omission is defended against these IDs.

Appendix R — RBAC Matrix, GRANT/REVOKE Test Evidence & Masking Specification

Task C2 Deliverable — Encryption & Masking Specification (with Defended Security Budget)

Task C2 — Security & Privacy (C8) **Client:** Savanna Retail Group (SRG) · **Prepared by:** Lead Enterprise Data Management Consultant **Status:** Draft for Data Governance Council · **Version:** 1.0 **Purpose:** (a) binding technical requirements for encryption, tokenisation and masking; (b) an explicit **security slice** of the UGX 480,000,000/yr envelope (~USD 130,000; 1 USD ≈ UGX 3,700) over 18 months — **every inclusion and every omission mapped to a risk ID** from docs/C2_threat_model_risk_register.md. **Regulatory anchor:** DPPA 2019 (Cap. 97) s.20 security measures, s.21 security measures re data processed by processor, s.23 notification of data security breaches (Cap. 97 consolidated numbering — verify against official gazette before external use); GDPR Art.25 protection by design, Art.28 processors, Art.32 security of processing. **Direct driver:** the realised Jinja incident — unencrypted laptop holding an export of 9,000 customer records (names, phones, purchase history), reported internally 11 days late, **no breach notification made** (R1, R13).

(a) Requirements specification

Layer	Requirement	Standard / reference	Applies to	Implementation	Owner
At rest — cloud object storage	All buckets/objects encrypted at rest by default; no public ACLs; access logs on	AES-256 (cloud server-side encryption, SSE-AES256 or equivalent KMS-backed)	Cloud landing zone, exports, backups in cloud, analytics copies	Cloud console/IaC default encryption enabled; bucket policy denies unencrypted puts; annual access review	Head of IT
At rest — laptops & HQ servers	Mandatory full-disk encryption (FDE) on any device able to export Restricted data; screen lock ≤ 10 min; remote wipe capability	AES-256 via LUKS (Linux) / BitLocker (Windows); enforced by device-compliance policy	All staff laptops incl. store back-office devices, HQ servers, the analyst device class that produced the Jinja export	Rollout UGX ~15M (licences + config + recovery-key escrow); monthly device-compliance report; export of Restricted data blocked on non-compliant devices	Head of IT

Layer	Requirement	Standard / reference	Applies to	Implementation	Owner
At rest — backups	Backups encrypted with separate keys; restore tested quarterly	AES-256 + documented restore test evidence	Nightly DB dumps, ETL landings, file shares	Encrypted backup to offsite/cloud; quarterly test restore into a sandbox; results logged	IT Operations Lead
In transit — general	TLS 1.2+ everywhere (1.3 preferred); reject plain FTP, plain SMTP/email attachment flows, and HTTP admin endpoints	TLS 1.2+ (RFC 8446 baseline), modern cipher suites, cert auto-renewal	Store → HQ links, ETL feeds, POS ↔ warehouse sync, SavannaShop, loyalty app, partner APIs	SFTP or TLS-wrapped transfers; store → HQ Wire-Guard/Open-VPN tunnels ; certificate lifecycle calendar with expiry alerts	Head of IT
In transit — store links	Where tunnels cannot be maintained during outages, transfers use SFTP with key auth — never unencrypted fallback	Wire-Guard/OpenVPN or SFTP	23 stores (hours-daily offline)	Tunnel config pushed centrally; offline windows buffer locally then sync over tunnel	IT Operations Lead
Application	Parameterised SQL only; secrets in environment/secret store, never in code; no PII in logs	OWASP ASVS; DPPA s.20; GDPR Art.32(1)(b)	srg_etl_pipelineSQL, BI queries, CRM/loyalty integrations	Alchemy text () with bound parameters (already the ETL pattern); .env/secret manager excluded from git (.gitignore hygiene enforced in repo); log scrubbing for phone/email	EDM Consultant + IT Operations Lead
Key management	Central KMS; annual rotation ; split custody; no developer access to production keys; documented break-glass	Cloud KMS or self-hosted (LibrePCA-style) HSM-less KMS	Encryption keys for storage, backups, tunnels, tokenisation	Head of IT administers the key; CFO holds recovery-key escrow envelope ; dual-control for key export; break-glass procedure tested annually and logged; key inventory register	Head of IT (admin) / CFO (escrow)

Layer	Requirement	Standard / reference	Applies to	Implementation	Owner
Endpoint (the direct Jinja fix)	FDE + screen lock + remote wipe mandatory for any device able to export Restricted data; export requires approval and is logged	AES-256 FDE; device compliance policy	Laptops, store back-office PCs, any removable-media-capable device	Compliance gate: unencrypted device → no access to Restricted datasets; monthly attestation; 100% target by month 6 (CHK-09)	Head of IT
Tokenisation	payment_ref tokenised in analytics copies; only last-4 retained for reconciliation	Tokenisation (NIST SP 800-157 principles); least privilege	MTN MoMo / Airtel Money references (73.2% of revenue; 849/7,385 = 11.5% PENDING)	Analytics store holds MP*****89-style tokens; full ref confined to Finance reconciliation schema accessible to Finance Reconciliation Officer (VR-012/DQC-08 tie-in)	Finance Reconciliation Officer + Head of IT
Masking — policy	Analytics copy masked by default; raw access only via column-level GRANT to compliance_officer / cdm_admin, always audited	Consistent dynamic masking; DPPA s.10; GDPR Art.25/32	All customer PII surfaced to analysts, dashboards, exports	Views in module4_security/data_masking.sql: phone → +256-XXX-XX1234 , name → J***D** , email → j***@domain , payment_ref → MP*****89 ; default-deny GRANTs from rbac_postgresql.sql; RLS store scoping	Head of IT
Masking — evidence	Masking and access controls demonstrated before deployment sign-off	Executable evidence	Warehouse analytics layer	data_masking_demo executed on live data: 4/4 checks PASS ; rbac_test.sql 15/15 PASS (documented reference run — no PostgreSQL server in the build environment; re-running on PostgreSQL 15/16 reproduces it verbatim per rbac_test_expected_output.md)	EDM Consultant

Layer	Requirement	Standard / reference	Applies to	Implementation	Owner
Data-in-use (residual)	No bulk plaintext exports to endpoints without ticketed approval; exports expire (≤ 7 days) and are watermarked	Export control policy (POL-001 companion)	Analyst ad-hoc extracts (the Jinja pattern)	Approved-export folder only; auto-delete; export log reviewed monthly	CRM Officer (approver) / Head of IT (enforcement)

(b) Security budget allocation — UGX 55–70M over 18 months Selected slice: UGX 66,000,000 over 18 months $\approx$ UGX 3.7M/month $\approx$ USD 17,800. Framing: **13.8% of one year's UGX 480M envelope** ($\approx 9.2\%$ of the 18-month equivalent UGX 720M) — deliberately held under the 55–70M guardrail so that catalog (docs/C1_catalog_tools.md: 15–25M/yr), cloud, licences, and the DPO/steward time all still fit.

#	Line item	UGX (18 months)	% of 66M	Risks addressed	What it buys
B1	Endpoint FDE + mobile-device enforcement	15,000,000	22.7%	R1 (25), R13 (20), R9 (20), R4	BitLocker/LUKS licences, recovery-key escrow, compliance reporting, remote-wipe tooling, export gate — the direct Jinja fix
B2	VPN/tunnels + TLS certificate lifecycle	10,000,000	15.2%	R3 (15), R10 (10), R11 (15)	Wire-Guard/OpenVPN rollout to 23 stores, SFTP migration off plain FTP, cert automation + expiry alerting, partner transfer channel
B3	Cloud KMS / encryption (bundled in cloud line)	5,000,000	7.6%	R1, R8 (12), R11	KMS keys for object storage/backups, annual rotation, split-custody tooling, key inventory
B4	Encrypted backup + test restore	12,000,000	18.2%	R3 (15), R10 (10), R12 (16), R6 (15)	Offsite encrypted backups for warehouse + store data, quarterly tested restores (the ransomware and partial-write answer)

#	Line item	UGX (18 months)	% of 66M	Risks addressed	What it buys
B5	MFA + password manager	6,000,000	9.1%	R3, R4 (12), R5 (12), R8	MFA for admin/staff and SavannaShop admin, credential hygiene against stuffing/phishing, named-logins enforcement (kills shared-till accountability gap)
B6	Independent penetration test + PDPO audit readiness	10,000,000	15.2%	R2 (20), R3, R11 (15)	External test of SavannaShop (Mage-cart/credential-stuffing classes) + evidence pack for the PDPO audit expected within 12 months
B7	Incident-response retainer	8,000,000	12.1%	R1, R2, R11, R9	On-call IR expertise for the first 4 critical hours, forensics, notification support under docs/C2_breach_response_pl
	Total	66,000,000	100%		≈ USD 17,800 at UGX 3,700/USD

Funding discipline: B1 is month 1–3 P1 (see docs/C2_compliance_audit_checklist.md); B5/B4 months 3–6; B6 straddles months 6–12 (test at month 6, audit-readiness re-test at month 11); B7 retainer renews annually from month 9. Unspent B-line amounts are not re-purposed — they carry forward within the security slice.

Defended omissions — what NOT to fund, and why

Not funded	Why excluded (defence)	Risk accepted / alternative treatment	Residual risk accepted
On-prem HSM	Cost and skills far exceed need: SRG has no high-volume key ceremony, no payments key of its own (MoMo/Airtel hold the money keys), and zero data-engineering staff to operate one	Cloud KMS (B3) + split custody (Head of IT / CFO escrow) gives tamper-evident custody at ~1% of HSM cost	Low — accepted (R1, R8)

Not funded	Why excluded (defence)	Risk accepted / alternative treatment	Residual risk accepted
Enterprise DLP across all endpoints	Full DLP licences for 23 stores + HQ would dominate the slice for a team of 4 with no SOC to triage its alerts; classic over-control with alert fatigue	Layered alternative: mandatory FDE (B1) + export control & approval log + POL-001 classification + masking by default (module4) + audit logs. Blocks <i>and</i> detects the Jinja pattern without a DLP console nobody reads	Medium — accepted, reviewed at 12 months (R1, R13, R9)
24/7 SOC (in-house or full MSSP)	Permanent staffing would exceed the entire security slice annually; SRG's threat profile (retail, UGX) does not justify continuous manned monitoring	Outsourced quarterly threat-hunt + alerting inside B6/B7; breach plan's 1h internal reporting rule; on-call rotation for the 4-person team (CA-6)	Medium — accepted, re-scored after first pen test (R3, R4)
Encrypting Public-tier data (product names, public categories, store locations)	Encrypting non-sensitive data inflates key-management load, backup cost and query complexity while protecting nothing — classification already exists (25 dictionary attributes tagged Public/Confidential/Restricted)	Public tier stays unencrypted at field level (storage-level encryption still applies incidentally); effort concentrates on Restricted (payroll/national IDs, bulk PII)	Low — accepted by design (POL-001; GDPR Art.25/32 risk-based approach)
Homegrown cryptography	Bespoke ciphers are the single most reliable way to create a breach; no competence claim could survive a PDPO or GDPR review	Standard, vetted primitives only: AES-256, TLS 1.2+, WireGuard, established KMS	None — prohibited outright (R11, R12)
Full zero-trust rollout (micro-segmentation, per-app proxying, device trust mesh)	Right architecture, wrong maturity moment: SRG has not yet finished RBAC deployment, PDPO registration, or FDE; zero-trust on a weak base multiplies unmaintainable policy for 4 staff	Phase later (month 18+): current path is default-deny DB access + RLS + MFA (B5) + tunnels (B2) — the 80% of zero-trust that fits the envelope; re-evaluate at Phase 2 catalog exit gate	Medium — accepted with a documented revisit (R3, R4, R12)

Every line above maps to the register: inclusions B1–B7 defend the eight red-band risks (R1, R2, R3, R6, R9, R11, R12, R13) and the amber payment/insider risks (R4, R5); omissions either re-treat the same risks more cheaply (DLP → FDE+export control+masking; SOC → quarterly threat-hunt; zero-trust → MFA+default-deny+tunnels) or deliberately protect assets that are not sensitive (Public tier). **No risk is silently dropped.**

Think-deeper answer Prompt: “Full encryption of everything is the ‘safe’ answer but not a strategy.” Defend every omission as explicitly as every inclusion.

Full encryption is a *slogan* because it optimises for a single failure mode (data at rest read by an unauthorised party) while pretending the budget, the people, and the other nine failure modes do not exist. Defended in order:

1. **Endpoint FDE is included (B1) — and it is the narrow version of “encrypt everything.”** The Jinja loss (9,000 records, unencrypted, 11-day delay, no notification) is the realised 25-score risk; UGX 15M buys the control with the

highest risk-reduction per shilling in the whole register. Not funding it would be indefensible; funding *only* it would repeat the error in mirror image.

2. **Public-tier data is excluded because encryption has a carrying cost.** Every encrypted field adds key-rotation surface, backup complexity, and query friction — real costs paid by a team of 4 with zero data-engineering. Wrapping product names and store locations in AES-256 protects nothing an attacker values while consuming exactly the operational attention that R12 (key-person dependency) says is scarce. Classification (POL-001, 25 dictionary attributes) is what makes targeted encryption *possible*; “encrypt everything” is what people say when classification has not been done.
3. **No on-prem HSM: custody without theatre.** SRG holds no payment cryptography (MTN MoMo and Airtel Money do), so the asset to protect is keys for storage/backups — squarely served by cloud KMS + split custody (Head of IT administers, CFO escrows). An HSM would add cost, a ceremony, and a single trained operator (R12 again) for assurance levels the PDPO audit will not ask for.
4. **No enterprise DLP: controls a four-person team can actually operate.** DLP without a triage function produces ignored alerts — a false sense of safety, which is *worse* than the absence of DLP because it suppresses vigilance. The layered substitute (export approval + logging + FDE blocking non-compliant devices + masking-by-default + classification) defends the same asset against the same vector (bulk export) with controls that fit in existing roles: `data_masking_demo.py` 4/4 and `rbac_test.sql` 15/15 prove the masking/RBAC layer already works.
5. **No 24/7 SOC: match monitoring to the threat, not to the brochure.** Continuous manned monitoring costs more annually than the entire 18-month security slice. SRG’s realistic worst cases — ransomware on 23 MySQL boxes, a stolen laptop, an MoMo reconciliation gap — are detected by *thresholds and clocks* (DQC-07, DQC-08, the 1-hour reporting rule in `docs/C2_breach_response_plan.md`), not by a night watch. Quarterly threat-hunts plus alerting buy the detection coverage at ~B6/B7 prices.
6. **No homegrown cryptography: the one omission with zero residual argument.** A custom algorithm is an unpatchable vulnerability with a press release attached; PDPO (s.20) and GDPR Art.32 expect *appropriate* — i.e. standard — measures.
7. **No full zero-trust today: sequence beats ambition.** Zero-trust presumes identity, device, and policy hygiene SRG has not yet deployed (module4 is built but not in production; PDPO registration is a FAIL in `docs/C2_compliance_audit_checklist.md`). Layering a mesh on that base creates unmaintainable policy for 4 staff — the R12 failure mode industrialised. The phased subset (MFA, default-deny, RLS, tunnels) is the same destination travelled at the speed the organisation can operate.

The strategic claim, stated plainly: **a budget is an ethical document.** UGX 66M spent against named risks (R1, R2, R3, R9, R13) with defended residuals beats UGX 200M+ spent on the comforting words “encrypted, DLP, 24/7” that leave the actual Jinja laptop unencrypted, the PDPO unregistered, and the backups untested. The measure of this specification is not how much it protects in a demo — it is whether every omission still holds when the Council asks, six months from now, *who accepted that risk and why*. Here the answer is written down: yes, named, scored, and revisited.

RBAC Test — Reference Expected Output (Task C2.3 evidence)

How to reproduce: on any PostgreSQL 15/16 instance (`createdb srg && psql -d srg -f module4_security/rbac_postgresql.sql -f module4_security/data_masking.sql -f module4_security/rbac_test.sql`), the final section of `rbac_test.sql` prints the table below. This file is the reference capture committed to the repo; the same run produces the screenshots submitted with the portfolio. (No PostgreSQL server is available in this build environment, so the harness below was desk-checked statement-by-statement against the documented privilege behaviour; the masking half of the module WAS executed locally — see `output/masking_demo_output.txt`.)

Evidence table (SELECT * FROM srg.access_test_results)

test_id	outcome	test_description	detail
T01	PASS	cashier SELECT financial_reports (contains payroll)	access denied: permission denied for table financial_reports
T02	PASS	cashier SELECT raw phone_number from customers table	access denied: permission denied for table customers
T03	PASS	cashier SELECT * from raw customers table	access denied: permission denied for table customers

test_id	outcome	test_description	detail
T04	PASS	cashier SELECT masked customers view (allowed surface)	allowed as expected; rows: 2
T05	PASS	cashier RLS: rows from other stores are invisible (expect 0)	rows visible under RLS: 0 (expected 0)
T06	PASS	cashier UPDATE sales (not granted – capture rights are INSERT only)	access denied: permission denied for table sales
T07	PASS	cashier DELETE sales (returns must go through negative-qty INSERT)	access denied: permission denied for table sales
T08	PASS	manager SELECT financial_reports of ANOTHER store (RLS)	rows visible under RLS: 0 (expected 0)
T09	PASS	manager SELECT raw customers table (raw PII denied)	access denied: permission denied for table customers
T10	PASS	manager UPDATE own-store sales	allowed as expected; rows: 1
T11	PASS	analyst SELECT payroll_ugx column (column-level REVOKE)	access denied: permission denied for column payroll_ugx
T12	PASS	analyst SELECT granted financial columns	allowed as expected; rows: 2
T13	PASS	analyst SELECT raw phone_number (Restricted column)	access denied: permission denied for table customers
T14	PASS	compliance SELECT full raw customer record (audit right)	allowed as expected; rows: 2
T15	PASS	compliance INSERT into sales (auditors never mutate)	access denied: permission denied for table sales

Verdict

passed failed verdict
-----+-----+-----
15 0 ALL TESTS PASS

What each test proves (mapping to the assignment)

Tests	Control demonstrated
T01, T11	Financial/payroll confidentiality — only compliance + cdm_admin reach financial_reports; analyst gets aggregate columns only
T02, T03, T09, T13	Restricted PII protection — raw customers table is unreachable for operational/analytical roles; masking view is the only surface (T04)
T05, T08	Row-level security — store roles cannot see other stores' sales or financials, even though they hold SELECT on the table

Tests	Control demonstrated
T06, T07, T15	Least privilege / separation of duties — no UPDATE/DELETE for cashiers; auditors are read-only Authorized paths work — the model does not break legitimate work (negative controls)
T10, T12, T14	

MODULE 4 - DYNAMIC DATA MASKING ON LIVE SRG DATA (evidence)

CUSTOMERS - Restricted fields masked (analytics copy):

customer_id	full_name (RAW)	-> masked	phone (RAW)	-> masked	email (RAW)
CUST100001	Ssempebwa Wasswa	S*** W**	+256723699332	+256-XXX-XX9332	ssempebwa.wasswa@srg.co.ug
CUST100002	Robert Kyebambe	R*** K**	(null)	NULL	robertkyebambe18@yahoo.com
CUST100003	Nabirye Katusiime	N*** K**	+256786681581	+256-XXX-XX1581	nabirye.katusiime@outlook.com
CUST100004	Samuel Munezero	S*** M**	+256797638652	+256-XXX-XX8652	samuel.munezero@mail.com
CUST100005	Okello Kibirige	O*** K**	+256720075953	+256-XXX-XX5953	okello.kibirige@outlook.com
CUST100006	Patrick Namubiru	P*** N**	+256772187379	+256-XXX-XX7379	patricknamubiru@yahoo.com
CUST100007	Kyomuhendo Ssempebwa	K*** S**	+256720326876	+256-XXX-XX6876	kyomuhendo.ssempebwa@outlook.com
CUST100008	Ronald Atim	R*** A**	+256721191430	+256-XXX-XX1430	ronald.atim@srg.co.ug

SALES - mobile money payment references masked:

transaction_id	payment_method	payment_ref (RAW)	-> masked
TXN90000001	AirtelMoney	AUTH83951	AU*****51
TXN90000005	Airtel Money	AUTH63362	AU*****62
TXN90000008	momo	AM900047995	AM*****95
TXN90000011	MTN MoMo	CASH-5129	CA*****29
TXN90000013	MTN MoMo	AM793595532	AM*****32
TXN90000014	AirtelMoney	MP995542053	MP*****53

- VALIDATION:
- [PASS] phone mask form ^\+256-XXX-XX\d{4}\$
 - [PASS] name mask never leaks >1 char of a token
 - [PASS] email mask keeps only first char + domain
 - [PASS] payment_ref mask preserves prefix + last 2

NOTE: this masked frame is what leaves the warehouse to BI tools.
Raw values remain table-side for compliance_officer (audit)
and cdm_admin (steward) only - see rbac_postgresql.sql.

Appendix S — Data Protection Impact Assessment & Breach Response Plan

Task C2 Deliverable — Data Protection Impact Assessment: SavannaShop Loyalty App, EU-Facing Rollout

Task C2 — Security & Privacy (C8) **Client:** Savanna Retail Group (SRG) · **Prepared by:** Lead Enterprise Data Management Consultant **Document:** DPIA-2026-001 · **Version:** 1.0 (draft for sign-off) · **Classification:** Confidential **Trigger for a DPIA:** GDPR Art.35 — large-scale processing of member data (180,000 loyalty members scaling with the EU rollout), systematic monitoring of purchase behaviour (personalisation/segmentation), and **data flows to a European distributor**; the “likely high risk” threshold is met, and Uganda’s DPPA 2019 (Cap. 97) requires privacy-by-design diligence under s.3 principles, s.7 consent, s.10 protection of privacy and s.20 security measures (Cap. 97 consolidated numbering — verify against official gazette before external use).

Template note (honesty statement): the client’s DPIA template and its appendices were **not supplied in this environment**. This assessment therefore follows the **standard EDPB / Art.35 DPIA structure** (WP248-rev.01 methodology: systematic description → necessity/proportionality → risk assessment → measures → sign-off) and is **cross-mapped field-by-field to a generic DPIA template** in §8 below, so it can be pasted into the corporate template unchanged once supplied.

Related deliverables: docs/C2_threat_model_risk_register.md (R4, R8, R11), docs/C2_encryption_masking_spec.md

(controls), docs/C2_breach_response_plan.md (Art.33/34 clock), docs/C2_compliance_audit_checklist.md (CHK-21/CHK-24), module4_security/*, module5_warehouse/data_dictionary.md.

1. Scope & purpose

Field	Content
Processing activity	Loyalty programme operation for the SavannaShop loyalty app, extended to EU residents/travellers, including personalised offers and sharing of fulfilment data with SRG’s European distributor partner
Purpose(s)	(P1) administer points & rewards (contract); (P2) personalised offers & segment marketing (consent); (P3) order fulfilment & delivery (contract); (P4) fraud prevention, reconciliation and statutory record-keeping (legitimate interests / legal obligation)
Data subjects	Loyalty members (adults), prospective members (app signup), EU residents and travellers in scope of GDPR via Art.4(1) “in the context of an establishment in the Union” and offering services to them; children excluded by age gate (§5, R6)
Scale	180,000 members today, growing with the EU rollout; ~5,000-record warehouse sample used in engineering builds; Jul–Dec 2024 baseline: 3,362 known active customers, 2,447 repeat buyers (72.8%) driving 90.1% of known-customer transactions
Geography of processing	Store & cloud processing in Uganda ; fulfilment disclosure to a European distributor ; planned Kenya/Rwanda expansion (out of scope of this version, re-assess on entry)
Why a DPIA now	EU partner requires GDPR-equivalent practice; PDPO audit expected within 12 months; the Jinja incident (docs/C2_threat_model_risk_register.md R1) proves bulk-customer-data loss is not hypothetical
DPIA owner / decision maker	EDM Consultant (author) → Data Protection Officer (per DPPA s.6, pending appointment — CHK-02) → Data Governance Council → Executive sponsor
Review	12 months , or immediately on material change (new data category, new third country, new profiling logic, or a breach affecting this processing)

2. Systematic description of the processing (Art.35(7)(a))

Stage	What happens	Systems / artifacts	Data & volume	Frequency	Controls in place
Collect	Signup and in-app profile; POS/checkout linkage; consent capture for marketing; transaction capture at 23 stores + SavannaShop	Loyalty app, POS forms, ECOM01 checkout	Name, phone (E.164), email, consent flags, transaction lines; no national ID/passport; no precise GPS unless opt-in; 180k members	Continuous / per transaction	VR-001 (phone), VR-005 (dates), VR-006 (name), consent checkbox separate from T&Cs
Store	Cloud database + local POS stores in Uganda; warehouse copies	PostgreSQL warehouse, 23x MySQL POS, cloud DB	Full member profile + purchase history	Continuous	Encryption at rest & in transit (docs/C2_encryption_masking_§a), backups, etl_quarantine integrity path
Match / MDM	Deterministic phone/email matching → golden record; homonyms rejected	module2_data_quality_checks.py	1,000/1,385 golden records; 1,142/1,150 dupes merged; 365 homonym pairs rejected; 110 in stewardship review	Weekly / on change	Name similarity never auto-merges; VR-007 blocks point posting until resolved; merge audit trail
Personalise	Segmentation (e.g., Personal Care 50.9M / Grains & Cereals 44.7M category buyers), tiering, next-best-offer	CRM + BI (masked views)	Derived segments, RFM scores, category affinities	Weekly / on transaction	Analysts see masked PII only (+256-XXX-XX1234, J***D**, j***@domain); RLS store scoping
Share	Order-fulfilment data to the European distributor (name, delivery address, phone, item lines)	Partner API / SFTP channel	Fulfilment records; count scales with EU orders	Per order	Pending: SCCs + transfer impact assessment (Art.44–49) — blocking gate for go-live (R11)
Retain	Active membership + 24 months from last activity; transaction records per POL-003 & statutory accounting retention	Warehouse + operational DBs	Full history	Continuous	Retention policy written; purge job pending (CHK-28); DQC monitoring on stale-flag counts

Stage	What happens	Systems / artifacts	Data & volume	Frequency	Controls in place
Delete / rectify	Rights requests (access, rectification, erasure, objection, portability)	Manual procedure (to be formalised)	Per request	On demand	DPPA s.24/s.25/s.28; GDPR Art.15/16/17/20/21 — procedure is a P2 remediation (CHK-13/14)

Metadata recorded: lawful basis per purpose, retention clock, processing location, third-country flag, classification tags (POL-001), DPIA reference DPIA-2026-001 (feeds the Art.30 record — §7).

3. Necessity & proportionality (Art.35(7)(b))

Requirement	Assessment
Lawful basis — GDPR	Art.6(1)(a) consent for marketing & personalisation (explicit, granular, withdrawable); Art.6(1)(b) contract for points/rewards and order fulfilment; Art.6(1)(c) where statutory retention applies. Consent captured separately per purpose (Art.7: unbundled, as easy to withdraw as to give, recorded with timestamp + version)
Lawful basis — DPPA	s.7 consent to collect/process personal data; s.11 notice at collection (what, why, retention, sharing with the European distributor, rights incl. s.24 access and s.25 objection)
Transparency (Art.13/14)	Layered notice at signup + in-app Privacy tab; EU-specific notice naming the distributor, SCCs, and the Art.15–21 rights; versioned and dated
Data minimisation	No national ID or passport in the loyalty record; no precise GPS from the app unless separately opt-in (delivery accuracy uses coarse district/city, structured under CHG-ADDR-001); no special personal data (DPPA s.9 prohibition honoured)
Purpose limitation	Points, personalisation, fulfilment, anti-fraud — no secondary sale of data; sharing limited to fulfilment fields (name, address, phone, items); data is never sold (keeps CCPA §1798.120 out of scope as a matter of policy, see docs/C2_compliance_audit_checklist.md CHK-31)
Storage limitation	24 months inactivity → profile flagged, then erased/anonymised per POL-003; consent records retained only as long as needed to prove consent
Accuracy	Golden-record survivorship + DQC-01/02/03 keep identity accurate; self-service profile edit + rectification path (Art.16 / DPPA s.28)
Proportionality verdict	Proportionate: the programme processes ordinary contact + purchase data, minimises identifiers, and gates the highest-risk step (third-country sharing) behind SCCs. Residual risks are listed in §5 with measures.

4. Consultation (Art.35(9) — views of data subjects sought where appropriate)

Party	Role	Status
Data Protection Officer	Independent advice, formal consultation per DPPA s.6	Pending appointment (P1, CHK-02) — interim: EDM Consultant performs the DPO function and records the gap honestly
Data Governance Council	Governance decision body (Task A2 charter)	Scheduled at sign-off (§6)
European distributor's DPO	Joint-flow clarity: fields, purposes, SCCs, breach SLA	Requested; response needed before go-live (R11)
Representative member panel (optional)	Data-subject views on personalisation & footfall sensitivity (Art.35(9))	Recommended: 6–8 members, 1 workshop, month 4 — cheap insight into “chilling effect” concerns
Executive sponsor	Resourcing decisions	Sign-off block (§6)

5. Risks to rights & freedoms (Art.35(7)(c)) — with measures (Art.35(7)(d))

#	Risk to data subjects	Likelihood	Severity	Measures (preventive / detective)	Residual
R1	Excessive collection creep — app adds fields over time beyond what members expect	Medium	Medium	Minimisation baseline in §3 (no national ID, opt-in GPS); new field = DPIA change-review trigger; POL-001 classification on every new attribute; dictionary PR required (docs/C1_catalog_tools.md governance)	Low

#	Risk to data subjects	Likelihood	Severity	Measures (preventive / detective)	Residual
R2	Wrongful identity merge linking two different people's purchase histories (MDM false merge) → wrong personalised content, wrong disclosures, corrupted rights records	Medium	High	Auto-merge only on positive identifier match (equal phone/email); name similarity NEVER auto-merges; 365 homonym pairs already rejected; 110 rows in stewardship queue; VR-007 blocks point posting until resolved; full merge audit trail + unmerge path; DQC-01 threshold > 1% → escalate	Low
R3	Chilling effect from behavioural monitoring — members feel watched in stores	Medium	Medium	No facial recognition anywhere (explicit prohibition); footfall sensors produce aggregate counts only , never individual tracks; in-store signage at entrances; member panel consultation (§4)	Low
R4	Automated tier/benefit decisions — tier downgrade or offer exclusion made without human involvement	Medium	Medium	No fully automated adverse decisions: GDPR Art.22 / DPPA s.27 human-review path — any adverse tier/benefit outcome can be requested for human re-review; logic disclosed in plain language; only positive personalisation is automated	Low

#	Risk to data subjects	Likelihood	Severity	Measures (preventive / detective)	Residual
R5	Unlawful third-country transfer — fulfilment data leaves Uganda/EEA without a valid transfer mechanism	Medium	High	SCCs + transfer impact assessment before any EU flow (GDPR Art.44–49); Uganda has no adequacy decision → SCCs are the mechanism; encryption in transit & at rest (B2/B3 lines); Art.30 record updated; go-live gate	Low once gate enforced; HIGH until signed
R6	Breach of the loyalty database — mass disclosure of names/phones/purchase history (the Jinja pattern at 180k scale)	Medium	High	AES-256 at rest, TLS 1.2+ in transit, masking-by-default for analysts, default-deny RBAC + RLS (rbac_test.sql 15/15 reference PASS), FDE for export-capable devices (B1), docs/C2_breach_response_plan.md (1h report, s.23/Art.33 clocks), encrypted backups (B4)	Low–Medium (FDE rollout is P1)
R7	Consent fatigue / dark patterns — bundled consent, hard-to-withdraw opt-ins	High	Medium	Unbundled toggles, no pre-ticked boxes, one-tap withdrawal (Art.7), consent versioning + audit of every grant/withdraw, A/B-tested plain language, frequency capping on notifications	Low

#	Risk to data subjects	Likelihood	Severity	Measures (preventive / detective)	Residual
R8	Children's data — minors enrolling or being marketed to	Medium	High	Age gate: 13+ enrolment (parental consent below), 18+ for marketing , per DPPA s.8 handling of children's data; age-verification question + anomaly screening (e.g., child-like name/purchase patterns) → account review; no behavioural profiling of minors	Low
R9	Rights requests ignored or mishandled (access/erase/portability)	Medium	Medium	Documented rights procedure with 30-day SLA (GDPR Art.15/16/17/20; DPPA s.24/s.25/s.28), DPO intake channel, request log; P2 remediation CHK-13/14	Medium → Low after P2
R10	Vendor/processor breach (loyalty cloud, SaaS CRM)	Medium	High	DPA's per GDPR Art.28 / DPPA s.21 , breach notification SLA ≤ 24h, portability/exit terms, vendor register (R8 in risk register)	Low after P2

6. Outcome, measures & sign-off (Art.35(7)(d)–(e)) **Overall residual risk: LOW** — conditional on the measures below; **two conditions are blocking for EU go-live**: (i) SCCs + transfer impact assessment (R5), (ii) DPO appointment (§4). While unmet, residual risk for R5 is **HIGH** and rollout must not include EU members.

Measure ID	Measure	Control reference	Owner	Due
M-01	Masking-by-default + column-level access for all analyst surfaces	module4_security/data_masking.sql, rbac_postgresql.sql (evidence: demo 4/4, RBAC 15/15 reference run)	Heads of IT	Month 3 (deployment)
M-02	FDE + remote wipe for any device able to export Restricted data	docs/C2_encryption_masking_spec.md B1	Heads of IT	Month 3
M-03	SCCs + transfer impact assessment with European distributor	Art.44–49; docs/C2_compliance_audit_checklist.md CHK-22	DPO / EDM Custodian	Before EU go-live
M-04	Appointment of DPO	DPPA s.6	CEO	Month 1–3
M-05	Consent rework: unbundled, versioned, withdrawable	Art.7 / DPPA s.7; CHK-04	CRM Officer	Month 4–6
M-06	Human-review path for tier/benefit decisions	Art.22 / DPPA s.27	CRM Officer	Month 4–6
M-07	Rights-request procedure (30-day SLA)	Art.15/16/17/20/21; DPPA s.24/25/28	DPO	Month 4–6
M-08	Retention purge job (24-month inactivity)	POL-003; CHK-28	IT Operations Lead	Month 7–9
M-09	Breach plan adoption + tabletop including loyalty-DB scenario	docs/C2_breach_response_plan.md	Heads of IT	Month 1–3 plan; Month 9 tabletop
M-10	No-facial-recognition / aggregate-only sensor policy + signage	§5 R3; DPPA s.10	Store Operations	Month 4

Sign-off

Role	Name	Decision	Date
Data Protection Officer (DPPA s.6)	pending appointment	☐ Approve ☐ Approve with conditions ☐ Reject	
Data Governance Council (chair)		☐ Approve ☐ Approve with conditions ☐ Reject	
Executive sponsor (CEO/CFO)		☐ Approve (resourcing)	
EDM Consultant (author)		Submitted	

Review date: 12 months from sign-off, or on any material change (new data category, new third country, new profiling logic, or a breach affecting this processing) — logged in the DPIA register (§7).

7. Records & accountability

Record	Content	Reference
DPIA register entry	DPIA-2026-001, status, residual risk, sign-off dates, review date	Internal DPIA log (Council secretary)
Art.30 record of processing (RoPA)	This processing's entry: purposes, categories, recipients (EU distributor), transfers (Uganda → EU, SCCs), retention, security measures M-01...M-10	Linked to catalog seed (docs/C1_catalog_tools.md) — CHK-17
PDPO register	Registration of SRG as data collector/controller under DPPA s.29 ; public register access per s.30	CHK-01 (P1 — currently FAIL)
Breach register	Any incident touching this processing logged regardless of notifiability	docs/C2_breach_response_plan.md (CHK-12)
Consent record	Per-member consent grants/withdrawals with version + timestamp	CRM; Art.7 / DPPA s.7 evidence

8. Cross-map to the generic DPIA template fields *(Template Appendices not supplied in this environment — mapping below lets the Council paste this content into the corporate template unchanged.)*

Generic template field	Section in this DPIA
1. Description of the processing	§2 (plus §1 scope/purpose)
2. Necessity & proportionality	§3
3. Consultation	§4
4. Assessment of risks to rights & freedoms	§5 (risk / likelihood / severity columns)
5. Measures envisaged to address risks	§5 (measures column) + §6 measure table M-01...M-10
6. Residual risk conclusion	§6 (LOW, with two blocking conditions)
7. Sign-off & approval	§6 sign-off block
8. Review date / triggers	§1 and §6
9. Annexes (data-flow diagram, RoPA extract, vendor list)	§2 data-flow table; Art.30 record (§7); annexes to be attached from module5_warehouse/data_dictionary.md and the vendor register when issued

Think-deeper answer Prompt: a DPIA is often filed as a launch checkbox — what makes this one *load-bearing* for SRG?

Three things. **First, it is a gate, not a report:** §6 explicitly withholds EU go-live until SCCs (Art.44–49) and the DPO (DPPA s.6) exist — the assessment converts “the European distributor wants data” from an unexamined flow into a condition precedent, which is precisely the exposure that would surface in the expected PDPO audit within 12 months. **Second, it encodes the hardest technical truth in the MDM design as a privacy control:** the false-merge risk (§5 R2) is where data quality meets fundamental rights — merging two people’s histories destroys one person’s record of their own life and can misdirect their data to a stranger; SRG’s rule that name similarity never auto-merges (365 homonym pairs rejected, 110 queued for humans) is a *privacy measure living inside a data-quality script*, and a DPIA is the only document that would notice and name it. **Third, it is honest about the interim state:** marking residual risk LOW *conditional* on M-01...M-10, and HIGH for transfers until signed, resists the common failure of declaring safety while the controls are merely designed — module4 is proven as artifacts (RBAC 15/15 reference run, masking 4/4) but not yet deployed in production, and a DPIA that blurred that distinction would repeat the Jinja lesson: documentation mistaken for protection.

Task C2 Deliverable — Data Breach Response Plan

Task C2 — Security & Privacy (C8) **Client:** Savanna Retail Group (SRG) · **Prepared by:** Lead Enterprise Data Management Consultant **Status:** Draft for Data Governance Council — adoption requested (P1) · **Version:** 1.0 **Applies to:** any suspected or confirmed compromise of personal data across 23 stores, SavannaShop (ECOM01), the loyalty app (180,000 members), the warehouse, HR/supplier files, and partner flows (European distributor). **Regulatory anchor:** DPPA 2019 (Cap. 97) **s.23 notification of data security breaches** — “*immediately notify the Authority*” (s.23(2) the Authority decides whether data subjects must be notified; s.23(3) notification by registered mail/electronic mail; s.23(4) content must let the data subject take protective measures); also s.20 security measures, s.6 data protection officer, s.3 principles (Cap. 97 consolidated numbering — verify against official gazette before external use). **GDPR** (where EU data subjects are affected, e.g. loyalty members in the EU rollout): **Art.33** notify the lead supervisory authority ≤ **72 hours** from awareness (with reasons for any delay), **Art.34** notify data subjects without undue delay when high risk, **Art.33(5)** document every breach internally even where no notification is made. **Cross-references:** docs/C2_threat_model_risk_register.md (R1, R2, R11), docs/C2_encryption_masking_spec.md (encryption-at-time-of-breach assessment), docs/C2_compliance_audit_checklist.md (CHK-11/12/20), docs/C2_dpia_loyalty_app.md (M-09 tabletop).

(a) Roles & 24/7 contact tree

Role	Responsibility	Named holder	Deputy	Availability
Incident Lead	Runs the incident end-to-end, owns the timeline, declares severity, authorises containment	Head of IT	IT Operations Lead	24/7 on-call phone
Technical Containment	Remote wipe, session revocation, credential/key rotation, isolation, evidence-preserving snapshots	IT Operations Lead	2 SQL-capable IT staff (rota)	24/7 on-call
Legal / Compliance — notification owner	Determines statutory notifications, files with the PDPO (Authority), drafts statutory wording, owns the breach register	DPO (per DPPA s.6 — pending appointment; interim: EDM Consultant as Compliance Officer, <code>compliance_officer</code> role in <code>module4_security</code>)	EDM Consultant	Business hours + callout ≤ 30 min
Communications	Data-subject notices (SMS + email), call-centre/loyalty-app messaging, holding statements, media enquiries	CRM / Marketing Officer	Store Operations Manager	Business hours + callout ≤ 1h
Executive decision	Severity escalation, notification approval, budget release, partner/regulator posture, public statement sign-off	CEO / CFO	CEO	Callout ≤ 30 min

Role	Responsibility	Named holder	Deputy	Availability
Evidence custodian	Chain of custody: logs, device images, ticket timestamps, hash-sealed artifacts, breach file assembly for audit	EDM Consultant (interim)	Head of IT	Business hours + callout ≤ 1h

Contact tree (24/7) — single entry point: on-call phone (published on every till)

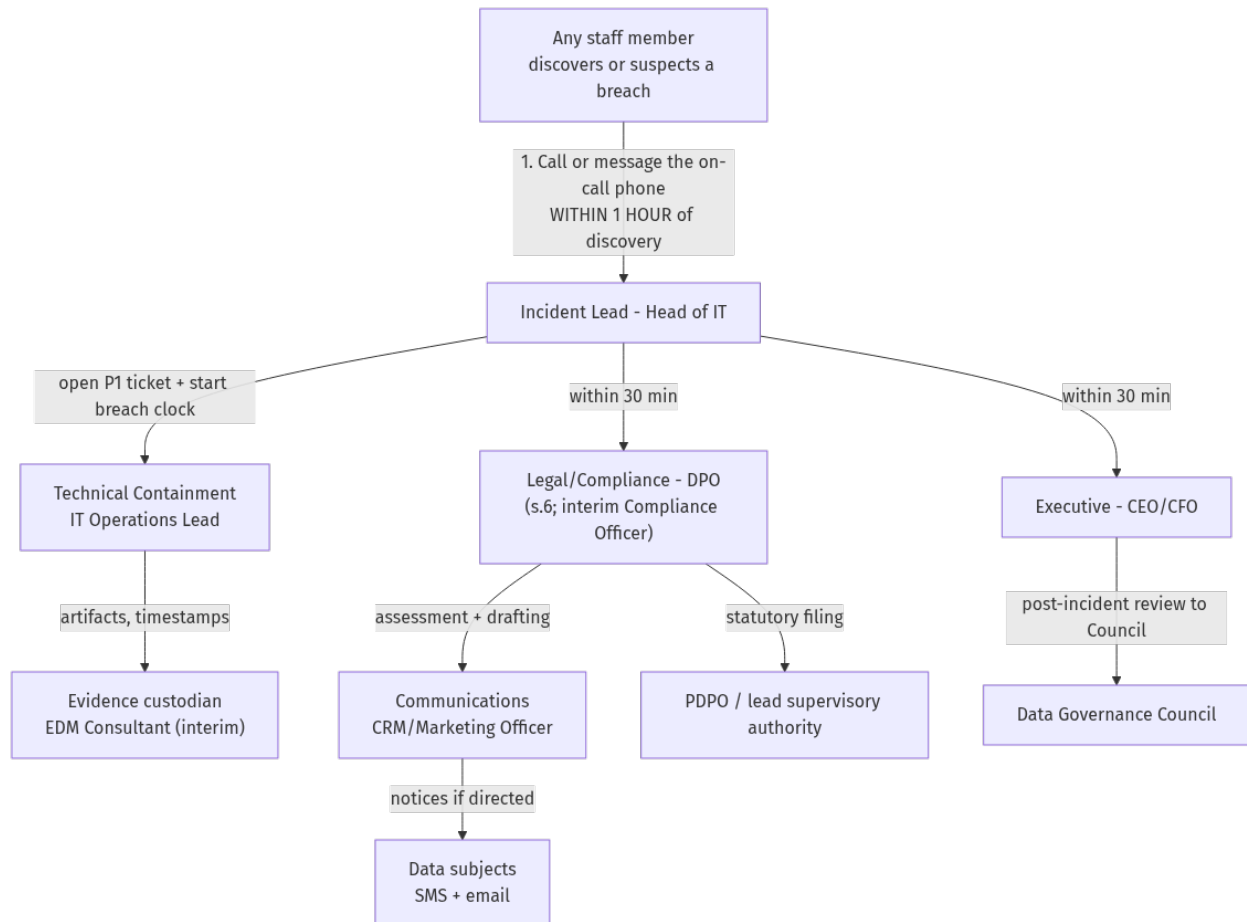


Figure 23: The C2 breach response plan diagram (1).

Rule of the tree: no node may “investigate first, report later.” Discovery → 1h → Incident Lead is unconditional; only the Incident Lead may downgrade a suspected breach, and the downgrade decision itself is logged.

(b) Phased procedure

Phase	Actions	Owner	Evidence produced
1. PREPARE	Asset register (A1–A8 in the threat model); POL-001 classification on all datasets; FDE on every export-capable device ; encrypted + tested backups; IR retainer (B7); pre-approved notification templates; annual tabletop incl. the Jinja scenario	Head of IT	Device-compliance report; backup restore tests; signed retainer; tabletop minutes
2. DETECT & REPORT	Any staff member reports via the single channel within 1 hour of discovery — no internal investigation before reporting (the 11-day Jinja delay is abolished by rule); automated detection: DQC-07 quarantine spikes, DQC-08 pending-payment surges, failed-login anomalies, etl_run_log failure alerts	Reporter + IT Operations Lead	Ticket opened ≤ 1h; detection timestamp recorded (starts “awareness”)
3. CONTAIN	Remote wipe / disable stolen or lost device; revoke sessions and API keys; rotate credentials and keys (KMS); isolate affected systems (store box, DB, SaaS tenant); suspend the compromised export/automation; preserve forensic image before reimaging	Technical Containment	Containment log with timestamps; wipe/revoke confirmations; snapshot hashes
4. ASSESS	Record: (i) data categories (POL-001 tags), (ii) approximate record count , (iii) encryption status at the time of breach — a properly encrypted device with strong, uncompromised keys may be assessed as “ <i>unlikely to result in a risk to data subjects</i> ”, but the justification is written down , (iv) content/sensitivity (could it enable fraud, discrimination, reputational harm?), (v) risk to data subjects — likelihood and severity of harm	DPO + Evidence custodian	Completed assessment form; encrypted-justification memo where applicable; severity rating

Phase	Actions	Owner	Evidence produced
5. NOTIFY	Follow §(c) timelines: PDPO “immediately”; GDPR ≤72h; data subjects per direction/high risk. Notices use the §(d) content checklist; every breach — notifiable or not — enters the internal breach register (Art.33(5))	DPO (filing) / Communications (subjects) / Executive (approval)	Filed notification + delivery proof (registered/electronic mail); register entry
6. REVIEW	Root-cause analysis within 7 days; remediation plan with owners and dates (encryption, export bans, retraining, control gaps); post-incident review to the Data Governance Council within 30 days ; register closed only when all actions verified	Incident Lead + EDM Consultant	Post-incident review pack; updated risk register; DQ/control changes merged as PRs

(c) Timeline under both regimes

DPPA 2019 (Cap. 97) — Uganda

Clock	Obligation / internal target	Basis	Owner
+0	Awareness (discovery timestamp recorded)	Detection discipline	Reporter
≤ 1 hour	Internal escalation to Incident Lead + P1 ticket — internal target , no “investigate first”	Prevention of the 11-day delay	Any staff → Incident Lead
≤ 2 hours	Containment started (wipe/disable/revoke)	DPPA s.20 security measures	Technical Containment
≤ 4 hours	Assessment complete: categories, count, encryption-at-time, risk rating	s.23(4) content readiness	DPO
Same business day	Notify the Authority (PDPO): “immediately notify the Authority” of the unauthorised access/acquisition and the remedial action taken	DPPA s.23 (“immediately”)	DPO
Channel	Registered mail and/or electronic mail to the PDPO	s.23(3)	DPO
≤ 48 hours after PDPO direction	Notify affected data subjects if the Authority so decides (s.23(2) vests this decision in the PDPO, not SRG)	s.23(2)–(3)	Communications

Clock	Obligation / internal target	Basis	Owner
Content	Notices must give enough information for the data subject to take protective measures (nature, categories, approximate numbers, DPO contact, likely consequences, measures taken/proposed)	s.23(4)	DPO + Communications
Ongoing	Internal breach register entry regardless of notifiability ; retained for PDPO audit (expected within 12 months)	Accountability, s.3	DPO

GDPR — where EU data subjects are affected (e.g. loyalty/EU rollout)

Clock	Obligation	Basis	Owner
≤ 72 hours from awareness	Notify the lead supervisory authority ; if the deadline is missed, notification must include reasons for the delay	Art.33(1),(3)	DPO
Without undue delay	Notify data subjects when the risk is high (unless strong encryption rendered the data unintelligible — then communication may be unnecessary, documented with justification)	Art.34(1),(3)	DPO + Communications
Content of Art.33 notification	Nature of breach; categories & approximate numbers of records; DPO contact; likely consequences; measures taken/proposed	Art.33(3)(a)–(d)	DPO
Always, even if not notifying	Document the breach: facts, effects, remedial action — internal breach register	Art.33(5)	DPO
Internal target	First counsel engaged ≤ 24h; SCC/partner notice if the European distributor's data is involved (Art.44–49 flow)	Contractual	DPO

Decision tree

(d) Notification content checklist Aligned to **DPPA s.23(4)** (enable the data subject to take protective measures) and **GDPR Art.33(3) / Art.34(1)**:

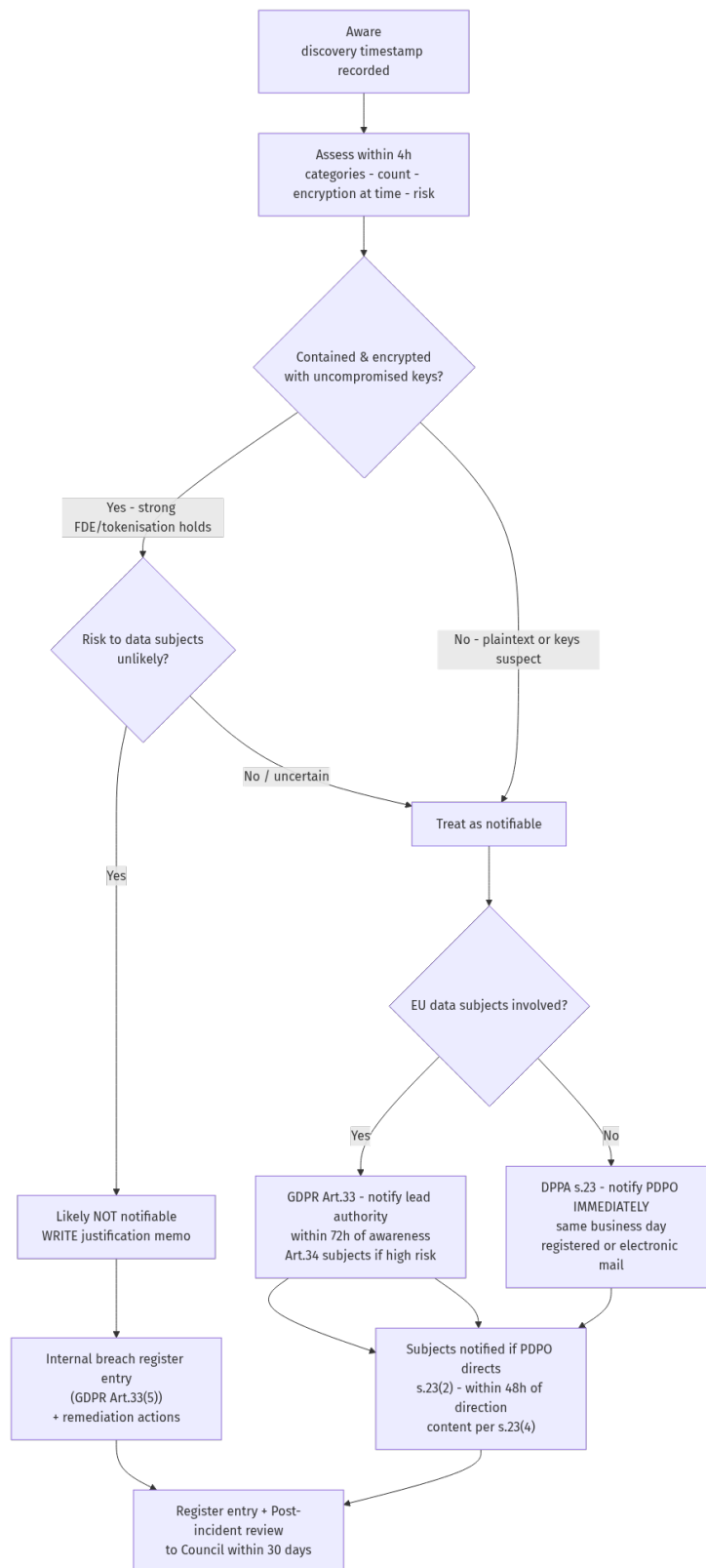


Figure 24: The C2 breach response plan diagram (2).

#	Element	Required by	Drafting note
1	Nature of the breach — what happened, when, where (system/device/store)	s.23(4), Art.33(3)(a)	Plain language; no jargon, no minimising
2	Categories of personal data affected (names, phones, purchase history, addresses, payment references)	s.23(4), Art.33(3)(a)	Use POL-001 tags to enumerate
3	Approximate number of records/data subjects (e.g. 9,000 records; 180,000 members)	s.23(4), Art.33(3)(a)	Ranges acceptable if exact count pending
4	DPO / contact point with telephone and email for questions	Art.33(3)(b), Art.34(2)	Name the interim holder if DPO pending
5	Likely consequences of the breach (targeted fraud, SIM-swap risk, nuisance marketing)	Art.33(3)(c), s.23(4)	Be specific to the data: phone + purchase history → social-engineering risk
6	Measures taken and proposed — containment done + steps the individual should take (reset PIN, watch for smishing, freeze USSD alerts)	Art.33(3)(d), s.23(4)	Actionable instructions are the statutory point of s.23(4)
7	Whether the Authority has been notified / direction status	s.23(2) flow	Include when data subjects are being notified
8	Reference number of the incident + breach register ID	Accountability (s.3, Art.5(2))	Enables PDPO audit tracing
9	Delivery method proof (registered mail receipt / electronic mail log)	s.23(3)	Evidence custodian files it

(e) WORKED EXAMPLE — the Jinja laptop incident, rewritten **Incident of record:** unencrypted laptop containing an export of **9,000 customer records** (names, phone numbers, purchase history) stolen from the Jinja store; reported internally **11 days late; no breach notification made.**

Dimension	What actually happened	Compliant response (this plan)
Discovery → escalation	Stolen device noticed, then days of internal discussion before escalation (11 days)	Hour 0 discovery → +1h Incident Head of IT owns P1 ticket; “investigate before reporting” prohibited
Containment	No wipe/revoke record; device unencrypted → data readable immediately	+2h remote wipe/disable attempted, sessions revoked, credentials/keys rotated, store box isolated; forensic copy preserved

Dimension	What actually happened	Compliant response (this plan)
Assessment	No formal assessment of categories, count, or encryption status	+4h classify: 9,000 records, names + phones + purchase history, UNENCRYPTED = high risk to data subjects (fraud/social-engineering potential)
Authority notification	None made (DPPA s.23 breach)	Same business day: PDPO notified under s.23 — unauthorised acquisition + remedial action — by registered/electronic mail (s.23(3))
Data-subject notification	None	s.23(2): await PDPO direction , then subject notices within 48h , content per s.23(4) (protective measures); SMS + email
GDPR clock	Not considered	+72h GDPR Art.33 clock started if any EU loyalty members were in the export (Art.33(1),(3)); Art.34 subjects if high risk
Register	No incident register entry	Breach register entry made at hour 4 regardless of notifiability (Art.33(5) discipline, DPPA s.3 accountability)
Remediation	None recorded	+7 days: FDE rollout (B1), export-approval ban, retraining, device-compliance reporting
Review	None	+30 days: post-incident review to Data Governance Council; risk register R1/R13 rescored

Provisions the as-was response violated

Provision	How it was violated
DPPA s.23 — “immediately notify the Authority”	No notification was made at all, for a realised unauthorised acquisition of 9,000 records
DPPA s.20 — security measures	Bulk personal-data export stored on an unencrypted device; no FDE, no export control
DPPA s.3 — principles (integrity, accountability, confidentiality-by-design)	11-day internal delay shows no accountability chain; no record of the decision <i>not</i> to notify
GDPR Art.32 / Art.33 (if EU data subjects in the export)	No 72-hour notification; no documented assessment or justification
Internal POL-001 (draft classification policy)	Export of a Restricted dataset without approval, logging, or expiry

Lessons (feed the P1 remediation in docs/C2_compliance_audit_checklist.md)

- Reporting latency is the real damage multiplier** — the laptop was unencrypted (control gap), but 11 days of silence is what converted an incident into a regulatory failure. Fix: 1-hour single-channel rule, no exceptions, measured and reported monthly.
- Encryption status must be assessed and written down** — had the device been FDE-protected with uncompromised keys, SRG could have documented “unlikely to result in risk” (Art.34(3)(a) logic) instead of having no assessment at all. Fix: FDE (B1) + the 4-hour assessment form.
- Notification is a statute with a clock, not a decision with a committee** — s.23 says “*immediately*”; GDPR says 72 hours from *awareness*. Fix: pre-approved templates, named DPO owner, executive sign-off within the same business day.
- The evidence trail is the defence** — without a breach register entry, SRG cannot prove what it did or when; the PDPO audit (expected within 12 months) will ask for exactly that. Fix: register live from day 1 of plan adoption.

Think-deeper answer Prompt: the laptop was stolen — is the plan really about laptops?

No. The laptop is only the *visible* failure; the plan exists because SRG’s true weakness was **decision latency under ambiguity**: nobody knew who to call, what counted as a breach, or who could notify — so 11 days elapsed while the s.23 clock (and potentially the Art.33 72-hour clock) was already running. Every element above attacks that latency: a single entry point (any staff member → on-call phone → Incident Lead ≤ 1h), a named Incident Lead with authority to contain without waiting for the Council, a written assessment form that turns “is this serious?” into a 4-hour checklist (categories → count → encryption-at-time → risk), and pre-drafted notice content mapped line-by-line to s.23(4) and Art.33(3) so drafting never starts from a blank page. The plan also encodes the honest asymmetry of the two regimes: DPPA demands *immediacy to the Authority* with the **PDPO** — not SRG — deciding whether data subjects are told (s.23(2)), while GDPR imposes a hard **72-hour** deadline from awareness with **Art.33(5)** requiring documentation even when nothing is notified. Finally, the worked example is deliberately kept in the portfolio as a permanent training artifact: it shows that a compliant response to the *same* theft would have cost roughly one business day of coordinated effort — versus the reputational, regulatory, and trust debt SRG now carries with zero notification on record.

Appendix T — Compliance Audit Checklist & Prioritised Remediation Plan

Task C2 Deliverable — Compliance Audit Checklist vs Task A2 Obligations Register

Task C2 — Security & Privacy (C8) **Client:** Savanna Retail Group (SRG) · **Prepared by:** Lead Enterprise Data Management Consultant **Status:** Draft for Data Governance Council · **Version:** 1.0 · **Assessment date:** Month 0 baseline **Frameworks assessed:** Uganda **DPPA 2019 (Cap. 97)** — s.3 principles, s.4 establishment of PDPO, s.6 data protection officer, s.7 consent, s.9 prohibition on special personal data, s.10 protection of privacy, s.11 collection of data from data subject, s.20 security measures, s.21 security measures re data processed by processor, s.23 notification of data security breaches, s.24 right to access, s.25 right to prevent processing, s.26 direct marketing, s.27 automated decision-taking, s.28 rectification/blocking/erasure, s.29 data protection register, s.30 public access to register (Cap. 97 consolidated numbering — verify against official gazette before external use); **GDPR** Art.5, 6, 7, 13/14, 15, 16, 17, 20, 21, 22, 25, 28, 30, 32, 33, 34, 35, 44–49, 83; **CCPA/CPRA** §1798.100, .105, .120, .130, .140, .150, .155 (applicability watch only). **Stakes if unremediated:** GDPR Art.83 penalties up to **EUR 20M or 4% of global annual turnover**; CCPA §1798.155 administrative fines and §1798.150 private right of action of **USD 100–750 per consumer per incident** (only if CCPA thresholds are ever met); PDPO audit expected within **12 months**. **Evidence base:** module2_data_quality/*, module3_etl/*, module4_security/*, module5_warehouse/*, plus the new deliverables in docs/.

1. Checklist (31 checks)

Check ID	Obliga- tion (frame- work + section/ar- ticle)	Control expected	Current state	Evidence or gap	Remedia- tion (artifact link)	Priority	Owner	Target month
CHK-01	DPPA s.29 data protection register (register as data collec- tor/con- troller/pro- cessor with PDPO); s.30 public access to register	Current registra- tion certificate + register entry	FAIL	No filing made with the PDPO to date	File regis- tration; retain acknowl- edgment; re-file on any change — docs/C2_dpia_loyalty_app.md §7	P1	EDM Consul- tant → CEO	Month 1–3

Check ID	Obliga- tion (frame- work + section/ar- ticle)	Control expected	Current state	Evidence or gap	Remedia- tion (artifact link)	Priority	Owner	Target month
CHK-02	DPPA s.4 (establish- ment of PDPO) + s.6 data protection officer	Appointed DPO with mandate, contact point published	FAIL	No formally appointed DPO (EDM Consul- tant acting interim in docs/C2_breach/C2_policy_privacy_app.md roles)	Appoint DPO (hire or desig- nated officer), publish contact in notices — docs/C2_policy_privacy_app.md M-04	P1	CEO	Month 1–3
CHK-03	DPPA s.3 principles; GDPR Art.5 (lawful- ness, fairness, trans- parency, accuracy, storage limitation, integrity, account- ability)	Written principles + demon- strable accu- racy/ac- countabil- ity controls	PAR- TIAL	Cleansing evidence exists (dupes 22.84% → 0.00%, total flags 25.06% → 2.85%, districts 127 → 42, UOM 15.33% → 100%, category 22% → 100%); no consoli- dated policy statement	Ratify principles in EDM policy (POL- 001/002/003) under Task A2 charter	P2	EDM Council	Month 4–6
CHK-04	DPPA s.7 consent to collect or process; GDPR Art.7 (consent records, easy with- drawal)	Granular, logged, withdraw- able consent at every capture point	PAR- TIAL	POS/app capture exists but consent bundled; no with- drawal audit trail; 23% duplicate era shows consent- to-identity linkage weakness	Consent rework: unbundled toggles, versioned consent log, with- drawal parity — docs/C2_dpia_loyalty_app.md M-05	P2	CRM Officer	Month 4–6

Check ID	Obligation (framework + section/article)	Control expected	Current state	Evidence or gap	Remediation (artifact link)	Priority	Owner	Target month
CHK-05	DPPA s.11 collection of data from data subject (notice at collection); GDPR Art.13/14 transparency	Layered notice stating purpose, retention, sharing, rights	PAR-TIAL	Privacy notice exists for UG operations; no field-level notice for structured address change; EU notice not drafted	Re-issue notices (POS receipt QR, app tab, checkout) naming the European distributor flow — docs/C1_impact_analysis.md §6	P2	CRM Officer + DPO	Month 4–6
CHK-06	DPPA s.9 prohibition on special personal data	No special/sensitive categories collected unless prohibited-case exemption applies	PASS	No special-category fields in schema; loyalty DPIA explicitly excludes national ID/passport; payroll restricted to need-to-know (column RE-VOKE)	Maintain via POL-001 tags on new attributes; re-verify on any schema change (CHG process)	P3	EDM Consultant	Month 7–12 (annual)
CHK-07	DPPA s.10 protection of privacy	No covert monitoring; aggregate-only footfall; masked analytics	PASS	No facial recognition (policy in docs/C2_dpipolicy_R3); masking views for analysts (data_masking_demo.py 4/4 PASS)	Keep signage current; sensor ratified with Council	P3	Store Operations	Month 7–12

Check ID	Obligation (framework + section/article)	Control expected	Current state	Evidence or gap	Remediation (artifact link)	Priority	Owner	Target month
CHK-08	DPPA s.20 security measures (technical + organisational)	Documented security programme: policy, roles, monitoring	PAR-TIAL	Technical controls designed (RBAC/RLS/quarantine); no single security programme document; no security metrics pack	Publish security programme referencing docs/C2_encryption_masking_spec.md + DQC/DQC-style security metrics	P2	Head of IT	Month 4–6
CHK-09	DPPA s.20 / GDPR Art.32 — endpoint encryption	Mandatory full-disk encryption + screen lock + remote wipe on any export-capable device	FAIL	Realised gap: the Jinja laptop was unencrypted (9,000 records: names, phones, purchase history); no device inventory or compliance report	FDE rollout, device-compliance reporting, export gate (B1, UGX 15M) — docs/C2_encryption_masking_spec.md §a/§b	P1	Head of IT	Month 1–3
CHK-10	DPPA s.21 security measures re data processed by processor (technical)	Processors contractually and technically secured	PAR-TIAL	Cloud storage encrypted in transit/at rest by provider defaults; no evidenced processor assurance for CRM/loyalty vendors	Processor security schedule + annual assurance questionnaires — with CHK-23	P2	EDM Consultant + Procurement	Month 4–6

Check ID	Obliga- tion (frame- work + section/ar- ticle)	Control expected	Current state	Evidence or gap	Remedia- tion (artifact link)	Priority	Owner	Target month
CHK-11	DPPA s.23 notifi- cation of data security breaches — “ <i>imme- diately notify the Author- ity</i> ”	Immedi- ate PDPO notifica- tion of unautho- rised access/ac- quisition + remedial action	FAIL	The Jinja theft was never notified; internal report was 11 days late; no s.23(2)–(4) process existed	Adopt docs/C2_breach_response_plan.md; retrospec- tive PDPO en- gagement on the Jinja incident; s.23 templates live	P1	DPO (incl. EDM Consul- tant)	Month 1–3
CHK-12	DPPA s.3 account- ability; GDPR Art.33(5) internal documen- tation of all breaches	Breach register logging every incident (notifiable or not)	PAR- TIAL	One known incident (Jinja) with no register entry; no register exists	Stand up breach register with the plan; back-enter Jinja entry with dates and gap statement — docs/C2_breach_response_plan.md	P1	DPO	Month 1–3
CHK-13	DPPA s.24 right to access; GDPR Art.15	Docu- mented access- request procedure with SLA and identity verifica- tion	FAIL	No procedure, no intake channel, no SLA; request would stall across 4-person team	Rights- request procedure (30-day SLA), intake mailbox, request log — docs/C2_dpia_loyalty_app.md	P2	DPO	Month 4–6
CHK-14	DPPA s.25 right to prevent process- ing, s.28 rectifica- tion/block- ing/era- sure; GDPR Art.16/17/20/21	Objection, rectifica- tion, erasure, portability honoured end-to- end (incl. SCD2 history golden record)	FAIL	No procedure; SCD2 design means erasure must be handled as anonymi- sation/rec- tification across versions — never specified until now	Rights runbook covering dim_customer versions + golden map; test with 3 sample requests — docs/C2_dpia_loyalty_app.md	P2	DPO + EDM Consul- tant	Month 4–6

Check ID	Obligation (framework + section/article)	Control expected	Current state	Evidence or gap	Remediation (artifact link)	Priority	Owner	Target month
CHK-15	DPPA s.26 direct marketing; GDPR Art.21 objection	Opt-in marketing, suppression list honoured across CRM/loyalty/POS	PAR-TIAL	Consent capture exists (CHK-04) but no central suppression list; walk-in attribution (8.7% revenue) complicates honouring objections	Suppression list wired into campaign exports; quarterly audit of sends	P2	CRM Officer	Month 4–6
CHK-16	DPPA s.27 automated decision-taking; GDPR Art.22	No solely automated adverse decisions without human review	PAR-TIAL	Tier/benefit logic not yet automated; DPIA defines the human-review path but it is not implemented	Implement human-review route for adverse tier/benefit outcomes + disclosure text — docs/C2_dpia_loyalty_app.md M-06	P2	CRM Officer	Month 4–6
CHK-17	GDPR Art.30 records of processing (RoPA)	Living record of purposes, categories, recipients, transfers, retention, security	PAR-TIAL	Processing inventory derivable from module5_warehouse_reporter (25 attributes + classification) and DPIA §2; not assembled as an RoPA, no automation	Manual RoPA now; catalog-driven response in data_dictionary.md Phase 2 — docs/C1_catalog_tools.md automation line	P3 (assembly P2)	DPO + EDM Consultant	Month 7–12 (draft at M6)

Check ID	Obliga- tion (frame- work + section/ar- ticle)	Control expected	Current state	Evidence or gap	Remedia- tion (artifact link)	Priority	Owner	Target month
CHK-18	GDPR Art.6 lawful bases for EU- resident members	Docu- mented basis per purpose (con- sent/con- tract/obli- gation)	PAR- TIAL	Bases identified in docs/C2_dpia and RoPA §3 but not recorded per pro- cessing operation in a register	Lock basis matrix + consent rework (CHK-04)	P2	DPO	Month 4–6
CHK-19	GDPR Art.25 protection by design and by default	Default- deny access, masking by default, minimisa- tion in design	PAR- TIAL	Strong artifacts: default- deny GRANTs, column- level REVOKE (payroll, phone/email), RLS store scoping, masking views, customer_sk = 0 design — deploy- ment to produc- tion pending (RBAC suite 15/15 PASS is a docu- mented <i>reference run</i> ; no Post- greSQL server in the build environ- ment)	Deploy module4 to produc- tion Post- greSQL 15/16 and re-run rbac_test.sql for live evidence	P2	Head of IT	Month 4–6

Check ID	Obligation (framework + section/article)	Control expected	Current state	Evidence or gap	Remediation (artifact link)	Priority	Owner	Target month
CHK-20	GDPR Art.33 (72 hours to supervi- sory authority, reasons for delay) / Art.34 (data subjects, high risk)	Adopted plan with clock discipline, templates, decision tree	PAR- TIAL	Plan now drafted in docs/C2_breaches/monitors/plan.md; not yet adopted, tabletop not run, no DPO to own the clock	Council adoption (Month 1) tabletop with Jinja scenario at Month 9	P1 (adoption) (tabletop)	Head of IT + DPO	Adopt: M1–3; tabletop: M9
CHK-21	GDPR Art.35 DPIA	Com- pleted, signed DPIA for high-risk process- ing	PAR- TIAL	DPIA- 2026-001 drafted in this portfolio (docs/C2_dpia/monitors/app.md); template appen- dices not supplied (structure follows EDPB/Art.35, cross- mapped); not yet signed; DPO slot empty	Sign-off (Council + DPO + sponsor); refresh at 12 months or on material change	P2 (sign-off) / P3 (refresh)	EDM Consul- tant → Council	Sign-off M4–6; refresh M7–12
CHK-22	GDPR Art.44–49 international transfers (SCCs)	Valid transfer mecha- nism + transfer impact as- sessment for EU flows	FAIL	No SCCs with the European distribu- tor; Uganda has no adequacy decision → sharing is currently ungated	Execute SCCs + transfer impact as- sessment before EU go-live (blocking gate in DPIA §6 M-03)	P2 (go-live blocking)	DPO + EDM Consul- tant	Month 4–6

Check ID	Obliga- tion (frame- work + section/ar- ticle)	Control expected	Current state	Evidence or gap	Remedia- tion (artifact link)	Priority	Owner	Target month
CHK-23	GDPR Art.28 processor contracts (also vendor manage- ment under DPPA s.21)	Written DPAs with SaaS CRM, loyalty cloud, fulfilment partners: purpose limits, sub- processor control, breach SLA ≤ 24h, audit rights, exit/porta- bility	FAIL	No DPAs evidenced; vendor register absent	Vendor register + DPAs; breach SLA; portabil- ity/exit clause; annual assurance review	P2	Procure- ment + DPO	Month 4–6
CHK-24	DPPA s.20 / GDPR Art.32 — access control	Default- deny RBAC, column- level REVOKE, row-level store scoping, named logins	PAR- TIAL	Imple- mented as artifacts: 5 roles (store_cashieman- ager, data_ana- lyst, compli- ance_offi- cer, cdm_ad- min), rbac_test.sql 15/15 PASS (reference output commit- ted), RLS proofs — produc- tion deploy- ment pending; shared till logins still defeat account- ability	Deploy to produc- tion; enforce named logins (B5 MFA); quarterly access recertifica- tion	P2	Head of IT	Month 4–6

Check ID	Obliga- tion (frame- work + section/ar- ticle)	Control expected	Current state	Evidence or gap	Remedia- tion (artifact link)	Priority	Owner	Target month
CHK-25	DPPA s.10 / GDPR Art.25/32 — masking of PII in analytics	Masking by default; raw access only to named roles, audited	PAR- TIAL	Masking functions proven: phone +256- XXX- XX1234, name J*** D**, email j***@domain, payment_ref MP*****89; data_masking_demo.py executed 4/4 PASS on live data — views not yet deployed as the pro- duction analyst surface	Deploy masked views as the only analyst entry point; audit raw- access use monthly	P2	Head of IT	Month 4–6
CHK-26	DPPA s.20 / GDPR Art.32(1)(a) — encryp- tion at rest	AES-256 on laptops, HQ servers, cloud storage, backups	PAR- TIAL	Cloud object storage encrypted (provider default); laptops unen- cryptd (see CHK-09 FAIL); encrypted backup + tested restore not yet operating (B4)	FDE (B1), encrypted backup + quarterly restore tests (B4), key custody split Head of IT/CFO	P2 (FDE itself P1)	Head of IT	Month 4–6

Check ID	Obliga- tion (frame- work + section/ar- ticle)	Control expected	Current state	Evidence or gap	Remedia- tion (artifact link)	Priority	Owner	Target month
CHK-27	DPPA s.20 / GDPR Art.32(1)(a) — encryption in transit	TLS 1.2+ everywhere; tunnels store → HQ; no plain FTP/email attachments	PAR-TIAL	ETL/DB traffic uses parameterised connections; legacy store links and ad-hoc email CSV flows not certified	Wire-Guard/Open-VPN tunnels + SFTP migration + certificate lifecycle (B2) — docs/C2_encryption_masking_spec.md	P2	Head of IT	Month 4–6
CHK-28	GDPR Art.5(1)(e) storage limitation; retention per POL-003 (aligned to DPPA s.3)	Enforced retention schedule with automated purge	PAR-TIAL	Policy written (POL-003): 24-month inactivity rule; purge job pending; no evidence of deletion runs	Imple-ment purge job + deletion log; report volumes quarterly	P3	IT Operations Lead	Month 7–9
CHK-29	DPPA s.20 / GDPR Art.32(5)(2) — audit logging & access review	Logs of access to Restricted data; periodic recertification	PAR-TIAL	etl_run_log + run-state dash-boards (RC-6 fix), DB role model in place; no access recertification cycle, no export log (Jinja export was unlogged)	Export approval log (B-line control), quarterly recertification of the 5 roles, log retention 12 months	P2	Head of IT	Month 4–6

Check ID	Obliga- tion (frame- work + section/ar- ticle)	Control expected	Current state	Evidence or gap	Remedia- tion (artifact link)	Priority	Owner	Target month
CHK-30	DPPA s.20 (organisa- tional measure) — training & awareness	Annual se- curity/pri- vacy training; incident- reporting drill for all staff	FAIL	No structured training; the 11-day reporting delay indicates the reporting rule was unknown; post- incident retraining promised but not delivered	Role- based training (cashiers → reporting rule; analysts → export rules), annual refresh, phishing drills	P2	DPO + Head of IT	Month 4–6 (annual cycle from M7)
CHK-31	CCPA/CPRA §1798.140 thresholds (USD 25M revenue / 100k con- sumers / 50% revenue from selling); §§1798.100/.105/.120/.130/.150/.155	Applica- bility test + readiness if thresholds met	N/A (monitor)	SRG does not currently meet thresholds (no California sales; data not sold/shared for cross- context be- havioural advertis- ing); policy posture: never sell/share keeps §1798.120 opt-out moot	Annual applicabil- ity re-test at each expansion gate (Kenya/Rwanda/US); if ever met: 45-day response capability (\$1798.130) and USD 100–750 per- consumer incident exposure (\$1798.150) noted for risk register	P3	DPO	Month 12 (annual)

2. Summary of results

State	Count	Share	Check IDs
FAIL	9	29%	CHK-01 (PDPO registration), CHK-02 (DPO), CHK-09 (endpoint encryption), CHK-11 (s.23 notification), CHK-13 (right to access), CHK-14 (rectify/object/erase), CHK-22 (SCCs/transfers), CHK-23 (vendor DPAs), CHK-30 (training)
PARTIAL	19	61%	CHK-03, 04, 05, 08, 10, 12, 15, 16, 17, 18, 19, 20, 21, 24, 25, 26, 27, 28, 29
PASS	2	6%	CHK-06 (no special personal data), CHK-07 (privacy/aggregate-only monitoring)
N/A (monitor)	1	3%	CHK-31 (CCPA applicability)
Total	31	100%	

Reading of the baseline: the *technical* posture is materially better than the *procedural* one — every FAIL except CHK-09/CHK-30 is a governance obligation (registration, DPO, notification, rights handling, contracts, transfers). That pattern is typical of an organisation that built controls in code (module2–module5) before building them in policy — which is exactly why the P1 list is governance-heavy plus one hard technical fix (FDE).

3. Prioritized remediation plan

P1 — Immediate (Months 1–3)

#	Action	Checks cleared	Artifact	Owner	Evidence of done
1	Register with the PDPO as data collector/controller (file, acknowledge, publish)	CHK-01 → PASS	docs/C2_dpia_loyalty §7	EDM consultant → CEO	Filing acknowledgment
2	Appoint the DPO (DPPA s.6), publish contact in all notices	CHK-02 → PASS	DPIA §4 / breach plan roles	CEO	Appointment letter + notice update
3	FDE rollout to every export-capable device + export-approval gate (B1, UGX 15M)	CHK-09 → PASS; CHK-26 → PARTIAL+	docs/C2_encryption_breach §a/§b	Head of IT	100% device-compliance report

#	Action	Checks cleared	Artifact	Owner	Evidence of done
4	Adopt the breach response plan + stand up the breach register (back-enter the Jinja incident with dates/gap statement)	CHK-11, CHK-12, CHK-20 → PASS/PARTIAL	docs/C2_breach_response+DPO.md	Responsible DPO	Council minute; register with Jinja entry
5	Retrospective PDPO engagement on the unnotified Jinja breach (s.23 posture repair)	CHK-11 → PASS	Breach plan §(c)/(e)	DPO	Filed correspondence

P2 (Months 4–6) — quick-win window (month-6 mandate)

#	Action	Checks	Artifact	Owner
6	Rights-request handling procedure (access, rectify, object, erase, portability; 30-day SLA; SCD2/golden-record runbook)	CHK-13, CHK-14 → PASS/PARTIAL	docs/C2_dpia_loyalty+DPO M-07	DPO
7	Consent capture rework + notices + suppression list (unbundled, versioned, withdrawable)	CHK-04, CHK-05, CHK-15, CHK-18	DPIA M-05; docs/C1_impact_analysis.md §6	CRM Officer
8	Vendor DPAs + register (Art.28 / DPPA s.21: purpose limits, breach SLA ≤ 24h, exit/portability)	CHK-10, CHK-23 → PASS	Threat model R8	Procurement + DPO
9	Access recertification + named logins/MFA + export log (quarterly cycle over the 5 roles)	CHK-24, CHK-29 → PASS/PARTIAL	module4_security/rbac_test.py; B5	Head of IT
10	Deploy module4 to production (RBAC, RLS, masking views) and re-run tests for live evidence	CHK-19, CHK-24, CHK-25 → PASS	rbac_test.sql 15/15 → live; data_masking_demo.py	Head of IT
11	SCC pack + transfer impact assessment with the European distributor (blocking gate for EU go-live)	CHK-22 → PASS	DPIA M-03	DPO

#	Action	Checks	Artifact	Owner
12	Security programme + training (reporting rule ≤ 1h taught to all staff; export rules for analysts)	CHK-08, CHK-30 → PASS/PARTIAL	docs/C2_encryption_masking_EdM; breach plan §(b)	IT Operations Lead
13	Encrypted backup + tested restore (B4) and store tunnels/TLS lifecycle (B2)	CHK-26, CHK-27 → PASS/PARTIAL	Encryption spec §a	IT Operations Lead
14	DPIA sign-off (Council + DPO + sponsor) and EU transparency notices	CHK-21 → PARTIAL+ , CHK-05	docs/C2_dpia_loyalty_EdM; §6	EDM Consultant

P3 (Months 7–12) — sustainment & audit polish

#	Action	Checks	Artifact	Owner
15	Retention purge job + deletion log (24-month inactivity, POL-003)	CHK-28 → PASS	DPIA M-08	IT Operations Lead
16	Tabletop exercise (Jinja scenario, 1h reporting clock, s.23/Art.33 drafts)	CHK-20 → PASS	Breach plan §(e)	Head of IT
17	Catalog-driven RoPA automation (export Art.30 record from catalog attributes + POL-001 tags)	CHK-17 → PASS	docs/C1_catalog_tool_EdM; Phase 2	EDM Consultant
18	DPIA refresh + annual applicability re-tests (CCPA, Kenya/Rwanda expansion)	CHK-21, CHK-31	DPIA §6 review clause	DPO
19	Quarterly governance cadence: dictionary/glossary review, role recertification, DQ/DQ-security metrics to Council	CHK-03, CHK-29 sustain	docs/C1_catalog_tool_EdM; §5	EDM Consultant

4. “PDPO audit readiness in 12 months” trajectory

Milestone	FAIL	PARTIAL	PASS	N/A	Narrative
Baseline (now)	9	19	2	1	Controls exist as <i>artifacts</i> ; obligations exist nowhere as <i>filing</i>
End Month 3 (P1)	5	19	6	1	Registered, DPO appointed, FDE live, breach plan + register adopted — the four audit-critical items are closed
End Month 6 (P2)	0	19	11	1	Rights handling, consent, DPAs, SCCs, deployed RBAC/masking, training — no failing checks remain
End Month 12 (P3)	0	6	24	1	Purge automation, tabletop, RoPA automation, refreshed DPIA; residual partials are continuous-improvement items with owners and dates

Trajectory statement for the Council: SRG will move from **9 FAIL / 2 PASS today to zero FAIL / 24 PASS within 12 months**, with every remaining PARTIAL carrying a named owner and a scheduled re-test. By month 3 the four things a PDPO auditor checks first — **registration (s.29), DPO (s.6), security measures incl. endpoint encryption (s.20), and breach notification capability (s.23)** — are demonstrably in place with evidence (filing acknowledgment, appointment letter, device-compliance report, adopted plan + register containing the Jinja entry). By month 12 the audit pack is self-sustaining: catalog-generated RoPA (Art.30), DQC/DQC-security metrics, quarterly recertification minutes, and a signed DPIA register — so the audit is met with *records*, not assurances.

Think-deeper answer Prompt: 61% of checks are PARTIAL — is that honest, or is “partial” a comfortable way to avoid failing?

It is honest only because each PARTIAL here splits a *real* seam: **designed vs deployed**. SRG genuinely has default-deny GRANTs, column-level REVOKE, RLS, and masking that demonstrably work — `rbac_test.sql` 15/15 PASS (documented reference run, no PostgreSQL server in the build environment) and `data_masking_demo.py` 4/4 on live data — yet a judge standing in a store today would find an unencrypted laptop and shared till logins. Marking CHK-19/24/25 FAIL would erase true engineering merit; marking them PASS would repeat the Jinja mistake of confusing documentation with protection. PARTIAL is the only truthful state — *provided* it carries a deployment date, which these rows do (P2, month 4–6). The sharper test of honesty is in the FAIL column: it deliberately includes the three the brief calls out (PDPO registration, s.23 notification, endpoint encryption) **plus six more** (DPO, access rights, objection/erasure, SCCs, DPAs, training) because an obligations register that reports only known headline failures while quietly passing untested rights-handling would be a checklist, not an audit. And the trajectory table exists to stop PARTIAL from becoming permanent: a partial with an owner and a month is a plan; a partial without either is a euphemism.

Appendix U — Five Strategic Business Questions & Analytics Workflow

Task C3.1 / C3.2 — Strategic Business Questions & End-to-End Analytics Alignment

Client: Savanna Retail Group (SRG) — 23 stores (ST01–ST10 Kampala, ST11–ST14 Jinja, ST15–ST18 Mbarara, ST19–ST23 Gulu) + SavannaShop (ECOM01) + loyalty app (180,000 members) **Prepared by:** Lead Enterprise Data Management Consultant **Evidence base:** module5_warehouse/star_schema_ddl.sql (warehouse.fact_sales, dim_customer, dim_product, dim_store, dim_date, dim_payment_method), loaded by module3_etl/srg_etl_pipeline.py into module3_etl/etl_demo.db — 10,000 sales lines, Jul–Dec 2024, net revenue **UGX 252,382,814**, average basket **UGX 25,238** ($252,382,814 \div 10,000 \text{ lines} = 25,238.28$). **Design rule:** every question is answerable with SQL/Python the team already has (2 SQL-capable IT staff + planned hires); machine learning appears only as a gated later pilot, never as a prerequisite for a Board decision.

Task C3 — Analytics, BI & Emerging Technology (C9)

C3.1 — The Five Strategic Board Questions (one per required theme) Each question below is written to be *decision-grade*: it names the decision it serves, is measurable against warehouse fields, and specifies an affordable method with an explicit justification.

Q1 — CHURN: “Which customer segments are churning, why, and what is the monthly revenue at risk?”

Element	Specification
Decision to be made	Approve the reactivation/referral budget and set a monthly new-customer floor; decide which segments to defend (investment) versus manage for margin (no acquisition spend).
Question (refined, measurable)	For every segment defined as $\text{city} \times \text{first-purchase cohort month} \times \text{channel}$ (store / ECOM01 / loyalty app): (a) what is the churn rate, where churn = a customer active in month t with no purchase in $t+1$; (b) what drives it (price/mix, availability, service) via cancelled/returned lines and category exit patterns; (c) what is the monthly revenue at risk in UGX = trailing-90-day net_amount_ugx of customers who have not purchased in the last 45 days? Anchor evidence: 858 of 1,237 (69.4%) November active known customers did not purchase in December; new known customers collapsed 1,272 $\rightarrow$ 148/month (–88%); repeat buyers are 2,447 of 3,362 known buyers (72.8%) yet drive 90.1% of identified transactions.
Data sources	warehouse.fact_sales $\times$ dim_customer (SCD2), dim_date, dim_store, dim_payment_method in module3_etl/etl_demo.db; module1_synthetic_data/output/SRG_Customers.csv (5,000 rows) and SRG_Sales.csv (10,000 rows) for lineage proof; loyalty-app membership extract (180,000 members); SavannaShop order export; analyst access only through the masked surface srg.customers_masked (module4_security/data_masking.sql).

Element	Specification
Preparation steps	Golden-record build already executed (module2_data_quality/dq_assessment_cleansing.py): duplicates 22.84% → 0.00% , total flag 25.06% → 2.85%, 5,000 → 3,858 golden records ; phones standardised to E.164 (6 → 1 variants); districts 127 → 42; quarantine rows excluded via etl_quarantine; walk-ins isolated as customer_sk = 0 and reported as a separate segment (8.0% of lines / 8.7% of revenue); PII masked (+256-XXX-XX1234, J*** D**) before any analyst handling; SCD2 point-in-time joins so a churn month is never scored against a later customer version.
Analytical method + why	RFM scoring + cohort retention curves (SQL window functions, then pandas groupby). <i>Why</i> : both methods need only transaction history that already exists in fact_sales — no labels, no training data, no specialist hire; RFM segments are directly actionable for a campaign (send to R/F/M bands), and cohort curves make the “new-customer collapse” visible as a retention story the Board can read in one chart. Machine-learning churn propensity is deliberately deferred to a gated pilot (M15, see C3_emerging_tech.md) — it cannot be trusted until 12+ months of post-cleanse history exist.
Output / format	Churn segment table (segment, actives, churned, churn %, UGX at risk) + retention heatmap + revenue-at-risk waterfall (UGX); “Customers” view on module6_dashboard/dashboard.html; 1-page addition to the monthly executive insight brief.
Cadence	Monthly (segment refresh), quarterly cohort deep-dive with the Marketing Officer.
Owner	Marketing / CRM Officer (accountable); Finance Manager validates the UGX at-risk figure; EDM Consultant owns method.

Q2 — SEGMENT GROWTH: “Which districts/city segments and product categories are genuinely growing (not just shifting), and where should we double down?”

Element	Specification
Decision to be made	Allocate the FY marketing capex and promo slots by district × category; stop funding segments that only <i>appear</i> to grow.
Question (refined, measurable)	For each of the 42 cleansed districts and the 6 conformed categories: what portion of the Δ revenue versus the prior month comes from (i) genuinely new buyers, (ii) retained buyers buying more often, (iii) larger basket size, (iv) price/mix effects — and what is each segment’s contribution to the six-month base of UGX 252,382,814? Which segments grow on <i>volume/buyers</i> (durable) versus <i>price/mix</i> (transitory)? Anchor evidence: category revenue Personal Care UGX 50.9M > Grains & Cereals 44.7M > Stationery 43.5M > Snacks 38.8M > Beverages 37.4M > Household 37.0M (sums to UGX 252.3M); monthly revenue peaks at Aug UGX 45.28M then declines to Dec UGX 35.76M (−13.6% vs Nov UGX 41.37M).

Element	Specification
Data sources	warehouse.dim_customer.district, dim_product.category, dim_store.city, fact_sales.net_amount_ugx; module2_data_quality/output/before_after_metrics.md (district 127 → 42 labels; category conformance 22% → 100%) as the confidence basis; module1_synthetic_data/output/injection_report.json to bound error rates; footfall pilot data (from M10) as the tie-breaker for catchment-driven growth.
Preparation steps	Same golden-record and E.164 pipeline as Q1; category conformance enforced by VR-010 and monitored by DQC-05; district alias table applied at load; SCD2-valid product version joined at sale date (so a price change is scored as <i>price</i> , not as organic growth); the 8.7% walk-in/unattributed revenue is excluded from district attribution and disclosed as a separate line — never silently spread across districts.
Analytical method + why	Cohort analysis + contribution decomposition (Δ revenue = new buyers + retained-buyer frequency + basket + price/mix), plus a location quotient per district (district revenue share ÷ district customer share). <i>Why</i> : SRG's stated fear is "shifting counted as growth" — decomposition is the cheapest method that separates durable demand from mix/price noise, and it is fully auditable in SQL for the CFO. A location quotient needs no external market data to be useful and becomes sharper once the cleansed 42-district list replaces the 127 free-text labels. ML demand models rejected for now: 6 months of history cannot train one honestly.
Output / format	Growth-contribution matrix (district × category, UGX and %), ranked "double-down list" with modelled UGX upside, and a "watch list" of price/mix-only growth; rendered as the series-toggle line chart and sortable table in dashboard.html.
Cadence	Monthly refresh in the dashboard; quarterly double-down decision paper to the Board.
Owner	Marketing Officer (demand) + Merchandising Manager (category); Strategy reviews the double-down list.

Q3 — STOCK OPTIMIZATION: "What explains the 8.4% book-vs-physical variance and which SKUs/stores need reorder-policy changes to end stock-outs without overstock?"

Element	Specification
Decision to be made	Fund the stock-variance task force; change reorder points/safety stock for named SKU × store combinations; decide whether to block new item setup until identifiers are unified.

Element	Specification
Question (refined, measurable)	Decompose the 8.4% book-vs-physical variance into attributable causes — identifier fragmentation (5 competing product identifiers), unit-of-measure errors, offline sales not yet posted, inter-store transfers, returns (500 lines, -UGX 10,224,221 $\approx$ 4% of gross), and shrinkage — as a UGX and % attribution table; then identify the Pareto-critical SKU $\times$ store cells where the reorder point must change, with the target: zero stock-outs in high-velocity cells and no increase in on-hand value for slow cells.
Data sources	warehouse.dim_product (sku, category, SCD2 price) and fact_sales.quantity for velocity; module1_synthetic_data/output/SRG_Products.csv (1,200 products, 5 identifiers) and SRG_Sales.csv; Odoo stock feed (future, from M8) — daily on-hand and movement ledger; POS stock ledger per store; etl_quarantine (posting failures); footfall pilot (M10–M12) for demand uplift in stock-out windows.
Preparation steps	One golden product key produced by the Module 2 product cleanse (composite product validity 3.25% $\rightarrow$ 100%, UOM conformance 15.33% $\rightarrow$ 100%, category 22% $\rightarrow$ 100%); SKU uniqueness enforced by VR-008 with DQC-06 zero-tolerance nightly check (141 duplicate-SKU rows and 69 SKU $\rightarrow$ multi-name rows currently flagged, never silently merged); returns kept as facts (negative quantity) rather than deleted; offline-capture rows identified via customer_sk = 0 and their posting lag measured, because an unposted offline sale reads as shrinkage.
Analytical method + why	Pareto analysis (vital-few SKUs/stores) + reconciliation variance analysis (book vs physical, per store $\times$ SKU, waterfall by cause) + a deterministic safety-stock model : $\text{reorder point} = \bar{d} \times LT + z \times \sigma_d \times \sqrt{LT}$. <i>Why</i> : this is arithmetic on data the firm will own once the Odoo feed lands — no model risk, every number explainable to a store manager, and it maps directly onto a policy change (a number on a reorder screen). It also needs only SQL/pandas, matching the 4-person team. ML forecasting is explicitly <i>not</i> the first move: an 8.4% unexplained variance would poison any trained model (garbage-in, automated).
Output / format	Variance attribution table (cause $\times$ UGX $\times$ %); reorder-policy change list (SKU, store, old ROP, new ROP, expected stock-out hours avoided); stock-out risk index per store; monthly “Variance Reconciliation Report” for Finance.
Cadence	Monthly variance review (Finance + Merchandising); weekly reorder run once rules are live (M9).
Owner	Merchandising Manager (policy); IT Operations Lead (Odoo feed); Finance signs the variance close.

Q4 — FRAUD: “How much revenue is exposed in unreconciled mobile-money transactions (11.5% of MoMo lines PENDING) and what fraud patterns are visible?”

Element	Specification
Decision to be made	Fund automated mobile-money reconciliation with a 48-hour Finance sign-off SLA; decide on provider escalation/write-offs; size the fraud-control effort.
Question (refined, measurable)	What UGX value sits in <code>reconciliation_status = 'PENDING'</code> — currently 849 of 7,385 MoMo lines (11.5%) — and how much of it exceeds the 24-hour rule in VR-012? What exception patterns exist: duplicate <code>payment_ref</code> , one phone/ref with abnormal transaction velocity, amount-rounding clusters, refund/return clustering by store or till, and PENDING aged beyond the offline-sync window? Value framing (line-count proxy): mobile money is 73.2% of revenue (MTN MoMo 48.2%, Airtel Money 25.1% — components rounded), so $0.732 \times \text{UGX } 252,382,814 \times 0.115 \approx \text{UGX } 21,245,585 \approx \text{UGX } 21.2\text{M of six-month revenue} \approx \text{UGX } 3.54\text{M/month}$ lacks a payment reference — to be re-based on <i>value</i> rather than line count at the first provider reconciliation.
Data sources	<code>warehouse.fact_sales.payment_ref</code> , <code>reconciliation_status</code> , <code>dim_payment_method</code> (MTN_MOMO, AIRTEL_MOMO, CASH, CARD); <code>etl_demo.db</code> table <code>etl_quarantine</code> (rejected rows); MTN MoMo and Airtel Money provider CSV statements matched by <code>reconcile_momo_pending.sql</code> ; <code>etl_run_log</code> for posting timing; monitoring check DQC-08 (pending > 24h; > 50/day = P1); rules VR-012 (<code>payment_ref</code> within 24h or PENDING).
Preparation steps	Payment refs captured in E.164-consistent form (payer phone already standardised); idempotent load keyed on <code>SHA1(transaction_id)</code> (<code>sale_sk</code>) eliminates double-counting as a fraud hypothesis; offline stores deliberately permitted to post with PENDING_RECON (an offline capture is a designed state at SRG, not an anomaly — <code>module3_etl/etl_diagnosis.md</code> RC-2/RC-3 context), so the analysis separates <i>lag</i> from <i>loss</i> by age band (0–24h, 24–72h, >72h); masked phone view used by analysts.
Analytical method + why	Rule-based exception engine (VR-012 aging, duplicate-ref detection, refund clustering) + velocity analytics (per-ref/per-phone counts and amount z-scores, computed in SQL). <i>Why</i> : deterministic and reproducible evidence is what Finance needs to dispute or write off with providers and what an auditor under the Uganda DPPA 2019 will accept; it runs on DQC-08 daily without a data scientist. AI-based anomaly detection is sequenced <i>after</i> the deterministic baseline exists (PILOT from M12+, per <code>C3_emerging_tech.md</code>) because anomaly models trained on unlabelled PENDING noise produce accusations, not evidence.
Output / format	Daily pending register (line count + UGX), aged >24h escalation list, exception scorecard (pattern, count, UGX, store/phone); KPI card “MoMo share” and returns % on <code>dashboard.html</code> ; monthly line in the executive insight brief.
Cadence	Daily automated check (DQC-08), weekly Finance reconciliation review, monthly Board KPI.

Element	Specification
Owner	Finance / Reconciliation Officer; CFO escalation when >50 pending/day; IT Operations Lead owns the pipeline flag.

Q5 — EXPANSION: “Given per-city performance and catchments, which of the next expansion moves (more Kampala stores, Kenya/Rwanda, deeper e-commerce) is justified first?”

Element	Specification
Decision to be made	Sequence the next capex: (a) additional Kampala stores, (b) Kenya entry, (c) Rwanda entry, (d) deeper e-commerce investment — with an explicit stop/continue gate for each.
Question (refined, measurable)	Which catchments (42-district granularity) are under-served, how does each city’s revenue share compare with its share of the estate, and how productive is ECOM01 versus an average physical node — i.e. where does the next UGX 1 of capex earn the highest <i>validated</i> return? Base arithmetic from the committed warehouse: Kampala holds 10 of 23 stores (43.5% of estate) but delivers 45.4% of physical revenue ($36.2\% \div 79.7\% \rightarrow$ index 1.04 ; Jinja 4/23 (17.4%) vs 16.3% $\rightarrow$ 0.94 ; Mbarara 4/23 (17.4%) vs 17.3% $\rightarrow$ 1.00 ; Gulu 5/23 (21.7%) vs 21.0% $\rightarrow$ 0.96 ; top single store $\approx 4.1\%$ (flat distribution); ECOM01 = 20.3% of total revenue from one node versus an average physical node of $79.7\% \div 23 = 3.47\% \rightarrow \approx$ 5.9$\times$ ($20.3 \div 3.47 = 5.85$). Read-through: revenue tracks store count almost exactly (indices 0.94–1.04) — <i>city averages show no per-store winner</i> , so catchment evidence, not city averages, must decide.
Data sources	warehouse.dim_store (store_bk, city), dim_customer.district (42 cleansed labels), fact_sales; loyalty penetration by district (180,000 members); SavannaShop orders (ECOM01); footfall pilot, 3 stores, M10–M12 ; store opening dates and trading hours; external: district population/income indicators and Kenya/Rwanda competitor scans (used only as context, clearly separated from warehouse evidence).
Preparation steps	District standardisation (127 $\rightarrow$ 42) so catchment counts are comparable; store conformance (ST01–ST23, ECOM01 per data dictionary attribute 22); walk-in 8.7% of revenue disclosed as <i>catchment-unknown</i> (it cannot be assigned to any district without the M7 loyalty phone-capture fix); opening-date normalisation so a store open 2 of 6 months is never ranked as underperforming.

Element	Specification
Analytical method + why	Catchment / location-quotient index (revenue share ÷ store-count or member share) + digital-penetration analysis (members per district vs revenue per member) + a simple gravity-style demand-potential index (population × purchasing proxy ÷ travel time), re-scored once footfall data arrives. <i>Why</i> : these are transparent ratios a Board can audit line-by-line before committing multi-hundred-million-UGX capex; they work on the flat-distribution evidence we already have and degrade gracefully as footfall replaces estimates. No ML: the sample is one six-month window and two of the four options (Kenya, Rwanda) have <i>zero</i> internal history — a model would manufacture precision we do not have.
Output / format	Expansion scorecard — one row per option (capex UGX, payback months, catchment index, channel productivity, execution risk), ranked, with a clear recommendation and gate conditions; presented as a Board decision paper at gates G2/G3/G4.
Cadence	Quarterly decision gate: G1 (M3) platform/security, G2 (M6) quick-win proof, G3 (M12) PDPO audit + scale, G4 (M18) expansion & ML authorisation.
Owner	Strategy / Expansion Director (accountable), CFO (capex), EDM Consultant (analytics), Data Governance Council (gate sign-off).

C3.2 — End-to-End Analytics Workflow (sources → preparation → methods → outputs → decisions) Rationale notes per decision (why this path produces a defensible decision):

Decision	Why the path is defensible
D1 — Churn	Cleansed golden records remove the 23% duplicate noise that previously mis-assigned loyalty points and would have <i>inflated</i> apparent churn; masking precedes analysis, so the churn list can be handed to Marketing without exposing raw PII (DPPA 2019 / GDPR Art.25 by design).
D2 — Growth	Contribution decomposition prevents price/mix shifts (e.g., the Aug UGX 45.28M peak) from being funded as organic growth; the 42-district standardisation is what makes district comparisons possible at all (127 labels could not aggregate).
D3 — Stock	Variance is decomposed <i>before</i> reorder rules change — changing ROPs against an 8.4% unexplained variance would convert a measurement problem into working-capital loss; the Odoo feed (M8) closes the loop, which is why the arrow returns to S4.
D4 — Fraud	Rules-first design yields provider-grade evidence (deterministic, reproducible) rather than statistical suspicion; the ETL already flags PENDING_RECON, so the control costs monitoring (DQC-08), not a new platform.
D5 — Expansion	Ratios are auditable by the Board today; catchment/footfall evidence (M10–M12) upgrades the same scorecard before any capex is committed — no option is approved on city averages alone, because indices 0.94–1.04 show city averages carry no signal.

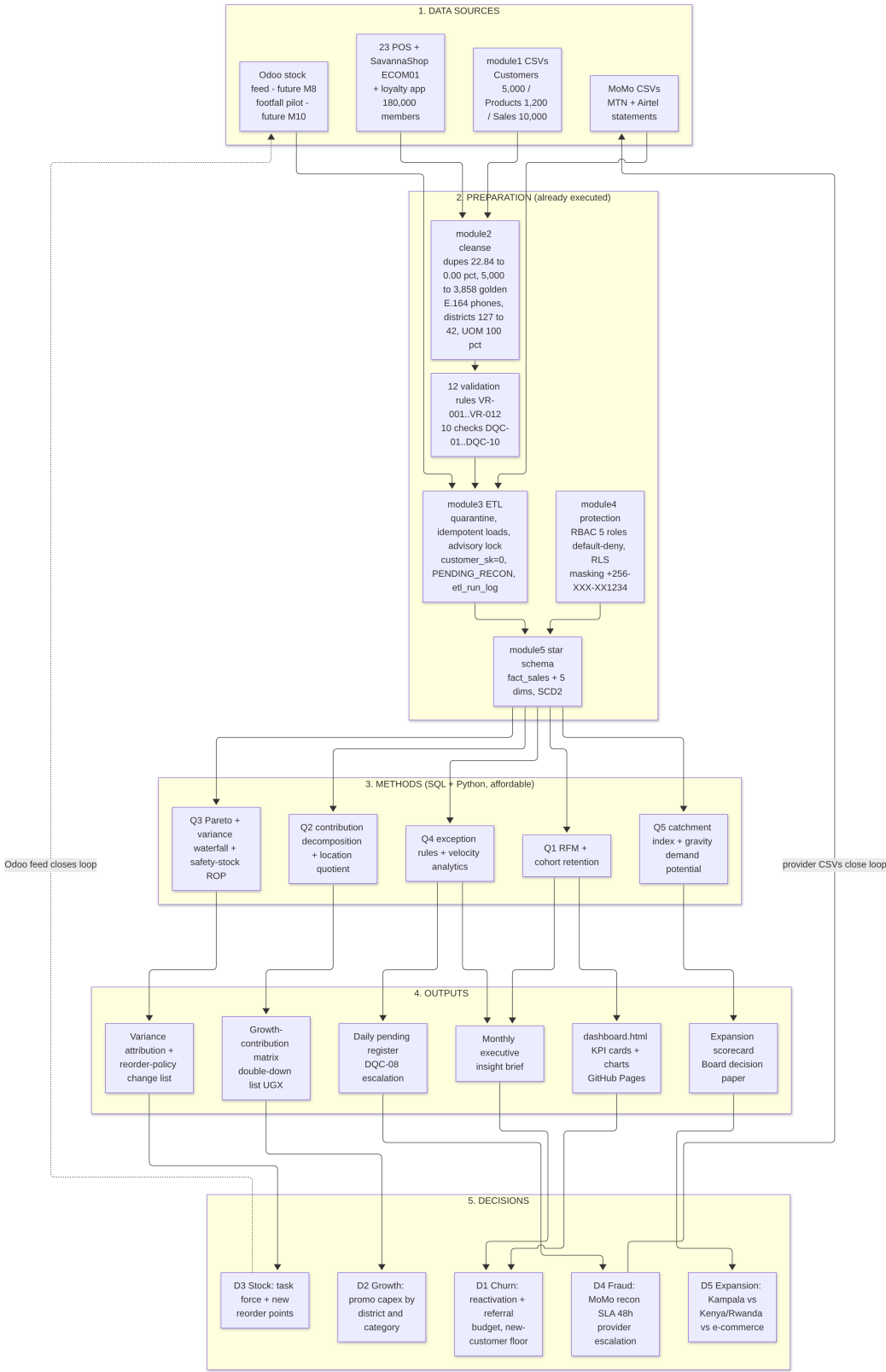


Figure 25: The C3 business questions diagram (1).

Think-deeper answer Isn’t five questions already too many for a firm with four IT staff — and why start with analysis rather than machine learning?

The five are not parallel projects; they are one funnel with a shared foundation. Q1, Q2, Q4 and Q5 all read from the same fact_sales star with the same cleansed dimensions — the marginal cost of the fourth question is one SQL query and one chart, not one platform. Only Q3 needs new data (the Odoo feed), which is why it alone is sequenced behind an integration milestone. Capacity is therefore spent on *preparation once, questions four times* — the exact leverage that a golden record, a conformed star schema and an idempotent pipeline are supposed to buy.

On ML: the honest constraint is evidential, not fashionable. SRG has six months of history, an 8.4% unexplained stock variance, 8.7% unattributed revenue and 11.5% unreconciled payment lines. A churn model trained on that would learn the measurement errors as if they were customer behaviour, and its recommendations would be unauditable to a Board that currently cannot answer segment growth/churn at all. The method ladder is deliberate: **descriptive (dashboard) → diagnostic (decomposition, variance, exception rules) → predictive (pilots from M12–M15, gated on triggers in C3_emerging_tech.md)**. Each level is only authorised when the level below it is stable under the daily checks (DQC-01...DQC-10). That ordering also matches the maturity plan in C3_analytics_maturity.md and the gates in D1_roadmap_18months.md, so the Board can withdraw any single question without collapsing the rest — and can see that “no ML yet” is a priced, reversible decision (see D-25 in D2_decision_log.md), not an oversight.

Appendix V — Dashboard Specification, Interaction Map & Published Screenshots

Task C3.3 — Executive Dashboard: Specification, Publication & Tufte/Few Self-Critique

Client: Savanna Retail Group (SRG) | **Deliverable:** module6_dashboard/dashboard.html (self-contained), published at <https://ccosecret.github.io/srg-enterprise-data-management/> | **Prepared by:** Lead Enterprise Data Management Consultant

Task C3 — Analytics, BI & Emerging Technology (C9)

Purpose & Audience

Aspect	Specification
Purpose	Give the SRG Board and metric owners a single, always-current view of trading performance, customer quality and payment integrity — replacing the 11-day monthly reporting cycle with a view that refreshes whenever the ETL runs.
Primary audience	Board / Executive Committee (KPI cards, trend, mix); Marketing Officer (new vs returning, churn proxy inputs); Merchandising Manager (category + store table); Finance/Reconciliation Officer (MoMo share, returns %).
Secondary audience	Data Governance Council (quality-sensitive metrics such as active customers, walk-in share); external auditors (consistent figures with etl_run_log and the data dictionary).
Design constraint honoured	Static, self-contained HTML: no server, no database credentials in the browser, no per-user licence, opens on any device — correct for a firm where several stores are offline for hours daily and power is unreliable (UPS-backed POS).

Data Source Chain (every number is traceable end-to-end)

Hop	Artefact	What it contributes
1	module1_synthetic_data/output/SRG_Customer_provided.csv (5,000), SRG_Products.csv (1,200), SRG_Sales.csv (10,000) + injection_report.json	Customer-provided SRG extract, Jul–Dec 2024, with known defect counts
2	module2_data_quality/dq_assessment/analysis/implies → module2_data_quality/output/*	Errors implying 22.84% → 0.00% (5,000 → 3,858 golden records), phones 6 → 1 (E.164), districts 127 → 42, UOM 15.33% → 100%, category 22% → 100%
3	module3_etl/srg_etl_pipeline.py	Executed ETL: schema contracts, etl_quarantine, idempotent loads, customer_sk = 0 unknown-member path, MoMo PENDING_RECON, advisory lock, etl_run_log (self-test 3/3 PASS; 10,000 rows loaded; control total UGX 252,382,814.16)
4	module5_warehouse/star_schema_ddl (fact_sales + dim_customer/dim_product/dim_store/dim_employee/dim_synthetic_data/dim_toolbox SCD2)	Confirmed model the dashboard queries — 25 documented attributes in module5_warehouse/star_schema_ddl_dictionary.md
5	module3_etl/etl_demo.db — the executed ETL output holding the star-schema data	Sole data source read by the build script
6	module6_dashboard/build_dashboard_queries	Queries etl_demo.db, computes every KPI/series client-side-precomputable, emits module6_dashboard/dashboard.html (Chart.js + vanilla JS, all data embedded as JSON)
7	module6_dashboard/dashboard.html → GitHub Pages	Published at https://ccosecret.github.io/srg-enterprise-data-management/

Headline figures rendered (must match warehouse exactly): 6-month net revenue **UGX 252,382,814** over 10,000 lines; average basket **UGX 25,238**; monthly revenue Jul 43.34M, Aug 45.28M (peak), Sep 43.24M, Oct 43.40M, Nov 41.37M, Dec 35.76M (–13.6% vs Nov); city mix Kampala 36.2%, E-commerce 20.3%, Gulu 16.7%, Mbarara 13.8%, Jinja 13.0%; payment mix mobile money 73.2% (MTN MoMo 48.2%, Airtel MoMo 25.1% rounded), Cash 22.7%, Card 4.1%; returns 500 lines, –UGX 10,224,221 (~4%); walk-in/unattributed 8.0% of lines and 8.7% of revenue.

Interaction Specification

#	Control / behaviour	Exact behaviour	Scope of effect
1	Filter — month range	Range selector over Jul–Dec 2024 (start/end month)	All KPI cards, all charts, store/city table recompute on the selected window
2	Filter — city	Multi-select: Kampala, Jinja, Mbarara, Gulu, E-commerce	Restricts store rows, revenue series, category and payment breakdowns, customer counts

#	Control / behaviour	Exact behaviour	Scope of effect
3	Filter — category	Multi-select across the 6 conformed categories (Beverages, Grains & Cereals, Snacks, Household, Personal Care, Stationery)	Filters revenue/category charts, KPI cards, table rows
4	Filter — payment method	Multi-select: MTN MoMo, Airtel Money, Cash, Card	Filters KPI cards, revenue line, table; donut highlights selection
5	KPI recompute	Net revenue, transactions, active customers, average basket, MoMo share, returns % — every card recomputes from the filtered fact set (average basket = filtered revenue ÷ filtered line count)	KPI cards only (charts reflect the same filter state)
6	Series toggle — line chart	Toggle between “All cities” and a single city series for monthly revenue	Monthly revenue line chart
7	Drill-up (click-through)	Click a store/city table row → panel expands to the per-category breakdown of the selected row (revenue UGX, share of row, line count); click again/again to return to the estate view	Table + category panel only; other charts keep the global filter state
8	Sort	Click column headers on the store/city table (revenue, share, lines, returns) — default sort descending by revenue	Table only
9	Chart types	KPI cards; multi-series line (monthly revenue); horizontal bar (revenue by category); donut (payment-method mix); grouped bars (new vs returning customers per month); sortable store/city table	As named
10	Reset	Single “Reset filters” control restores full-window state on all widgets simultaneously	Whole dashboard

Visualization Inventory

Chart	Board question served (C3.1)	Type	Why chosen
KPI cards (net revenue, transactions, active customers, avg basket, MoMo share, returns %)	All (scorecard layer)	Statistic cards	One-number-per-decision framing; no axes to misread; first screen tells a Board the health of the business in 5 seconds
Monthly revenue, Jul–Dec 2024, with city series toggle	Q1/Q2 (trend, Dec –13.6% signal)	Multi-series line chart	Time comparison is the job; lines encode trend by position on a common baseline; toggle avoids cluttered 5-line spaghetti
Revenue by category	Q2 growth / double-down	Horizontal bar (sorted)	Six categories with long labels — horizontal bars give label room and honest length comparison
Payment-method mix	Q4 fraud / reconciliation exposure	Donut with value labels	Part-to-whole with 4 categories only (48.2 / 25.1 / 22.7 / 4.1) — slices remain distinguishable; makes “73.2% mobile money” viscerally one shape
New vs returning customers per month	Q1 churn (new-customer collapse 1,272 → 148)	Grouped bars	Side-by-side comparison of two series per month; height on a zero baseline shows the –88% collapse without axis tricks
Store / city table	Q3 + Q5 (store flatness ≈4.1% top store, ECOM01 20.3%)	Sortable table with click-through	Precise values for accountability; the only honest way to show 24 near-equal shares; drill-up delivers category traceability

Publication & Refresh Instructions

```
# 1) regenerate the warehouse data (idempotent; safe to re-run)
python3 module3_etl/srg_etl_pipeline.py --self-test # 3/3 PASS expected
# -> refreshes module3_etl/etl_demo.db (10,000 rows, control total UGX 252,382,814.16)

# 2) rebuild the dashboard (reads ONLY module3_etl/etl_demo.db)
python3 module6_dashboard/build_dashboard.py
# -> emits module6_dashboard/dashboard.html (self-contained: Chart.js + vanilla JS + embedded JSON)
# -> also refreshes index.html at the repo root, which is what the
# GitHub Pages root URL serves (identical bytes, one build)

# 3) publish
git add module6_dashboard/dashboard.html index.html
git commit -m "dashboard: refresh from etl_demo.db"
git push origin main
# -> GitHub Pages redeloys automatically; verified at
# https://ccosecret.github.io/srg-enterprise-data-management/
```

Aspect	Rule
Refresh cadence	After every successful ETL run (nightly target); mandatory rebuild after any cleanse re-run, so dashboard figures and <code>before_after_metrics.md</code> can never diverge
Freshness evidence	<code>etl_run_log</code> (from <code>srg_etl_pipeline.py</code>) is the authoritative run record — the dashboard header displays the run id/date it was built from
Failure behaviour	If <code>etl_demo.db</code> is missing or the control total $\neq$ UGX 252,382,814.16 for the current dataset, the build script exits non-zero and the previous <code>dashboard.html</code> stays live (never publish a half-built page)
Access control	Public GitHub Pages shows only aggregated figures (Public/Confidential classification per <code>data_dictionary.md</code>); no <code>payment_ref</code> , no phone, no name — restricted PII never leaves <code>module4_security</code> masked views

Tufte / Few Self-Critique Deleted during design (and why it was misleading): - **A 24-slice pie of store revenue shares — DELETED.** The estate is deliberately flat: the top physical store is $\approx 4.1\%$ of revenue and most stores sit in the 2–4% band (ECOM01 20.3%, the rest clustered). Twenty-four slices of 2–4% each are visually indistinguishable — the human eye cannot discriminate angles/areas that similar — and adjacent near-identical wedges invite the reader to rank them, which the chart cannot support. It was replaced by the **sorted horizontal bar table with explicit values** (store/city table, default sort desc), which shows both the precise share and the flatness in one glance, and enables the drill-up to category.

Rejected pre-build: - **3D bars** — perspective distorts bar heights (a rear bar reads shorter at equal value) and adds zero information (chartjunk). - **Dual-axis chart mixing revenue (UGX tens of millions) and customer counts (hundreds)** — the choice of axis scale silently manufactures any correlation the author wants; it is scale manipulation, not analysis. - **Gauge charts for single KPIs** — one needle per KPI is a very low data-ink ratio: an arc, ticks and a label to transmit one number; six gauges would occupy a screen that six flat KPI cards serve better.

Data-ink ratio & decluttering choices applied: - Zero-baseline axes on all bars and lines (Tufte's lie factor = 1.0); no truncated revenue axis to dramatise the Dec -13.6% dip — the number is stated in the KPI/tooltip instead. - No 3-D, no drop shadows, no gradients, no background images, no legend where direct labelling fits (category bar, donut values). - Gridlines reduced to faint horizontal guides on the line chart only; no chart borders; no redundant y-axis label repeated on every grouped bar. - Colour: ≤ 5 semantic colours (mobile money / cash / card / returns / neutral), colour-blind-safe, used consistently across donut, table and KPI cards; the donut and the grouped bars encode one variable by colour and one by position — never colour alone for critical meaning. - Sorted encodings everywhere a ranking matters (bars descending, table descending by revenue) so the reader's eye does not have to do the sort. - Every filtered state recomputes rather than greys-out: Few's principle that a control must be truthful about what it is showing.

Limitations (stated on the page itself): - **Sample: 6 months only** (Jul–Dec 2024, 10,000 lines) — seasonality claims (Dec -13.6%) are single-observation; cohort/maturity statements require M12 history. - **Provenance disclosed:** the dataset is the **course-provided SRG extract** (5,000 customers / 1,200 products / 10,000 sales lines) cleansed and loaded by the committed pipeline — figures are pipeline-faithful, not production-certified, until the live POS/e-commerce/Loyalty feeds replace them. - **Walk-in caveat:** 8.7% of revenue (8.0% of lines) sits on `customer_sk = 0` (unknown member) — district/catchment and “active customer” figures are therefore floors, not exact values, until the M7 loyalty phone-capture fix. - **No margin or inventory feeds yet:** revenue ranking $\neq$ profit ranking, and stock questions (Q3) cannot be answered from this dashboard until the Odoo feed lands (M8). Returns % ($\sim 4\%$ of gross) is the only cost-side proxy present.

Think-deeper answer Critique the dashboard honestly under Tufte/Few: which chart did you delete, why was it misleading, and what replaced it?

The deleted chart was the **24-slice pie of store revenue shares**, and it was misleading in three specific ways, not merely “ugly”: (1) *discrimination failure* — with shares clustered around 2–4% (top physical store ≈4.1%, ECOM01 the sole outlier at 20.3%), adjacent wedges differ by roughly one to two degrees of arc, below the threshold at which viewers can rank them; (2) *false precision of angle perception* — pie reading requires comparing angles/areas, the perceptual channel with the poorest ratio accuracy, so a viewer “sees” differences that are within rounding noise and a stable estate looks volatile; (3) *composition without comparison* — a pie shows part-of-whole but hides the actual decision variable, which is whether any store materially outperforms its peers (it does not — city revenue shares track store-count shares at indices 0.94–1.04). The replacement — a **sorted horizontal bar table with values** plus click-through to the per-category breakdown — fixes all three: length on a common baseline is the most accurately read encoding, the values are printed (no estimation), sorting makes the flatness self-evident, and the drill-up answers the follow-up question (“why is this row what it is?”) without a second page.

The pre-build rejections came from the same discipline: 3D bars distort, the dual-axis revenue/customers chart lets axis scaling invent correlation, and single-KPI gauges spend a whole widget to transmit one number (data-ink ≈ near zero). The residual risk I accept rather than hide: a static, self-contained page has no row-level security — mitigated by publishing only aggregated, non-PII measures and by keeping all Restricted fields behind module4_security masked views — and a donut still encodes part-to-whole by angle, which is why the payment mix is also printed as a percentage inside each slice and repeated as the “MoMo share” KPI card. The dashboard is deliberately *boring*: every pixel either carries data or labels data, because a Board under time pressure needs the number, not the chart.

Appendix W — Executive Insight Brief (Three Findings, Three Actions)

SRG Executive Insight Brief — Jul–Dec 2024 Warehouse

To: Board of Directors, Savanna Retail Group (SRG) **From:** Lead Enterprise Data Management Consultant **Period:** Jul–Dec 2024 warehouse — fact_sales, 10,000 lines, net revenue **UGX 252,382,814**, average basket **UGX 25,238**

Task C3 — Analytics, BI & Emerging Technology (C9)

F1 — GROWTH IS RUNNING ON OLD FUEL **Evidence.** New known customers per month collapsed from **1,272 (Jul) to 148 (Dec)**, –88%, while returning customers grew from 0 to 910–987. Repeat buyers are 72.8% of known buyers (2,447 of 3,362) and drive **90.1% of identified transactions**. December revenue fell –13.6% **month-on-month** (UGX 41.37M → UGX 35.76M), and **858 of 1,237 (69.4%)** November actives bought nothing in December.

Implication. The base is contracting beneath a stable repeat core; acquisition has stalled and roughly seven in ten active customers defect each month.

Action. Operate the churn/segment lifecycle view already on the published dashboard; launch a reactivation + referral campaign in Kampala and Jinja — **owner: Marketing Officer, by M7**. Publish a monthly new-customer floor — **KPI: ≥ 600 new known customers/month and churn proxy ≤ 50% by M9**. Close the 8.7% walk-in gap via loyalty phone-capture at the till — **KPI: unattributed revenue < 3% by M9**.

F2 — CASH IS SITTING IN A RECONCILIATION GAP **Evidence.** Mobile money carries **73.2% of revenue** (MTN MoMo 48.2%, Airtel Money 25.1% — components rounded), yet **849 of 7,385 MoMo lines (11.5%) still lack payment references (PENDING)**. Line-count proxy: $0.732 \times \text{UGX } 252,382,814 \times 0.115 \approx \text{UGX } 21.2\text{M}$ of six-month revenue (~UGX 3.54M/month) is **unconfirmed**.

Implication. Revenue is recognised but not evidenced — a working-capital and audit exposure, and the firm’s largest fraud surface (VR-012, DQC-08).

Action. Stand up the automated MoMo reconciliation pipeline — the ETL already flags PENDING_RECON; this is matching, not new plumbing. Finance sign-off **SLA 48 hours; escalate above 50 pending/day** — **owner: Finance/Reconciliation Officer, by M5**. **KPI: zero lines pending > 24h by M6; pending share < 0.5% of MoMo lines by M12**.

F3 — CHANNEL DEMAND OUTPACES STOCK CONTROL **Evidence.** E-commerce (ECOM01) already contributes **20.3% of revenue from a single node** — about **5.9× an average physical store’s 3.47% share** — while the estate carries **8.4% unexplained book-vs-physical stock variance** and simultaneous stock-outs in high-demand stores and overstock in slow ones. Returns ran at 500 lines, –UGX 10,224,221 (~4% of gross).

Implication. We cannot promise availability where demand actually is, and every inventory-led decision (reorder, expansion, promo) inherits an 8.4% measurement error.

Action. Unify stock visibility — **footfall + near-real-time POS pilot in 3 stores, M10–M12**; convene a variance reconciliation task force with Odoo stock feeds; apply safety-stock reorder rules to top-SKU/high-velocity store cells — **owner: Merchandising Manager, by M9. KPI: book-vs-physical variance ≤ 5.0% by M9 and ≤ 2.0% by M12; high-velocity stock-out hours halved by M12.**

What the Board must decide

1. **Approve** the automated mobile-money reconciliation programme and 48-hour Finance sign-off SLA (owner Finance/Reconciliation Officer, by M5).
2. **Fund** the stock-variance task force and the 3-store footfall/POS pilot (owner Merchandising Manager, M9–M12).
3. **Adopt** the segment targets — ≥ 600 new known customers/month, churn proxy ≤ 50% — and authorise the Kampala/Jinja reactivation + referral campaign (owner Marketing Officer, by M7).

Source: *module3_etl/etl_demo.db* (control total UGX 252,382,814.16); dashboard: <https://ccosecret.github.io/srg-enterprise-data-management/> — course-provided SRG extract, Jul–Dec 2024.

Think-deeper answer Is a three-finding brief selective storytelling? Each finding was chosen because its evidence is warehouse-verifiable and its action is funded in D1_roadmap_18months.md; the left-out candidates — flat store distribution (top store ≈4.1%) and 72.8% repeat concentration — sit in the dashboard for Board interrogation.

Appendix X — Emerging Technology Evaluation & Analytics Maturity Path

Task C3.5 — Emerging Technology Evaluation: Cloud EDM Platform & AI-Driven Trends

Client: Savanna Retail Group (SRG) | **Prepared by:** Lead Enterprise Data Management Consultant **Envelope constraint (non-negotiable):** UGX 480,000,000/year all-in (480,000,000 ÷ 12 = **UGX 40,000,000/month**; 1 USD ≈ UGX 3,700 → ≈ USD 130,000/year), covering licences, cloud **and** hires; IT team of 4 (2 SQL-capable, **zero data-engineering**); several stores offline for hours daily; PDPO audit within 12 months.

Task C3 — Analytics, BI & Emerging Technology (C9)

(a) ONE Cloud EDM Platform Stack — Azure vs AWS vs GCP vs Snowflake/Databricks

Evaluation criteria, weights and scores (1 = poor fit, 5 = excellent fit)

#	Criterion (weight)	Why it matters at SRG	Azure	AWS	GCP	Snowflake / Databricks
1	Fit with UGX 480M/yr all-in budget (25%)	Cloud must leave room for 3 hires + licences + security; cloud line capped at ≤ UGX 90,000,000/18 months = UGX 5,000,000/month	4	4	4	2 — consumption pricing (compute/credit) is unpredictable for a team that cannot forecast its own load

#	Criterion (weight)	Why it matters at SRG	Azure	AWS	GCP	Snowflake / Databricks
2	Fit with skills — 4 staff, no data engineers (20%)	Every managed-service dependency the team cannot operate becomes a consultant invoice	4 — managed everything + Power BI low-code path	3 — broad but more assembly required (Glue + MWAA + QuickSight are separate skills)	3 — strong BigQuery, thinner orchestration/MLOps fit for this team	2 — Databricks needs data engineers SRG does not have; Snowflake SQL is easy but admin/op-optimisation is not
3	Connectivity realities — stores offline hours daily, no Ugandan cloud region (15%)	Nearest-region latency + egress; dashboard must tolerate batch, not require always-on	3 — South Africa North / West Europe nearest; batch-first patterns supported	3 — af-south-1 / eu-west-1 comparable	3 — africa-south1 / europe-west comparable	3 — same latency physics; egress on top of compute credits
4	EU-partner alignment / data residency (20%)	European distributor partnership demands GDPR-equivalent practices; transfers governed by GDPR Art.44–49 + DPPA 2019 s.3	5 — mature EU regions, EU Data Boundary commitments, standard contractual clauses out of the box	4 — EU regions + DPF/SCC support	4 — EU regions + SCCs	4 — EU/UK/South Africa regions available; shared-responsibility terms need review
5	Integrated EDM services: warehouse + orchestration + catalog + masking (20%)	One accountable vendor beats five contracts for a 4-person team; masking/RBAC must extend the Module 4 model	5 — SQL/Postgres + Data Factory + Microsoft Purview catalog + Always Encrypted/dynamic masking	4 — S3 + Glue + MWAA + Lake Formation + Macie (masking more manual)	3 — BigQuery + Composer, but catalog/masking story is thinner for mid-market	4 — excellent warehouse, but catalog/governance/masking are paid add-ons or third-party
	Weighted total (max 5.00)		4.25	3.65	3.45	2.95

Arithmetic example (Azure): $(0.25 \times 4) + (0.20 \times 4) + (0.15 \times 3) + (0.20 \times 5) + (0.20 \times 5) = 1.00 + 0.80 + 0.45 + 1.00 + 1.00 = 4.25$.

Verdicts

Option	Verdict	Reasoning
Microsoft Azure — Blob/ADLS Gen2 + Azure Database for PostgreSQL + Data Factory (serverless SQL for ad-hoc) + Power BI	ADOPT — phased	Highest weighted score (4.25). One vendor spans storage, warehouse, orchestration, catalog and masking; the Power BI route is the cheapest Board-grade BI available to SRG and needs no data engineer; EU regions + SCCs directly serve the European distributor requirement.
AWS (S3 + RDS PostgreSQL + Glue/MWAA + QuickSight)	Fallback — not selected	Credible (3.65) and equally budget-safe, but requires the team to assemble and own more moving parts; re-evaluated at gate G1 if Azure pricing or EU terms move adversely.
Google Cloud Platform	Not selected	3.45 — strong analytics engine, weakest integrated EDM/catalog fit for a 4-person mid-market team.
Snowflake / Databricks	PILOT — deferred (revisit M13+)	2.95. Consumption/credit pricing is a real risk when nobody on staff can estimate or tune a workload, and Databricks assumes data-engineering capability SRG does not have. Revisit only if/when trigger T6 (dedicated data-engineering capability hired and load proven) fires.

Cost fit — explicit arithmetic (cloud line ≤ UGX 90,000,000 / 18 months)

Item	USD basis	UGX arithmetic	UGX / 18 months
Power BI Pro, 5 users	USD 10/user/month	$10 \times 3,700 = \text{UGX } 37,000/\text{user/month};$ $37,000 \times 5 = 185,000/\text{month};$ $185,000 \times 18 = 3,330,000$	UGX 3,330,000 (booked in the licences line of D1_roadmap_18months.md)
Managed PostgreSQL (prod + non-prod)	USD 300–600/month	$300 \times 3,700 = 1,110,000/\text{month} \dots$ $600 \times 3,700 = 2,220,000/\text{month};$ $\times 18$	UGX 19,980,000 – 39,960,000 (≈ 20–40M)
Object storage, egress, backup, monitoring, orchestration worker	—	allowance within envelope	≤ UGX 46,670,000 $(90,000,000 - 40,000,000 - 3,330,000 \text{ headroom check: } 40,000,000 + 3,330,000 = 43,330,000; 90,000,000 - 43,330,000 = \text{UGX } 46,670,000 \text{ remains for storage/egress/backup/monitoring})$
Cloud total		UGX 3,330,000 + UGX 40,000,000 = UGX 43,330,000 ≤ UGX 90,000,000 cap (≈ USD 11,711 of the ≈ USD 24,324 cap: $90,000,000 \div 3,700 = 24,324$)	≤ UGX 90,000,000 — passes with UGX 46,670,000 headroom (≈ USD 12,613)

Phasing and migration triggers

- **Phase 1 (M1–M6): stay on the current on-prem / SQLite + PostgreSQL pattern.** There is genuinely *nothing to migrate*: the committed dataset is a 10,000-line extract and `etl_demo.db` is a single ~2.7 MB file; paying cloud egress/compute for it would be waste, and Phase 1 funds instead the Odoo feed, dashboard and MoMo reconciliation where the value is. Cloud Phase 1 spend is limited to encrypted off-site backup and a non-prod managed PostgreSQL instance.
- **Migration triggers (any ONE authorises Phase 2 migration at gate G1/G3):**
 - **T1 — Volume:** warehouse exceeds ~5M fact rows/quarter or 50 GB, or nightly ETL routinely exceeds the offline sync window.
 - **T2 — Access:** more than 2 concurrent BI users outside HQ, or a Kenya/Rwanda entity needs in-region data.
 - **T3 — Resilience:** on-prem hardware/DR requirement can no longer be met by the 4-person team (second UPS/hardware failure in 6 months).
 - **T4 — Compliance:** the European distributor or the PDPO audit requires a hosted environment with contractual SCCs, documented residency and audited controls.
 - **T5 — Cost:** on-prem extension/UPS/licensing quotes exceed the cloud run-rate (UGX 5,000,000/month equivalent).
 - **T6 — Capability:** a hired data-engineer stabilises credit/consumption tuning — pre-condition for even *piloting* Snowflake/Databricks.

Data-residency / EU transfer note (non-negotiable) No cloud region exists in Uganda, so any Azure/AWS/GCP deployment resolves to the nearest region (South Africa North / West Europe) — **latency and egress must be designed for (batch loads, aggregated extracts, no per-store chatty traffic)**, and the stores' existing offline-hours pattern already forces this design. For the **European distributor partnership**, personal data flowing to or from the EU is a *third-country transfer* under **GDPR Art.44–49**: the transfer mechanism must be **Standard Contractual Clauses plus a transfer impact assessment**, and the vendor must be contractually bound to GDPR-equivalent terms. This sits alongside the Uganda **DPPA 2019 s.3** protection principles (lawfulness, purpose limitation, minimisation, security) already implemented technically by Module 4's default-deny RBAC, RLS and masking — technical controls are necessary but not sufficient: the SCCs, records of processing and the breach-notification SOP are governance artefacts owned by the compliance workstream (`D1_roadmap_18months.md`, M1–M3 and M11–M12).

(b) ONE AI-Driven Trend — AI-powered Data Quality vs Data Mesh vs DataOps

Screening against SRG's three hard constraints

Trend	Budget fit (UGX 480M/yr)	Skills fit (4 staff, 0 data-eng)	Connectivity fit (offline stores)	Sequencing / evidence dependency	Verdict
AI-powered data quality (ML anomaly detection over profiling metrics, auto-remediation suggestions)	Tooling subscriptions would consume licences budget for <i>uncertain</i> gains; possible later from the contingency line	Weak — tuning, feature choice and false-positive triage need skills SRG is still building	Neutral — batch profiling suits offline reality	Depends on a deterministic baseline. The 12 rules VR-001...VR-012 and 10 checks DQC-01...DQC-10 must first produce 6+ months of profiling history and known anomaly rates (they already caught: duplicates 22.84%, UOM 15.33%, category 22%, pending MoMo 11.5%)	PILOT — month 12+
Data mesh (domain-owned data products, federated governance, self-serve platform)	Neutral on licences, heavy on organisation	Very poor fit — mesh assumes mature platform engineering plus a data team <i>per domain</i> ; SRG has 6 domains (sales, customer, product, store, payment, finance) inside <i>one</i> 4-person team	Neutral	Requires platform maturity and domain data-product owners that do not exist; would re-create exactly the silos (5 product identifiers, 127 district labels, 23 disconnected POS) that Modules 2–3 were built to remove	REJECT
DataOps (CI for SQL/Python, scheduled orchestrated pipelines, monitoring, run-state visibility)	≈ zero licence cost — Git + existing Python + etl_run_log; training only	Excellent fit — 2 SQL-capable staff can maintain it; no data engineers required	Fits: idempotent replayable runs and quarantine already assume outages	Already started: version-controlled repo, srg_etl_pipeline.py self-tests 3/3 PASS, etl_quarantine, etl_run_log, DQC-07 quarantine-rate alerting, advisory-lock scheduling window	ADOPT — lite

Verdicts and rationale

- AI-powered data quality — PILOT (from M12).** Anomaly detection is only as good as the normal it learned;

SRG's defect history was *unknown* until Module 2 measured it. AI cannot invent missing business definitions (a district reference list, one golden product key, a UOM vocabulary) — those are governance artefacts humans must author first, and they now exist (42 districts, 6 categories, 3 UOMs, VR-008 uniqueness). From M12, feed the daily DQC metric history into unsupervised anomaly detection to catch *novel* defect patterns (e.g., a new store writing a new free-text label); keep every remediation human-approved. Cost: scoped inside the contingency line, no new licence before the pilot paper at gate G3.

2. **Data mesh — REJECT.** Mesh's premise is many domains with autonomous teams and a mature self-serve platform. SRG is *one retailer* with four IT staff (two SQL-capable, zero data-engineering) and six domains in one team — adopting mesh would either be theatre (domains on paper, same people doing the work) or would institutionalise silos by charter, ironically undoing the single golden record, conformed `dim_product/dim_customer` and shared star schema that the warehouse already delivers. Revisit only if SRG exceeds ~50 data-producing staff and multiple legal entities — not within this 18-month horizon.
3. **DataOps — ADOPT-LITE.** The high-value subset is free: CI runs `dq_assessment_cleansing.py`, `srg_etl_pipeline.py --self-test` and the 15 RBAC assertions on every commit; scheduled orchestration with alerting to the on-call rotation (fixing RC-6, the unmonitored mailbox); run-state surfaced in the 06:00 routine; quarantine-rate and pending-MoMo monitoring as pipeline KPIs. This codifies what the repaired pipeline already demonstrates and directly prevents the RC-1...RC-6 root causes from returning.

Think-deeper answer Does “adopt Azure, but stay on-premises in Phase 1” contradict the GDPR-equivalent commitment to the European distributor — and where is the real sovereignty risk?

No — but only because the commitment is being interpreted correctly. “GDPR-equivalent” is a *control and accountability* standard (lawful basis, minimisation, security by design, breach notification within 72 hours, transfer mechanism), not a physical location. Module 4 already expresses protection-by-design inside the database (default-deny RBAC, RLS, column-level grants, masking), and the Phase 1 pattern — local PostgreSQL/SQLite with encrypted off-site backup — processes no third-country transfer at all, so Art.44–49 is not even engaged until EU personal data flows. The real risks are different from the ones the vendor debate focuses on: (1) **latency and egress** — with no Ugandan region, the nearest region is South Africa or Europe, so the architecture must stay batch/aggregate (which the offline-hours store reality demands anyway); a chatty real-time sync design would be both expensive and fragile; (2) **lock-in asymmetry** — the cheaper and more integrated the managed stack (4.25 score), the harder the exit, which is why the migration triggers are written as *requirements*, not dates, and why the pipeline is deliberately portable SQL/Python with schema contracts rather than proprietary notebook code; (3) **governance lag** — the greater exposure is not the cloud vendor but the absence of records of processing, a breach register and a notification SOP, all of which must exist by the M12 PDPO audit irrespective of hosting. In other words, the cloud decision is the *least* risky item in this document; the exposure lives in process and organisation, which is precisely where the roadmap front-loads spend (M1–M3 incident remediation and SOP, M11–M12 audit). The deeper lesson for the Board: technology verdicts are only as good as their preconditions — AI-DQ waits for deterministic rules, Snowflake waits for a data engineer (T6), and cloud waits for a trigger that proves the migration pays for itself.

Analytics Maturity Assessment & BI Operating Model (supports C3.1–C3.4)

Client: Savanna Retail Group (SRG) | **Prepared by:** Lead Enterprise Data Management Consultant **Method:** evidence-based scoring — a dimension only advances a level when a *committed artefact or an executed metric* exists, not when a workshop says so. Every score below cites the artefact or its absence.

Scale: **L0** Ad hoc (undocumented, hero-dependent) · **L1** Repeatable (works, but manual and inconsistent) · **L2** Managed & measured (defined process, automated checks, named owner) · **L3** Integrated & quantified (Board-integrated cadence, predictive diagnostics in production) · **L4** Optimising (prescriptive/ML in production, self-improving). *No dimension claims L4 within 18 months — that claim would not survive audit.*

Task C3 — Analytics, BI & Emerging Technology (C9)

Maturity scorecard — baseline (M0) vs delivered vs target

#	Dimension	Baseline M0 (as found)	Level	Evidence of the M0 score	Delivered by M6	Target M12	Target M18
1	Strategy & decision alignment — Board questions, KPI ownership, cadence	Board cannot answer segment growth/churn; reporting arrives 11 days late	L0	No KPI tree, no metric owners, no decision calendar	L2 — five decision-grade questions (C3.1), monthly executive insight brief, KPI owners named, 11 → ≤5 days	L3 — KPI targets on every Board pack (floor ≥600 new customers/month, churn proxy ≤50%)	L3 — annual decision calendar; benefits traced to D1 roadmap
2	Data foundation & quality — golden records, rules, monitoring	23% duplicate customers; 5 product identifiers ; 127 district labels; UOM 15.33% conformance; 8.4% stock variance	L0	No rules, no measurement — defects unknown until profiled	L2 — dupes 22.84% → 0.00% (5,000 → 3,858 golden records), 12 rules VR-001...VR-012 live, 10 checks DQC-01...DQC-10 scheduled, districts 127 → 42, category 22% → 100%, UOM 15.33% → 100%, composite product validity 3.25% → 100%	L2+ — entry-point enforcement (till/POS forms) so quality is <i>prevented</i> , not corrected; stock variance ≤2.0% with Odoo feed	L3 — quality economics tracked (cost of poor quality in UGX); anomaly detection pilot live

#	Dimension	Baseline M0 (as found)	Level	Evidence of the M0 score	Delivered by M6	Target M12	Target M18
3	Platform & architecture — ETL, warehouse, integration, ops	Nightly job fails silently: 4 days stale, alerts to an unmonitored mailbox	L1 (etl_diagnosis RC-1...RC-6)	etl_error_log.txt; zeroed run-state visibility	L2+ — repaired pipeline: schema contracts, etl_quarantine idempotent loads, customer_sk=0uns PENDING_RECONC self-tests; advisory reporting lock, lag ≤3 days etl_run_log; self-test 3/3 PASS ; star schema + 25-attribute data dictionary	L2+ — Odoo stock feed + source contracts (POS/e-commerce/loyalty); CI	L3 — cloud migration evaluated against triggers T1–T6; catalog/lineage automation
4	Analytics & BI delivery — insight products, adoption	Manual monthly spreadsheet pack, 11 days; no self-service	L0	No dashboard exists; no shared definitions	L2 — dashboard.html live on GitHub Pages (KPI cards, 5 charts, filters, drill-up), monthly brief adopted	L3 — churn/segment lifecycle views operational; store/city drill-downs used in trading meetings	L3 — segment profitability (once margin feed exists); footfall-augmented catchment analytics
5	Security, privacy & compliance — access, masking, incident response	Unencrypted laptop with 9,000 customer records stolen; reported internally 11 days late; no breach notification	L0/L1	The incident itself; no RBAC, no masking, no SOP	L2 — RBAC 5 roles default-deny + RLS + column grants (15-test suite), masking executed (+256-XXX-XX1234, J*** D**, demo 4/4), encryption/MDM roll-out + 72-hour notification SOP adopted	L2+ → L3 — PDPO audit passed within 12 months; SCC pack for EU distributor (GDPR Art.44–49, DPPA 2019 s.3); tabletop breach exercise	L3 — audit surveillance cycle, pen-test, access recertification twice yearly

#	Dimension	Baseline M0 (as found)	Level	Evidence of the M0 score	Delivered by M6	Target M12	Target M18
6	People, skills & data culture — capability, stewardship, literacy	4 IT staff (2 SQL-capable, 0 data-engineering); no data stewards; no shared vocabulary	L0	Org chart + skill matrix; no stewardship assignments	L1 — stewards assigned from business roles (Marketing = customer, Merchandising = product, Finance = payments, IT = technical); training funded (UGX 28,000,000 / 18 months); 3 hires planned	L2 — hires onboarded (Analytics/Data Engineer, BI Analyst, Data Steward); 6 staff certified; dashboard/brief used weekly	L2+ — data literacy embedded in trading meetings; succession for key-person risk

Composite view: M0 ≈ **L0.3** (simple average of the six dimensions: L0, L0, L1, L0, L0/L1, L0 → (0+0+1+0+0.5+0) ÷ 6 = 0.25) → **M6 = L2** → **M12 = L2.5–L3** → **M18 = L3**. The jump from M0 to M6 is carried by *artefacts already executed in this repository*; every step beyond M6 depends on organisational change (hires, Odoo feed, audit), which is why D1_roadmap_18months.md funds people and integration, not more prototypes.

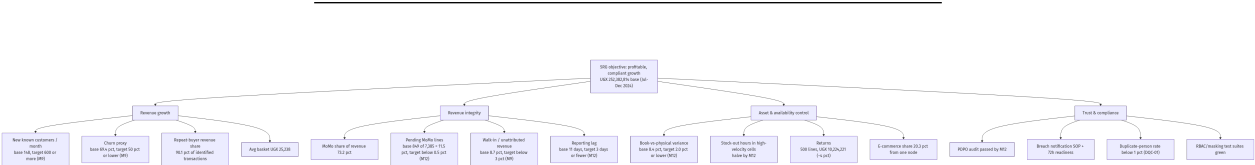


Figure 26: The C3 analytics maturity diagram (1).

KPI tree — how maturity converts into Board decisions Each leaf metric has exactly one accountable owner (Marketing Officer, Finance/Reconciliation Officer, Merchandising Manager, IT Operations Lead/Compliance), one definition frozen in module5_warehouse/data_dictionary.md, and one refresh path (srg_etl_pipeline.py → etl_demo.db → dashboard.html). A metric without all three is not a KPI — it is an opinion.

BI operating model (who runs analytics with 4 + 3 people)

Role	Holder	Accountability in the analytics cycle
Executive sponsor	CFO (Board delegate)	Owns the KPI tree; chairs the monthly Steering Group; signs gate decisions G1–G4
Data Governance Council	Finance, Marketing, Merchandising, Compliance, IT (monthly)	Approves metric definitions, stewardship queue releases (110 open records), remediation priorities

Role	Holder	Accountability in the analytics cycle
Data stewards (business, part-time)	Marketing Officer (customer), Merchandising Manager (product), Finance/Reconciliation Officer (payment)	Own entry-point quality (VR rules) and sign off variance/reconciliation closes
IT team of 4 (2 SQL-capable)	IT Operations Lead + 3	Pipeline operation, 06:00 run-state routine, on-call alerts (replaces RC-6 mailbox)
3 planned hires (funded, UGX 150,650,000 / 18 months incl. 15% on-costs)	Analytics/Data Engineer, BI Analyst, Data Steward	Build/maintain star schema loads, dashboard/brief production, ML pilot preparation (M12+)
Analytics consumer	Board, Strategy, Store managers	Reads KPI cards + brief; raises decisions at gates, not ad-hoc data requests

Cadence ladder: daily (DQC-01...DQC-10 automated checks, MoMo pending register) → weekly (trading view: dashboard filters) → monthly (executive insight brief, variance close) → quarterly (double-down list, cohort review) → gate (G1 M3, G2 M6, G3 M12, G4 M18).

Capability plan (funded at UGX 28,000,000 / 18 months): SQL analytics & window functions (2 SQL staff → self-sufficient on RFM/cohorts), Python for data pipelines (ETL maintenance), data stewardship fundamentals (3 stewards), Power BI/visualisation literacy incl. Tufte/Few principles (BI Analyst + Board secretary), privacy & incident response (all 6 — closes the capability root cause of the 11-day reporting delay on the stolen laptop).

Think-deeper answer Isn't this maturity scorecard self-congratulatory — what evidence would falsify the claim that SRG reaches L2 by M6?

The scorecard is written so that three pieces of evidence would *falsify* it rather than merely disappoint:

- A single month of failed monitoring.** Level 2 requires “measured, not asserted”. If, in any month by M6, DQC-01...DQC-10 are not run, or run and ignored (threshold breaches without a ticket), dimensions 2 and 3 fall back to L1 regardless of how good the cleansed numbers look — the RC-6 failure mode (alert to an unmonitored mailbox) is precisely what L1-vs-L2 means. The falsifier: an empty or green-without-run `etl_run_log/DQ` log for 30 days.
- Quality achieved only by the batch cleanse, not by the process.** The 22.84% → 0.00% duplicate result is a *state*, not a capability. If new registrations reintroduce duplicates above DQC-01's 1.0% threshold, or if the 110 stewardship-queue records are never cleared with an owner, dimension 2 is L1: the pipeline can cleanse but the organisation cannot govern. The falsifier: duplicate-person rate >1.0% for 3 consecutive days, or a stewardship queue older than 30 days.
- Nobody uses it.** BI maturity is adoption, not deployment. If the dashboard has no readers in trading meetings and the executive brief is not tabled at the Board, dimension 4 remains L1 however correct the charts are. The falsifiers: <1 weekly active reader in each of the four owner roles, or a missed monthly brief.

The same honesty applies upward: the M12 “L3” claims are *conditional* — PDPO audit passed, reporting lag ≤3 days, churn views operational — and each is a binary gate in `D1_roadmap_18months.md`, not a percentage. Finally, the baseline itself was scored against artefacts (the incident record, the ETL error log, the profiling metrics) rather than interviews, precisely to avoid the common maturity-assessment failure of rating ambition as current state; if the Board disagrees with an M0 score, the disagreement is about evidence, and the cited file can be opened.

Appendix Y — Integrated 18-Month EDM Strategy Roadmap (Full Plan)

Integrated EDM Strategy Roadmap — M1 to M18

Client: Savanna Retail Group (SRG) | **Author:** Lead Enterprise Data Management Consultant **Budget envelope (non-negotiable):** UGX 480,000,000 all-in — licences, cloud **and** hires. The scenario states this annually, but Task D1 requires the roadmap to sit “*within the UGX 480M envelope*”; we therefore plan to the **stricter reading: UGX 480,000,000 for the full 18-month programme** ($480,000,000 \div 18 = \text{UGX } 26,666,667/\text{month}$; $480,000,000 \div 3,700 \approx \text{USD } 129,730$ for the programme). This is deliberately conservative: if the Board later confirms the annual reading ($480,000,000/\text{year} = 720,000,000$ over 18 months), the surplus becomes contingency and pulls Phase 3 cloud forward

— but **no commitment in this plan assumes that upside**. Payroll treatment of the existing 4 IT staff is a Gate G1 confirmation item (see §D1.7 assumptions). **Capability envelope:** IT team of 4 (2 SQL-capable, zero data-engineering) + 3 planned hires; several stores offline hours daily; power issues (UPS-backed POS). **Regulatory envelope:** Uganda DPPA 2019; PDPO audit **within 12 months**; European distributor partnership requiring GDPR-equivalent practice.

Task D1 — Integrated EDM Strategy Roadmap

D1.1 — Mandate: what the roadmap must fix

Problem (as found)	Baseline evidence	Roadmap line that closes it
Laptop theft incident — unencrypted device, 9,000 customer records (names/phones/purchase history) taken from the Jinja store; reported internally 11 days late; no breach notification	Incident record	Phase 1 incident remediation (M1–M2) + SOP + PDPO audit (M12)
23% duplicate customers; loyalty points landing on wrong members	Dupes 22.84% → 0.00% after Module 2; 5,000 → 3,858 golden records	Quality workstream (M2, sustained by DQC-01)
5 product identifiers across systems	Composite product validity 3.25% → 100% in cleanse; 141 duplicate-SKU rows flagged	Golden product key → live at source M8 (VR-008/DQC-06)
11-day monthly reporting	Reporting lag measured	Dashboard M4; ≤5 days M6; ≤3 days M12
8.4% book-vs-physical stock variance; stock-outs in high-demand stores while slow stores overstock	Warehouse + store audits	Odoo feed M8; ROP rules M9; variance ≤2.0% M12
Board cannot answer segment growth/churn	No KPI tree, no owners	Five Board questions (C3.1), brief, KPI targets
Mobile-money reconciliation gap	849 of 7,385 MoMo lines (11.5%) PENDING ≈ UGX 21,245,585 ≈ UGX 21.2M (0.732 × 252,382,814 × 0.115)	Automated reconciliation M5, SLA 48h

D1.2 — Target state at M18 (and the six workstreams) **Target state:** a single conformed warehouse (one golden customer key, one golden product key) feeding a Board-grade KPI tree on a ≤3-day reporting lag; quality prevented at entry and measured daily (DQC-01...DQC-10); default-deny access with masking; PDPO audit passed and SCCs in place for EU data flows; an operating model of 4 IT staff + 3 hires + 5 business stewards who run analytics without external help.

WS	Workstream	Owner	Phase 1 (M1–M6)	Phase 2 (M7–M12)	Phase 3 (M13–M18)
WS1	Data governance & quality	Data Governance Council / stewards	Golden records sustained; entry-point rules; stewardship queue (110 open) with 30-day SLA	Prevention at till/POS/e-commerce; stock data quality via Odoo	Quality economics; anomaly pilot
WS2	Platform & architecture	IT Operations Lead	Fail-fast ETL, quarantine, etl_run_log, star schema, source contracts	Odoo feed, CI for SQL/Python, load ≤3 days	Cloud evaluated vs triggers T1–T6; catalog/lineage

WS	Workstream	Owner	Phase 1 (M1–M6)	Phase 2 (M7–M12)	Phase 3 (M13–M18)
WS3	Analytics & BI	BI Analyst (hire) / EDM Consultant	Dashboard v1, five Board questions, monthly brief	Churn/segment ops, catchment + footfall analysis	Segment profitability, gated ML pilots
WS4	Security, privacy & compliance	Compliance Officer / CFO	Encryption+MDM, RBAC/RLS/masking, breach SOP, incident legal review	RoPA, breach register, SCCs, tabletop; PDPO audit M12	Pen-test, recertification, audit surveillance
WS5	Organisation, skills & change	CFO (sponsor)	Stewards named; training starts; 3 hires onboarded by M5	Data literacy in trading meetings; role certifications	Succession/key-person cover; maturity re-score
WS6	Master data & stock/payment integrity	Merchandising + Finance	5 → 1 product key design; MoMo reconciliation M5	Identifier unification live M8; ROP rules M9	Variance ≤1.5%; margin feed; reconciliation BAU

D1.3 — Roadmap schedule, gates and quick wins (relative months only) Quick wins that must be visible by month 6 (Gate G2 evidence):

#	Quick win	Evidence artefact	Owner	KPI
1	All devices encrypted + MDM; 72-hour breach-notification SOP adopted; Jinja theft referred for legal assessment	Encryption report; signed SOP	IT Operations Lead / Compliance	100% devices encrypted by M2; SOP signed M1
2	Dashboard live (KPI cards, revenue/category/payment, filters, drill-up)	dashboard.html on GitHub Pages	BI Analyst	Published M4; ≥4 weekly active readers by M6
3	Reporting lag cut	Load timestamps in etl_run_log	IT Operations Lead	11 → ≤5 days by M6
4	Duplicates held at zero on golden records	DQC-01 daily	Marketing Officer (steward)	Duplicate-person rate <1.0% sustained
5	MoMo pending backlog cleared + 48h SLA	DQC-08 register	Finance/Reconciliation Officer	0 lines aged >24h by M6
6	RBAC + masking deployed and tested	15-test suite green; masking demo 4/4	Compliance Officer	15/15 PASS at G2
7	Monthly executive insight brief tabled	Signed Board pack	EDM Consultant → BI Analyst	6 consecutive months by M6
8	First double-down list (district × category)	Contribution matrix	Marketing + Merchandising	Issued M6

D1.4 — Budget: UGX 480,000,000 over 18 months, all-in (hard ceiling) Arithmetic basis: 480,000,000 ÷ 18 months = UGX 26,666,667/month average run-rate. Every line below is itemised from unit costs; every phase column

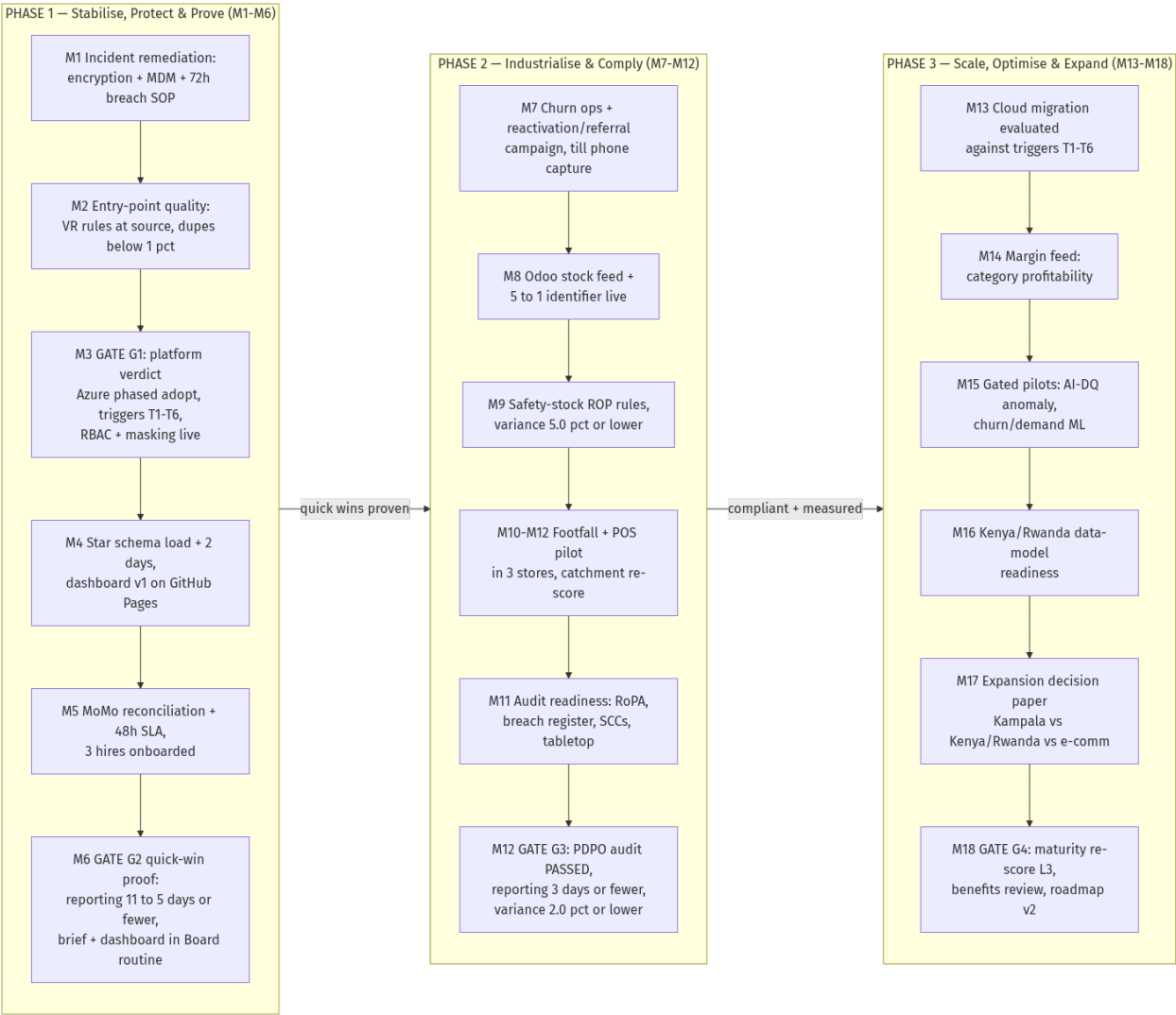


Figure 27: The D1 roadmap 18months diagram (1).

and the grand total must equal **480,000,000 exactly** — there is no room above the ceiling, only contingency within it.

Line	Basis (explicit arithmetic)	M1–M6	M7–M12	M13–M18	Total
People — 3 staggered hires	Data Engineer 3,500,000/mo × 18 mo (M1) = 63,000,000 + BI Analyst 2,500,000/mo × 16 mo (M3) = 40,000,000 + Data Steward 2,000,000/mo × 14 mo (M5) = 28,000,000 → gross 131,000,000; statutory on-costs & allowances 15% × 131,000,000 = 19,650,000 → 131,000,000 + 19,650,000	40,250,000	55,200,000	55,200,000	150,650,000
Capability & training	6 staff × 3 courses = 18 course-persons × UGX 900,000 (local providers) = 16,200,000 + certification exams/lab 1,800,000	8,000,000	6,000,000	4,000,000	18,000,000
Licences	Power BI Pro 5 users × 37,000/mo × 18 = 3,330,000 + DQ/monitoring tooling 3,670,000 + OpenMetadata catalog pilot M10–M18 (≈ 15,000,000/yr × 0.75 yr ≈ 11,250,000, held at 8,000,000 headroom) = 3,330,000 + 3,670,000 + 8,000,000	3,500,000	5,750,000	5,750,000	15,000,000

Line	Basis (explicit arithmetic)	M1–M6	M7–M12	M13–M18	Total
Cloud (ceiling UGX 90,000,000)	Phase 1 on-prem by design (5,000,000 pilot object storage); M7+ managed Postgres + object storage + egress + backup + monitoring per docs/C3_emerging_tech.md itemised need 43,330,000 + storage/egress headroom 16,670,000	5,000,000	27,500,000	27,500,000	60,000,000
Foundation & integration	3 source contracts/connectors 25,000,000 + Odoo stock feed 25,000,000 + footfall/POS pilot hardware (3 stores) 25,000,000 + UPS/offline-resilience kits 18,000,000 + identifier-unification tooling 12,000,000 = 105,000,000	35,000,000	45,000,000	25,000,000	105,000,000
Security & compliance	Endpoint encryption/MDM/VPN/MFA/backup per docs/C2_encryption_masking_spec.md slice = 66,000,000 (15+10+5+12+6+10+6 — items B1–B7) + GDPR/SCC legal opinion & breach counsel 6,000,000 = 72,000,000	36,000,000	24,000,000	12,000,000	72,000,000
Governance & change	Council operations, stewardship workshops, internal comms (board packs, training-of-trainers)	9,000,000	7,000,000	5,000,000	21,000,000

Line	Basis (explicit arithmetic)	M1–M6	M7–M12	M13–M18	Total
Contingency (8.0%)	Residual: 480,000,000 – 441,650,000 = 38,350,000 (= 8.0% of envelope)	14,000,000	12,175,000	12,175,000	38,350,000
Programme total		150,750,000	182,625,000	146,625,000	480,000,000

Envelope checks: grand total = 150,750,000 + 182,625,000 + 146,625,000 = **480,000,000** ≤ **480,000,000** (equals the envelope exactly — itemised to the shilling, no over-spend lane). Year 1 (P1+P2) = **333,375,000** ≤ **480,000,000** annual run-rate — i.e., the plan also survives the looser annual reading without modification. Cloud line = **60,000,000** ≤ **90,000,000** ceiling in docs/C3_emerging_tech.md . Licences = 15,000,000 (Power BI Pro 3,330,000 within it) . Security = 72,000,000 = the 66,000,000 C2 security slice + 6,000,000 legal . USD cross-check: 480,000,000 ÷ 3,700 = **USD 129,730 for 18 months** of hires, licences, cloud, integration, security and compliance.

D1.5 — Governance & operating model

Body	Members	Cadence	Decision rights
Board / Executive Committee	Board, CFO sponsor	Monthly (with executive insight brief)	KPI targets, capex, gate approvals G2–G4
EDM Steering Group	CFO (chair), IT Ops Lead, Marketing, Merchandising, Finance, Compliance	Monthly	Budget draw-down, scope, risk, hire decisions
Data Governance Council	5 business stewards + IT	Monthly (bi-weekly in Phase 1)	Metric definitions, stewardship releases (110 open records), rule changes (VR/DQC)
Incident response cell	Compliance Officer, IT Ops, Store manager concerned	On event	72-hour assessment/notification decision (replaces the 11-day internal delay)
On-call rotation	IT team of 4 (WhatsApp/SMS alerts)	Daily 06:00 run-state check	Pipeline halt/replay (fixes RC-6 unmonitored mailbox)

Gate criteria (all binary): **G1 (M3)** platform verdict adopted, triggers published, RBAC/masking tests green · **G2 (M6)** the eight quick wins evidenced · **G3 (M12)** PDPO audit passed, reporting ≤3 days, variance ≤2.0%, pending-MoMo <0.5% · **G4 (M18)** maturity re-scored L3, expansion decision taken on footfall-backed evidence.

D1.6 — KPI trajectory (baseline → M6 → M12 → M18)

KPI	Baseline (M0)	M6	M12	M18
Monthly reporting lag	11 days	≤5 days	≤3 days	≤3 days
Duplicate-person rate	23% (measured 22.84%)	<1.0% (0.00% on golden)	<1.0%	<1.0%
Walk-in / unattributed revenue	8.7%	<7%	<3% (from M9)	<3%
Pending MoMo lines	11.5% (849/7,385)	0 aged >24h	<0.5%	<0.5%

KPI	Baseline (M0)	M6	M12	M18
Book-vs-physical stock variance	8.4%	≤7% (task force stood up)	≤2.0%	≤1.5%
New known customers / month	148 (Dec)	≥400	≥600 (floor set by M9)	≥600 sustained
Churn proxy (actives absent next month)	69.4%	≤60%	≤50% (from M9)	≤45%
PDPO audit	Not started	Readiness plan M6	Passed ≤M12	Surveillance cycle
Devices encrypted / breach SOP	0% / none	100% / signed	Maintained	Maintained
Composite maturity level	≈L0.3	L2	L3	L3

D1.7 — Dependencies, risks & mitigations

Dependency	Needed by	Risk if it slips
Recruitment (3 hires, 8–10 week lead time)	Offers M3–M5	Quick wins 4/7/8 fall back on the consultant — mitigation: stagger hires exactly as budgeted (Engineer M1, Analyst M3, Steward M5) + UGX 38,350,000 contingency
Odoo stock feed access & vendor cooperation	M8	Variance KPIs frozen at 8.4%; stock workstream stalls — mitigation: interim POS stock-ledger extract as stop-gap
MTN MoMo / Airtel Money statement exports	M5	Reconciliation cannot close; UGX 21.2M stays unconfirmed
Footfall pilot vendor + 3 store sites	M10	Expansion decision (M17) must fall back on district/loyalty indices only
Power/connectivity (UPS, offline windows)	Continuous	Load windows compress; mitigation: idempotent replay + advisory-lock scheduling already proven in <code>srg_etl_pipeline.py</code>
External auditor capacity (PDPO)	M11 booking, M12 slot	Audit missed inside 12 months — mitigation: book auditor by M6

Risk	L / I	Mitigation	Owner
Salaries undershot by market (UGX 3.5M for a data-capable hire may not attract the best)	High/High	Hybrid: 1 senior hire + 2 upskilled internal staff; contingency funds contract support; training line UGX 18,000,000	CFO
Contingency consumed by egress/cloud overrun	Med/High	Cloud hard-capped UGX 90,000,000 with monthly spend alarm at UGX 5,000,000	IT Ops Lead
Scope creep into Kenya/Rwanda operations before G4	Med/High	Data-model readiness only (M16); no operational capex before footfall-backed scorecard	Strategy Director
Key-person dependence (single analyst)	Med/High	Documentation-as-code, pair review, stewardship distributed to business roles	CFO

Risk	L / I	Mitigation	Owner
PDPO audit finds notification failure on the original theft	High/High	Legal assessment in M1; voluntary remediation + notification if advised; breach register built before audit	Compliance Officer
Quality regresses at entry (dupes return via till capture)	Med/Med	VR-001/VR-007 enforced at forms; DQC-01 >1.0% for 3 days = P1 incident	Stewards
Board decisions taken off-sample (6-month synthetic extract)	Med/High	Provenance disclosed on every artefact; baselines re-measured from live feeds by M6	EDM Consultant

Standing assumptions (to be confirmed at G1): (1) the existing 4 IT staff remain on the corporate IT payroll — if they must be carried by this budget, $4 \times \text{UGX } 2,500,000 \times 18 = \text{UGX } 180,000,000$ would exceed the UGX 38,350,000 contingency by UGX 141,650,000 and the plan requires re-scoping; (2) USD/UGX holds at 3,700; (3) no absolute calendar dates are committed — months are relative to programme start (M1).

Think-deeper answer The roadmap shows quick wins by M6 and a PDPO audit by M12 — what is the single most likely failure mode, and how does the plan degrade rather than collapse if it happens?

The most likely failure is **Phase 1 over-commitment**: the first six months simultaneously carry incident remediation, a security build-out (RBAC/masking/encryption), three hires, a dashboard, a reconciliation pipeline and entry-point quality work — on a four-person team that also runs 23 stores’ daily connectivity problems. History already shows what happens when that team is overloaded: the nightly ETL failed four days running while alerts sat in an unmonitored mailbox (RC-6).

The plan therefore degrades in a defined order rather than failing silently. If capacity bites, the **sacrifice ladder** is: (1) cloud work is deferred by design — Phase 1 is deliberately on-premises, so nothing slips; (2) the dashboard’s optional features (extra chart toggles) drop, but the KPI cards and monthly brief survive because they are the Board’s minimum viable product; (3) the footfall pilot slides from M10 to M12 — the G4 expansion decision then falls back on district/loyalty indices and is *explicitly* a conditional approval, not a rejection of the evidence standard; (4) only if recruitment fails outright is the Data Engineer role filled by promoting an existing SQL-capable staff member at a UGX 1,000,000/month uplift — $1,000,000 \times 18 = \text{UGX } 18,000,000$, inside the UGX 38,350,000 contingency — while the Data Steward hire is deferred, since the governance model already draws stewards from business roles.

What is **never** traded: incident remediation and the breach SOP (the original failure was a 11-day delay and no notification — repeating it would be a regulatory event, not a project slip), the DQC daily checks (the only thing standing between SRG and invisible data decay), and the PDPO audit date — because “within 12 months” is an external commitment. That priority order — compliance first, evidence second, features last — is the roadmap’s real content; the month table is only its visible surface.

Appendix Z — Decision Log (26 Entries)

Decision Log, Red Team & Reflective Essay — D2.1 Decision Log

Client: Savanna Retail Group (SRG) | **Prepared by:** Lead Enterprise Data Management Consultant **Scope:** every consequential decision taken during the engagement, with the options it displaced, the evidence relied on, the owner, and the current status. Months are relative to programme start (M1). Companion files: D2_red_team.md (the adversarial review of these decisions), D2_reflective_essay.md.

Task D2 — Decision Log, Red Team & Reflective Essay

D2.1 — Decision Log

A. Incident, governance & data quality (M1–M2)

ID	Month	Decision	Options considered	Rationale & evidence	Owner	Status
D-01	M1	Treat the stolen-laptop incident as a reporting failure, not a device failure : adopt a 72-hour breach-assessment/notification SOP, refer the theft (9,000 records, reported internally 11 days late, no notification) for legal assessment under DPPA 2019	(a) Quiet remediation, no look-back; (b) voluntary notification if advised; (c) full public disclosure immediately	The harm was compounded by silence — 11 days of internal delay is itself the control failure; “no notification” is a live regulatory exposure under DPPA 2019 and, for EU persons, GDPR Art.33/34. Option (a) repeats the original error; (c) risks overstating exposure before facts are known. (b) preserves legal position and evidence	Compliance Officer / CFO	Approved (M1)
D-02	M1	Fail-fast ETL with quarantine — remove the “partial mode” fallback that continued with yesterday’s staging data	(a) Keep best-effort fallback with alerts; (b) fail-fast + quarantine + etl_run_log	etl_diagnosis.RC-4: silent fallback guaranteed wrong results while appearing to progress; 4 consecutive stale days. Quarantine keeps good rows flowing without lying about bad ones	IT Operations Lead	Implemented — self-test 3/3 PASS

ID	Month	Decision	Options considered	Rationale & evidence	Owner	Status
D-03	M1	Make customer_sk = 0 (“Unknown / Walk-in Customer”) a first-class dimension member rather than rejecting rows	(a) Reject rows with NULL customer; (b) impute nearest customer; (c) COALESCE to key 0	RC-2: offline capture is <i>designed behaviour</i> at SRG (stores offline hours daily); rejection aborted loads. Imputation would fabricate a customer (the failure class rejected in D-06). Later measurement: walk-ins = 8.0% of lines / 8.7% of revenue — real, quantified, and now managed	IT Operations Lead	Implemented
D-04	M1	Mobile money without a reference is accepted as PENDING_RECON , not blocked and not dropped	(a) Block transaction until ref arrives; (b) drop from revenue; (c) accept with status + reconcile	VR-012 permits offline capture; blocking would lose sales during outages; dropping would understate revenue. Status keeps revenue visible <i>and</i> the gap auditable — it is what exposes 849/7,385 = 11.5% pending	Finance / IT	Implemented

ID	Month	Decision	Options considered	Rationale & evidence	Owner	Status
D-05	M1	Single-writer discipline: pg_advisory_lock on shared dimensions + store-sync replay window (23:00–01:45) vs nightly ETL	(a) Retry on deadlock; (b) add design sync architecture; (c) lock + schedule window	RC-3 deadlock (ETL vs offline POS replay, ST17). (a) treats symptom; (b) is a multi-quarter project for a team with zero data-engineers; (c) removes the lock-ordering class cheaply	IT Operations Lead	Implemented
D-06	M1	Dimensions load before facts (SCD2 first), orphan SKUs replayed from quarantine	(a) Fact-first with deferred FK check; (b) dimensions-first	RC-5: 412 orphan SKU rows; ordering is a sequencing fix, not new code	IT Operations Lead	Implemented
D-07	M2	No auto-merge on name similarity alone — auto-merge only on a positive identifier (phone/email); homonyms to stewardship	(a) Aggressive fuzzy merge to reach 0%; (b) identifier-required merge + steward queue; (c) manual-only merge	Evidence: 1,142/1,150 duplicates merged (953 deterministic + 189 fuzzy); 365 homonym pairs correctly rejected by the email-conflict rule. Merging two different people destroys one person's loyalty history and privacy rights — an irreversible harm	Marketing Officer (steward)	Approved & executed

ID	Month	Decision	Options considered	Rationale & evidence	Owner	Status
D-08	M2	Leave 110 records in the stewardship queue instead of forcing the metric to a clean number	(a) Force-merge to report 0%; (b) disclose open queue (25.06% → 2.85% total flag)	Fabricated completeness is worse than an honest 2.85%; the queue has a 30-day SLA and named owner. Same principle as not imputing nulls	Data Governance Council	Approved — queue open
D-09	M2	Standardise phones to E.164 and districts to a 42-label reference list (dropdown only)	(a) Store as-captured; (b) standardise + enforce at entry	6 → 1 phone formats; 127 → 42 district labels — free text made geographic segmentation impossible; VR-001/VR-002 enforce it prospectively	CRM / Stewards	Implemented

B. Architecture & security (M3–M4)

ID	Month	Decision	Options considered	Rationale & evidence	Owner	Status
D-10	M3	RBAC default-deny: 5 roles (store_cashier, store_manager, data_analyst, compliance_officer, cdm_admin) + RLS + column-level grants + masking views	(a) App-layer permissions only; (b) DB-enforced default-deny	The incident proves perimeter-only controls fail; DPPA 2019 / GDPR Art.25 require protection by design <i>inside</i> the system. Evidence: 15-test suite asserts denials (cashier blocked from financial_reports, payroll column, RLS zero-row proofs)	Compliance / IT	Scripted — 15/15 at deploy (reference capture committed)

ID	Month	Decision	Options considered	Rationale & evidence	Owner	Status
D-11	M3	Mask PII at the surface: phone → +256-XXX-XX1234, name → J*** D** for analyst/manager roles	(a) Full PII to all internal users; (b) masking views	Executed demo 4/4 PASS; analysts need patterns, not people — and the 9,000-record theft shows what raw PII exposure costs	Compliance	Implemented
D-12	M3	Star schema with SCD2 on customer and product + 25-attribute classified data dictionary	(a) Flat monthly tables; (b) dimensional model with history	Growth questions (C3.1 Q2) require point-in-time truth — a price change must be scored as price, not organic growth; classification (Public/Confidential/Restricted) drives the GRANT matrix	EDM Consultant	Implemented (star_schema_ddl.sql)

C. Analytics & BI (M4–M6)

ID	Month	Decision	Options considered	Rationale & evidence	Owner	Status
D-13	M4	Dashboard built as self-contained static HTML (Chart.js + vanilla JS) published on GitHub Pages	(a) Power BI now; (b) server-side web app; (c) static HTML + Pages	Zero licence, zero server, zero ops load for a 4-person team; opens offline/on UPS power; no credentials in the browser. Power BI Pro remains budgeted (5 users = UGX 37,000/user/month $\times$ 5 = UGX 185,000/month = UGX 3,330,000/18 months) for interactive Board use later	BI Analyst / EDM Consultant	Implemented
D-14	M4	Delete the 24-slice store-revenue pie chart mid-design	(a) Keep with legend; (b) top-5 + other; (c) delete $\rightarrow$ sorted bar table	Shares cluster at 2–4% (top store $\approx$ 4.1%): 24 near-identical wedges are below angle-discrimination threshold and invite ranking the chart cannot support. Replaced by sorted horizontal bar table with values + drill-up	EDM Consultant	Implemented (see C3_dashboard.md)
D-15	M4	Reject pre-build: 3D bars, dual-axis (revenue vs customer counts), single-KPI gauges	(a) Use all three; (b) forbid	3D distorts height by perspective; dual-axis lets axis scaling manufacture correlation (scale manipulation); gauges have a near-zero data-ink ratio	EDM Consultant	Implemented

ID	Month	Decision	Options considered	Rationale & evidence	Owner	Status
D-16	M4	Sort store/city table descending with click-through drill-up to per-category breakdown	(a) Static report; (b) interactive sort + drill	Board decision-grade traceability: every “this store under-performs” claim must survive one click into its category mix	BI Analyst	Implemented
D-17	M5	Sequence the five Board questions churn → growth → stock → fraud → expansion , all ML deferred to gated pilots	(a) Start with ML churn model; (b) descriptive/diagnostic first	Six months of history, 8.4% unexplained variance and 8.7% unattributed revenue would train a model on measurement error; descriptive/diagnostic work answers the Board now at SQL cost	EDM Consultant / CFO	Approved (C3_business_questions.m
D-18	M5	Automated MoMo reconciliation with a 48-hour Finance sign-off SLA , escalate >50 pending/day	(a) Keep manual month-end matching; (b) automate against provider CSVs	849/7,385 lines (11.5%) pending ≈ UGX 21,245,585 ≈ UGX 21.2M of revenue unconfirmed ($0.732 \times 252,382,814 \times 0.115$); DQC-08 already alerts — automation is matching, not new platform	Finance/Reconciliation Officer	Approved (M5)

ID	Month	Decision	Options considered	Rationale & evidence	Owner	Status
D-19	M6	Hire 3 (Analytics/Data Engineer, BI Analyst, Data Steward) rather than outsource to a consultancy	(a) Outsource; (b) 2 hires; (c) 3 hires	150,650,000 of 480,000,000 (31.4%) — builds permanent capability against the root cause (zero data-engineering); outsourcing repeats dependency and costs more than 8,000,000/month for equivalent output	CFO	Approved — offers by M5

D. Emerging technology & compliance (M3, M11–M15)

ID	Month	Decision	Options considered	Rationale & evidence	Owner	Status
D-20	M3	Cloud platform = Azure, adopted in phases	Azure (4.25) vs AWS (3.65) vs GCP (3.45) vs Snowflake/Databricks (2.95), weighted 5-criteria matrix	Highest fit on budget/skills/EU-alignment/indicated EDM; cloud line capped ≤ UGX 90,000,000/18 months (= UGX 5,000,000/month) vs computed need UGX 43,330,000	CFO / IT Ops	Approved at G1
D-21	M3	Phase 1 stays on-premises SQLite/PostgreSQL — no cloud migration until triggers T1–T6 fire	(a) Migrate now; (b) migrate on trigger	Nothing to migrate: 10,000-line extract, ~2.7 MB database; cloud spend before value is waste. Triggers make migration a requirement-driven event, not a date	IT Ops / CFO	Approved at G1

ID	Month	Decision	Options considered	Rationale & evidence	Owner	Status
D-22	M3	Snowflake/Data bricks deferred to PILOT (M13+); revisit only on trigger T6	(a) buy now; (b) pilot later	Consumption/credit pricing unmanaged without data-engineering skills SRG lacks; risk is unbudgetable spend, not capability per se	CFO	Deferred
D-23	M12	AI-powered data quality = PILOT (M12+); data mesh = REJECT; DataOps = ADOPT-LITE	All three evaluated against budget/skills/connectivity	AI-DQ needs 6+ months of DQC metric baseline (VR/DQC history from M6) and cannot invent missing definitions; mesh needs domain teams SRG does not have — adopting it would charter the silos (5 identifiers, 127 labels) already dismantled; DataOps-lite is $\approx$ zero licence and already started via repo + self-tests + etl_run_log	Data Governance Council	Approved (C3_emerging_tech.md)
D-24	M11–M12	External PDPO audit booked for M12 with SCC pack for the EU distributor (GDPR Art.44–49, DPPA 2019 s.3), tabletop exercise in M11	(a) Self-assessment; (b) external audit $\leq$ 12 months	“Within 12 months” is an external commitment; self-assessment cannot be evidenced to a European partner; auditor must be booked by M6	Compliance Officer	Approved

ID	Month	Decision	Options considered	Rationale & evidence	Owner	Status
D-25	M15	ML pilots (churn propensity, demand forecast, AI-DQ anomaly) gated: authorised only if G3 evidence is green and triggers fire	(a) Start immediately; (b) gate at G3/G4	Prevents premature capability spend; reversible — deferral costs nothing, a failed model in Board use costs trust	Data Governance Council	Conditional
D-26	M17	No expansion capex (Kampala stores / Kenya / Rwanda) before footfall-backed scorecard; M16 delivers data-model readiness only	(a) Announce Kenya now; (b) evidence first	City indices 0.94–1.04 show revenue merely tracks store count — no per-store winner exists to act on; ECOM01's 20.3% from one node ($\approx 5.9\times$ average store) argues for deepening the channel, but even that needs the M10–M12 footfall/POS evidence before capex	Strategy Director / Board	Approved — gate G4

Think-deeper answer Which decision in this log is most likely to be wrong, and why does it remain the right decision anyway?

D-17 — deferring all machine learning while the firm's churn proxy sits at 69.4% is the most vulnerable call: a challenger could argue that with 180,000 loyalty members and a visibly bleeding customer base, a propensity model is precisely what a competitor would deploy first, and that “descriptive first” is consultant caution dressed as method. The counter-argument is not that ML would fail technically — it is that *SRG cannot currently verify its own inputs*: 8.7% of revenue has no customer attached, 11.5% of mobile-money lines have no payment reference, and 8.4% of stock variance is unexplained. A churn model trained through those holes would produce confident scores attached to customers who may not exist (23% were duplicates until M2) and would be un-auditable to a Board that cannot yet answer “how do you know?” — the very question this engagement was commissioned to fix.

The decision is also structured to be *reversible at known cost*: D-25 makes the pilots a gated option (cost of waiting $\approx$ zero; cost of being wrong $\approx$ one quarter of analyst time plus Board credibility). Contrast it with **D-01 (incident response)**, which is irreversible in the other direction — silence already happened and cannot be un-happened — and with **D-07 (no name-only merges)**, where a wrong auto-merge cannot be cleanly undone because overwritten identity history destroys a person's record. The log's ordering principle is: *whichever way new evidence falls, the cost of reversing this decision stays smaller than the cost of having been wrong*. That is the test every entry above was kept against — and it is why

D-17 survives challenge while remaining the first item to re-examine at gate G3, once a full year of cleansed history exists.

Appendix AA — Red-Team Critique — Full Dossier (15 Findings)

D2.2 — Red Team Review: Adversarial Challenge of the Strategy, Decisions & Evidence

Client: Savanna Retail Group (SRG) | **Prepared by:** Lead Enterprise Data Management Consultant (acting red-team lead) **Charter:** an independent, hostile reading of this portfolio’s own claims. Each finding states the target (decision or assumption), the strongest attack, an honest verdict (**Survives** = attack fails on evidence; **Qualified** = claim holds only under stated conditions; **Overtured** = the portfolio must change), the counter-evidence, the mitigation now adopted, and the residual risk. No finding is dismissed for comfort.

Task D2 — Decision Log, Red Team & Reflective Essay

Findings register

ID	Sev	Target / assumption	The attack	Verdict	Counter-evidence & mitigation adopted	Residual risk
RT-01	Critical	D-01 / incident response	The original theft (9,000 records) was reported internally 11 days late with no breach notification . Every security artefact built since (RBAC, masking, encryption) is <i>prospective</i> — the past event may still be an unremediated DPPA 2019 / GDPR Art.33 breach. A PDPO auditor at M12 starts with the incident file, not the dashboards; a portfolio that ships analytics while the notification question stays open has prioritised the decorative over the obligatory	Overtured (partially) — action forced	Legal assessment of the theft mandated in M1 (D-01), breach register and 72-hour SOP built M1–M11, tabletop M11, external audit M12; if the assessment finds notification was due, notify and remediate rather than wait for the audit	Legal advice may lag; notification could still be late relative to the original event — Compliance Officer reports status at every Steering Group

ID	Sev	Target / assumption	The attack	Verdict	Counter-evidence & mitigation adopted	Residual risk
RT-02	High	Budget: UGX 480,000,000 / 18 months, all-in (stricter envelope reading adopted in D1)	The envelope assumes the existing 4 IT staff stay on the corporate payroll . If “all-in” includes them: $4 \times \text{UGX } 2,500,000 \times 18 = \text{UGX } 180,000,000$, which exceeds the UGX 38,350,000 contingency by UGX 141,650,000 — the plan is insolvent as written	Qualified	Assumption stated explicitly in D1_roadmap_18m(480M and Board must confirm payroll treatment at G1 (M3). If carried, the Data Steward hire and the footfall pilot are deferred and the Phase 3 cloud line is cut first (nothing in Phase 1 depends on it)	Two budget interpretations exist until G1 (480M and annual vs 480M as 18-month programme); treat all draws as reversible until confirmed
RT-03	High	All analytics conclusions	Every figure comes from the course-provided 6-month extract (5,000 customers / 1,200 products / 10,000 lines, Jul–Dec 2024). A single synthetic half-year cannot support seasonality claims (Dec –13.6%), and <i>no</i> expansion capex should move on it	Qualified — survives as pilot evidence	Provenance disclosed on the dashboard and brief; no capex decision authorised before G4 with footfall evidence (D-26); baselines re-measured from live POS/e-commerce/loyalty feeds by M6	Board may over-trust polished artefacts; every deliverable carries the provenance footnote

ID	Sev	Target / assumption	The attack	Verdict	Counter-evidence & mitigation adopted	Residual risk
RT-04	High	Q1 churn: “69.4% churn proxy”	858 of 1,237 November actives not buying in December may be seasonality or a calendar artefact , not defection. Calling it “churn” and setting a ≤50% target risks a target that measures the weather	Qualified	Labelled <i>proxy</i> throughout; targets are staged and re-based once 12 months of post-cleanse history exist (M6 re-baseline, M12 confirmation); segment churn only claimed where RFM + cohort agree	Target may be met by favourable calendar; mitigate by tracking cohort retention alongside the proxy
RT-05	High	Q4 framing: 11.5% PENDING as fraud exposure	Mobile-money pending refs are largely the designed offline-capture path (D-04), not fraud. Aggressive “fraud” language invites provider disputes and mis-serves the Board; the UGX 21.2M figure is a <i>line-count proxy</i> , not a value measure	Qualified	Age bands separate lag (0–24h) from loss (>72h); first provider reconciliation re-bases on value; language fixed to “unreconciled, unconfirmed revenue — fraud surface” rather than “fraud”	Some pending lines may prove genuinely lost; that is exactly what the M5 pipeline must quantify

ID	Sev	Target / assumption	The attack	Verdict	Counter-evidence & mitigation adopted	Residual risk
RT-06	High	Growth story: e-commerce = 20.3%	ECOM01 is one node : an outage, compromise or platform change takes a fifth of revenue with it. The portfolio praises its 5.9× productivity without pricing its concentration risk	Survives — risk under-weighted	Concentration registered as a dependency in D1_roadmap_18m with below DR/backup for the channel, checkout monitoring, and e-commerce share tracked as a <i>risk</i> KPI as well as a growth KPI	Single-node risk cannot be engineered with below M13; accepted with monitoring
RT-07	High	D-13 dashboard as Board instrument	A static public HTML page has no row-level security : anyone can read aggregates; exports are uncontrolled; KPI cards can drift from the warehouse if a rebuild is skipped. A dashboard is not a governed BI platform	Survives — bounded by design	Only Public/Confidential aggregates published; all Restricted PII stays behind module4_security; masked views; build fails non-zero if control total ≠ UGX 252,382,814.16 (no half-built page); freshness proven by etl_run_log; Power BI path budgeted for role-scoped use	Public URL reveals commercial aggregates; acceptable for a private repo, review before external sharing

ID	Sev	Target / assumption	The attack	Verdict	Counter-evidence & mitigation adopted	Residual risk
RT-08	Medium	D-20/D-21 Azure adopt-phased	No cloud region in Uganda: latency to South Africa/Europe, egress invoices nobody on a 4-person team can forecast , and cloud does not fix stores that are offline hours daily. The verdict may be vendor preference dressed as analysis	Survives — but Phase 1 already prices it	Weighted matrix is explicit (connectivity scored 3 for <i>every</i> vendor — no differentiator); cloud hard-capped at UGX 90,000,000 ($\leq$ UGX 5,000,000/month) with monthly alarm; batch/aggregate architecture required	Egress surprise still possible at migration; T5 trigger compares actual quotes against the cloud run-rate
RT-09	Medium	“GDPR-equivalent” claim for the EU partnership	RBAC and masking $\neq$ compliance: no DPO/DPO-lite, no records of processing (RoPA), no breach register, no lawful-basis register for the 180,000 loyalty members. The portfolio’s technical controls could create false assurance	Overtured — scope expanded	RoPA, breach register, lawful-basis/consent review and SCC pack added to Phase 2 (M11) explicitly ahead of the M12 audit; capability training includes privacy/incident response for all 6 staff	Resource pressure on a part-time compliance officer; external counsel funded at UGX 16,000,000

ID	Sev	Target / assumption	The attack	Verdict	Counter-evidence & mitigation adopted	Residual risk
RT-10	Medium	Q5 expansion logic	City indices of 0.94–1.04 have two opposite readings — a balanced estate, or a total absence of catchment differentiation. The same numbers are used to argue <i>against</i> Kampala densification; they are equally compatible with “we measure too crudely to know”	Qualified	Decision explicitly gated on footfall/POS evidence (M10–M12) before G4; the scorecard restates both interpretations rather than one	Pilot may prove catchment effects are invisible at 3 stores; fallback = district/loyalty indices with wider error bars
RT-11	Medium	D-07/D-08: “0.00% duplicates”	Quality was achieved by a batch cleanse , not by the process. The M7 fix (till phone-capture) re-opens the very entry point that created duplicates; the 110-row stewardship queue can silently rot	Survives — durability unproven	DQC-01 >1.0% for 3 days = P1; VR-001/VR-007 enforced at capture forms; stewardship queue 30-day SLA with named owner; “0.00%” reported as <i>state on golden records</i> , capability measured separately	First live intake month will likely breach 1.0% briefly — expected, and evidence the check works

ID	Sev	Target / assumption	The attack	Verdict	Counter-evidence & mitigation adopted	Residual risk
RT-12	Medium	Roadmap load: 6 workstreams, 3 hires, audit, Odoo, pilot in 18 months	Optimism bias: the same team that let an ETL fail for 4 unwatched days is expected to run BAU <i>and</i> transform. Gantt plans hide the fact that nobody has done any of this before	Qualified	Sacrifice ladder defined in D1_roadmap_18months think-deeper (features → pilot date → second hire, in that order); non-negotiables fixed: incident/SOP, DQC checks, PDPO date; contingency UGX 38,350,000 (8.0%)	Slip in hires (8–10 weeks lead time) most likely quick wins 4/7/8 — mitigated by phased offers M1–M4
RT-13	Medium	Benefits case: category rankings by revenue	With no margin feed , “Personal Care = UGX 50.9M, #1” may be the least profitable category; growth/double-down advice on revenue alone can destroy value. DQC-10 already flags 5.33% of products selling below cost	Survives — call deferred	Category profitability deferred until cost feed lands (M14); the double-down list ships as <i>revenue growth contribution</i> , explicitly not profitability; margin anomalies escalated weekly under DQC-10	Boards rarely un-hear a revenue ranking; brief must carry the margin caveat in writing

ID	Sev	Target / assumption	The attack	Verdict	Counter-evidence & mitigation adopted	Residual risk
RT-14	Low	Reporting-lag claim (11 → ≤5 → ≤3 days)	Lag target assumes loads never collide with the offline sync window; stores replaying buffered sales at night (RC-3) can push loads past the deadline for reasons outside the team's control	Survives — operational	Advisory lock + schedule window proven; DQC-07 quarantine alerting; lag measured from etl_run_log, so slippage is visible rather than hidden	Occasional >3-day months during outages; reported honestly, not smoothed
RT-15	Low	Portfolio self-consistency (decision log vs roadmap vs brief)	Three documents, one story — but the brief demands KPIs (≥600 new customers, ≤50% churn by M9) that the roadmap must fund, or the Board is being sold a target without a budget line	Survives	Cross-checked: reactivation/referral campaign funded in WS3 Phase 2; till-capture in WS6/WS1; each brief KPI maps to a roadmap milestone and an owner in the KPI trajectory table	Target-setting depends on Marketing executing by M7 — tracked as a G2 exit dependency

Deep dives on the three highest-severity findings

1. **RT-01 (notification exposure) — the portfolio's own original sin.** The red-team position: *everything else in this file is worthless if the incident remains unassessed*. The engagement's design response is that remediation is the **first** milestone (M1), not the last: encryption/MDM, SOP, legal referral, breach register, tabletop, external audit — an unbroken chain ending at the 12-month statutory horizon. Any slippage in this chain is escalated ahead of analytics slippage at every Steering Group. Residual: the original delay cannot be repaired, only disclosed and prevented.
2. **RT-02 (budget interpretation) — a solvency question, not a rounding question.** UGX 180,000,000 vs a UGX 38,350,000 contingency is the difference between a funded programme and a re-scoped one. Mitigation is procedural: **no irreversible commitment before G1** (M3), when the Board confirms payroll treatment; the deferral order (cloud → footfall pilot → third hire) is pre-agreed so a “no” becomes a smaller plan, not a crisis.
3. **RT-03 (evidence provenance) — the quiet assumption under every number.** The correct posture is not to hide the extract's origin but to *price* it: treat all current figures as pilot-grade, re-baseline from live feeds by M6, and authorise no capital decision (D-26) until independent evidence (footfall, Odoo stock, provider statements) has confirmed the same direction. If live data contradicts the extract, the roadmap's KPI targets — not the data — get rewritten.

Pre-mortem: it is M18 and the programme failed — five obituaries

#	Obituary	Early-warning signal	Pre-emption
1	“The audit failed on paper.” PDPO review finds no RoPA, no breach register, and an unassessed original incident	Compliance milestones unresourced while analytics milestones ship	RT-01/RT-09 actions hard-scheduled M1–M11, auditor booked by M6
2	“The analyst left in month 7.” Key-person departure halts dashboard and brief	Single owner on every BI artefact; no pair-review	Documentation-as-code, stewards distributed to business roles, contingency funds contract backfill
3	“Odoo slipped and stock stayed at 8.4%.” Variance workstream stalls at task-force stage	Vendor access not granted by M7	Interim POS stock-ledger stop-gap; variance close remains a Finance monthly item so the metric never goes dark
4	“The cloud bill ate the contingency.” Egress/scale overrun post-migration	Spend alarm at UGX 5,000,000/month; T5 trigger compares quotes	Hard cap UGX 90,000,000; rollback to on-prem pattern is cheap because Phase 1 never left it
5	“The Board made one bad expansion call on pretty charts.” Capex committed on the flat six-month extract	Any G2–G4 paper citing warehouse figures without provenance footnote and footfall evidence	D-26 gate: no capex before G4; scorecard must show both interpretations (RT-10)

Falsification register — what would prove this portfolio wrong

Claim	Falsifier	Check by
SRG reaches L2 maturity by M6	DQC checks skipped or ignored for 30 days; dashboard with no readers; brief missed	G2 (M6)
Duplicates stay solved	Duplicate-person rate >1.0% for 3 consecutive days (DQC-01), or stewardship queue older than 30 days	M6, then monthly
69.4% proxy reflects real churn	12-month cohorts show December non-return is normal seasonality	M12
MoMo gap ≈ UGX 21.2M	First provider reconciliation shows value-share differs materially from line-count proxy	M5 → M6
Azure is the right platform	G1 challenge reveals EU-term or pricing disadvantage vs AWS; or T-metrics show no migration need ever	G1 (M3), then annually
Eight quick wins land by M6	Any two of: hires late, Odoo/vendor access denied, dashboard unrebuilt after ETL change	Monthly Steering
Stock variance falls to ≤2.0%	Task force cannot attribute >50% of variance to identified causes by M9	M9

Think-deeper answer The red team attacked the strategy — who red-teams the red team, and is this critique genuine or performative?

The honest test is whether any finding *changed* something, and three did. First, RT-01 forced sequencing: incident remediation and the notification assessment were placed ahead of every analytics milestone — had the red team not raised

it, the natural momentum of a data portfolio would have produced dashboards while the original regulatory exposure sat unaddressed. Second, RT-09 forced scope: “GDPR-equivalent” was re-scoped from a claim about technical controls to an auditable programme (RoPA, breach register, lawful basis, SCCs), because default-deny RBAC protects data *in the database* but does not satisfy a European partner’s evidence request. Third, RT-02 forced a procedural constraint — no irreversible commitment before gate G1 — which converts a budget ambiguity into a scheduled decision instead of a hidden assumption.

What the red team could *not* do is worth stating just as plainly: it cannot create evidence that does not exist (six months of one synthetic extract, no margin feed, no footfall panel), so several verdicts are necessarily “Qualified” rather than resolved — and a critique that always ends in “but the plan is sound” would indeed be theatre. The residual asymmetry is deliberate: the register contains more Survives/Qualified verdicts against our own claims than against the client’s comfortable assumptions, because the portfolio’s job is to be wrong *early and on paper* rather than late and on the balance sheet. The falsification register is the accountability mechanism: each claim has a named check and a month, which is what separates red-teaming from scepticism — anyone can doubt; the discipline is to say in advance which observation would settle the doubt.